

NIST AI RMF Profile: Trustworthy AI in Critical Infrastructure and High-Consequence Applications

Community of Interest Discussion Draft Sep 28, 2026 (a)

Raymond Sheh and Martin Stanley | aiciprof@nist.gov

NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#), in preparation for the formal comment period. See the [Community of Interest Slack Announcements channel](#) for the latest version.

Document Structure

This document is available in both PDF (for printing) and Markdown (for AI assistants) formats. We value the real-world, human insights you bring, and welcome your use of AI to help you to provide them. We suggest that reviewers leveraging AI assistants monitor for text truncation or generalizations. This profile's structure intentionally departs from typical guidance, so some pre-processors may omit table rows or appendices unless explicitly directed to parse the text in its entirety.

This document begins with guidance for reviewers, followed by an Introduction covering the profile's audience, scope, approach to AI trustworthiness, and how to use this document. The core content is a table of 13 distinct Practices, subdivided into Tasks and Implementations, structured around operational workflows and extensively cross-referenced. Notes for reviewers are prefixed by a ">" and highlighted in blue; treat these as meta-commentary rather than guidance. After the table come the Acknowledgements and Glossary, five appendices, and a conceptual changelog. Appendices A, C and D are placeholders; Appendix B maps real-world incidents to Practices, and Appendix E holds additional information for reviewers. The document ends with the marker END OF DISCUSSION DRAFT.

Notes to the Reviewer

Thank you for taking the time to review this early-stage discussion draft! To maximize your opportunity to shape this resource from the ground up, we are intentionally prioritizing early availability for community review over editorial refinement. Please expect rough text, incomplete sections, partial/incomplete references, uneven emphasis, and layout inconsistencies as we trial options and rapidly integrate ongoing feedback. To make the best use of your time, please focus on high-level content, structural utility, and terminology. Future iterations will address consistency, copyediting, and formatting.

We are incredibly grateful for the input this community has already shared. If a past suggestion isn't reflected in this draft, please rest assured it isn't forgotten; our team is navigating a substantial processing backlog alongside complex cross-sector perspectives and scope constraints. To help you avoid duplicating effort, incomplete fields are marked "Candidates - suggestions welcome" or "None yet - suggestions welcome", and [Appendix E: Additional Information for the Reviewer](#) lists roadmap items not yet in the text. If there is a missing point you feel strongly about that isn't reflected in either this draft or that list, we welcome a brief summary that highlights the core issue and its operational importance, so we can ensure it stays front and center.

Tips for Providing Feedback

To help our team give every piece of input the deep attention it deserves and avoid losing important concepts in the noise, we would be incredibly grateful if you could keep these guidelines in mind:

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Direct and Actionable: If a specific practice, task, or implementation needs refinement, please include its index number and your suggestion for concrete alternative text or structural changes. Where a point applies to the document as a whole, to Table 2, or to an appendix, please provide surrounding context in lieu of the index number.

Summarize Big Ideas: For complex or high-level recommendations, please provide a clear, actionable, one- or two-sentence summary of your core point. Feel free to indicate if you are open to a brief follow-up conversation with our team to explore your suggestions further.

Sector and Governance Implications: We value your domain expertise on how AI impacts the operational, safety, and governance realities of your specific sector. Where this document introduces an AI concept, the input we find most useful is how it will land with your colleagues: which terms may be read differently in your sector, and how we might introduce them better.

Ground AI in Real-World Experience: We also use AI to assist with this work and are particularly looking to you for the insights that it cannot provide, rather than for general explanation of AI concepts. If you use an AI assistant to help with your feedback, please ensure that your real-world insights are accurately and concisely captured, so that the output prioritizes actionable advice and references that end users can readily implement. Please do also add a short disclosure and, if you like, a brief description of how AI helped you.

Help Us with References: Let us know if the references we have pointed to are in the right place, if there are better ones, and which specific sections offer the most transferable utility to an AI deployment. Please prioritize sources that are actionable and add a brief note on the operational context and where it applies.

Build on our To-Do Items: Please review the "Ideas and References Already in Progress" section in [Appendix E: Additional Information for the Reviewer](#) and see if we're already on the right track, and let us know of any additional insights that might help. Similarly, we welcome suggestions for placeholders currently marked "TBD."

Key Areas for Feedback

We have inserted reviewer notes throughout the tables and at the end of the document. We are also particularly seeking feedback on the following general points.

Scope & Sector Alignment: We prioritize shared challenges that offer transferable, cross-sector insights. What universally critical elements are missing, and which current examples should be adjusted to resonate more widely? Which sections are better suited for future sector-specific companion resources? How can this central document best serve as a foundational reference for guidance that you or your sector's organizations may be developing?

Operational Feasibility & Safety: Are these tasks realistically achievable across legacy operational technology (OT) and resource-constrained environments? For example, in high-speed automated systems, when are manual "human-in-the-loop" workflows practical versus when do operational realities and resource constraints require automated, deterministic safety boundaries or fail-safe logic? Is the general language clear and functional when applied to your sector's specific safety realities?

Strategic Governance & Executive Translation (Open Design Area): We seek inputs, including use cases, operational scenarios, and references to regulations and other governance artifacts, to help executive leadership map high-level governance, organizational missions, and compliance obligations to the practices in this document. We also welcome suggestions for how to best facilitate this connection in a way that is appropriate for this cross-sector profile, as well as factors to consider for possible future sector-specific guidance.

Document Design Criteria: Do the current entries successfully hit the relevant Document Design Criteria that appear in [Appendix E: Additional Information for the Reviewer](#)? Are there additional design criteria we should adopt to ensure this profile remains practical and actionable?

Glossary Priorities: Which terms are most likely to cause confusion when bridging the gap between AI development and real-world critical infrastructure governance? What specific definitions or semantic

conflicts should we explicitly clarify to prevent communication breakdowns between sectors or along the supply chain?

Suggested Ways to Review this Document

This document is not meant to be read cover to cover. We suggest reading this front matter, then choose your own adventure: start wherever your interest or responsibility lies and follow the cross-references or hand the Markdown to your AI assistant and ask it for the parts and paths that matter to you. We welcome any level of feedback you can provide. Here are some suggested paths, depending on the time you have available.

Narrative Scan: Focus on the Introduction and the high-level Practice/Task headings. Evaluate whether our overall approach and risk families align with your sector's realities.

Priority Check: Review the core practices in the main table. If your organization could only focus on a limited subset of these, which are your immediate "must-haves"? Which ones are missing?

Technical Deep Dive: Examine the specific Implementation rows and framework mappings relevant to your technical, operational, procurement, or policy role. Help us refine the operational, contractual, and technical "bridge language" to ensure these controls work cleanly in real-world environments and organizational workflows. (Note: Some practices are more complete than others, and some fields are empty or minimal. We warmly welcome your ideas for filling these out.)

Thanks for helping us make this profile more useful for your sector!

Certain commercial entities, products, services, and projects may be identified in this document to adequately describe a concept. Such identification is not intended to imply recommendation or endorsement by NIST, nor is it intended to imply that the entities are necessarily the best available for the purpose.

This document was created with the assistance of Google Gemini (various versions) and Anthropic Claude (various versions). These were used to brainstorm ideas, critique writing, and suggest wording in accordance with the authors' instructions. All content has been reviewed and verified by the authors for accuracy and originality in the context of a working draft.

1. Introduction

The Trustworthy Artificial Intelligence (AI) in Critical Infrastructure and High-Consequence Applications Profile (TACIP) assists organizations across the 16 Critical Infrastructure (CI) sectors (shown in Table 1) and high-consequence applications, their associated supply chains, and broader ecosystem. It provides actionable guidance for adopting trustworthy AI systems, including AI-enabled agents and tools, to meet growing demands for enhanced capacity, reliability, efficiency, and safety within real-world operational environments. While framed around critical infrastructure, the risk management practices within this profile apply broadly to any high-consequence or safety-critical application where AI failures pose significant risk.

For the purpose of this document, AI is defined as “a machine-based system that can, for a given set of human-defined objectives, make predictions, recommendations or decisions influencing real or virtual environments.” This definition, adapted from 15 U.S.C. (United States Code) § 9401, includes reasoning, planning, optimization, and statistical systems, deep learning neural networks, large language models (LLMs), and hybrid systems that combine features of multiple forms of AI.

This document is not intended to be exhaustive and should not be treated as a rigid compliance checklist, but rather as a collection of common risk management considerations with cross-sector applicability. It establishes that operational trust requires both governance and technical evidence. This profile populates the NIST AI RMF from the control and task level downwards to examples of actionable implementations, and upward towards governance to a shared practice layer. This guidance is intentionally not 'governance-complete' and stops where sector-agnostic guidance ends. Sector-specific organizations are encouraged to adapt and extend this profile and make it their own, complete with sector-specific prioritizations, contextualizations, use cases, operational scenarios, hazards, and case studies.

AI systems are software-based and should be subject to the same risk management controls, including those for testing, evaluation, validation, and verification (TEVV) and cybersecurity. However, AI systems are developed and operated in ways that differ from more traditional software systems. As such, many of the assumptions that underpin existing governance and risk management controls need to be adjusted, extended, and re-interpreted to achieve their original governance and risk management intent. Furthermore, AI systems can introduce new risks, and heighten risks previously considered lower priority, and thus require new governance and risk management approaches.

The NIST AI Risk Management Framework (AI RMF) establishes a foundation for AI risk management by contextualizing AI's impacts within widely accepted risk management principles. Based on the AI RMF, the TACIP helps CI organizations address their unique risks and requirements for AI trustworthiness in Information Technology (IT), Operational Technology (OT), and Industrial Control Systems (ICS) environments.

The TACIP assists organizations in defining how trustworthy AI relates to operational considerations and the complex balance between factors such as safety, accuracy, optimization, and resource availability. For instance, when prioritizing safety, a hypothetical 75% accurate system with guaranteed safe failures may be preferable to another hypothetical 95% accurate system that has unknown failures. The profile helps organizations locate and contextualize relevant, actionable guidance and resources to understand and manage AI risks within the enterprise's overall risk management. By improving transparency into the trade-offs between leveraging the benefits of different AI systems and allocating resources to manage AI risk, this profile can help enhance the efficiency and competitiveness of critical infrastructure organizations and the vendors of AI systems that serve them.

Chemical	Commercial Facilities	Communications	Critical Manufacturing
Dams	Defense Industrial Base	Emergency Services	Energy
Financial Services	Food and Agriculture	Transportation Systems	Information Technology
Healthcare and Public Health	Nuclear Reactors, Materials, and Waste	Government Services and Facilities	Water and Wastewater Systems

Table 1: The 16 Critical Infrastructure Sectors defined in National Security Memorandum 22 (NSM-22).

This profile assists CI organizations, including operators, managers, owners, suppliers, and government agencies in effectively navigating the balance between the benefits and risks of AI, throughout the AI lifecycle. The introduction of AI into CI creates a unique risk landscape in which anomalies and unforeseen interactions can cascade, leading to potentially significant consequences for large populations. CI systems are required to have high levels of availability, safety, transparency, security, and reliability, in addition to accuracy and efficiency. They may be expected to have long operational lifespans, operate in changing conditions without needing intervention, and integrate with legacy systems. This profile highlights practices and resources that assist CI organizations in understanding how the convergence of different forms of AI into CI systems affects their ability to meet these requirements and controls for managing the associated risks.

The AI RMF uses the term trustworthiness to refer to a set of abstract characteristics, such as being safe, secure, or fair, that an AI system may need to have, or that may be desirable, in a given context of use. This profile translates these abstract characteristics into actionable risk management controls for the selection, development, deployment, operation, maintenance, and decommissioning of AI systems in CI.

1.1. Audience

This profile is written for audiences and organizations across a wide range of AI and CI experience and expertise, AI maturity, and available resources for risk management.

The guidance in this document deliberately spans a spectrum, from low-cost, high impact initial precautions through to more advanced and comprehensive measures. Organizations with limited expertise and resources will find actionable guidance on basic measures that they can take immediately and that can provide measurable improvements in their risk management. Organizations with greater expertise and resources will find more advanced guidance to further improve their management of AI risk. See Section 1.4 for ways to use this document.

The primary audience for this profile is CI system acquirers (including procurement, contract, and legal officials), operators, managers, and owners, who wish to adopt and risk-manage AI systems and communicate their requirements and challenges to vendors of CI and AI systems. As such, it is organized according to suggested practices, drawn from use cases that directly speak to governance challenges in CI applications and environments.

> To the Reviewer: We welcome suggestions on how to best set expectations for what the reader needs to already know to understand the different parts of this document. The Practices, in particular, need to be properly understood by non-AI-focused executive leadership, who will have different understandings of basic terms (e.g., "AI," "bias," or "model"). We have found enough variation that whatever definition we use, there will be some readers who will (unknowingly) have a different understanding that can cause problematic misinterpretation. We do/will define these in the glossary/crosswalk (where we also solicit suggestions!) but, of course, a reader who thinks they know what a term means may not think to look there. We'd love suggestions on how we might address this issue while keeping this document manageable and within scope.

Practices are written for strategic or executive-level managers, Tasks for technical managers, and Implementations for personnel who carry out the task directly. This layout enables strategic leaders to read top-down when delegating work, or technical teams, including engineering staff, policy writers, and procurement leads, to read bottom-up to locate guidance for specific AI use cases, lifecycle stages, or identified risks. Organizations superimpose their own top-level enterprise risk governance onto these concrete tasks, dynamically establishing which controls must be implemented immediately versus which can be phased in across the asset lifecycle and allocate limited resources within their unique risk profile.

Secondary audiences include developers looking to integrate AI capabilities into CI environments. By breaking down tasks and implementations and providing references, this profile assists them in translating CI requirements into technically meaningful controls. Throughout this profile, "organizations" and "stakeholders" refer collectively to acquirers, operators, managers, owners, developers, and vendors (including those who may not be exclusively serving CI), unless a specific role is called out.

For systems engineers, enterprise architects, and compliance officers seeking to map these operational practices into formal system lifecycle and AI management frameworks (such as ISO/IEC/IEEE 15288, NIST SP 800-160, or ISO/IEC 42001), crosswalks are provided in [Appendix D: Crosswalks](#).

> To the Reviewer: The crosswalks are still a work-in-progress. We're open to suggestions for other high-priority crosswalks that we should call out here!

1.2. Scope

This profile applies to all AI systems used in CI environments and high-consequence applications, spanning the full range from general-purpose productivity or analytics tools adopted without CI-specific vetting to AI systems deliberately developed or adapted for CI and mission-critical tasks. This includes cases where the AI system's vendor no longer exists or may be unaware that their product has entered a CI environment, shifting the responsibility for CI-specific adaptation and risk management downstream in the AI system supply chain.

General-purpose AI assistants used to generate configuration files, automation code, or operational procedures, or to summarize OT-actionable documentation and communications, fall within this scope even when they have no direct connection to an OT or ICS control loop. Because these tools are frequently procured and classified under standard IT or SaaS contracts, the resulting path from assistant output, to engineer review, to deployed configuration or action can be overlooked by hazard review and risk classification processes that were designed around direct OT connections.

This profile also encompasses stand-alone AI tools, agentic systems capable of autonomous action, and 'embedded' AI features integrated into larger software or hardware systems, where the presence, and nature of the AI system may be hidden from the operator, whether based on machine learning, other AI approaches such as symbolic logic and reasoning, or hybrid approaches.

Traditional IT, OT, and ICS systems are generally designed to produce consistent outcomes through a documented, engineering process. While the environment and hardware are understood to have a random component, control programs are generally deterministic (produce the same outputs for the same inputs). Indeed, much of OT and ICS revolves around making systems overall deterministic and compensating for randomness caused by the environment, wear and tear, and so on. In contrast, AI system outcomes can vary in unpredictable ways, due to both the inherent non-deterministic (random) behavior of many AI systems, as well as the ability to respond to a much wider variety of signals in a more complex manner, particularly as AI systems are deployed in contexts that are different to those in which they are trained.

Existing assurance regimes, including system authorization and the continuous monitoring that many of them already incorporate, can remain the foundation for managing AI systems. AI introduces additional factors that can invalidate the assessment. An AI system's behavior can shift after it is authorized, such as through model updates, drift, changes in its inputs, and seemingly unrelated changes to the operating environment, without any change the organization itself made, and outside the bounds of traditional change management. This profile therefore builds on those regimes, with particular attention to what should trigger reassessment and to monitoring what an AI system does, not only how it is configured.

Introducing AI systems into critical environments alters the total risk profile, meaning that organizations should ensure performance or efficiency gains do not introduce unmitigated brittleness or run the risk of degrading essential operational skillsets over long system lifecycles. While holistic AI trust extends well beyond cybersecurity, operational resilience and cyber defense remain deeply intertwined. To avoid duplicating dedicated cybersecurity guidance, this profile defines high-level operator expectations across shared domains, such as identity, supply chain, logging, and incident response. Control-level specifics are deferred to established and upcoming cybersecurity guidance, AI-specific and otherwise. Rather than specifying control-level exploit mitigations, the practices emphasize bounding downstream physical and operational consequences.

In doing so, this profile applies the principle behind zero trust architecture, that trust is not granted implicitly on the basis of location or prior authorization but verified at each boundary, to AI risk more generally. An AI system's outputs, actions and inputs warrant verification where they cross into other systems, physical processes and human decisions, whether a departure from expected behavior arises from compromise, malfunction or a change in operating conditions.

In machine-speed environments, the practices in this document can provide vital layers of resilience against operational disruption, regardless of whether the underlying cause is adversarial or otherwise. Examples of such AI systems include, but are not limited to:

- Chatbots, general-purpose AI systems, and generative AI systems based on Large Language Models (LLMs) for internal, inter-organizational, and public use.
- Automated decision support and governance systems used for tasks such as summarizing regulatory compliance requirements and automating routine administrative approvals.
- AI-enabled decision support and advisory tools that generate recommendations, prioritizations, triage rankings, or root-cause hypotheses from structured operational, sensor, or tabular data.
- Embodied intelligent systems such as robots, edge devices with data processing and autonomous decision making capabilities, and other cyberphysical systems.
- Strategic simulations and digital twins that use AI-driven models for long-term resource forecasting, optimization, "what-if" scenario planning, and predicting the cascading impacts.
- Dynamic resource and logistics management tools that optimize the real-time distribution, routing, and load distribution of essential resources.
- Intelligent surveillance and monitoring systems that use a wide variety of different information sources to detect unauthorized access, environmental hazards, faults, and anomalous behavior.
- Operator advisory and situational awareness systems designed to prioritize notifications and alarms, and provide human operators with the context needed for high-impact interventions.
- High-consequence enterprise applications, such as automated claims clearinghouses, credit and liquidity risk algorithms, prior-authorization workflows, and automated compliance reporting tools.
- Safety-critical decision support tools, including clinical diagnostic algorithms, emergency service dispatch triage, disaster relief logistics, and public safety threat prioritization systems.
- Critical digital substrates and software pipelines, including AI-assisted code generation, infrastructure-as-code (IaC) synthesizers, automated CI/CD deployment pipelines, and configuration management tools.
- AI agents and agentic systems, machine vision and perception systems, AI systems that include machine learned models, including but not limited to neural networks, and AI systems that include, but are not limited to, symbolic reasoning, planning, logic programming, and mathematical modeling.

This profile aligns with, contextualizes, references, interprets, adapts, and facilitates the operationalization of guidance documents at the intersection of AI, IT, OT, ICS, software development, operations, cybersecurity, and critical infrastructure. The profile provides guidance for applying the four AI RMF Core functions of Govern, Map, Measure, and Manage, that is relevant to all critical infrastructure sectors and high-consequence applications. Examples include:

- Unifying definitions for key terms and concepts at the intersection of AI, critical infrastructure, and related domains to facilitate efficient, effective cross-sector co-operation and interoperability.
- Guiding requirements analysis to tailor the risk management of AI systems to the performance and reliability expectations and operational realities of critical infrastructure, including legacy systems, physically distributed assets, and resourcing.
- Addressing stringent requirements in the critical infrastructure sector, including the need for deterministic behavior, explainability, graceful degradation, and fail-safe operation.
- Emphasizing the heightened need for adversarial robustness in all lifecycle stages of AI in critical infrastructure.
- Supporting the critical infrastructure needs for rigorous testing, evaluation, validation, and verification (TEVV) of systems, including those that include AI.
- Illuminating critical infrastructure-specific capabilities and trade-offs with competing and complementary AI techniques, technologies, and approaches.
- Promoting visibility and collaboration across the supply chain of AI to address the unique needs, challenges, and risks of AI in critical infrastructure.
- Highlighting practical, actionable, and measurable steps that can be taken by organizations at any level of AI expertise and risk management maturity.

While this profile natively supports risk management across all lifecycle stages, practices are structured around operational workflows (such as procurement, incident response, and decommissioning) to maximize utility for infrastructure operators, rather than development phases.

This document is not intended to be exhaustive or duplicative. Rather, it focuses on highlighting a variety of practices with high impact and/or general applicability across CI sectors. Where possible, it serves as a translator, crosswalk, and index to existing relevant guidance, frameworks, and other resources. These practices have been chosen as starting points for CI organizations to make informed benefit-risk determinations for integrating AI into CI operations.

The practices guide organizations toward tasks and example implementations that can be tailored to their unique needs, risk profiles, expertise, and available resources. They are subdivided into tasks and implementations that highlight a wide spectrum of options, offering accessible entry points that can result in impactful risk reduction for resource-constrained environments alongside more advanced strategies. Accordingly, organizations may apply this profile at different levels of rigor, recognizing that what constitutes an accessible or "foundational" step for one entity may require significant operational balancing for another. The overarching goal is to ensure this profile provides practical utility for everyone, allowing stakeholders to choose from a flexible menu of tasks that best match their unique operational realities, asset lifecycles, and risk tolerances.

1.3. Trustworthiness

This profile defines trust as "a belief that an entity meets certain expectations and therefore, can be relied upon."¹ It is vital that this trust, across the wide variety of CI organizations, is appropriately calibrated to the underlying trustworthiness of the system. Both over- and under-trust can result in adverse impacts and opportunity costs. Trustworthiness is defined according to several characteristics that are considered together. For example, a system might be highly effective and secure, but may be fragile and sensitive to changes in its environment. While adversarial compromise of such a system may be unlikely, it still cannot be trusted to function as intended if the environment changes.

To preserve consistency with the foundational NIST AI RMF, this profile builds on and recontextualizes its trustworthiness characteristics. While these terms may differ from standard process safety or industrial control lexicons, retaining this shared baseline provides a practical, common framework for cross-sector communication. This profile deliberately re-contextualizes, re-prioritizes, and re-groups these baseline characteristics into an operational set specifically aligned to the needs of CI and safety-critical applications, as shown in [Table 2](#). The concept of trustworthiness in this context is further expanded upon in [Appendix A: Trustworthiness Characteristics](#). By highlighting these specific characteristics and terms, this profile helps organizations to evaluate the suitability of these systems relative to other AI and non-AI systems, including the systems they may already be using.

This profile facilitates improved communication of trustworthiness requirements and capabilities between actors in the supply chain of AI systems. For example, the Reliable, Robust and Resilient characteristics correspond to the terms of a typical service-level agreement (SLA): the performance it commits to and how consistently it is delivered, the conditions under which that commitment holds, and the degraded service and restoration expected when it cannot be met. For AI systems, performance should include correctness, which is hard to measure, not least because a system can deliver 99.999% availability while giving convincing but wrong answers.

¹ From NIST Special Publication 800-160v1r1, Engineering Trustworthy Secure Systems.

Characteristic	Illustrative Considerations for Critical Infrastructure
<i>Does it do the correct thing?</i>	
Valid (the right system for this use, established for this deployment)	An AI system valid in one deployment (a particular system, place, and time) can be wrong in another: a different plant, patient population, sensor mix, or organizational convention. Validity can change over time, through seasonal variation and changes in equipment, terminology, or regulation. Defining validity fixes what counts as expected, a scope that is specified rather than discovered and that determines whether a given departure is a question of reliability, robustness, or resilience.
Accurate (how well outputs agree with a known or accepted reference)	Meaningful AI system accuracy is rarely captured by one number: a missed safety trip and a spurious shutdown are not equivalent, and neither are a summary that drops a safety caveat and one that adds an irrelevant detail. Complexity makes the reference hard to choose; a system tuned to whichever was easiest to obtain can improve on the measure while getting worse at the task.
Bias Managed (systematic error identified and deliberately handled)	Every system has errors that affect performance, each with a direction and a cause; these should be removed, compensated for, or bounded. They enter AI systems via datasets, encoded background and domain knowledge, assumptions needed for learning but seldom stated, and how humans use outputs. Errors that fall unevenly on those affected are covered in Fair.
<i>Does it keep doing the correct thing, particularly as conditions change?</i>	
Reliable (performs as required over time, in expected conditions and use)	A mean time between failures or SLA figure for AI systems may be misleading when the scope of relevant performance data and failures is poorly defined, because wrong outputs may be hard to detect. Updates that can invalidate prior statistics may not look like updates: a vendor swapping a model, or the system keying on a dimension that varies without being operationally relevant.
Robust (keeps performing and limits harm when conditions or use go beyond expectations)	Conditions and use vary: weather, load, degraded sensors, unfamiliar formats, or a summarization tool used to draft a procedure. Every variable can sit within its stated limits while the combination is one nobody expected. For AI systems, the space is often too large to characterize unless testing is designed and interpreted based on how the AI system generalizes.
Resilient (degrades gracefully when it must and maintains the ability to resume operation)	For many AI systems, behavior is characterized by observation rather than first principles. The boundaries of expected conditions and use, and where the fallback is needed, may not be obvious. Resilience has to be considered and maintained deliberately, and fallback plans made with appropriate consideration of the way the AI system degrades.
<i>Does it avoid unintentional or deliberate harm?</i>	
Safe (avoid harm to people, property or environment, in defined conditions)	Every system is blind to hazards its design and development left out, and AI systems often cover enough situations that the gaps are hard to find, especially if they include learning without human direction. Harm does not require it to act either: a harmful recommendation carried out by a person also reaches the process, so risk management should follow the influence of AI system outputs.
Secure (withstands attack)	Built for generality, AI systems often take high-dimensional inputs such as images, sensor records, documents and free text, which cannot be meaningfully sanitized. An adversary who shapes them changes what the system does without breaching anything, and probing may reveal capability nobody intended to deploy, or boundaries the operator never knew were there.
<i>Does it allow its behavior to be observed, understood, and accounted for?</i>	
Transparent (the information exists and can be obtained)	Critical infrastructure may have formal root-cause analysis obligations. An AI system may act on a document, a retrieval, a model version, internal state, or external agentic interactions that no log captures, and what mattered is known only afterward. Capture has to be designed, not inherited.
Explainable & Interpretable (what the output means, and how it was reached)	AI systems can consider more variables, in more complex ways than a person can understand given available time, attention, training, and cognitive capacity. Explanations and interpretability can help people understand its behavior and act appropriately, be it in the moment or in an investigation.
Accountable (responsibility is named and can be enforced)	The scale and variety of inputs that influence an AI system throughout its lifecycle can impair the ability to meaningfully assign responsibility for the system's behavior, even where that behavior can be explained. Responsibility therefore has to be allocated in advance, not deduced after the event.
<i>Does it meet its obligations to those who depend on it?</i>	
Privacy-Enhanced (sensitive data stays contained)	AI systems can identify individuals, or previously private information about them, from records that revealed nothing before. In critical infrastructure the same applies to operations, where telemetry can expose staffing or production. What reaches a model or a vendor's log cannot be recalled.
Fair (service does not degrade for some of those it affects)	AI-mediated allocation, detection, prioritization or recommendation can perform unevenly across equipment, conditions, locations, populations, or customers, potentially violating service obligations that an operator may have. This profile helps identify and measure that variation; what level is acceptable is a determination for the operator in its regulatory and operational context.

Table 2: Trustworthy AI Characteristics as re-contextualized for the priorities of Critical Infrastructure, along with examples of illustrative considerations. [Appendix A: Trustworthiness Characteristics](#) provides definitions of the trustworthiness characteristics in full along with distinctions and tensions between them.

1.4. Using this Profile

This document is not meant to be read from start to finish. It is structured so that readers can start wherever their interest or responsibility lies and follow the cross-references from there. Each Practice, Task and Implementation carries an index number, and the cross-references between items use those numbers. The labelled fields in each cell state what an item covers, what it does not, and where the rest is addressed, so that a reader who arrives at any item can find its neighbors.

Readers may find the following paths useful as starting points. Executive leadership may begin with [Appendix B: Historic Incident-to-Practice Mapping](#), which connects a selection of real-world incidents to one or more Practices, then read the corresponding Practice descriptions to establish governance ownership and delegate Task-level implementation. Technical managers and practitioners may begin from a specific AI system, lifecycle stage or risk, using the Search Keywords to locate the relevant Practice or Task, then working down to its Implementations and following the cross-references to related items. Those concerned with a particular trustworthiness characteristic may begin with [Table 2](#) and search the table for the items that contribute to it, work against it, or balance it against another characteristic. Those mapping this profile to existing frameworks may begin with the AI RMF subcategory fields and [Appendix D: Crosswalks](#). Organizations with limited resources may begin with the AI systems whose outputs most directly reach physical processes, safety functions, or essential services, since the effort that several Tasks call for scales with consequence (for example, Task [1.3: Implement evaluation and test plans, including TEVV, across the AI lifecycle](#), Task [2.2: Establish requirements for redundancy in AI-Driven functions](#) and Task [3.2: Implement independent guardrails \("safety wrappers"\) for AI outputs](#)).

We anticipate that many readers will load the Markdown version of this document into an AI assistant, and use it to understand how the guidance applies to their situation and to help them act on it. The index numbers, cross-references and labelled fields described above are intended to support this use as well. Because this profile is deliberately sector-agnostic, how useful an assistant's answers are depends largely on the organizational context it is given alongside it: the sector, the AI system and what it is connected to, the regulatory and contractual obligations that apply, existing policies and risk management processes, and the resources available. How that context is provided will vary. It may be described in the conversation, supplied as documents where organizational policy permits, or drawn out by asking the assistant to question the user about their situation before making recommendations. Some of this context may be sensitive, so consider what the assistant is permitted to receive and where that information will go. Suggested ways to work with the document through an assistant include:

- Describing your AI system, sector and role, and asking which Practices and Tasks apply.
- Asking what a given Task would involve for your organization, and which References to consult.
- Asking which items address a specific risk.
- Describing an incident, whether your own or one reported elsewhere, and asking which items might have prevented or limited it, as input to a lessons-learned or after-action review.
- Asking which trustworthiness characteristics may be in tension for your use case, and where this profile discusses them.
- Where the assistant can search, asking it to find current or related references using the descriptions this profile gives for each citation.

An assistant can make this document easier to use, but it can also misrepresent it. Some tools truncate long documents or summarize tables without saying so, so ask the assistant to work from the full text, and check that it has seen all of the Practices and appendices. An assistant may also present a Practice or Task as a requirement, or fill gaps with guidance that is not in this document. Ask it to cite the index numbers it is drawing on, and check important points against the text itself. This profile is guidance to inform professional judgment. Neither this document nor an assistant's reading of it is a substitute for that judgment, or for the regulatory and contractual obligations that apply to your organization. The assistant you use may itself be an AI system within the scope of this profile, whose risks should be managed accordingly, particularly if its outputs will inform configurations, procedures or operational decisions.

> To the Reviewer: We welcome suggestions and reports of other ways of using this document that you have found useful, and in particular, prompts that you have found work well. We are also in the process of developing additional resources, such as accompanying metadata, that can further help AI assistants navigate this document.

2. The Trustworthy AI in Critical Infrastructure Profile

The Trustworthy AI in Critical Infrastructure Profile is organized to help critical infrastructure stakeholders translate trustworthy AI objectives into actionable risk management activities. It does so through a structured set of practices, tasks, and illustrative implementations grounded in critical infrastructure use cases, case studies, and operational scenarios expanded upon in [Appendix B: Historic Incident-to-Practice Mapping](#) and [Appendix C: Use Cases and Operational Scenarios](#), and informed by operational realities and existing risk management resources.

Each practice presents an application-relevant description of the risks that it addresses along with examples of tasks, implementations, and references that facilitate the translation of these high level practices into actionable controls for a given CI environment. These are designed to be generally relatable across infrastructure sectors and include context to help organizations navigate the inherent trade-offs between different risk management considerations.

- **Practice:** A high-level, governance-focused description of a risk management objective aimed at a management and governance audience, specifically CI Asset Owners, C-Suite Executives, and Strategic Managers. Each practice includes a unique identifier and a clear incentive for adoption, emphasizing organizational mission and resilience rather than purely technical goals. Practices are designed to be conceptually distinct and ready for delegation to appropriate internal departments.
- **Tasks:** Discrete, assignable steps necessary to achieve the goals of a practice, tailored for a technical management audience, specifically Technical Managers, Compliance Officers, and Operations Leads. These tasks identify specific actions that can be executed independently and provide a clear bridge between governance policy and operational implementation. Tasks often draw from across the AI RMF Functions, Categories, and Subcategories to emphasize a holistic approach to managing risk.
- **Implementations:** Illustrative examples of tools, processes, or methods used to fulfill a task, serving as a guide for Engineering Personnel, Field Operators, Systems Integrators, AI Vendors, and Governance/Compliance Personnel. These suggestions provide a flexible spectrum of options designed to offer immediate value to organizations of all resource levels, while also outlining more advanced strategies.

Each cell in the table also carries up to four labelled fields. These serve the three audiences above differently, and a reader may use only some of them.

- **Search Keywords:** Terms that should lead a reader to this item, including words other sectors use for the same thing, and suggestions for terms that the reader might search for in other resources for more information. Search and navigation aids rather than a taxonomy, and not exhaustive.
- **Trustworthiness:** Up to three headings; a heading appears only where there is something to put under it. **Main Trustworthiness Contributions** lists characteristics from [Table 2](#) that this item may contribute to, and the limits of those contributions. **Trustworthiness Effects to Consider** lists characteristics that this item may work against as a side effect, and points to where that is addressed. **Trustworthiness Tensions to Balance** lists characteristics that may pull against each other within this item, including a characteristic against itself, together with the conditions that bear on the choice between them.
- **Related AI RMF subcategories:** The subcategories of the NIST AI RMF (1.0) that this item relates to. Listing one means this item can contribute toward that outcome. It does not mean that following this item satisfies the subcategory: AI RMF subcategories are organization-wide outcomes, and any single item here addresses part of one at most. The lists are not exhaustive.
- **References:** Pointers to material that may help in implementing this item. Each citation in a cell names the part that applies and why it is relevant there. These descriptions are also intended to

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

help a reader, or an AI assistant, locate the current version or successor of a reference, or related material, when the cited document has been revised or superseded. Each description opens with a label denoting the kind of document: **Regulation, Standard, Guidance, Research, Commentary, Incident Report, or Working Document**, followed by information about the publisher and the reference itself. **Working Document** marks a source that presents itself as unfinished, such as a draft or a concept paper; it is cited because the work is relevant and under way, not because it is settled. The labels describe the document, not its worth: a seminal research paper may be as relevant as a standard, and the description says why each source is cited. References are neither requirements nor endorsements, and are not exhaustive.

>To the Reviewer:

>The references in Practices 1 to 6 and 13 have been rebuilt on the scheme described above. Practices 7 to 12 have not yet had that pass. We would welcome comment on the scheme as much as on the individual references.

>Where a field is incomplete, a marker says why. "Candidates - suggestions welcome" means we have some and would welcome more. "None yet - suggestions welcome" means we intend content here and have none.

>The trustworthiness and AI RMF subcategory fields are being rebuilt on the descriptions above, and this draft shows that work partway. Practices 1 to 6 and 13 carry both fields in the new form while Practices 7 to 12 are in progress. A cell whose field still reads Trustworthiness Characteristics is awaiting the three headings described above rather than carrying a different field. We would welcome comment on Practices 1 to 6 and 13 as examples of the approach, as much as on any individual entry.

The 13 core practices are summarized below. Many of the practices detailed herein are not novel inventions, but rather time-tested principles drawn from classic systems security engineering (such as NIST SP 800-160), process safety, and operational resilience. As the ease of fielding AI capabilities outpaces traditional engineering workflows, this profile highlights these foundational disciplines, adapting established practices to AI systems.

Practice 1: Establish requirements for success

Define performance, safety, and security baselines to help ensure that AI systems, if adopted, deliver measurable operational value aligned with organizational mission goals.

Practice 2: Define AI Robustness, Resilience, and Quality of Service expectations

Establish multi-layered safeguards to maintain essential service delivery and functional safety when AI performance deviates or degrades.

Practice 3: Define risks, policies, and oversight for automated AI and agentic behavior

Set deterministic boundary logic, risk thresholds, and independent safety wrappers for high-risk autonomous AI actions.

Practice 4: Define procedures for emergency avoidance override, recovery, and situation awareness

Maintain "break-glass" intervention procedures, out-of-band communication channels, and real-time situational awareness displays so human operators can safely override AI actions.

Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools

Implement distinct non-human identities (NHIs), cryptographically verifiable authentication, and least-privilege permissions to bound an AI agent's operational scope and blast radius.

Practice 6: Integrate visibility of the external supply chain of AI into vendor and 3rd party risk management

Apply pre-acquisition procurement oversight and supply-chain transparency (using AIBOMs and hazard reachability disclosures) to evaluate external vendor dependencies.

Practice 7: Manage internal AI supply chain and data provenance

Maintain post-acquisition operational governance over internal AI deployments, dataset provenance, prompt versioning, and safety wrapper configurations.

Practice 8: Incorporate AI-aware incident analysis and response procedures

Formulate forensic response protocols, triage pathways, and root-cause analysis capabilities tailored to probabilistic and non-deterministic AI system failures.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aicpinfo@nist.gov.

Practice 9: Provide calibrated, needs-based AI risk management training

Deliver role-specific training to combat automation complacency, build accurate mental models of AI limitations, and preserve critical manual control skills.

Practice 10: Implement multi-tiered AI system logging and audit capabilities

Capture decision-level runtime telemetry, prompt history, and guardrail interactions in immutable, tamper-evident logs for forensic auditability.

Practice 11: Maintain AI-aware mission continuity and disaster recovery planning

Pre-allocate backup operational resources and document "manual mode" fallback playbooks to ensure essential service delivery during extended AI system outages.

Practice 12: Independently verify AI-generated operational logic and artifacts across their lifecycle

Subject machine-authored code, configurations, and procedures to multi-layered deterministic testing and subject matter expert reviews prior to operational execution and across their lifecycle.

Practice 13: Establish procedures for retiring AI systems and withdrawing their authority

Withdraw an AI system's authority completely at end of life, preserve the knowledge and evidence that would otherwise be destroyed with it, and record what happens to everything that depended on it.

> To the Reviewer:

> The following text describes the intended complete state of the document. Many of its aspects are currently incomplete (e.g., not all tasks have complete mappings and the glossary is still a work-in-progress).

The Table of Practices, Tasks, and Implementations that follows is space-constrained and not intended to be exhaustive, nor is it intended to be a checklist. Rather, it is intended to inform active professional discretion, illustrating specific examples of controls that are generally achievable and impactful in managing risk, and how to contextualize them in a critical infrastructure setting. Organizations should consider related additional risk management controls that may apply to their situation. Much more information on each practice can be found in the references and associated guidance and commentary. Each task includes mappings to AI RMF sub-categories. Organizations may cross-reference these with other AI risk management resources, including other AI RMF profiles, for additional guidance.

The order of the practices, tasks, and notional implementation examples in the table does not imply any ordering, be it importance, sequence, or otherwise. Prioritization is specific to the implementing sector or organization, and should be based on factors that include their regulatory and other obligations, operating environment, localized risk tolerances, legacy dependencies, and available resources. [Appendix B: Historic Incident-to-Practice Mapping](#) may help to inform this determination.

Many of the terms used in this table are defined in [Glossary and Terminology Crosswalk](#), particularly where they have different definitions across sectors and/or between the AI and cybersecurity communities. In many cases, terms are context-specific and may have slightly different meanings between sectors.

Unless this profile defines a term, this profile uses it in its general sense. Where a sector, regulation or standard gives a term a precise meaning, such as validation, verification, incident or safety function, this profile does not invoke that meaning, and following this profile does not by itself establish conformance with a requirement stated in those terms.

> To the Reviewer:

> We welcome suggestions for terms that should be in the glossary! We particularly welcome suggestions that might be confused between sectors, or that have specific compliance/regulatory meanings that we should clarify.

Organizations adopting this profile should ensure that terms are appropriately defined in the context of their own environments and use cases and crosswalked to similar terms and concepts used by organizations and supply chain entities with whom they interact.

Table of Practices, Tasks, and Implementations

>To the Reviewer:

>We welcome suggestions for additional practices, tasks, implementations, and references from within and beyond your sector. This profile prioritizes content and examples that generalize and offer broad, transferable value across all 16 critical infrastructure sectors, even if they may be focused on one sector or application. Highly specialized or unique content is still welcome and valuable for potential future sector-specific companion resources, developed by, or in partnership with, sector organizations.

>This profile addresses AI risk from an operational and consequence-containment perspective, intentionally deconflicting with and referencing cybersecurity-focused control-level guidance. Security-adjacent content still appears where it best illustrates an AI-specific failure mode, or where a control area sits at the boundary between operational and cybersecurity risk. Our intent is to address the operational and CI-specific context and to point to cybersecurity-specific resources that will cover it in depth. We welcome suggestions on how to bridge this profile with such resources.

> We welcome suggested additions to "Search Keywords" that would help readers scanning for concepts relevant to their sector or role find their way to the right Practice and Task.

> References currently appear at all three levels: some at the Practice level, intended for a governance/executive audience already familiar with high-level policy, and covering multiple Tasks and Implementations at once rather than repeating them; others at the Task and Implementation levels, aimed at a more technical audience implementing that specific control. Adding operational context to these references is ongoing work. We welcome thoughts on how to make these references and associated contextualizations more useful for these specific audiences.

Practice	Task	Implementation
1: Establish requirements for success Define performance, safety, and security benchmarks across the entire end-to-end system, including hardware, control logic, data sources, human operators, as well as AI components. These establish the baseline for existing and proposed systems to ensure AI-driven systems align with the organization's mission and operational resilience goals while achieving desired improvements. This helps ensure that where AI is adopted, it delivers measurable operational value rather than purely technological optimization. These requirements provide a verifiable framework for system acceptance and ongoing oversight, supporting clear accountability and audit-readiness throughout the asset lifecycle. Because these requirements are defined independently of any particular solution, a valid outcome of this Practice is the determination that AI is not the appropriate means of meeting them here, whether because a non-AI approach serves them better, or because a local constraint prevents an otherwise suitable AI system from meeting them in this specific deployment. This practice focuses on helping to ensure that the adoption of AI provides measurable improvements. It is related to Practice 2: Define AI Robustness, Resilience, and Quality of Service expectations, which helps ensure that any trade-offs still result in acceptable overall levels of robustness, resilience, and quality of service.	1.1: Identify current requirements Catalog the functional, safety, and performance requirements for the operational processes the AI system is intended to support or augment. This task helps ensure that AI-specific objectives are grounded in established mission-critical benchmarks and provides the authoritative framework for system acceptance and ongoing oversight. It also helps ensure that visibility is maintained into the expected benefits to be gained relative to the trade-offs elsewhere, and highlights when those benefits might no longer be present. Note that establishing operational success criteria requires evaluating the initial Risk Surface according to Task 3.8: Scope and map the expanded AI Attack Surface and Risk Surface to ensure optimization gains do not introduce unmitigated exposure elsewhere. Main Trustworthiness Contributions: Valid: Contributes the specification of expected conditions and use: mission scope, operating envelopes, environmental parameters and functional dependencies across sensors, networks, control software, actuators and operators, recorded as a structured requirements matrix that remains auditable (Implementation 1.1.2: Structured requirements mapping). It does not test the delivered system against that specification. For that, see Task 1.3:	1.1.1: Operational baseline review Perform a baseline review of existing operational documentation, such as safety manuals, standard operating procedures (SOPs), and service level agreements (SLAs), for the targeted process. Distill these into a "Requirements Summary" that explicitly lists measurable success criteria (e.g., latency or throughput targets) along with minimum and ideal thresholds for performance. This implementation differs from Task 1.2: Create quantitative baselines for existing systems in both normal and challenging conditions by focusing on establishing a baseline from which improvements can be measured. References: >None yet - suggestions welcome 1.1.2: Structured requirements mapping Conduct cross-functional requirements analysis with SMEs, including those from engineering, operations, safety, compliance, and legal departments, to translate high-level mission goals into a structured requirements matrix for the AI system, and the broader operational system within which it operates. Requirements should explicitly define: - Operational Task and Mission Scope, including the tasks that the system (AI and overall) is expected to perform, functional dependencies across sensors, network backbones, control software, physical actuators, and human operators in the oversight loop. - Defined Operating Envelopes such as quantified input/output ranges (e.g., deterministic setpoint limits, clinical dosage thresholds, transaction execution ceilings), latency ceilings, and physical tolerance boundaries.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
> To the Reviewer: > Specific, standardized risk management scoring metrics are considered too domain- and sector-specific for this document - instead, we encourage sector-specific organizations to develop such metrics. Having said that, what additional resources would you like to see, be it in this document or possible companion resources, that might facilitate organizations developing such metrics? Search Keywords: operational baseline, success criteria, system acceptance, factory acceptance test (FAT), site acceptance test (SAT), operating envelope, cyber-physical consequence tiering, TEVV scope, performance benchmark, key performance indicator (KPI), legacy process baselining, edge-case stress testing, domain-specific terminology, business case for AI, non-AI alternative evaluation, audit-readiness, requirements matrix Main Trustworthiness Contributions: Valid: Contributes the statement of what success means for this deployment, written before a solution is chosen, so that whether an AI system is the right means here is decided on evidence rather than assumed. It does not hold that judgment in place once performance later deviates from those requirements. For that, see Practice 2: Define AI Robustness, Resilience, and Quality of Service expectations. Accurate: Contributes the reference that performance is judged against, set across the end-to-end system rather than the AI component alone, with minimum and preferred levels stated in advance. It does not decide how much of a given kind of error the organization is willing to carry. For that, see Implementation 3.1.3: Define acceptable risk thresholds and associated control responses. Accountable: Contributes acceptance criteria fixed in advance, together with evidence that they were met, so that a decision to proceed rests on a documented bar and can be reviewed against it later. It does not capture what the system did once in service. For that, see Practice 10: Implement multi-tiered AI system logging and audit capabilities.	Implement evaluation and test plans, including TEVV across the AI lifecycle. Safe: Contributes consequence tiering: requirements that reach physical machinery, environmental safety or human life are classified as such, which is what raises verification rigor and calls for deterministic boundary constraints (Implementation 1.1.2: Structured requirements mapping). It does not define those constraints or the states entered when one is exceeded. For those, see Implementation 3.2.2: Define and independently enforce deterministic operational constraints and Implementation 3.2.3: Specify fail-safe states and fallback behavior. Trustworthiness Effects to Consider: Fair: Requirements are elicited through internal functions such as engineering, operations, safety, compliance and legal (Implementation 1.1.2: Structured requirements mapping), so obligations toward the people a service reaches enter through the roles that already hold them. Because this Task is the authoritative list that later testing works from, a service obligation absent here is absent from acceptance. Task 1.4: Establish the AI System's Domain Knowledge and Linguistic Alignment Requirements carries part of this for systems that work in natural language, by making comprehension of community language variation a success criterion. >TBD - Whether evenness of service across the populations an operator serves belongs in the requirements matrix for AI systems that allocate, prioritize or triage rather than communicate. This entry is incomplete until that is settled. Suggestions welcome. Related AI RMF subcategories include: MAP 1.1 (on defining operating context): This Task documents the operational processes, deployment settings, operating envelopes and environmental conditions that the AI system will meet, drawn from safety manuals, SOPs and SLAs that already exist; it does not derive the adverse and adversarial conditions that it catalogs. For those, see Task 3.8: Scope and map the expanded AI Attack Surface and Risk Surface. MAP 1.6 (on defining and communicating user requirements): This Task elicits requirements from engineering,	- Environmental Operating Conditions, including physical, digital, and operational boundary parameters (e.g., sensor noise thresholds, data schema variations, network latency ranges, equipment wear tolerances). - Adverse and Adversarial Conditions, including enumerating expected environmental stresses (e.g., weather events, process upsets, sensor degradation) and attack surfaces as mapped in Task 3.8: Scope and map the expanded AI Attack Surface and Risk Surface (e.g., prompt injection, data poisoning, compromised telemetry) and corresponding explicit behavioral requirements, such as those outlined in Implementation 3.2.3: Specify fail-safe states and fallback behavior. - Cyber-Physical Consequence Tiering such as explicit classification of requirements that directly impact physical machinery, environmental safety, or human life (see Implementation 3.1.3: Define acceptable risk thresholds and associated control responses), triggering elevated verification rigor (see Implementation 12.1.1: Artifact Risk Classification) and deterministic boundary constraints (see Implementation 3.2.2: Define and independently enforce deterministic operational constraints). - Other non-functional requirements, such as specific auditability standards and data retention periods (see Task 10.1: Define decision-level logging and metadata retention policies). References: >None yet - suggestions welcome

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aicprof@nist.gov.

Practice	Task	Implementation
Trustworthiness Effects to Consider: Secure: The requirements this Practice produces describe where the system's limits sit, which conditions it is expected to meet, and what exceeding them would cost. Handling and distribution of that documentation is a matter for the organization's existing information classification practice. Trustworthiness Tensions to Balance: Valid versus Robust: Where a deployment's conditions are stable and well understood, drawing the requirements tightly makes both the bar and the evidence clear. Where conditions vary widely, a tightly drawn scope makes acceptance easier while leaving behavior outside that scope uncharacterized, and the organization carries whatever falls there. One resolution is to require behavior beyond the stated scope to be characterized separately before acceptance. Others include widening the scope and funding the evidence it then needs, or declining the deployment where neither is affordable. Related AI RMF subcategories include: MAP 1.4 (on defining AI business value): This Practice requires that AI adoption be justified by measurable operational value rather than purely technological optimization, and that the value be stated in terms that the organization can check later; it does not determine whether the trade-offs made to obtain that value leave acceptable service levels. For that, see Practice 2: Define AI Robustness, Resilience, and Quality of Service expectations. GOVERN 1.2 (on defining trustworthy AI policies): This Practice turns trustworthiness characteristics into benchmarks that a specific system can be accepted or rejected against; it does not set the standing policies that bound AI behavior once the system is running. For those, see Practice 3: Define risks, policies, and oversight for automated AI and agentic behavior. MEASURE 1.1 (on selecting and prioritizing measurements): This Practice establishes performance, safety and security benchmarks across the end-to-end system, and treats what cannot be measured directly as requiring additional verification rather than assumption; it does not enumerate the risks those measurements should be prioritized against.	operations, safety, compliance and legal subject matter experts and records them as a structured requirements matrix that remains auditable later; it does not test the delivered system against them. For that, see Task 1.3: Implement evaluation and test plans, including TEVV across the AI lifecycle. MAP 2.1 (on defining AI system task and methodology): This Task defines the operational tasks and mission scope that the AI system and the wider system are expected to perform, together with their dependencies on sensors, networks, control software, actuators and human operators; it does not select the model class or the method by which those tasks are implemented. References: >Candidates - suggestions welcome Guidance NIST AI 600-1. Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, from NIST. Organizes suggested actions against the AI RMF subcategories for generative AI specifically, including dual-use foundation models, so an organization identifying requirements for a generative deployment can work from a set already organized by AI RMF subcategory rather than assembling one.	
	1.2: Create quantitative baselines for existing systems in both normal and challenging conditions Establish quantitative performance baselines for current legacy or manual processes to provide a comparative metric for evaluating AI system effectiveness. These baselines capture performance under both normal and stressed operating conditions, enabling technical managers to identify specific risks and measure improvements associated with the adoption of AI. This task differs from Implementation 1.1.1: Operational baseline review by focusing on minimum performance under challenging conditions to ensure that performance gains do not result in increased brittleness. Main Trustworthiness Contributions: Valid: Contributes the measured "before" that a claimed improvement is checked against (Implementation 1.2.1: Establish manual or legacy process performance and	1.2.1: Establish manual or legacy process performance and safety baselines Before deploying an AI system, measure and document the current performance and safety metrics of the manual or legacy process it will support or replace, giving the organization a concrete "before" picture to compare against once the AI system is live. References: >None yet - suggestions welcome
		1.2.2: Develop high-fidelity operational baselines including edge-case performance under stress Extend the baseline in Implementation 1.2.1: Establish manual or legacy process performance and safety baselines to include performance under stressed or edge-case conditions, not just normal operation, so that any brittleness introduced by the AI system can be identified by comparing like-for-like stress performance rather than only normal-condition performance.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
For that, see Task 3.8: Scope and map the expanded AI Attack Surface and Risk Surface. MANAGE 1.1 (on authorizing the system): This Practice supplies the acceptance criteria and audit-ready evidence on which a proceed decision rests; it does not identify who holds the authority to make that decision. For that, see Implementation 3.9.1: Establish Accountable Ownership. References: >Candidates - suggestions welcome Guidance Principles for the Secure Integration of Artificial Intelligence in Operational Technology, December 2025, joint guidance from nine national cybersecurity agencies across seven countries, led by the United States Cybersecurity and Infrastructure Security Agency. Section 2.1, Consider the OT Business Case for AI Use, is the closest external counterpart to this Practice: it treats whether to adopt AI as a question to be answered rather than assumed. Sections 4.1 and 4.2 cover monitoring and oversight mechanisms, and safety and failsafe mechanisms. Guidance Roles and Responsibilities Framework for Artificial Intelligence in Critical Infrastructure, from the United States Department of Homeland Security. Part III, Critical Infrastructure Owners and Operators, sets out what that role is expected to carry, which is the perspective from which the requirements in this Practice are written. Standard ISO/IEC/IEEE 15288:2023, Systems and software engineering: system life cycle processes, published jointly by ISO, IEC and IEEE. Clause 6.4.2, the stakeholder needs and requirements definition process, is the general systems-engineering form of what this Practice asks for, and is useful where an organization already runs a lifecycle process that AI requirements should join rather than sit beside. Guidance NIST SP 800-218A, Secure Software Development Practices for Generative AI and Dual-Use Foundation Models, from NIST. Tasks PO.1.1 and PO.1.2 cover identifying and documenting security requirements for AI software development, which is the security portion of the requirements this Practice establishes.	safety baselines), which is what lets a conclusion that an AI system is not the right means here rest on evidence. It does not cover benefits for which the legacy process offers no counterpart, such as a capability that did not previously exist. Robust: Contributes the comparison point beyond expected conditions: the manual or legacy process measured under stress and edge cases (Implementation 1.2.2: Develop high-fidelity operational baselines including edge-case performance under stress), so brittleness introduced by an AI system appears as a like-for-like difference rather than as a surprise in service. It does not characterize the AI system's own behavior in those conditions. For that, see Task 2.3: Establish protocols for and regularly perform systematic and achievable Testing, Evaluation, Validation, and Verification (TEVV). Trustworthiness Tensions to Balance: Accurate versus Robust: Where only normal operation is baselined, a candidate that improves the average compares well. Where the stressed baseline is measured as well, a candidate that is sharper on average and weaker at the edges shows the trade, and the two comparisons can point to different decisions. One resolution is to set an acceptance bar on the stressed baseline as well as the normal one, so that an average gain does not by itself carry the decision. Others include accepting the trade with the brittleness recorded as a known limitation, or keeping the legacy path available for the conditions in which it performs better, with the resources for that allocated under Task 11.1: Identify and prioritize AI-dependent essential functions. Related AI RMF subcategories include: MAP 3.1 (on understanding benefits): This Task measures how the manual or legacy process actually performs before anything is deployed, so a claimed benefit can be checked against a documented "before" rather than an estimate; it does not examine benefits for which the legacy process offers no counterpart, such as a capability that did not previously exist. MAP 3.2 (on understanding costs): This Task baselines performance under stressed and edge-case conditions as well as normal ones, so that	References: >None yet - suggestions welcome

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	brittleness introduced by the AI system shows up as a like-for-like comparison rather than as a surprise in service; it does not relate the resulting costs to a level of risk the organization is willing to carry. For that, see Implementation 3.1.3: Define acceptable risk thresholds and associated control responses. MANAGE 2.1 (on allocating resources): This Task documents how the viable non-AI alternative performs, including under stress, so that keeping that alternative becomes a costed choice rather than an assumption; it does not allocate the resources needed to keep it available. For that, see Task 11.1: Identify and prioritize AI-dependent essential functions. References: >None yet - suggestions welcome	
	1.3: Implement evaluation and test plans, including TEVV, across the AI lifecycle Develop and execute a systematic testing, evaluation, validation, and verification (TEVV) program that assesses AI performance against established requirements, as defined in Task 1.1: Identify current requirements and, in particular, Implementation 1.1.2: Structured requirements mapping, at each stage of the asset lifecycle, and against previous baselines (if any). This task serves as the anchor for TEVV considerations throughout this profile. It supports the generation of verifiable, audit-ready evidence, with re-evaluation as environments change handled under Implementation 2.3.4: Recurrent Risk Evaluations. Specialized applications of this framework appear throughout this profile: Task 2.3: Establish protocols for and regularly perform systematic and achievable Testing, Evaluation, Validation, and Verification (TEVV) extends TEVV to anomaly and edge-case behavior, Implementation 4.1.3: Regularly practice and evaluate intervention processes applies TEVV to override and intervention procedures, Implementation 7.5.2: Perform automated "champion-challenger" and drift assessment applies TEVV to champion-challenger drift assessment, and Task 11.4: Establish system integrity re-validation and re-commissioning protocols applies TEVV to system re-commissioning.	1.3.1: Define TEVV scope and requirements per AI system For AI systems deployed in safety-critical CI operational roles, define TEVV scope requirements that map to the categories defined in Implementation 1.1.2: Structured requirements mapping and are proportionate to consequence severity of errors identified during risk assessments within Practice 3: Define risks, policies, and oversight for automated AI and agentic behavior and explicitly account for CI-specific failure modes, including model drift, adversarial manipulation, and degraded-mode operation. Test suites should be proportionate to the system's cyber-physical consequence tier and evaluate performance across: • Nominal & Boundary Envelope Testing: Validating system execution against the defined input/output ranges, setpoint limits, and latency ceilings established under Implementation 1.1.2: Structured requirements mapping. • Adverse & Adversarial Stress Testing: Assessing system stability and containment logic against the specific environmental stresses and attack vectors cataloged under Task 3.8: Scope and map the expanded AI Attack Surface and Risk Surface and Implementation 1.1.2: Structured requirements mapping. • Degraded-Mode & Fallback Verification: Verifying that when operating parameters exceed Implementation 1.1.2: Structured requirements mapping boundaries, the system predictably initiates derated operations or transitions to an independent safe fallback state (Implementation 3.2.3: Specify fail-safe states and fallback behavior). Establish pass/fail criteria for each lifecycle stage including pre-deployment, post-incident, and periodic drift or degradation checks. Test and Evaluation (T&E) planning documentation, of the kind already used for many traditional

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	Main Trustworthiness Contributions: Valid: Contributes the evidence that a delivered system meets the requirements and boundary envelopes set in Task 1.1: Identify current requirements, with scope, environment and pass/fail criteria fixed per lifecycle stage before testing begins (Implementation 1.3.1: Define TEVV scope and requirements per AI system), and with the conditions beyond which that evidence does not hold recorded alongside it. It does not detect the loss of validity that appears only after the operating environment moves. For that, see Implementation 2.3.4: Recurrent Risk Evaluations. Safe: Contributes the verification that a system exceeding its defined boundaries derates or transitions predictably, and the rule that a system whose evidence does not support autonomy is held in a more restrictive oversight mode, with the oversight capacity that mode needs confirmed as available rather than assumed (Implementation 1.3.1: Define TEVV scope and requirements per AI system). It does not specify the fallback states themselves. For those, see Implementation 3.2.3: Specify fail-safe states and fallback behavior. Transparent: Contributes the acceptance record: test plans, dataset provenance documentation, model cards and empirical results held as one package for regulatory audit, lifecycle review and post-incident evaluation (Implementation 1.3.4: Generate and maintain audit-ready TEVV evidence). It does not capture what the system did in service. For that, see Practice 10: Implement multi-tiered AI system logging and audit capabilities. Trustworthiness Tensions to Balance: Valid versus Safe: Where an application can sustain a planned outage, such as a report summarization tool or an off-peak batch process, testing during an authorized window yields evidence about the system that will actually run (Implementation 1.3.2: Categorization of Testing Environments). Where service delivery or a physical control loop cannot tolerate disruption, that evidence has to come instead from staging mirrors, hardware-in-the-loop rigs, simulators or digital twins, whose behavior may differ from the live system in ways <u>the test will not show. One resolution is to record the difference between the test environment and the live</u>	CI systems to specify what will be tested, under what conditions, and against what success criteria before testing begins, provides a useful model for defining these requirements up front, rather than determining them ad hoc during testing. Where an AI system cannot be shown to satisfy reliability requirements for autonomous operation, constrain it to a more restrictive oversight mode, appropriate to the consequence severity of the application, until TEVV evidence supports a higher level of autonomy (see Task 4.5: Define operational regimes for human-on-the-loop and human-out-of-the-loop operation for the available modes). Confirm that the oversight capacity required by that mode is actually available, rather than assuming it: high algorithmic error rates can quickly exceed operator triage capacity, and that capacity is shared with every other system the same operators watch. Where it is not available, limit use of the AI system to what the available oversight capacity can support, as discussed in Task 4.4: Attention Governance and Alert/Alarm Flood Mitigation. To prevent accidental operational outages caused by evaluation overhead, procurement and engineering policies should explicitly avoid high-load active adversarial testing, automated input fuzzing, or dense red-teaming (testing a system by deliberately seeking to compromise it as an attacker would) vectors on live, production model paths. All destructive profiling or exploratory boundary testing should be restricted to isolated staging environments, offline hardware-in-the-loop (HIL) test rigs, high-fidelity digital twins (detailed virtual replicas of physical equipment or processes that are kept up to date with real data), or during scheduled downtime, with sufficient time and resources to recover if necessary. References: >Candidates - suggestions welcome Guidance NIST SP 800-82r3. Guide to Operational Technology (OT) Security, from NIST. Section 6.3.2, Security Continuous Monitoring, covers the monitoring side of lifecycle evaluation in an OT setting, and Appendix C.3.4, Accidental Events, covers the non-adversarial failure modes that TEVV scope has to reach as well as attacks. Guidance Principles for the Secure Integration of Artificial Intelligence in Operational Technology, December 2025, joint guidance from nine national cybersecurity agencies across seven countries, led by CISA. Section 1.2 covers the secure AI system development lifecycle and Section 3.3 covers AI testing and evaluation. Standard ISA/IEC 62443-4-1, Security for industrial automation and control systems, Part 4-1: Secure product development lifecycle requirements, from the International Society of Automation and the International Electrotechnical Commission. Clause 9, Practice 5: Security Verification and Validation

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	system as a stated limit on the evidence, and to bound what is claimed from it. Others include raising fidelity for the specific behaviors that carry the most consequence, or confirming a narrow set of them live during scheduled downtime. Related AI RMF subcategories include: MAP 2.3 (on applying scientific methodologies): This Task fixes TEVV scope, test environment and pass/fail criteria per lifecycle stage before testing begins, and keeps destructive and adversarial testing off live production paths, except during scheduled downtime as discussed in Implementation 1.3.1: Define TEVV scope and requirements per AI system and Implementation 1.3.2: Categorization of Testing Environments; it does not address the data availability, representativeness and suitability that MAP 2.3 also names. For those, see Task 7.2: Validate data provenance for model inputs. MEASURE 2.5 (on measuring validity and reliability): This Task demonstrates validity and reliability against the requirements and boundary envelopes set in Task 1.1: Identify current requirements, and records the conditions beyond which that evidence does not hold; it does not detect the loss of validity that appears only after the operating environment moves. For that, see Implementation 2.3.4: Recurrent Risk Evaluations. MEASURE 2.6 (on measuring safety): This Task verifies that a system exceeding its defined boundaries derates or transitions predictably, and constrains it to a more restrictive oversight mode where the evidence does not support autonomy; it does not specify what the fallback states themselves should be. For that, see Implementation 3.2.3: Specify fail-safe states and fallback behavior. References: >Candidates - suggestions welcome The following references illustrate how different CI sectors have formalized TEVV-equivalent processes. Readers should look for analogous frameworks within their own sector's regulatory or standards environment. Regulation DoD Manual 5000.101, "Operational Test and Evaluation and Live Fire Test and Evaluation of Artificial	Testing, is the industrial control equivalent of the verification requirements set here. Guidance NIST AI 100-2e2025, Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations, from NIST. Provides the baseline taxonomy of adversarial machine learning vulnerabilities, including evasion and data poisoning, which can be used to structure lifecycle test coverage. Regulation DoD Manual 5000.101, Section 4.1, a policy issuance of the United States Department of Defense. Covers the process for planning operational test and evaluation of AI-enabled systems. >To the Reviewer: >Implementation references are intended to help those implementing these tasks find further reading, be it to help them implement this task, or to better understand where this task fits in with other things that they may already be familiar with, including other policies and regulations. We would like to provide just enough context to help the reader determine what is useful (particularly if we're referencing long documents) but we also need to keep this short as most of these implementations will have references. We are trying a few different ways of doing this and while we do this, the references will look different in different places in this document. Let us know what you think about this balance and which ones you prefer! 1.3.2: Categorization of Testing Environments TEVV activities across the system lifecycle should be conducted within a validated environment tailored to the operational nature of the underlying infrastructure: - For critical applications where service delivery, safety constraints, or physical control loops cannot tolerate production path disruption or performance overhead, adhere to the production path testing exclusions defined in Implementation 1.3.1: Define TEVV scope and requirements per AI system. Testing, including active verification, automated input fuzzing, and adversarial red-teaming should be restricted to non-production systems such as staging mirrors, hardware-in-the-loop (HIL) test rigs, simulators, or high-fidelity digital twins. - For critical applications that possess regular, planned downtime or can sustain temporary outages without safety impacts (e.g., administrative or transactional batch processors, data summarization tools, or off-peak fraud queues), it may be safe to test directly on the active production system strictly during authorized maintenance or scheduled outage windows. Where feasible, this may be preferable to testing on simulators or staging systems, whose behavior may unintentionally differ from the live system.

Practice	Task	Implementation
	Intelligence-Enabled and Autonomous Systems." December 9, 2024, a policy issuance of the United States Department of Defense, binding on DoD components. Section 4 sets out the process for operational and live fire test and evaluation of AI-enabled and autonomous systems. Regulation DoD Directive 3000.09, "Autonomy in Weapon Systems," January 25, 2023, from the same department. Section 3 covers verification and validation and testing and evaluation of autonomous and semi-autonomous systems.	References: >None yet - suggestions welcome
		1.3.3: Evaluate AI system behavior against requirements and operational baselines Assess AI system performance against TEVV requirements defined in Implementation 1.3.1: Define TEVV scope and requirements per AI system, and the operational baseline reviewed in Implementation 1.1.1: Operational baseline review. DoD 5000.101 Section 4.3 Test Execution provides examples of high level guidance to understand operational test and evaluation considerations. References: >None yet - suggestions welcome
		1.3.4: Generate and maintain audit-ready TEVV evidence TEVV activities should produce structured, verifiable evidence suitable for regulatory audit, lifecycle review, and post-incident evaluation. To establish operational trust, evidence packages should pair governance evidence (test plans, dataset provenance documentation, model cards) with technical evidence (empirical evaluation results, simulation logs, boundary test receipts). Evidence artifacts should include test plans, dataset provenance documentation, model cards, and evaluation results. References: >None yet - suggestions welcome
	1.4: Establish the AI System's Domain Knowledge and Linguistic Alignment Requirements For AI systems that interact in natural language (including chatbots, summarization tools, schematic/diagram parsers, and user interfaces that generate unique textual or graphical human output), identify and document domain-specific knowledge, industry terminology, operational ontologies, graphical conventions, and community context that the AI system needs to understand in order to perform its intended function accurately and safely. Especially for multimodal and language models trained on large, general datasets, success criteria should include a verified understanding of sector-specific jargon, graphical symbols, operational nuances, and community variations	1.4.1: Maintenance & Operations For a predictive maintenance or digital twin system, require the AI to demonstrate mastery of technical standards (e.g., distinguishing between "forced outage" and "planned maintenance") to ensure correct prioritization. References: >None yet - suggestions welcome 1.4.2: Administrative & Support For report summarization or customer service systems, establish "Contextual Accuracy" benchmarks to verify that LLM-based tools correctly interpret industry-specific jargon without introducing "hallucinations" or misprioritizing critical alerts.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	to language, particularly where colloquial variations exist or where domain-specific conventions can be expected to diverge from those of the broader community. For high-consequence applications, including otherwise benign AI systems, such as chatbots, or parsers of scanned technical diagrams that provide outputs that are used for high-consequence decisions, verification of understanding should be commensurate with the consequence. This may exclude post-hoc statistical explanations that are not guaranteed to reflect the AI system's understanding (see Implementation 4.6.2: Derive confidence and rationale for learned components from their decision processes and Implementation 8.1.2: Identify AI systems that may not satisfy root cause analysis requirements) and/or necessitate additional verification of the AI system's outputs. This helps ensure that the system's outputs, whether in optimization, predictive maintenance, digital twins, report summarization, or AI-generated code, procedures, and configurations, are aligned with the precise technical, conceptual, safety, and execution logic requirements of the industry and the community it serves. Main Trustworthiness Contributions: Valid: Contributes the sector knowledge requirement: the terminology, operational ontologies, graphical conventions and community context an AI system needs to hold for this industry, written as success criteria, verified in proportion to consequence, and with post-hoc statistical explanation ruled out as evidence of understanding. It does not test a delivered system against those criteria. For that, see Task 2.4: Perform Linguistic and Domain-Context Robustness Testing. Accurate: Contributes contextual accuracy as a stated benchmark rather than general fluency: whether sector terms, symbols and priorities are read as the sector uses them, so that a plausible summary which misreads a critical alert fails a criterion (Implementation 1.4.2: Administrative & Support). It does not verify the artifacts the system generates once they exist. For that, see Practice 12: Independently verify AI-generated operational logic and artifacts across their lifecycle. Fair: Contributes comprehension across community and colloquial language variation as an explicit success criterion, so that uneven understanding across the	References: >None yet - suggestions welcome 1.4.3: Infrastructure Optimization Define the specific operational states and physical constraints the system should "understand" (e.g., grid stability terminology in Energy) to ensure optimization recommendations are technically valid. References: >None yet - suggestions welcome 1.4.4: Requirements for AI-Generated Code, Configurations, Procedures, and Other Logic For AI systems that generate artifacts that affect execution, including by other systems (e.g., code and configurations) and by people (e.g., procedures, summaries of manuals) ensure that success criteria comprehensively capture both formal documented specifications and tacit institutional knowledge. References: >None yet - suggestions welcome

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	populations an operator serves fails a stated requirement instead of passing unremarked. It does not evaluate unevenness in the decisions that follow or in the outcomes they produce. Trustworthiness Tensions to Balance: Accurate versus Explainable & Interpretable: Where a domain requirement can be written as a checkable distinction, such as separating a forced outage from planned maintenance (Implementation 1.4.1: Maintenance & Operations), demonstrated understanding and measured accuracy move together. Where the requirement is tacit institutional knowledge (Implementation 1.4.4: Requirements for AI-Generated Code, Configurations, Procedures, and Other Logic), a system can score well on the part that was written down, while the evidence that it holds the rest is exactly what this Task declines to take from post-hoc statistical explanation. One resolution is to raise verification of the outputs themselves in proportion to consequence, which this Task provides for. Others include writing the tacit knowledge down before the requirement is set, or limiting the system's role to the part of the domain that can be stated. For where a stated part could be implemented symbolically, see Task 4.6: Ensure that confidence and rationale shown to personnel reflect how the AI system reached its output. Related AI RMF subcategories include: MAP 2.2 (on defining AI system utility and oversight needs): This Task documents the sector terminology, operational ontologies and graphical conventions that a system must hold, so that its knowledge limits can be stated for one industry rather than in general; it does not define the oversight mode applied where those limits are reached. For that, see Task 4.5: Define operational regimes for human-on-the-loop and human-out-of-the-loop operation. MEASURE 2.9 (on measuring interpretability and explainability): This Task requires understanding to be verified in proportion to consequence, and treats post-hoc statistical explanations as insufficient evidence that the system understood the domain; it does not cover whether the confidence and rationale shown to an operator at run time reflect how the output was produced. For that, see Task	

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aicprof@nist.gov.

Practice	Task	Implementation
	4.6: Ensure that confidence and rationale shown to personnel reflect how the AI system reached its output. MEASURE 2.11 (on measuring fairness and bias): This Task makes comprehension of community and colloquial language variation an explicit success criterion, so that uneven understanding across communities fails a stated requirement instead of passing unremarked; it does not evaluate bias in the system's decisions or in the outcomes they produce.	
2: Define AI Robustness, Resilience, and Quality of Service expectations Establish safeguards which maintain essential service delivery and functional safety when AI system performance deviates from expected levels, regardless of the cause. Such safeguards should be considered at multiple points in the system to establish a layered approach and reduce the likelihood of cascading failures. Search Keywords: graceful degradation, fail-operational, quality of service (QoS), rate limiting, dynamic throttling, process-informed guardrails, watchdog controller, enforcement application, heterogeneous redundancy, defense in depth, digital twin testing, hardware-in-the-loop (HIL), distribution drift, concept drift, time-to-divergence, parameter cycling, multi-vendor interoperability, inductive bias, shortcut learning Main Trustworthiness Contributions: Resilient: Contributes the layered safeguards that keep essential service delivery and functional safety in place while AI performance is away from expected levels, through fallback to reduced capability or to a known-safe mode of operation. It does not cover sustained operation without the AI system through a prolonged outage, which Practice 11: Maintain AI-aware mission continuity and disaster recovery planning covers.	2.1: Establish AI usage thresholds and rate control mechanisms Define and implement technical constraints on the volume, frequency, and scope of AI-driven actions, communications, and resource usage, particularly where there are physical and safety limitations or constrained resources. This task reduces the potential for rapid, automated system instability and resource bottlenecks by helping ensure that AI interactions remain within predefined operational tolerances and do not overwhelm upstream or downstream legacy systems. Main Trustworthiness Contributions: Resilient: Contributes a ceiling on how fast a departure can propagate, so that an AI system behaving unexpectedly consumes a bounded amount of resource, control authority and operator attention before the wider system falls back to a safe state (Implementation 2.1.1: Implement baseline rate limiting). It does not supply the independent mechanism that acts once that ceiling is reached, which Task 2.2: Establish requirements for redundancy in AI-Driven functions supplies. Safe: Contributes limits placed where AI activity meets physical and resource constraints, holding the volume, frequency and scope of automated action within what the surrounding equipment and legacy systems were built to absorb. It does not define the operating boundary that an individual command should respect, which	2.1.1: Implement baseline rate limiting Rate limit the various resources and actions that an AI system can take, including consuming AI generation resources (often measured in tokens), making configuration change requests, taking control actions, and requesting attention from humans and other systems. This reduces the likelihood that automated activity will saturate critical networks or cause instability in other systems, particularly legacy systems that may not be designed for the rapid changes in resource usage or control that can result from some AI systems. It may also highlight signs of adversarial action or interference. Ensure that when rate limits are hit, the system's overall behavior falls back to a safe state and that operators are notified via non-disruptive alerts where appropriate (Implementation 3.2.3: Specify fail-safe states and fallback behavior and Task 4.4: Attention Governance and Alert/Alarm Flood Mitigation). This may be particularly important where AI is used to improve efficiency in normal times, resulting in either more systems utilizing the same allocated resources or the same systems being allocated fewer resources. Such rate limits act as a first line of defense against overload, particularly in unusual or unforeseen situations where the efficiency gains may not hold. To safeguard operator cognitive capacity and minimize alert fatigue, notification delivery metrics should follow exception batching, aggregation, and soft-throttling strategies, some of which are discussed in Task 4.4: Attention Governance and Alert/Alarm Flood Mitigation. Rate limits should account for legitimate increases in command frequency during upset or abnormal operating conditions. An AI system responding correctly to a fast-moving abnormal condition, such as a rapid pressure excursion or a cascading equipment fault, may need to issue a higher volume of valid commands than during steady-state operation, and a rate limit tuned only to normal conditions could suppress legitimate corrective actions at the moment they matter most. Rate limit thresholds should therefore be informed by Implementation 2.1.2: Develop process-informed guardrails, rather than

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
Robust: Contributes the expectation itself: the range of conditions and uses across which AI performance should hold, and the testing that shows where it stops holding. It does not establish the level of performance required in the first place, which Practice 1: Establish requirements for success establishes. Reliable: Contributes repeated re-checking against a maintained reference, so that gradual departure from expected performance is found on a schedule rather than at the moment it reaches the service. It does not provide the moment-to-moment detection of sudden departures, which Practice 3: Define risks, policies, and oversight for automated AI and agentic behavior provides. Trustworthiness Effects to Consider: Secure: Redundant paths, independent monitors and fallback routes each add a further way for an instruction to reach the process. Practice 3: Define risks, policies, and oversight for automated AI and agentic behavior covers the scoping of the attack and risk surface that grows as they are added. Trustworthiness Tensions to Balance: Robust versus Resilient: Where the AI system meets a departure it was designed to absorb, holding performance and degrading gracefully point the same way. Where safeguards are set to keep the AI-enabled function performing across a wider range of conditions, the boundary at which the fallback should engage becomes harder to observe, and the fallback, when it does engage, starts from further outside familiar territory. One resolution is to fix the point at which the fallback engages from the consequence of being wrong rather than from how far the AI system can be pushed. Others include treating the wider range as a documented allowance that prompts review rather than as normal operation. Accurate versus Robust: Where operation stays close to the conditions the AI system was tested in, closer agreement with the reference and steadiness across conditions move together. Where the expectation is set to hold across a wide range of conditions, an AI system tuned for its best average agreement may be the more fragile choice at the edges. One resolution is to state the required performance separately for normal and for stressed conditions, so that the two are procured, tested and accepted as distinct expectations. Others include accepting	Implementation 3.2.2: Define and independently enforce deterministic operational constraints defines. Trustworthiness Effects to Consider: Transparent: An AI system held at a limit continues to operate while its activity is being constrained, so the constraint is a fact about the deployment that should be recorded and notified rather than inferred. Implementation 2.1.1: Implement baseline rate limiting directs notification of limit events, and Practice 10: Implement multi-tiered AI system logging and audit capabilities covers retention of the record. Trustworthiness Tensions to Balance: Safe versus Safe: Where the AI system's demand is steady, a fixed ceiling holds automated activity inside what the surrounding equipment can absorb. Where a fast-moving abnormal condition calls for a higher volume of valid commands, such as a rapid pressure excursion or a cascading equipment fault, the same ceiling can suppress correct action at the moment it matters most. One resolution is Implementation 2.1.2: Develop process-informed guardrails, which sets the permitted rate from the state of the process rather than as a single fixed value across all operating conditions. Others include raising the ceiling for a declared abnormal condition, or treating a limit reached during an excursion as a trigger for the fallback in Task 2.2: Establish requirements for redundancy in AI-Driven functions rather than as a cap held in place. Related AI RMF subcategories include: MAP 4.2 (on establishing risk controls for AI system components): This Task contributes rate limits, process-informed guardrails and throttles as the internal controls placed around the AI component itself; it does not cover the independent mechanism that acts once those controls are exceeded. For that, see Task 2.2: Establish requirements for redundancy in AI-Driven functions. MEASURE 2.4 (on monitoring deployed AI systems): This Task contributes the automatic response to production monitoring, throttling the AI system when its behavior departs from expected patterns; it does not define the detection regime that recognizes the departure.	applied as a single fixed ceiling across all operating conditions. 2.1.2: Develop process-informed guardrails These dynamically determine the appropriate rate at which AI systems should be utilizing resources or taking actions. For example: • An AI-based optimization system may use more tokens during quiet periods. • Rapid changes to power grid load distribution should be avoided when the grid is running close to capacity. These guardrails should be deterministic and based on the application's needs. Such guardrails give the AI system flexibility to use additional resources or take additional actions when the application requires it, such as during quieter periods, while maintaining tight control during rapid change or heightened activity. 2.1.3: Implement anomaly-driven detection and throttling This should be based on patterns of expected behavior of the AI system, particularly in situations where tight guardrails may be difficult to develop.

Practice	Task	Implementation
a narrower range of conditions of use and carrying the remainder on the fallback. Related AI RMF subcategories include: MEASURE 2.6 (on measuring safety): This Practice contributes the fail-safe behavior, derated modes and boundary testing that a demonstration of failing safely rests on; it does not set the residual risk tolerance against which acceptable safety is judged. For that, see Implementation 3.1.3: Define acceptable risk thresholds and associated control responses. MEASURE 2.7 (on measuring security and resiliency): This Practice contributes the resilience half of that evaluation, in redundancy, graceful degradation and layered safeguards that sustain service delivery when AI performance deviates; it does not catalog the adversarial exposure that MEASURE 2.7 pairs resilience with. For that, see Task 3.8: Scope and map the expanded AI Attack Surface and Risk Surface. MANAGE 2.4 (on decommissioning or superseding AI systems): This Practice contributes the automatic mechanisms, from rate limits through redundant paths to watchdog controllers, that disengage an AI system whose behavior is inconsistent with intended use; it does not cover the operator-initiated intervention that follows. For that, see Practice 4: Define procedures for emergency avoidance override, recovery, and situation awareness. MANAGE 2.2 (on ensuring sustained value): This Practice contributes the quality-of-service floor that a deployed AI system continues to deliver while it degrades; it does not define the value that the system was adopted to deliver. For that, see Practice 1: Establish requirements for success. References: >Candidates - suggestions welcome Guidance NIST SP 800-82r3, Guide to Operational Technology (OT) Security, from NIST. Section 4.1.1, Framing OT Risk, covers how an OT organization arrives at impact levels, and its Table 3 gives example definitions across outage duration, national infrastructure and services, cost as a share of revenue, legal exposure, public confidence and harm to people on site. Those categories	For that, see Task 3.4: Monitor for anomalous AI behavior. 2.2: Establish requirements for redundancy in AI-Driven functions Establish a risk-proportionate redundancy strategy to maintain continuous operations during AI degradation, distribution drift, or system failure. Redundancy requirements should be commensurate with consequence severity. This may range from heterogeneous AI model and infrastructure diversity (for complex digital workflows where non-AI fallbacks are technically infeasible) up to deterministic, rule-based software algorithms or out-of-band non-AI physical interlocks (for high-consequence cyber-physical systems). This task directly preserves the system's Resilience by enforcing graceful degradation (operating in reduced capability or derated modes) or transitioning to a known fail-safe state or legacy/manual control, reducing the impact of a total loss of service due to AI component failure. This task complements Task 3.4: Monitor for anomalous AI behavior. Main Trustworthiness Contributions: Resilient: Contributes the graded fallback that keeps a function available while the AI system is not: secondary models on distinct architectures, training distributions and hosting where a non-AI path is infeasible, rising to deterministic algorithms or physical interlocks where consequence is high (Implementation 2.2.1: Maintain fully functional backup systems). It does not define the state that the control system enters once the AI system is disengaged, which Implementation 3.2.3: Specify fail-safe states and fallback behavior defines. Reliable: Contributes an independent, non-AI check on whether the AI system is still performing as required, in continuous monitoring of output integrity, execution latency and setpoint stability (Implementation 2.2.2: Deploy "watchdog" controllers). It does not produce the evidence that the fallback operates as intended when called on, which Task 2.3: Establish protocols for and regularly perform systematic and achievable Testing, Evaluation, Validation, and Verification (TEVV) produces.	2.2.1: Maintain fully functional backup systems Establish a risk-proportionate redundancy gradient for AI-driven functions, matching the level of architectural isolation to system consequence tiers (Implementation 3.1.3: Define acceptable risk thresholds and associated control responses). For lower and moderate-consequence applications where non-AI fallbacks are technically infeasible, organizations should deploy heterogeneous AI redundancy, utilizing secondary models built on distinct architectures, training distributions, and hosting infrastructure to mitigate single-points-of-failure and shared model drift. For high-consequence or cyber-physical functions, redundancy should escalate to include independent, deterministic algorithmic fallbacks or out-of-band non-AI physical safety interlocks (Implementation 3.2.2: Define and independently enforce deterministic operational constraints). Develop and communicate expected guarantees of performance during fail-over procedures so that downstream entities can prepare for potential impacts. 2.2.2: Deploy "watchdog" controllers Watchdog controllers, also referred to as "enforcement applications," are based on independent, deterministic architectures that monitor AI output and automatically perform fail-over, consistent with Implementation 3.2.3: Specify fail-safe states and fallback behavior. Deploy independent watchdog controllers to continuously monitor AI system health, execution latency, setpoint stability, and output integrity. To ensure watchdog mechanisms do not introduce unmanaged complexity, secondary attack surfaces, or weaponized failover vectors, organizations should enforce: - Guaranteed Determinism (Non-AI Assurance): Watchdog logic should be strictly non-AI, lightweight, and deterministic. Example implementations may include dedicated hardware timers, separate Field-Programmable Gate Arrays (FPGAs) or microcontrollers, with minimal, formally verified software logic completely isolated from the primary AI application stack. - Tamper & Exploit Resistance: Watchdog controllers should operate out-of-band on hardened, privileged infrastructure with read-only telemetry access, helping ensure that an upstream compromise (of the AI system or otherwise), prompt injection, or network intrusion cannot modify watchdog setpoints, disable execution checks, or corrupt trip logic. Note that the watchdog itself may be part of the attack surface as discussed in Task 3.8: Scope and map the expanded AI Attack Surface and Risk Surface. - Mitigation of Destructive/Forced Failover: Watchdog trigger thresholds

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
are written as outcomes rather than as causes, so the same characterization reaches service loss that follows an AI performance deviation as well as service loss that follows an attack. Guidance NIST SP 800-160v1r1, Engineering Trustworthy Secure Systems, from NIST. Its Appendix E states the design principles for trustworthy secure design. Protective Failure (E.23) requires that the failure of one system element be contained, so that it does not cause unacceptable loss or trigger a further loss scenario, which is the cascading failure this Practice asks a layered approach to reduce; Loss Margins (E.18), Defense in Depth (E.9) and Protective Recovery (E.24) carry the rest of the layering. Section 3.5 reasons in terms of loss rather than graded impact, and its Table 2 names limited capacity, being diminished delivery of function, service or capability, as a loss limitation objective in its own right. Standard ANSI/ISA-62443-3-3-2013, Security for industrial automation and control systems, Part 3-3: System security requirements and security levels, from the International Society of Automation, a technical society that develops automation standards, approved as an American National Standard. Clause 11, Resource Availability, is the industrial control counterpart of the service delivery floor this Practice sets. Guidance Adapting Zero Trust Principles to Operational Technology, published 29 April 2026 by the Zero Trust Operational Technologies Security Working Group, a joint initiative of the Cybersecurity and Infrastructure Security Agency, the Department of War and the Department of Energy, with the Department of State, the Federal Bureau of Investigation and NIST contributing. Pages 12 and 13, on network and microsegmentation, hold that isolation prevents cascading failures across interconnected systems and that segmentation limits the blast radius of a cyber or operational incident, so the reasoning reaches a malfunctioning AI path and not only a compromised one. The guide's Table 1 states what OT segmentation is for in contrast to IT segmentation: system availability and system safety rather than data confidentiality, with an extremely low tolerance for downtime because disruptions can have physical consequences.	Trustworthiness Effects to Consider: Secure: Each redundant path, and each monitor able to force a transition, is a further route by which the process can be commanded or stopped. Implementation 2.2.2: Deploy “watchdog” controllers hardens the watchdog itself through read-only telemetry access and isolation from the AI application stack, and Task 3.8: Scope and map the expanded AI Attack Surface and Risk Surface covers scoping the exposure that the wider redundancy strategy adds. Trustworthiness Tensions to Balance: Safe versus Resilient: Where the process can absorb a transition at any point, tripping to the fallback on a watchdog signal serves continuity and safety together. Where the trip would land during an active process transition or a critical control maneuver, the transition is itself the hazard, and a corrupted input or a deliberate actor can force it. One resolution is Implementation 2.2.2: Deploy “watchdog” controllers's state-aware interlocks and rate-of-change validation on the trigger, so that the trip is qualified by what the process is doing. Others include sequencing the fallback so that it reaches a deterministic state in steps rather than at once. Resilient versus Resilient: Where a non-AI path is infeasible, secondary models on distinct architectures, training distributions and hosting remove the single point of failure in the implementation. Where the shared exposure is to the operating environment instead, such as distribution drift that reaches every model built on similar data, that diversity does less, while a deterministic algorithm or a physical interlock holds under the same drift and carries less of the function. One resolution is Implementation 2.2.1: Maintain fully functional backup systems's redundancy gradient, which fixes the degree of independence from the consequence tier rather than from what is convenient to build. Others include pairing the two, with the deterministic path bounding the diverse one. Related AI RMF subcategories include: MANAGE 2.4 (on decommissioning or superseding AI systems): This Task contributes the independent, non-AI watchdog that disengages or supersedes an AI system whose output, latency or setpoint stability falls outside intended use; it does not define the state that the control system	should still incorporate state-aware interlocks and rate-of-change validation to prevent corrupted inputs or malicious actors from forcing an unintended failover during sensitive operational windows (e.g., during active process transitions or critical control maneuvers). Triggers should initiate safe, deterministic fallback sequences (Implementation 3.2.3: Specify fail-safe states and fallback behavior) rather than uncoordinated abrupt shutdowns. Ensure the watchdog itself is included within Implementation 3.4.3: Monitor validation control integrity. Notify operators of any watchdog-triggered fail-over per Task 4.2: Ensure that personnel are able to gain and maintain situational awareness, so that a failure the watchdog catches does not go unnoticed by operators. > To the Reviewer: > We understand that terms like “watchdog” controllers can vary from industry to industry. We'd love further suggestions as to other terms that might be used for such concepts, both here and in other places in this document, to make sure that we're all on compatible pages even if we all use different terminology.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	enters once the AI system is disengaged. For that, see Implementation 3.2.3: Specify fail-safe states and fallback behavior. MEASURE 2.6 (on measuring safety): This Task contributes the redundancy gradient and watchdog controllers that make failing safely an implemented property rather than an assumed one; it does not produce the evidence that those mechanisms work. For that, see Task 2.3: Establish protocols for and regularly perform systematic and achievable Testing, Evaluation, Validation, and Verification (TEVV). GOVERN 6.2 (on establishing contingency plans for critical third parties): This Task contributes the runtime contingency for a failing third-party model, in secondary models built on distinct architectures, training distributions and hosting infrastructure; it does not cover the pre-acquisition visibility that identifies which third-party dependencies are high-risk. For that, see Practice 6: Integrate visibility of the external supply chain of AI into vendor and 3rd party risk management.	
	2.3: Establish protocols for and regularly perform systematic and achievable Testing, Evaluation, Validation, and Verification (TEVV) Perform rigorous testing and analysis specifically focused on the AI system's behavior in anomalous or edge-case conditions and environments, extending the TEVV protocols established in Task 1.3: Implement evaluation and test plans, including TEVV, across the AI lifecycle to govern specialized boundary and stress conditions. This task provides the verifiable evidence needed to confirm that fail-safe mechanisms and manual overrides operate as intended, supporting long-term reliability. It also supports rigorously identifying the attack and risk surface as discussed in Task 3.8: Scope and map the expanded AI Attack Surface and Risk Surface and supports the evaluation of downstream risk as discussed in Task 3.5: Define and control risks to adjacent and related systems.	2.3.1: Baseline AI system performance Establish a “validated standard” dataset consisting of curated historical inputs into the system for both normal and known-fault conditions, and expected outputs, and expected levels of performance against this dataset. This dataset should be regularly reviewed and updated to account for drift in the environment, task, and/or expected behavior. AI systems should be regularly tested against this dataset during scheduled intervals as defined in Implementation 2.3.4: Recurrent Risk Evaluations and deviations from acceptable thresholds for performance should be flagged for review and remediation as necessary.
	Main Trustworthiness Contributions: Robust: Contributes evidence of how the AI system behaves beyond the conditions it is expected to meet, by	2.3.2: Targeted failure mode mapping Map the highest risk AI-specific behaviors in response to both malicious attack (e.g., attacks listed in MITRE ATLAS and NIST AI 100-2e2025) as well as unintentional reasons (e.g., model drift). Conduct regular adversarial testing of AI systems to verify system behavior and proactively adjust or implement risk management controls where appropriate. 2.3.3: Use Digital Twins to regularly test AI system behavior Testing should cover anomalous conditions that are close to, or likely to result from, the system's current operational state. For AI systems deployed in cyber-physical environments (e.g., OT, SCADA,

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	exercising it against edge cases, injected faults and stressed physical, network and human parameters in environments built for destructive testing (Implementation 2.3.3: Use Digital Twins to regularly test AI system behavior). It does not set the criteria that the results are judged against, which Task 1.3: Implement evaluation and test plans, including TEVV, across the AI lifecycle sets as the anchor for TEVV throughout this profile. Reliable: Contributes conformance over time as a measured quantity: a curated set of normal and known-fault inputs kept current, an initial high-frequency window that measures how fast this deployment actually diverges, and an evaluation cadence derived from that measured rate (Implementation 2.3.1: Baseline AI system performance and Implementation 2.3.4: Recurrent Risk Evaluations). It does not detect an acute departure between evaluations, which Task 3.4: Monitor for anomalous AI behavior covers through continuous runtime monitoring. Resilient: Contributes the evidence that the fallback path works when called on, by injecting equipment trips, sensor failure modes and mistimed interventions rather than assuming the response to them (Implementation 2.3.3: Use Digital Twins to regularly test AI system behavior). It does not specify the states themselves; Implementation 3.2.3: Specify fail-safe states and fallback behavior does that. Trustworthiness Effects to Consider: Safe: Boundary, adversarial and destructive testing places the AI system into the conditions it exists to avoid. Implementation 1.3.2: Categorization of Testing Environments restricts that testing to staging mirrors, hardware-in-the-loop rigs, simulators and digital twins where the production path cannot absorb the disruption. Trustworthiness Tensions to Balance: Valid versus Safe: Where the deployment has planned downtime or can absorb a temporary outage, evidence gathered on the live system is the evidence that applies to it, and Implementation 1.3.2: Categorization of Testing Environments treats that as preferable. Where the process cannot tolerate disruption, the evidence has to come from a twin or a rig whose behavior may differ from the installed system in the respects being tested. One resolution is the pairing described in Implementation 2.3.3: Use Digital Twins to regularly test AI system	ICS, robotics, autonomous systems), testing should extend beyond offline data replays to high-fidelity digital twins and Hardware-in-the-Loop (HIL) simulation environments. Consider incorporating where relevant: - Physical Dynamics & Non-Linearities: High-fidelity modeling of underlying physical processes, including thermodynamics, fluid dynamics, mechanical inertia, friction, wear-and-tear, substitution of nominally equivalent parts and components through repair and maintenance, and non-linear process behaviors across nominal and extreme operating regimes. - Actuator Kinematics & Sensor Realism: Modeling of physical actuator response times, valve travel rates, motor saturation, sensor noise, calibration drift, signal quantization, and intermittent telemetry drops. - Control Network Latency & Jitter: Replication of OT/ICS communication bus characteristics (e.g., Modbus, PROFINET, CAN bus latency), network jitter, packet drops, and processing delays between the AI agent, local PLCs, and physical assets. - Internal Human-in-the-Loop (HITL) Dynamics: Simulation of operator behavioral factors, including realistic human response latencies during alarms, cognitive fatigue, manual override timing, mistimed interventions, and automation bias (both over-reliance and delayed manual takeover). - External Human & Social Interactions: Modeling of external human inputs and behavioral variables, including rapid consumer demand surges, pedestrian/vehicular traffic patterns (for mobile or field-deployed assets), field technician maintenance actions, and unauthorized physical access events. - Ambient & Exogenous Environmental Stressors: Simulation of external environmental conditions, including weather extremes (freezing, heatwaves, severe storms), ambient temperature/pressure fluctuations, electromagnetic interference (EMI), solar/radiation noise, and physical site degradation. - Process Upset & Fault Injection Capabilities: Deterministic fault injection for sudden equipment trips, rapid environmental shifts, sensor failure modes, and simulated cyber-physical attack vectors (e.g., spoofed sensor telemetry or delayed command execution). These should be deterministic between tests to ensure that results are repeatable and can be traced appropriately. - Hardware In the Loop Interfacing (HIL): Direct integration with physical programmable logic controllers (PLCs), safety instrumented systems (SIS), or hardware proxies executing real-time control cycles to validate closed-loop stability before production deployment. While digital twins and HIL rigs provide safe environments for destructive and high-consequence stress testing, they cannot fully replicate all open-world operational variables. Testing strategies should balance twin-based evaluation with controlled, low-risk real-world testing (e.g., passive shadow mode or phased operational commissioning). Testing strategies are discussed in Implementation 1.3.2: Categorization of Testing Environments. Continuous baseline comparisons between live sensor telemetry and digital

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	behavior, which combines twin-based evaluation with passive shadow mode or phased commissioning and compares live telemetry against twin predictions so that divergence stays measured. Others include limiting the claims drawn from twin results to the conditions the twin is known to reproduce. Related AI RMF subcategories include: MEASURE 2.3 (on ensuring realistic measurement): This Task contributes the high-fidelity digital twins and hardware-in-the-loop rigs that reproduce deployment conditions closely enough for destructive and edge-case testing; it does not decide when testing on the live production path is permissible. For that, see Implementation 1.3.2: Categorization of Testing Environments. MEASURE 2.1 (on documenting measurement approaches): This Task contributes the validated standard dataset of curated normal and known-fault inputs, kept current against drift, as the documented test set; it does not set the pass/fail criteria that the dataset is exercised against. For those, see Task 1.3: Implement evaluation and test plans, including TEVV, across the AI lifecycle. MEASURE 3.1 (on tracking known and emerging risks): This Task contributes the recurrent and trigger-based re-evaluation that tracks drift and emergent behavior from actual performance in deployed contexts; it does not set the drift limits at which a fail-safe response becomes necessary. For those, see Implementation 3.3.2: Establish Maximum Drift Thresholds.	twin predictions should be performed to identify model/twin divergence over time without exposing physical assets to unmanaged operational risk (Implementation 2.3.4: Recurrent Risk Evaluations). 2.3.4: Recurrent Risk Evaluations Establish periodic and trigger-based re-evaluation protocols to detect distribution drift, being the gradual or sudden deviation of real-world operational environments, seasonal population changes, physical sensor responses, equipment dynamics, or mission tasks from the conditions captured during model training and initial validation. This applies to both OT environments, such as optimization based on sensor data, as well as IT and office environments, such as summarizing medical reports where content and language distributions may vary depending on factors such as seasonal ailments, the arrival of new diseases and treatments, or changes in social media trends. Because unmanaged drift can cause silent degradation of decision accuracy or violate safe operating boundaries, continuous monitoring and recurrent evaluation should be structured across two operational phases to establish empirical drift baselines: Phase 1: Commissioning and Baselining (Burn-In Period) Upon initial deployment or major re-training, the system should enter an initial high-frequency monitoring window (e.g., real-time telemetry checks, hourly/daily batch evaluations, scaled to consequence tier). This phase captures live field data to establish empirical baselines for operational drift, input distribution shifts, and real-world system decay under actual operating conditions. Phase 2: Adaptive Recurrent Evaluation Once empirical divergence behaviors are established during Phase 1, ongoing evaluation cadences should be set to a fraction (e.g., one-quarter) of the empirically measured Time to Divergence, commensurate with the consequence of undetected divergence. If operational drift accelerates or un-modeled environmental shifts occur, the evaluation interval should dynamically scale down to match the accelerated decay rate. Event-Driven Triggers: Independent of scheduled time intervals, full re-verification should be executed immediately upon: - Upstream data schema shifts, sensor replacements, or physical equipment retrofits. - Safety interlock trips, watchdog fallback events (Implementation 2.2.2: Deploy “watchdog” controllers), or out-of-bounds operational excursions. - Vendor model updates, upstream component patches, or security vulnerability disclosures (Implementation 6.1.5: Operational AI Hazard Reachability Disclosures). - Continuous telemetry otherwise indicates that actual drift velocity is accelerating faster than the estimated baseline.

Practice	Task	Implementation
		This is a scheduled, batch-level evaluation; see Task 3.4: Monitor for anomalous AI behavior for continuous, runtime anomaly detection and Implementation 3.3.2: Establish Maximum Drift Thresholds for the specific drift thresholds that trigger fail-safe responses. Where historical incident or drift data is too limited to support a confident quantitative estimate, organizations should use the best available approximation (e.g., expert judgment or analogous systems) and revise the cadence as real operational data accumulates, rather than treating the initial estimate as fixed. To execute these evaluations without impacting availability or safety, organizations should follow Implementation 1.3.2: Categorization of Testing Environments. Systems should be tested against the "validated standard" datasets maintained under Implementation 2.3.1: Baseline AI system performance to quantify statistical drift, concept drift, and shifts in error distributions (such as false positive/negative rates). If performance metrics degrade below the baselines established in Task 1.2: Create quantitative baselines for existing systems in both normal and challenging conditions or intersect with the boundaries defined in Implementation 3.2.2: Define and independently enforce deterministic operational constraints, the system should initiate formal change-management or mitigation workflows. These workflows may include model retraining, throttling via Task 2.1: Establish AI usage thresholds and rate control mechanisms, or transitioning the process to the backup as specified in Implementation 2.2.1: Maintain fully functional backup systems while mitigations are implemented. References: >To the Reviewer: >We are also evaluating the relevance of OCC Bulletin 2026-13 and ISO/IEC 42001:2023 for determining evaluation cadence; feedback and suggestions for other references welcome.
	2.4: Perform Linguistic and Domain-Context Robustness Testing Integrate domain-specific linguistic and contextual validation into the system's TEVV protocols. This Task helps ensure that the AI system, especially when utilizing pre-trained models, remains robust and reliable when encountering specialized industry terminology, operational jargon, or community-specific language. The goal is to prevent failure modes where linguistic ambiguity or a lack of domain awareness leads to incorrect system actions, safety-critical "hallucinations," or the misprioritization of critical infrastructure alerts.	2.4.1: Benchmarking on application-specific terminology Develop or utilize sector-specific datasets that include significant application-specific terminology. This includes ambiguous operational terms (e.g., distinguishing between a "soft trip" and a "hard shutdown"), colloquial terms used by different roles in the sector, and terms whose application- and role-specific meanings differ from conventional use. This dataset should be used to measure the model's precision in interpreting application-specific text, such as in summarizing reports, interpreting natural language instructions, and performing internal and external-facing chatbot tasks.
		2.4.2: Localization and Community Validation

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	Main Trustworthiness Contributions: Robust: Contributes invariance across the language the AI system meets in service, testing whether performance holds on sector jargon, role-specific meanings and terms whose local sense differs from conventional use (Implementation 2.4.1: Benchmarking on application-specific terminology). It does not identify which terminology and language varieties are in scope for a deployment, which Task 1.4: Establish the AI System's Domain Knowledge and Linguistic Alignment Requirements identifies. Accurate: Contributes a check aimed at the error that reads as correct, using subject matter experts to spot-check and red-team outputs that sound plausible and are technically wrong (Implementation 2.4.3: Technical Accuracy and "Plausible Hallucination" Audits). It does not verify an individual artifact before it is deployed, which Practice 12: Independently verify AI-generated operational logic and artifacts across their lifecycle covers. Fair: Contributes measurement of whether delivery holds across the service area, testing robustness against regional dialects and community-specific terminology for customer-facing and public-sector systems (Implementation 2.4.2: Localization and Community Validation). It does not determine what level of variation is acceptable, which remains a determination for the operator in its regulatory and operational context. Trustworthiness Tensions to Balance: Accurate versus Accurate: Where the terminology set is broad and refreshed from current operational language, measured precision on it tracks understanding in service. Where it is small and fixed, an AI system can be tuned toward it and improve on the measure while getting worse at the task. One resolution is Implementation 2.4.3: Technical Accuracy and "Plausible Hallucination" Audits's expert spot-check and red-team review, which tests against judgment the dataset does not contain. Others include refreshing the terminology set from operational text as it changes, or holding part of it back from those tuning the system. Related AI RMF subcategories include:	For customer-facing or public-sector systems, test the AI's robustness against regional dialects and community-specific terminology to ensure equitable and accurate delivery of information across the service area. 2.4.3: Technical Accuracy and "Plausible Hallucination" Audits Implement specific TEVV protocols to identify plausible-sounding but technically inaccurate outputs. For AI systems providing or generating diagnostics, maintenance summaries, operational advice, procedures, code, or configurations, use subject matter experts to at least spot-check and/or assist in red-teaming the system's instructions. This testing should focus on edge cases where the AI might generate incorrect maintenance steps that appear valid on the surface but would damage physical assets or violate safety protocols if executed. References: >Candidates - suggestions welcome Guidance NIST AI 600-1. Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, from NIST. Section 2.2, Confabulation, names and defines the failure this Task tests for, including outputs that diverge from the prompt or contradict earlier statements in the same context, and treats it as a consequence of how generative models work rather than as an attack. Guidance NIST AI 100-2e2025, Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations, from NIST. Section 3.4.2, Integrity Attacks, covers indirect prompt injection that drives a generative system to produce incorrect summaries of its sources or to return attacker-specified content, and records that the disruption is often subtle enough that an end user does not notice it. Its scope is inaccuracy an attacker induces, so an output that is plausible and wrong with no attacker present falls outside the taxonomy.

Practice	Task	Implementation
	MEASURE 2.11 (on measuring fairness and bias): This Task contributes robustness testing against regional dialects and community-specific terminology, so that information reaches the whole service area accurately; it does not identify which communities and language varieties are in scope. For that, see Task 1.4: Establish the AI System's Domain Knowledge and Linguistic Alignment Requirements. MEASURE 2.5 (on measuring validity and reliability): This Task contributes the linguistic half of generalizability, testing whether a model trained on general text stays reliable on sector jargon and role-specific meanings; it does not test generalization across physical components and hardware. For that, see Task 2.5: Verify and Ensure Policy Robustness Against Component, Hardware, and Data Schema Variance. MEASURE 4.1 (on gathering feedback on measurement approaches): This Task contributes subject matter expert review and community validation as the means by which test material is tied to the deployment context; it does not cover the physical and process context that MEASURE 4.1 also expects measurement approaches to reflect. For that, see Task 2.3: Establish protocols for and regularly perform systematic and achievable Testing, Evaluation, Validation, and Verification (TEVV). 2.5: Verify and Ensure Policy Robustness Against Component, Hardware, and Data Schema Variance Ensure that learning systems that optimize their behavior, such as reinforcement learning systems, do not learn to rely on undocumented, unspecified, or beyond-specification behavior of their target system. Such dependence may cause unexpected suboptimal system behavior, failure, damage, or otherwise increase the attack and risk surface (see Task 3.8: Scope and map the expanded AI Attack Surface and Risk Surface) if the AI system is subsequently deployed on, uses, depends on, or interacts with, other systems that have identical specifications but behave differently outside of their specified parameters. For example, an AI system trained to optimize pressure levels might learn to rely on a training-system valve that can physically open wider than its specification requires,	2.5.1: Train Across the Full Operating Range AI systems trained within a narrow slice of their operating window risk failing when conditions legitimately vary across the broader system profile. To ensure resilience across both digital execution layers and, where applicable, cyber-physical operating ranges: • Simulation & Synthetic Parameter Cycling: When training models via simulations or digital twins, developers should intentionally randomize and cycle environmental, digital, and physical process parameters across their full allowed specification limits (e.g., maximum/minimum rated latencies, tolerances, pressure and thermal thresholds, sensor noise, equipment wear states, and ambient variations). • Physical & Hardware Representative Testing: When training or validating on physical hardware, testing should be conducted across a representative cross-section of functionally equivalent assets, incorporating varying levels of component wear, calibration drift, and environmental exposure. • Symbolic Background Knowledge & Constraint Encoding: For systems utilizing symbolic background knowledge or formal domain rules, system operating envelopes and component specifications should be explicitly

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	where the specification defines only a minimum flow rate. If this AI system is subsequently deployed to control a different system with the same specifications, but where the valve just meets specifications, the system may behave in an undesirable manner. This task also supports Implementation 7.5.4: Audit Interoperability for Hardware or Data Substrate Substitution. Main Trustworthiness Contributions: Robust: Contributes invariance across the specification range rather than across one installation, by cycling environmental, digital and physical parameters to their full allowed limits and testing functionally equivalent parts from different manufacturers at differing states of wear (Implementation 2.5.1: Train Across the Full Operating Range and Implementation 2.5.2: Multi-Vendor Testing). It does not trigger re-testing when a component or data feed is substituted in service, which Implementation 7.5.4: Audit Interoperability for Hardware or Data Substrate Substitution triggers. Valid: Contributes a check that an AI system proven in one deployment is the right system for another built to the same specification, by finding learned dependence on behavior that the specification permits but does not require. It does not confirm fit against the receiving deployment's own requirements, which Task 1.3: Implement evaluation and test plans, including TEVV, across the AI lifecycle confirms. Trustworthiness Tensions to Balance: Robust versus Accurate: Where the assets an AI system will meet over its life genuinely span the specification range, a policy learned across that range performs better in service. Where one installation sits at a stable point within the range, cycling parameters across the whole of it spends learning capacity on configurations that will not be met, and the resulting policy may do less well on the one that is. One resolution is to scope the parameter cycling in Implementation 2.5.1: Train Across the Full Operating Range to the range the AI system may actually be deployed across, including planned replacements and multi-vendor substitution. Others include keeping the narrower policy and treating any substitution as a re-qualification trigger under	encoded so the AI learning process avoids relying on capabilities outside authorized design boundaries. This is intended to prevent the AI from constructing execution policies that fail when a system or component operates at a different, yet fully compliant, point within its formal specification sheet. References: >Candidates - suggestions welcome Guidance ISO/IEC TR 5469:2024, Artificial intelligence: functional safety and AI systems, a technical report from the International Organization for Standardization and the International Electrotechnical Commission. Covers risks associated with environmental complexity, data distribution against hazard analysis, and test coverage limitations. Research Taguchi, G. (1986). Introduction to Quality Engineering: Designing Quality into Products and Processes. Asian Productivity Organization, an intergovernmental body headquartered in Tokyo. Establishes the engineering principle of exposing a system to deliberate parameter variation during development. Its subject is manufactured products and the processes that make them, and the parameter cycling this Implementation asks of simulation and digital twin training applies that principle to a training regime. 2.5.2: Multi-Vendor Testing For high-consequence systems, the AI system's validation should include testing in simulation environments, digital twins, and/or dedicated test-rigs. These should include equivalent parts from different manufacturers and at different levels of wear and tear that are representative of what may appear in the environments that the AI system would be deployed in over time. This is necessary to detect hidden, non-generalized model behavioral strategies (learned policies), such as a hidden reliance on capabilities that may be outside of the physical parts' specifications. For time-critical systems, testing should be performed on non-production environments as specified in Implementation 1.3.2: Categorization of Testing Environments.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	Implementation 7.5.4: Audit Interoperability for Hardware or Data Substrate Substitution. Related AI RMF subcategories include: MEASURE 2.5 (on measuring validity and reliability): This Task contributes the generalizability limit that matters most in cyber-physical deployment, where a learned policy depends on out-of-specification component behavior that was present during training; it does not test generalization to unfamiliar language and terminology. For that, see Task 2.4: Perform Linguistic and Domain-Context Robustness Testing. MAP 2.3 (on applying scientific methodologies): This Task contributes representativeness as a property of the hardware and parameter space rather than of the data alone, by cycling parameters across full specification limits and testing multi-vendor parts at varying wear; it does not cover the wider TEVV design that MAP 2.3 also names. For that, see Task 1.3: Implement evaluation and test plans, including TEVV, across the AI lifecycle.	
3: Define risks, policies, and oversight for automated AI and agentic behavior Establish well-defined, deterministic, actionable boundaries, policies, and oversight for high-risk actions that may cause disruption to safety-critical (cyber-)physical processes. This practice combines with the requirements defined in Practice 1: Establish requirements for success and Practice 2: Define AI Robustness, Resilience, and Quality of Service expectations to define the tradespace of the risks and benefits of using the AI system, and the costs associated with controls that may be needed. It also defines the deterministic automated boundaries and immediate technical fail-safe states (See Practice 4: Define procedures for emergency avoidance override, recovery, and situation awareness for real-time human intervention and Practice 11: Maintain AI-aware mission continuity and disaster recovery planning for long-term manual continuity). Search Keywords: agentic oversight, deterministic guardrails, safety wrappers, interlock, permissive, fail-safe state, fail loudly, blast radius	3.1: Identify risk tradeoffs Document possible high-risk actions that the AI system may perform, including the generation of content or code, and their potential operational impacts. Maintain this documentation over time as the AI system, task, process conditions, and environment change. Main Trustworthiness Contributions: Accurate: Contributes the error typology that gives an accuracy figure operational meaning: which kinds of error can occur at which decision point, from false positives and negatives through instruction misinterpretation to increased output latency. It does not measure how often each occurs, which Task 1.3: Implement evaluation and test plans, including TEVV, across the AI lifecycle covers. Safe: Contributes the consequence side of the same map: how an error at each decision point reaches people, equipment or the environment, including the path where an engineer reviews AI-generated output before it becomes a deployed configuration. It does not define the	3.1.1: Identify AI system decision points and potential outcomes of AI system errors Determine decision points that may be affected by errors in AI-generated outputs (e.g. control action, predictions, recommendations, summaries, code, procedures, or system configurations) and how they can influence operations, including downstream effects. In addition to unintentional errors, consider decision points where a capable adversary could deliberately manipulate AI-generated outputs to achieve a specific harmful outcome, distinct from the AI simply malfunctioning on its own. For cyber-physical and industrial systems, mapping should explicitly encompass decision points bridging enterprise IT and Operational Technology (OT) environments, establishing end-to-end visibility across the IT/OT boundary to detect telemetry spoofing, unauthorized command paths, or unverified configuration transfers. Error modes to evaluate include false positives/negatives, increased measurement bias, reduced precision, instruction misinterpretation, or increased output latency. Downstream operational effects to identify include: An AI-based machine vision system for detecting the presence and extent of defects can affect the actions of both automated systems as well as humans, such as if the vision system overestimates or

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
containment, autonomy limits, operating envelope, prompt injection, training data poisoning, SSVc scoring, consequence-driven thresholds, automation complacency, manual control drills, shadow AI governance, operational enforceability, intercept points, zero trust Main Trustworthiness Contributions: Safe: Contributes the boundary that holds whatever the AI system produces: limits and fallback states enforced outside the AI system itself, so that an action violating a defined constraint can be stopped before it reaches the process. It does not supply the human intervention that follows, which Practice 4: Define procedures for emergency avoidance override, recovery, and situation awareness supplies. Accountable: Contributes responsibility allocated before deployment, together with evidence that a decision to restrict or suspend an AI-enabled capability can be carried through into what the system actually does. It does not supply the record of what the system did, which Practice 10: Implement multi-tiered AI system logging and audit capabilities supplies. Secure: Contributes the scope of AI-specific exposure the organization is taking on, including AI capability that arrives outside procurement and is therefore absent from the risk profile. It does not supply the access controls that bound what an AI system may reach, which Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools supplies. Trustworthiness Effects to Consider: Safe: The notifications, escalations and exception reports required here compete for the attention of the same operators, and an operator saturated with them is less able to act on the one that matters. Task 4.4: Attention Governance and Alert/Alarm Flood Mitigation treats attention as a finite resource to be governed. Trustworthiness Tensions to Balance: Safe versus Valid: Where the safe operating envelope is well characterized and stable, a boundary drawn around it costs little of the value the AI system was adopted for. Where the envelope shifts with the stage of the process, or is known only approximately, a boundary drawn conservatively also blocks the behavior that made the AI	boundary that keeps the AI system away from those consequences, which Task 3.2: Implement independent guardrails ("safety wrappers") for AI outputs defines. Trustworthiness Tensions to Balance: Accurate versus Safe: Where one technical metric tracks the consequence closely, scoring on the metric and scoring on consequence rank the same risks first. Where the same error rate carries very different consequences at different decision points, a threshold set on the metric directs effort to the wrong place, which is why Implementation 3.1.3: Define acceptable risk thresholds and associated control responses points thresholds toward consequence-driven schemes rather than vulnerability scores or model confidence. One resolution is to keep the metric as the trigger and the consequence class as the response; others include setting a separate threshold at each decision point, or treating the metric as evidence for likelihood alone. Related AI RMF subcategories include: MAP 5.1 (on identifying risk likelihood and impacts): This Task identifies each decision point at which an AI error changes an operational outcome, and estimates the cost and likelihood of that error across normal, degraded and emergency conditions; it does not extend the analysis to systems affected only through shared adjacency or shared infrastructure. For those, see Task 3.5: Define and control risks to adjacent and related systems. MAP 1.5 (on documenting risk tolerances): This Task sets consequence-driven threshold criteria that bound acceptable AI behavior, and ties each threshold to a defined organizational response; it does not identify who may accept a risk against those thresholds. For that, see Implementation 3.9.2: Define Decision Authority and Reassessment Triggers. MAP 2.2 (on defining AI system utility and oversight needs): This Task documents how AI output reaches an operational decision, including the second-order path where an engineer reviews AI-generated configuration or code before it is deployed; it does not specify how an operator is told that the system has reached a limit. For that, see Task 3.3: Establish Failure Notification Requirements.	underestimates defects. - Conventional productivity tools, such as report summarizers, applied to summarizing technical condition reports, affect the decisions made by humans who rely on the summaries, particularly if they fail to recognize application-specific terminology (Implementation 2.4.1: Benchmarking on application-specific terminology) and erroneously omit mentions of signs of imminent failure. - General-purpose AI assistants used to generate configuration files, automation scripts, or diagnostic guidance for OT/ICS systems can introduce the same type of error as an AI system directly connected to the control loop, even though the assistant itself has no OT connection. This second-order path, in which an engineer reviews assistant-generated output before it is deployed as a configuration or action, should be identified and assessed as a separate decision point, since the presence of human review does not by itself establish that the output was adequately verified. See Practice 12: Independently verify AI-generated operational logic and artifacts across their lifecycle for further discussion. References: >Candidates - suggestions welcome Guidance NIST AI 200-1: AI Use Taxonomy: A Human-Centered Approach, from NIST. Its Table 1, Taxonomy of Human-AI Activities, page 4, lists the kinds of activity an AI system performs for a person, including content synthesis, detection, monitoring, prediction and decision making. A published counterpart to the list of output types above, and a fuller checklist when enumerating what a deployment actually does. Guidance MITRE ATLAS, maintained by MITRE, a not-for-profit organization in the United States that operates federally funded research and development centers. A matrix of tactics and techniques observed in attacks on AI-enabled systems, structured after the same organization's ATT&CK matrix for enterprise systems. Supplies named techniques for the second half of the enumeration asked for here, the decision points at which an adversary shapes an output deliberately rather than the system erring on its own. Commentary Dragos 2026 OT Cybersecurity Year in Review, from Dragos, a commercial industrial control system cybersecurity company in the United States, drawing on its own threat intelligence and field engagements. Estimates that fewer than 10 percent of OT networks worldwide have network visibility and monitoring in place, and reports poor segmentation between IT and OT networks as the most common architectural weakness in its 2025 service reports, present in 81 percent of them. Evidence for the condition under which the IT/OT boundary decision points named here go unobserved. 3.1.2: Evaluate misclassification tradeoffs Assess or estimate the operational cost (financial and otherwise) and

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
system worth adopting. One resolution is to derive the boundary from the process rather than from the AI system, and to revisit it as the process changes; others include narrowing the deployment to the range where the envelope is known, or accepting the reduced benefit as the price of the boundary. Related AI RMF subcategories include: GOVERN 3.2 (on defining human-AI configuration): This Practice contributes the policies that differentiate what an AI system may decide for itself, what it may only recommend, and what a person should authorize before it acts; it does not define the oversight regimes that apply where an action happens faster than a person can respond. For those, see Task 4.5: Define operational regimes for human-on-the-loop and human-out-of-the-loop operation. MAP 4.2 (on establishing risk controls for AI system components): This Practice contributes the internal controls placed around an AI component, including deterministic guardrails, fail-safe states, compartmentalization and resource limits; it does not cover the controls a vendor should meet before a component is acquired. For those, see Task 6.1: Develop policies for AI supply chain requirements. MAP 5.1 (on identifying risk likelihood and impacts): This Practice contributes the identification of high-risk AI actions, the likelihood of each error, and its operational impact, reaching systems that are only adjacent to the AI system as well as those it acts on directly; it does not weigh those impacts against the benefits the system is meant to deliver. For the other side of that tradespace, see Practice 1: Establish requirements for success and Practice 2: Define AI Robustness, Resilience, and Quality of Service expectations. GOVERN 2.1 (on establishing roles and responsibilities): This Practice contributes the accountable ownership, decision authority and escalation paths without which a governance decision about an AI capability cannot be enforced; it does not cover the roles exercised during an emergency intervention. For those, see Practice 4: Define procedures for emergency avoidance override, recovery, and situation awareness. GOVERN 4.1 (on establishing a risk-aware culture): This Practice contributes practices that keep operators actively engaged with automated output, and that treat an		likelihoods of errors identified in Implementation 3.1.1: Identify AI system decision points and potential outcomes of AI system errors, across normal, degraded, and emergency operating conditions. Examples include production outages and reduced safety margins. 3.1.3: Define acceptable risk thresholds and associated control responses Establish threshold criteria that bound acceptable AI behavior in terms of impact severity, likelihood, and recovery feasibility. When establishing risk thresholds, avoid over-indexing on purely technical, point-in-time metrics, whether traditional vulnerability scoring systems (such as the Common Vulnerability Scoring System (CVSS)) or raw algorithmic performance benchmarks (such as model confidence scores, error rates, or statistical accuracy). Instead, utilize consequence-driven frameworks, drawing on the operational prioritization logic of models like Stakeholder-Specific Vulnerability Categorization (SSVC), to evaluate risks based on real-world impacts to public health, safety, and mission continuity. Associate these risk thresholds with a defined organizational response such as enforced action, system isolation, authority throttling, or operator escalation. Review these risk thresholds and control responses as the AI system, task, and operational environment change. Implementation 3.9.2: Define Decision Authority and Reassessment Triggers discusses how to determine who holds authority to accept a risk against these thresholds, and to restrict or suspend operation when they are exceeded. References: >Candidates - suggestions welcome Guidance NIST Special Publication 800-30 Revision 1, Guide for Conducting Risk Assessments, from NIST. Sections 3.1 to 3.3 set out preparing for, conducting and communicating a risk assessment, with the conducting step broken into numbered tasks. Appendix G gives assessment scales for the likelihood of a threat event occurring and of its resulting in adverse impacts, Appendix H scales and a template for impact, and Appendix I scales for risk determination. These are the published scales behind the impact severity and likelihood limbs of a threshold set here, applied once per decision point.
	3.2: Implement independent guardrails ("safety	3.1.4: Artifact-driven impact analysis Conduct an assessment of how an error in AI-generated content, code, procedures, or configurations could lead to cascading failures in physical infrastructure. 3.2.1: Identify AI output intercept points

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
unvetted AI tool as something to detect rather than tolerate; it does not deliver the training that sustains that mindset. For that, see Practice 9: Provide calibrated, needs-based AI risk management training. References: >Candidates - suggestions welcome Guidance NIST Special Publication 800-30 Revision 1, Guide for Conducting Risk Assessments, from NIST. Sets out the steps of a risk assessment, preparing, conducting, communicating and maintaining, at the organization, mission and system tiers. The method behind the risk determinations this Practice requires, written to give senior leaders what they need to choose a course of action.	wrappers”) for AI outputs Enclose AI systems within hard-coded, deterministic guardrails (or boundary logic) that do not depend on the AI system and detect if safety constraints are likely to be violated and take appropriate actions to maintain functional safety. Such actions may include limiting the AI system’s output, engaging fallback controllers and plans, notifying human operators, and logging. Independent, deterministic safety wrappers add a critical layer of defense alongside emergency software patching cycles during active exploits. By enforcing hard-coded constraints at the operational boundary, these wrappers can block, at machine speed, unsafe commands or invalid data transactions that violate defined constraints. This extends the zero trust principle of verifying at each boundary from access requests to the outputs of the AI system itself. Guardrail rigor should scale with how directly a system's output reaches a physical process, not with how the system is labeled or procured. A system that directly optimizes, controls, or influences physical equipment, such as an AI adjusting valve pressure or grid dispatch, should default to the full deterministic, independent guardrail treatment described above. A general-purpose AI assistant used to summarize records, draft reports, or generate configuration files, automation code, or operational procedures may warrant lighter controls, such as content review, while its output stays purely informational. But because these assistants are often procured under standard IT or SaaS contracts, the path from assistant output to engineer review to deployed configuration can be missed by hazard review processes built around direct OT connections. Once that output is used to inform an operational decision or generate a deployed configuration or control artifact, full guardrail rigor should apply. Guardrail design should also account for whether the underlying process is continuous or batch-based: continuous processes, such as power generation, can often define a single fixed safe operating envelope, while batch processes, such as many chemical operations, may require different operating boundaries at each stage of the batch cycle, making a static guardrail definition insufficient. Align these measures with Practice 4: Define procedures	For AI decision points deemed to be significant (defined in Implementation 3.1.1: Identify AI system decision points and potential outcomes of AI system errors), identify operational intercept points where monitoring and controls can be enforced across one or more locations in the system architecture. These intercept points may indicate where a "guarded proxy" architecture is advisable (see Implementation 5.3.3: Separate privilege via encapsulated downstream agents and tools): remove direct asset access from the AI agent or system and route execution requests through an encapsulated downstream tool equipped with independent deterministic constraints (Implementation 3.2.2: Define and independently enforce deterministic operational constraints). For example, an AI flow-rate optimizer should not hold direct control-bus credentials; it should submit recommendations to a dedicated setpoint broker that independently verifies range, rate-of-change, and safety interlock rules before writing changes to physical hardware. In this scenario, intercept points exist at multiple operational layers, including the setpoint interface, the local controller, and existing emergency shutoff mechanisms. 3.2.2: Define and independently enforce deterministic operational constraints Define the boundary that the AI system should remain within for safe operation. These might be in- and out-of-range values, semantic and behavioral constraints, rate-of-change violations, and deterministic logical constraints that should be respected regardless of the AI system's confidence level. These deterministic constraints should be defined and enforced independent of the AI system's internal logic (e.g., via out-of-band safety wrappers, intermediate deterministic command validation proxies, or hardware interlocks at the physical process boundary). This out-of-band architecture helps ensure constraint enforcement remains active even during model failures, prompt injections, or autonomous agents exceeding their intended constraints. These constraints should reflect the most restrictive combination of the organization's, equipment's, application's, and the AI system's safe operating limits (including the limits of the AI system's training). Constraints should apply uniformly to all command sources at the physical process boundary, including AI recommendations, automated agents, remote operator sessions, and any other upstream system. Authentication and physical safety are separate concerns: confirming who or what sent a command (addressed in Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools) does not guarantee that the command itself is safe to execute. An authenticated source can still issue a damaging command through error, misconfiguration, or compromise. Absent an explicit, authorized override, such safety wrappers should intercept physically unsafe commands regardless of their source or underlying cause. Where such constraints need to be lifted, e.g., to facilitate an experienced

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	for emergency avoidance override, recovery, and situation awareness and in particular Task 4.4: Attention Governance and Alert/Alarm Flood Mitigation to integrate appropriate, timely, and feasible human intervention, and with Practice 10: Implement multi-tiered AI system logging and audit capabilities to ensure visibility into the AI system's attempted behavior, even when guardrails prevent actual harm. Main Trustworthiness Contributions: Safe: Contributes enforcement that does not depend on the AI system being correct: deterministic limits applied at the process boundary to every command source, so an unsafe command is stopped whatever produced it. It bounds the hazards that were identified and written as constraints, and it stays a mitigation rather than a closure. For the hazards not yet identified, see Task 3.8: Scope and map the expanded AI Attack Surface and Risk Surface and Implementation 3.8.3: Dynamic Risk Surface Coupling Analysis. Resilient: Contributes the defined state the control system enters when a constraint is violated or the AI system becomes unavailable: holding last-known-safe setpoints, reverting to a conservative baseline, or de-escalating to a legacy deterministic controller, with the state-consistency rules that keep re-entry from producing an uncommanded action. It does not cover sustained operation in that state, which Task 11.2: Define manual and alternative operating procedures for long-term mission continuity covers. Trustworthiness Effects to Consider: Reliable: The enforcement layer is a component in its own right, and a wrapper that has stopped enforcing looks much like one with nothing to stop. Implementation 3.4.3: Monitor validation control integrity requires continuous monitoring of validation control states. Trustworthiness Tensions to Balance: Safe versus Robust: Where the process holds one stable safe operating envelope, as many continuous processes do, a fixed deterministic boundary costs little of the AI system's ability to handle varied conditions. Where the envelope changes at each stage of a batch, or an experienced engineer is working through a situation the boundary never anticipated, a static constraint also blocks	human engineer remotely dealing with a novel situation, such constraints should be explicitly overridden in accordance with emergency safety protocols. The same principle of independently-enforced constraints applies beyond physical process control: for AI systems that generate or filter information rather than direct commands, the "constraint" may be one of required completeness or fidelity, independently enforced regardless of the AI system's own judgment about what is relevant. For example: • An attacker gaining access to a plant human-machine interface (HMI) could issue setpoint commands indistinguishable from legitimate AI recommendations. • A valve controlled by an AI system might have constraints that the AI system may not have properly learned, such as not being opened and closed in quick succession, and not being opened at the same time as another valve. • A condition report summarization tool should be constrained to include information about every asset, even if the AI system judges a given condition not to be of concern. • An AI system routing high-volume transactions or processing patient records should be bounded by deterministic validation rules that block anomalous account or resource allocations (e.g., assigning an atomic resource to two entities), prevent unauthorized data aggregation, or flag out-of-bounds risk parameters prior to downstream operational execution. • An AI system executing automated financial trades or market transactions should be bounded by pre-trade risk controls, such as hard credit limits, maximum order value thresholds, and price collars (aligned with 17 CFR 240.15c3-5), that deterministically block out-of-bounds orders before market entry, regardless of the model's confidence score. • An AI system's pressure setpoint recommendation should be restricted to a 10 to 30 PSI range before it reaches the physical system, by hard constraints to not exceed these limits regardless of its recommendation, with a safety layer that is not under AI control. References: >Candidates - suggestions welcome Guidance Principles for the Secure Integration of Artificial Intelligence in Operational Technology, December 2025, joint guidance from nine national cybersecurity agencies across seven countries, led by the United States Cybersecurity and Infrastructure Security Agency. Section 4.1 directs establishing safe operating bounds for OT devices and maintaining a known good state, or thresholds for safe behavior, against which departure can be recognized. Section 4.2 covers failsafe mechanisms that let an AI system fail without disrupting critical operations, including how to bypass or replace it.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	the response the situation calls for. One resolution is the explicit, authorized override under emergency safety protocols that Implementation 3.2.2: Define and independently enforce deterministic operational constraints provides; others include defining the constraint separately for each stage of the cycle, or deriving it from the current process state rather than fixing it at design time. Related AI RMF subcategories include: MAP 4.2 (on establishing risk controls for AI system components): This Task specifies the control itself: a deterministic constraint enforced out of band at an identified intercept point, applied to every automated command source at the physical process boundary; it does not confirm that the control is still functioning once deployed. For that, see Task 3.4: Monitor for anomalous AI behavior. MEASURE 2.6 (on measuring safety): This Task defines the fail-safe states the control system should enter when a constraint is violated or the AI system becomes unavailable, which is the behavior a safety evaluation is run against; it does not perform that evaluation. For that, see Task 2.3: Establish protocols for and regularly perform systematic and achievable Testing, Evaluation, Validation, and Verification (TEVV). MAP 3.5 (on establishing human oversight processes): This Task requires that where one AI system verifies another's output, the human reviewer holds authority to reject the artifact and capacity to examine it, because the presence of a reviewer is not by itself verification; it does not cover validation of the artifact against specification and institutional knowledge. For that, see Practice 12: Independently verify AI-generated operational logic and artifacts across their lifecycle.	Section 2.4 lists challenges in AI-OT integration, among them helping ensure that failsafe mechanisms revert to traditional automation or to manual operation. Standard ISA/IEC 62443-3-3, SR 3.5 (Input Validation), SR 3.6 (Deterministic Output), and SR 3.4 (Software and Information Integrity), from the International Society of Automation and the International Electrotechnical Commission. The industrial control system requirements nearest to the input bounds, predictable output and integrity checks this Implementation places outside the AI system. Guidance OWASP Top 10 for Large Language Model Applications, version 1.0, 2026, from the OWASP GenAI Security Project, a volunteer community project of the Open Worldwide Application Security Project. LLM01:2026, Prompt Injection, covers the input boundary and asks that every model response be validated against a strict output schema in trusted application code before any downstream system acts on it, using structural validation rather than a second model call, and that credentials and state-change capability be held in application code with privileged calls routed through a deterministic policy engine that revalidates intent and arguments at execution time. LLM10:2026, Improper Output Handling, covers the output boundary, and LLM03:2026, Excessive Agency, covers the consequences of model output reaching privileged actions. Regulation 17 CFR 240.15c3-5. Risk management controls for brokers or dealers with market access, a rule of the United States Securities and Exchange Commission codified in Title 17 of the Code of Federal Regulations. Paragraph (c)(1)(i) requires controls that reject orders exceeding pre-set credit or capital thresholds, and paragraph (c)(1)(ii) controls that reject orders exceeding price or size parameters. Paragraph (d) places those controls under the direct and exclusive control of the broker or dealer, which is the regulated form of the separation this Implementation asks for between the system that produces an action and the layer that permits it. 3.2.3: Specify fail-safe states and fallback behavior Define deterministic states the control system should enter when AI output violates the constraints defined in Implementation 3.2.2: Define and independently enforce deterministic operational constraints, when an AI action is refused under Implementation 5.2.2: Action-level, context-aware authorization policies, or when the AI system becomes unavailable or degraded. These fail-safe states should incorporate clear protocols for tracking algorithmic state consistency during failover and re-commissioning cycles. Recovery logic should explicitly dictate whether an overridden AI agent resumes operations by synchronizing with its last active context window, resetting to a validated baseline template state, or gracefully de-escalating control to a legacy deterministic controller, preventing sudden uncommanded physical actions from an un-synchronized model state.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
		For example: • If an AI system commands a valve to be opened while another incompatible valve is also open, the system might fall back onto a less optimal, but known-safe non-AI controller to determine, for the current plant state, which valve has precedence. • If a device loses communication with its AI-based controller, it might default to a pre-defined safe state and broadcast an alert, rather than executing a possibly corrupted last AI-issued command. Note that a 'fail-safe state' does not necessarily mean simply de-energizing or shutting down a system, which can introduce secondary hazards. Fail-safe logic should define deterministic, application-appropriate states, such as holding last-known-safe setpoints, reverting to hard-coded conservative baselines, or reverting control to legacy non-AI controllers. Where an AI action is refused part-way through a sequence, the fail-safe state should account for the steps already executed, since stopping at the refused step can leave the process in a state nobody designed for. For example, if an AI agent changing over pumps is refused authorization to start the standby pump after it has already stopped the duty pump, the fallback might restart the duty pump or hand the changeover to a deterministic controller, rather than leaving both pumps stopped. This Implementation should be aligned with those of Practice 4: Define procedures for emergency avoidance override, recovery, and situation awareness so that immediate-term automated fail-safe and fallback policies are visible to, and align with, subsequent human intervention. References: >Candidates - suggestions welcome Guidance NIST SP 800-82r3, Guide to Operational Technology (OT) Security, from NIST. Section 6.2.4.5, Response and Recovery Plans, pages 114 to 116, covers preparing and testing the plans a disrupted OT system is restored under. Appendix F.7.6, control CP-10, System Recovery and Reconstitution, page 251, addresses whether state variables should be returned to initial values or to the values held before the disruption, which is the choice this Implementation asks recovery logic to make explicit. Appendix F.7.17, control SC-24, Fail in Known State, page 288, covers selecting a failure state that keeps OT state variables consistent with the physical state they represent, and notes that a de-energized state can itself disturb the process. 3.2.4: Define further logging and communication actions Specify logging and communication actions that the organization should take when AI outputs violate constraints. Actions can include notifying necessary operators and systems, and enabling enhanced logging to provide further details.

Practice	Task	Implementation
		For example, when a validation control rejects an AI-generated shutdown command on a generation unit, the plant control room, operators and any connected systems should be notified, and the incident logged along with associated information that may be necessary to update the AI system. Alarms tracking such failures should be throttled or rate-limited rather than flooding operator consoles and logs with repetitive rejection events. For example, multiple identical failures could be consolidated into a single notification. See Task 4.4: Attention Governance and Alert/Alarm Flood Mitigation for further details.
		3.2.5: Artifact verification AI-generated content, such as code, configuration, or procedures, with a high potential for impact (see Implementation 3.1.4: Artifact-driven impact analysis) should be checked via independent means. This should ideally involve non-AI or deterministic techniques. Where it is not possible to avoid the situation of AI systems checking AI outputs, significant care should be taken to ensure that any AI system used for verification doesn't have correlated failure modes to the AI system used for generation (e.g., it doesn't use the same model or training data), and that a human-in-the-loop oversight mode applies to the verification step, with the reviewer holding the authority to reject the artifact and sufficient oversight capacity to examine it. The presence of a reviewer is not by itself verification. See Practice 12: Independently verify AI-generated operational logic and artifacts across their lifecycle for further discussion.
	3.3: Establish Failure Notification Requirements Define the operational conditions under which an AI system should overtly assert a state of exception ("fail loudly") versus when it may attempt autonomous error recovery, clearly distinguishing notification alerts from physical fail-safe states. This task helps ensure that for high-consequence applications, operators maintain sufficient situational awareness to make timely, informed intervention decisions and are protected against undetected operational drift caused by "quiet" AI failures. This is particularly important in multi-system and agentic workflows, where failures in one agent may be unintentionally masked by the resilience of other agents, silently reducing safety margins, degrading performance, or causing preventable damage. The need to "fail loudly" should be considered carefully against the limited oversight capacity of humans (or AI systems) triaging the resulting alarms, to avoid "alarm flood" situations, where a large number of "high priority" alarms reduce the ability to address the underlying	3.3.1: Context-Specific Failure Modes Conduct an engineering assessment for each application to determine its failure notification requirements. For example, silent resilience (e.g., automated retries or soft failovers) may be appropriate for non-critical administrative tasks where internal algorithmic recovery does not alter physical processes or mask safety margins. Conversely, for safety-critical IT/OT/ICS applications, a 'fail loudly' protocol should be enforced with explicit human notifications, even if the system continues to operate, perhaps in a degraded capacity. These notification states should be programmatically linked to the independent safety wrappers in Task 3.2: Implement independent guardrails ("safety wrappers") for AI outputs to ensure that an unacknowledged 'loud' failure automatically forces a transition to a deterministic fallback state (per Implementation 3.2.3: Specify fail-safe states and fallback behavior). To prevent alarm floods and alert fatigue, utilize containment techniques such as time-delay hysteresis, dynamic deadbands (control and sensor ranges where minor fluctuations are ignored and assumed to be noise), and state-based alarm aggregation to compress rapid automated iterations into a single operational event change. See Task 4.4: Attention Governance and

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	problem, especially when unusual failures happen as discussed in Task 4.4: Attention Governance and Alert/Alarm Flood Mitigation. Main Trustworthiness Contributions: Transparent: Contributes the requirement that a departure announces itself at the time: which conditions oblige the AI system to assert an exception, and the thresholds at which degradation becomes a reportable event rather than a later finding. It does not capture what the AI system did in the ordinary case, which Task 10.1: Define decision-level logging and metadata retention policies covers. Valid: Contributes a quantitative limit on how far the operating environment, inputs, task and context may move from the conditions the AI system was established for before a mitigation is required, reviewed at a defined interval and on significant environmental change. It does not establish fit in the first place, which Task 1.3: Implement evaluation and test plans, including TEVV across the AI lifecycle covers. Trustworthiness Effects to Consider: Safe: Each condition that obliges the AI system to speak adds to what the same operators have to read, and this Task's own text notes that a large number of high-priority alarms reduces the ability to address the underlying problem. Task 4.4: Attention Governance and Alert/Alarm Flood Mitigation governs notification volume as a question of capacity. Trustworthiness Tensions to Balance: Resilient versus Transparent: Where autonomous recovery restores an administrative function without touching a physical process or a safety margin, a retry that goes unannounced costs little. Where the same recovery masks a degradation that is consuming a safety margin, or one agent's resilience absorbs another agent's failure, the recovery removes the signal that anything moved. One resolution is the per-application assessment in Implementation 3.3.1: Context-Specific Failure Modes, which sets the notification requirement from the consequence rather than from recovery being available; others include announcing the recovery at a lower priority,	Alert/Alarm Flood Mitigation for further details. 3.3.2: Establish Maximum Drift Thresholds Establish quantitative monitoring and thresholds against which the AI system is continuously or periodically evaluated for how far the real-world operating environment, data inputs, task, and system context can shift from the historic conditions on which the system was trained before mitigations are put in place, defining the specific thresholds that determine when the periodic evaluations in Implementation 2.3.4: Recurrent Risk Evaluations or the continuous monitoring in Task 3.4: Monitor for anomalous AI behavior should trigger a fail-safe response. Determine if exceeding a maximum drift threshold should result in notifications, forced fail-over, or other restrictions on the operation of the system. Minimum responses should include operator notification. For safety-critical applications, responses should include automatic restriction of AI authority or forced failover to a deterministic backup system. Drift thresholds should account for seasonal, operational, and environmental variation relevant to the CI sector, in addition to the physical degradation and changes over time of underlying OT hardware. For example, an AI model trained on summer demand patterns in a water distribution system should have explicit thresholds that detect and flag degraded performance during winter conditions before that degradation can cause operators to miss a safety-relevant alert. Similarly, a healthcare diagnostic AI should flag clinical drift when shifted between different patient demographics, and a financial liquidity model should trigger boundaries during sudden, non-historical macroeconomic shocks. Drift thresholds should be reviewed and recalibrated at a defined interval or whenever a significant change in the operational environment occurs. This implementation mitigates hazard risk associated with silent AI performance degradation. An AI model trained on historical operational data can progressively lose accuracy as the operational environment shifts, without generating any visible failure or alert. Operators could continue to rely on the AI's outputs without realizing its reliability has degraded below acceptable thresholds. References: >Candidates - suggestions welcome Guidance Principles for the Secure Integration of Artificial Intelligence in Operational Technology, December 2025, joint guidance from nine national cybersecurity agencies across seven countries, led by the United States Cybersecurity and Infrastructure Security Agency. Principle 4, Embed Oversight and Failsafe Practices Into AI and AI-Enabled OT Systems, pages 18 to 20. Section 4.1 directs establishing safe operating bounds for OT devices that detect AI drift and model changes affecting safety and performance, and maintaining a known good state or thresholds for safe

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	or counting it against a drift threshold so that repetition becomes visible. Related AI RMF subcategories include: MANAGE 4.3 (on incident response): This Task defines when an AI system should assert a failure overtly rather than recover quietly, and the pre-authorized pathway by which each class of output reaches the person who should act on it; it does not address what happens when notification volume exceeds what operators can triage. For that, see Task 4.4: Attention Governance and Alert/Alarm Flood Mitigation. MEASURE 2.5 (on measuring validity and reliability): This Task converts the documented limits of a model's generalizability into quantitative drift thresholds, each with a defined response when the operating environment moves beyond it; it does not establish those limits. For the testing that establishes them, see Task 2.3: Establish protocols for and regularly perform systematic and achievable Testing, Evaluation, Validation, and Verification (TEVV). GOVERN 4.3 (on enabling AI testing, incident identification, and information sharing): This Task makes an AI failure identifiable at the moment it occurs, by treating silent recovery as a choice to be justified for each application rather than as the default; it does not cover the analysis that follows once a failure has been identified. For that, see Practice 8: Incorporate AI-aware incident analysis and response procedures. References: >Candidates - suggestions welcome Guidance NIST SP 800-82r3, Guide to Operational Technology (OT) Security, from NIST. Appendix F.7.18 tailors the System and Information Integrity controls to OT, for cybersecurity failures. SI-17, Fail-Safe Procedures, is added to all three baselines so that an organization holds a written record of which failures draw which response, and its OT discussion holds that the same failure event may warrant different responses at different impact levels, and that a fail-safe state should account for impacts on human safety, physical systems and the environment. SI-13, Predictable Failure	behavior. Section 4.2 covers the failsafe mechanisms a breached threshold can hand control to. 3.3.3: Actionable Operator Decision & Escalation Pathways Establish clear, pre-authorized decision pathways that dictate how personnel respond to AI outputs across normal, degraded, and emergency operating conditions. Organizations should operationalize these pathways into simplified quick-reference guides, HSI prompts, and standard operating procedures. Examples to consider include: Trust & Execute: Routine, high-confidence recommendations within validated baseline operating envelopes (as identified in Task 1.1: Identify current requirements) executed without further review and notified for visibility. Spot-Check & Investigate: Recommendations with moderate confidence scores or novel input parameters (e.g., an unusual maintenance condition, borderline prior-authorization claim, or atypical network routing request), requiring a brief manual sanity check before execution. Escalate to Oversight: Persistent, non-critical model anomalies or recurring "soft" failures that do not threaten immediate safety or service continuity but indicate algorithmic drift or data schema shifts (as discussed in Implementation 3.3.2: Establish Maximum Drift Thresholds). Immediate Emergency Override: Any AI output that intersects with deterministic safety/policy wrappers (as discussed in Task 3.2: Implement independent guardrails ("safety wrappers") for AI outputs), violates hard physical or financial limits, or occurs during an unannounced multi-system outage.

Practice	Task	Implementation
	Prevention, and SI-6, Security and Privacy Function Verification, each record that restarting or shutting down on the identification of an anomaly may not be acceptable in OT for operational reasons, which is what makes quiet recovery a decision rather than a default. Standard ANSI/ISA-62443-3-3, from the American National Standards Institute and the International Society of Automation. Sets system-level security requirements and security levels for industrial automation and control systems. Standard ISA-18.2, Management of Alarm Systems for the Process Industries, from the International Society of Automation. Covers exception reporting and alarm prioritization, which is the established practice a requirement to fail loudly has to sit inside if the resulting alarms are to stay actionable. >To the Reviewer: >This concept is one that is familiar to the OT community and, for that matter, the electronic and mechanical engineering disciplines. For example, in many cases the purpose of an electrical or mechanical fuse is to cause a piece of equipment to “fail loudly” even if it could have kept going for a little bit longer (but then may have caused more damage when it finally failed). >What would be examples of sector-specific guidance/regulations relating to the concept of “failing loudly” that would be applicable to AI (both within OT/ICS and otherwise)?	
	3.4: Monitor for anomalous AI behavior Define policies and procedures for detecting acute, undesired, unexpected, and unusual AI system behavior, as continuous, real-time monitoring that complements the scheduled batch evaluations in Implementation 2.3.4: Recurrent Risk Evaluations and operates against the thresholds defined in Implementation 3.3.2: Establish Maximum Drift Thresholds. This includes violations and near violations of constraints defined in Implementation 3.2.2: Define and independently enforce deterministic operational constraints as well as other metrics such as unusual changes in performance or output, even if they remain	3.4.1: Define observability requirements Identify observable AI system behaviors and metrics, including output patterns, decision frequencies, and validation control states.
		3.4.2: Establish operational baselines and deviation thresholds Define what normal AI system behavior looks like under authorized operating conditions, and establish the deviation ranges to determine abnormal behavior.
		3.4.3: Monitor validation control integrity Establish continuous monitoring of validation control states (defined in Task 3.2: Implement independent guardrails (“safety wrappers”) for AI outputs) to validate that mechanisms are actively and correctly functioning.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	within safe constraints. Detection of regular anomalous behavior should also feed into the estimation of drift velocity in Implementation 2.3.4: Recurrent Risk Evaluations. This includes distinguishing, where feasible, between anomalies likely caused by incidental drift or error and those consistent with deliberate interference. Main Trustworthiness Contributions: Reliable: Contributes the continuous check that the AI system still performs as it did when it was accepted, covering near-violations and changes in output that stay inside the safe constraints, so degradation arising between scheduled evaluations is caught. It does not set the limits those observations are judged against, which Implementation 3.3.2: Establish Maximum Drift Thresholds sets. Secure: Contributes the runtime separation of an anomaly consistent with drift or error from one consistent with deliberate interference, together with confirmation that the enforcement layer is still functioning. It does not monitor access boundaries or privilege escalation by AI entities, which Task 5.4: Implement continuous security monitoring for AI entity actions covers. Trustworthiness Effects to Consider: Privacy-Enhanced: Observing output patterns means retaining outputs, and for an AI system working on records or documents those outputs carry whatever the source carried. Implementation 10.1.3: Forensic Integrity and Privacy-Preserving Log Partitioning sets the masking and partitioning arrangements for telemetry that holds sensitive material. Trustworthiness Tensions to Balance: Secure versus Reliable: Where the cause of an anomaly is clear, the response follows from it. Where one observation could be drift or could be interference, the reliability response of recalibrating or widening the baseline and the security response of preserving state and investigating point in opposite directions, and handling manipulation as drift adapts the AI system toward the manipulated distribution. One resolution is to	3.4.4: Define runtime anomaly escalation procedures Extend communications actions defined under Implementation 3.2.4: Define further logging and communication actions to cover sustained or recurring behavioral anomalies of AI systems.

Practice	Task	Implementation
	hold the baseline and escalate under Implementation 3.4.4: Define runtime anomaly escalation procedures until the cause is established; others include preserving the evidence while continuing to operate under tightened constraints. Related AI RMF subcategories include: MEASURE 2.4 (on monitoring deployed AI systems): This Task defines the observable behaviors, operational baselines and deviation ranges by which a deployed AI system is watched continuously, including whether its validation controls are still functioning; it does not cover the scheduled evaluation that runs alongside that monitoring. For that, see Implementation 2.3.4: Recurrent Risk Evaluations. MEASURE 3.1 (on tracking known and emerging risks): This Task tracks emergent behavior against an operational baseline, and distinguishes, where feasible, anomalies caused by drift or error from those consistent with deliberate interference; it does not track risks that leave no observable trace in the system's own behavior. MANAGE 2.3 (on responding to emerging risks): This Task defines the escalation procedure that a sustained or recurring anomaly should trigger where it matches no previously characterized failure mode; it does not cover the intervention and recovery that follow. For those, see Practice 4: Define procedures for emergency avoidance override, recovery, and situation awareness.	
	3.5: Define and control risks to adjacent and related systems Define and control risks to other systems that may be affected by a failure in this system, including: - Systems that are intentionally interdependent with this system, where errors travel along functional, data, or operational dependencies ("cascading failures"). - Systems that may be unrelated except for shared adjacency in a physical, logical, network, resource, supply chain, or other sense ("splash damage" or "blast radius").	3.5.1: Map direct functional and algorithmic dependencies Trace and document downstream logical, algorithmic, and operational paths of AI outputs to identify how errors, whether in control outputs, direct executable code, or human-mediated summaries, could trigger a chain reaction through connected assets. These dependencies often extend beyond traditional IT/OT/ICS boundaries; for example, an AI agent defending an IT network might erroneously disable authentication traffic, physically locking personnel out of a facility. To fully capture these risks, organizations should conduct a high-value asset (HVA) assessment that extends outward to map functional dependencies on upstream suppliers and downstream customers, helping ensure automated errors do not propagate along the extended supply chain.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	Main Trustworthiness Contributions: Safe: Contributes containment of consequence beyond the AI system's own function: execution confined to isolated segments, and limits on shared resources such as compute, bandwidth, power and exclusive sensor access, so a failure reaches a bounded set of assets. It does not bound what the AI system is permitted to reach in the first place, which Task 5.3: Implement principles of least agency and least privilege for AI entities covers. Resilient: Contributes the common-cause analysis that redundancy rests on: whether systems and safeguards that are functionally independent share a facility, a power or cooling supply, a network path, a hypervisor or a municipal substrate. It does not establish the redundancy itself, which Task 2.2: Establish requirements for redundancy in AI-Driven functions covers. Trustworthiness Tensions to Balance: Safe versus Reliable: Where an AI system's demand for a shared resource is steady, a hard limit protects the systems alongside it while the AI-enabled function continues to perform as required. Where demand rises during the same upset that raises demand elsewhere, the limit removes capacity from the function at the point it is most needed. One resolution is the graded arrangement in Implementation 3.5.4: Define and implement resource limiting, where a soft limit and a notification precede the hard limit; others include reserving capacity for the highest-consequence function, or defining the state the function enters when it is throttled. Related AI RMF subcategories include: MAP 5.1 (on identifying risk likelihood and impacts): This Task identifies impacts on systems that share physical space, network paths, logical substrates or scarce resources with the AI system, and on systems downstream of it; it does not cover impacts at the AI system's own decision points. For those, see Task 3.1: Identify risk tradeoffs. MAP 3.3 (on documenting application scope of the AI system): This Task bounds the scope an AI system can reach, by confining its execution to isolated segments and capping the shared resources it may consume; it does not define	3.5.2: Identify indirect shared infrastructure and collateral damage exposure Audit the operational environment to identify functionally independent systems that are vulnerable to collateral damage from an AI failure. Evaluation criteria should include cross-cutting environmental and infrastructure commonalities, such as: - Physical Proximity: Independent physical assets co-located in the same facility or enclosure, or that share the same power, cooling, or other physical resources. - Network Topography: Systems sharing the same network switches, backbones, or uplink paths. - Logical Substrates: Unrelated applications sharing the same hypervisor, underlying cloud tenant, base operating system image, or database instance. This mapping should also consider whether a single event or action could affect multiple identified safeguards at once, rather than assuming redundant controls fail independently. This asset assessment should, where possible, reach outward past the facility's immediate perimeter to evaluate shared municipal substrates, such as the regional electrical grid, water networks, or telecommunication backbones, where a localized AI failure or resource-saturation event could cause regional collateral damage. Where direct technical visibility or telemetry past the facility's perimeter is unavailable, organizations should utilize qualified engineering approximations and best-available sector intelligence to estimate these external impacts. These estimations should be explicitly documented as bounded technical assumptions to ensure transparency regarding data limitations, preventing the assessment from stalling due to incomplete external information. The task of mapping internal dependencies is common to Implementation 7.6.1: Internal Dependency Mapping (Orphan System Prevention). Maintaining this map can reduce the effort needed when this system is later decommissioned. This mapping is also the basis for identifying what depends on an AI system at retirement, under Implementation 13.3.3: Determine and record what happens to everything that depended on the system. 3.5.3: Impact compartmentalization (sandboxing) Restrict AI agent execution to isolated micro-segments of the network or other infrastructure. For example, an AI optimizing valve pressure should not be able to affect core safety instrumented systems (SIS). 3.5.4: Define and implement resource limiting Identify limited resources that the AI agent or system shares with other

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	the intended scope from which those bounds should be derived. For that, see Practice 1: Establish requirements for success. GOVERN 4.2 (on documenting impact): This Task requires that impacts estimated beyond the facility perimeter be recorded as bounded engineering assumptions where telemetry is unavailable, so that the limits of the assessment stay visible to a later reader; it does not cover communicating those impacts to the operators of the affected systems.	systems (AI or otherwise), such as compute, tokens, exclusive hardware/sensor access, power, network bandwidth, and cooling. Define and implement appropriate soft and hard limits on the AI system's use of these resources, along with appropriate notifications for when these limits are approached or exceeded.
	3.6: Mitigate automation complacency and skills degradation Establish continuous readiness and training protocols that keep critical human capabilities exercised. Reliance on an AI system is often the intended result of adopting one, be it to make new aspects of the task possible or perform existing tasks with more efficiency. Where it takes over work people did before, it reduces the occasions on which those capabilities are used (see Bainbridge 1983). Practice to sustain these capabilities has to be arranged rather than left to routine operation. This task requires organizations to identify critical human capabilities that should be preserved, helping ensure that operators retain the technical expertise, cognitive situational awareness, and manual or legacy override proficiency necessary to manage operations during prolonged AI outages or catastrophic failures. Note that this includes full manual overrides (where system velocity makes this possible, see Task 4.5: Define operational regimes for human-on-the-loop and human-out-of-the-loop operation), the ability to monitor and operate deterministic fallback or legacy systems (Task 3.2: Implement independent guardrails ("safety wrappers") for AI outputs), and decision-making processes necessary to perform appropriately risk-managed unplanned shutdowns (Practice 11: Maintain AI-aware mission continuity and disaster recovery planning).	3.6.1: Baseline Human Competency Retention Identify and document the core operational skills (e.g., manual loop tuning, raw data interpretation, manual dispatch) that risk being eroded by day-to-day AI reliance. Incorporate periodic, audited training or, commensurate with available operational resources, simulator-based testing to verify that human operators can safely run the infrastructure without AI assistance.
		3.6.2: Scheduled "Manual Control" Drills Where appropriate, establish a routine cadence of scheduled operational drills analogous to facility "live-load generator exercising" or "blackout drills" in OT, paper-based charting and manual triage cycles in healthcare, or offline transaction reconciliation procedures in finance. During designated low-risk or off-peak windows, simulate a failure of the AI system. The failure could include a loss of availability or a combination of other failures as identified in Task 3.1: Identify risk tradeoffs. These drills should be designed to achieve two primary outcomes: • Technical Validation: Verify that fallback deterministic control systems, analog backups, and safety interlocks successfully assume the operational load without data loss or safety breaches. • Human Readiness: Force human operators to actively manage operations via legacy or manual methods, preserving the critical muscle memory, tactical domain skills, and situational awareness required to safely navigate a real-world, unannounced AI outage. For applications where this is not possible within safety or regulatory constraints, they should be performed within non-production systems, see Implementation 1.3.2: Categorization of Testing Environments for further details.
	Main Trustworthiness Contributions:	3.6.3: Cognitive Engagement Monitoring Design the human-system or human-machine interface (HSI or HMI) to

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	Resilient: Contributes periodic exercise of the fallback path under real load: drills in which deterministic controllers, analog backups and safety interlocks take over the operation, which is what separates a documented fallback from a demonstrated one. It does not cover sustained operation once the fallback is carrying the process, which Task 11.2: Define manual and alternative operating procedures for long-term mission continuity covers. Bias Managed: Contributes a bound on one human-cognitive error source, automation bias, by placing active verification at high-consequence boundary thresholds so that agreement with an AI output is an act rather than a default. It does not address the notification rate that produces desensitization, which Task 4.4: Attention Governance and Alert/Alarm Flood Mitigation covers. Trustworthiness Effects to Consider: Reliable: Simulating a failure of the AI system is itself an operational action, and a drill placed in a window judged low-risk can still meet a real disturbance. Implementation 3.6.2: Scheduled "Manual Control" Drills directs drills that cannot be run safely on the live system to non-production environments, which Implementation 1.3.2: Categorization of Testing Environments categorizes. Trustworthiness Tensions to Balance: Safe versus Safe: Where verification steps are reserved for high-consequence boundary thresholds, operator engagement is spent where the consequence is greatest. Where they are applied widely, the same steps become routine, and a check performed routinely returns agreement without examination while still consuming capacity needed elsewhere. One resolution is the restriction to high-consequence thresholds in Implementation 3.6.3: Cognitive Engagement Monitoring, deployed with the calm technology and mixed-initiative choices in Implementation 4.4.4: Applying consolidation and low-cognitive-load design techniques; others include varying when the check falls so that it is not anticipated, or moving the exercise into scheduled drills. Related AI RMF subcategories include: MAP 3.4 (on defining operator proficiency): This Task identifies the manual and interpretive skills that	prevent passive monitoring. Consider active human verification step-throughs or "sanity checks" for truly high-consequence AI recommendations to counter the psychological tendency of operators to automatically trust machine outputs (automation bias). To manage the critical tradespace between active human validation and cognitive exhaustion, these checkpoints should be reserved strictly for high-consequence operational boundary thresholds. They should be deployed flexibly, utilizing the mixed-initiative and calm technology design choices referenced in Implementation 4.4.4: Applying consolidation and low-cognitive-load design techniques to prevent alert fatigue from driving superficial operator compliance.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	day-to-day AI reliance erodes, and requires periodic audited verification that operators can still run the infrastructure without AI assistance; it does not deliver the instruction that builds those skills. For that, see Task 9.2: Deliver specialized training on human-AI interaction and automation bias. GOVERN 4.1 (on establishing a risk-aware culture): This Task designs the operator interface against passive monitoring, placing active verification steps at high-consequence boundaries so that trust in an AI output stays deliberate; it does not address the alert fatigue that too many such checkpoints would cause. For that, see Task 4.4: Attention Governance and Alert/Alarm Flood Mitigation. References: Research Bainbridge, L., Ironies of Automation, Automatica volume 19 number 6, 1983, pages 775 to 779. <i>Automatica</i> is the journal of the International Federation of Automatic Control, an international body whose members are national control engineering organizations. A seminal paper on the human factors of automated process control. Its subject is the process-control computers of 1983, and the mechanisms it identifies are relevant to AI systems. Section 1.1.1 sets out why manual skills decay when unused, so that "a formerly experienced operator who has been monitoring an automated process may now be an inexperienced one", and section 2.3 discusses what maintaining them requires, including hands-on control periods and simulator practice.	
	3.7: Govern and mitigate risks from unauthorized, transient, and "Shadow AI" systems Establish organizational policies, procurement gates, and contractor onboarding workflows to detect, restrict, and manage risks associated with unvetted or unauthorized AI systems, localized open-source foundational models, and agentic tools brought into the operational environment by internal personnel or third-party contractors. In combination with Practice 7: Manage internal AI supply chain and data provenance, this task helps ensure that any AI capability utilized within the facility's physical or logical boundary is explicitly accounted for in the	3.7.1: AI Attestation Consider requiring third-party contractors to sign a formal attestation declaring any AI-backed analytical tools, Large Language Models (LLMs), or automated code/configuration generation software utilized during their contract period. These should be cataloged in the organization's AI system inventory and subject to appropriate risk management controls as described in Implementation 7.1.1: Create and maintain a "Master AI Asset List" (regarding inventory) and Task 1.3: Implement evaluation and test plans, including TEVV across the AI lifecycle and Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools and Practice 7: Manage internal AI supply chain and data provenance (regarding controls).

Practice	Task	Implementation
	organization's risk profile and configuration management baselines. Main Trustworthiness Contributions: Secure: Contributes visibility of AI capability that entered the environment outside procurement: contractor attestation, detection of traffic to public AI endpoints, and scanning for unapproved applications and local models, so an AI system operating outside the credential directory becomes known. It does not deny those entities access, which Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools covers. Privacy-Enhanced: Contributes the point at which an undeclared external AI service becomes visible, where condition reports, operational records or facility information may otherwise leave through an endpoint nobody cataloged. It does not govern the dataflows of services the organization has authorized, which Task 6.3: Identify and control dataflows across the AI supply chain covers. Trustworthiness Effects to Consider: Privacy-Enhanced: Detection works by observing the traffic and endpoints that personnel and contractors use, so it also produces a record of how individuals work. Governing that record belongs with the organization's existing workforce monitoring and privacy practice. Trustworthiness Tensions to Balance: Secure versus Secure: Where sanctioned tooling covers the work people need to do, restricting unvetted AI removes exposure at a modest cost. Where it leaves the need unmet, the same restriction moves the use to personal devices and accounts, which detection and logging reach less well than the corporate network did. One resolution is to pair each restriction with a sanctioned route that meets the underlying need; others include a time-bounded permit for a declared tool under the attestation in Implementation 3.7.1: AI Attestation, or accepting the restriction and resourcing the gap it leaves. Related AI RMF subcategories include:	>To the Reviewer: >This implementation is about visibility, with the aim of enabling oversight of otherwise shadow IT systems through the other controls in this document (e.g., TEVV, identity and access control, etc.). On the one hand, we want to keep this concise, on the other hand perhaps a little more direction might be useful to direct the reader to why this attestation is useful. How would you strike this balance? 3.7.2: AI Use Detection Incorporate the detection and logging of traffic to known public commercial AI API endpoints. Include scanning for unapproved AI applications, including containerized applications and software models. Monitor for unusual high-volume traffic that may indicate an unauthorized AI system ingesting data.

Practice	Task	Implementation
	GOVERN 1.6 (on building the AI inventory): This Task brings AI that entered the environment without procurement, including contractor tooling and locally run open-source models, into the same inventory as sanctioned systems; it does not cover registration of components the organization has deliberately acquired. For those, see Task 6.2: Align AI and existing CI asset lifecycle management. GOVERN 6.1 (on establishing third-party risk management processes): This Task treats contractor attestation and onboarding as the point at which third-party AI use becomes declarable at all; it does not set the trustworthiness and visibility requirements that a vetted vendor should meet. For those, see Task 6.1: Develop policies for AI supply chain requirements. MANAGE 3.1 (on monitoring and responding to third-party risks): This Task detects use of external commercial AI services by logging traffic to known API endpoints and scanning for unapproved models and containers; it does not monitor the actions of AI entities that hold authorized credentials. For those, see Task 5.4: Implement continuous security monitoring for AI entity actions. References: >Candidates - suggestions welcome Guidance NIST SP 800-82r3, Guide to Operational Technology (OT) Security, from NIST. Control CM-8, System Component Inventory, with enhancement (3), Automated Unauthorized Component Detection, is the established control for finding components that entered an environment without authorization, and the OT tailoring selects it at the moderate and high baselines. The tailoring adds no OT-specific discussion to this control, so what it gives here is the control and its baseline placement rather than commentary on applying it in an OT setting. Guidance AI Shared Responsibility Framework, version 1.0, Workstream 2: Preparing Defenders for a Changing Cybersecurity Landscape, from the Coalition for Secure AI, an OASIS Open Project. Page 4 names the condition this Task exists for: unsanctioned AI usage thriving in the	

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	gray areas between IT security, business units and external vendors, where, left unassigned, no single group monitors for rogue usage or owns the risk of sensitive data exposure. Page 15 gives a detection list covering discovery of ungoverned AI tool usage, network monitoring for AI service API calls and web usage, departmental AI spending and subscription tracking, and risk assessment of what is found, alongside criteria for when tool usage should escalate into a governed enterprise system. Its responsibility matrix places accountability for shadow AI detection on the operating organization rather than on any provider.	
	3.8: Scope and map the expanded AI Attack Surface and Risk Surface Catalog both the adversarial exploitation vectors (AI Attack Surface) and the non-adversarial, systemic vulnerability vectors (AI Risk Surface) introduced by AI deployment across all lifecycle stages. Technical managers should evaluate how non-deterministic AI logic expands operational risk beyond traditional cybersecurity boundaries to encompass all TACIP Trustworthiness Characteristics described in Table 2. To enable the evaluation of the reachable risk surface of third-party AI components, vendors should provide the disclosures, described in Implementation 6.1.5: Operational AI Hazard Reachability Disclosures, to formally declare which upstream model limitations are operationally contained before deployment. Main Trustworthiness Contributions: Secure: Contributes the catalog of AI-specific adversarial exposure: the interfaces at which a crafted input can reach inference, from direct and indirect prompt injection to training data poisoning, model extraction and tool invocation. It does not place controls at the interfaces it finds. For those, see Task 3.2: Implement independent guardrails ("safety wrappers") for AI outputs and Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools. Safe: Contributes the half of the picture where harm arises with no attacker present: feedback loops or distribution shifts driving controllers out of limits, plausible hallucinations in generated logic, and opaque pathways	3.8.1: AI Attack Surface Mapping (Adversarial Exposure) Identify and catalog technical AI-specific attack vectors, such as direct and indirect prompt injection, training data poisoning, model extraction, context window manipulation, and malicious tool/API invocation. Document all interfaces where adversarial inputs can reach AI inference logic. References: >Candidates - suggestions welcome Guidance NIST AI 100-2e2025, Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations, from NIST. Section 2.3 covers poisoning attacks on predictive systems and section 2.4.4 model extraction. Sections 3.3 and 3.4 cover direct prompting attacks and indirect prompt injection against generative systems. Section 3.5 covers agents that select and call tools, where a prompt injection becomes an action taken in the environment. Published counterparts for most of the vectors this Implementation asks to be cataloged, each with the mitigations reported for it. Guidance MITRE ATLAS, maintained by MITRE, a not-for-profit organization in the United States that operates federally funded research and development centers. A matrix of tactics and techniques observed in attacks on AI-enabled systems, structured after the same organization's ATT&CK matrix for enterprise systems. Organized by the stage of an attack rather than by the kind of attack, which is the axis that matches documenting the interfaces at which an adversarial input reaches inference. 3.8.2: System-Wide Risk Surface Mapping (Non-Adversarial Trustworthiness Exposure) Map system vulnerabilities across all TACIP Trustworthiness Characteristics where non-deterministic AI behavior can cause physical, operational, or administrative harm without an active attacker. For example: • Safety & Resilience: Unintended feedback loops or distribution

Practice	Task	Implementation
	that slow a response. It does not weigh the consequence of each exposure, which Task 3.1: Identify risk tradeoffs covers. Trustworthiness Effects to Consider: Secure: The catalog states where an AI system can be reached and which hazards a deployment has left reachable, which is useful to an adversary who obtains it. Handling it belongs with the organization's existing information classification and handling practice. Trustworthiness Tensions to Balance: Safe versus Safe: Where a hazard has been shown unreachable in this deployment and the control that makes it so is stable, treating it as contained lets attention go to the deviations that can occur. Where autonomy is widened, one agent is chained to another, or the operating environment moves, the same hazard can become reachable while the record still shows it contained. One resolution is the periodic coupling analysis in Implementation 3.8.3: Dynamic Risk Surface Coupling Analysis, which treats a widened risk surface as a trigger to re-evaluate the guardrails a containment claim rested on; others include time-bounding a containment claim, or re-confirming it whenever guardrail scope changes. Related AI RMF subcategories include: MAP 4.1 (on understanding AI component-level risks): This Task catalogs the adversarial vectors that can reach AI inference logic, including direct and indirect prompt injection, data poisoning, model extraction and malicious tool invocation; it does not obtain the vendor statements that show which upstream model limitations remain reachable in deployment. For those, see Implementation 6.1.5: Operational AI Hazard Reachability Disclosures. MEASURE 2.7 (on measuring security and resiliency): This Task supplies the attack and risk surface that a security and resilience evaluation is scoped against, which is the identification MEASURE 2.7 refers back to the MAP function for; it does not carry out that evaluation. For that, see Task 2.3: Establish protocols for and regularly perform systematic and achievable Testing, Evaluation, Validation, and Verification (TEVV).	- shifts driving physical controllers out of safe limits. - Explainability & Forensic Auditability: Opaque decision pathways that impede real-time operator situational awareness or post-event root-cause analysis. - Privacy & Data Protection: Systemic ingestion or leakage of sensitive telemetry, facility blueprints, or personally identifiable information (PII) into retrieval repositories or prompts. - Fairness & Bias: Algorithmic distortion causing unequal resource dispatch, asymmetric hazard detection across different equipment ages/vendors, or biased administrative reviews. - Accuracy & Reliability: Plausible hallucinations in report summaries, diagnostic feeds, or AI-generated execution logic. 3.8.3: Dynamic Risk Surface Coupling Analysis Conduct periodic evaluations of how changes in the operating environment, data distribution drift, increased agentic autonomy, or multi-agent chaining expand or contract the system's risk surface over time. Ensure that risk surface expansion automatically triggers re-evaluation of independent guardrails (Task 3.2: Implement independent guardrails ("safety wrappers") for AI outputs) and of the oversight thresholds established under Implementation 4.5.1: Define engineering time-constant thresholds, since a widened risk surface can move a path across a threshold that was previously satisfied.

Practice	Task	Implementation
	GOVERN 1.2 (on defining trustworthy AI policies): This Task turns each trustworthiness characteristic into a category of operational exposure to be mapped, so that safety, explainability, privacy, fairness and accuracy are examined as vulnerability surfaces rather than as aspirations; it does not define the characteristic set or the terms used for it. References: >Suggestions welcome	
	3.9: Assess and document organizational readiness for each AI-enabled capability Determine whether the governance and oversight mechanisms applicable to an AI-enabled capability are executable for the specific capability and operating context. Make this determination before deployment, and again whenever a material change occurs. For the conditions that trigger reassessment, see Implementation 3.9.2: Define Decision Authority and Reassessment Triggers.	3.9.1: Establish Accountable Ownership Identify an accountable owner for the AI-enabled capability and associated governance decisions. Document responsibility for governance decisions across the AI lifecycle, including responsibility for determining whether the capability may be deployed, continue operating, or operate under modified conditions. Where responsibilities span multiple organizational functions, identify the role accountable for resolving conflicting recommendations or decisions.
	This assessment is capability- and context-specific rather than a general organizational maturity assessment. An organization may have established AI policies and governance structures while still lacking the accountability, authority, escalation paths, operational capability, or enforceability necessary to govern a particular AI-enabled capability. This is distinct from Task 4.5: Define operational regimes for human-on-the-loop and human-out-of-the-loop operation, which concerns whether a person can intervene in a single machine-speed action as it happens. This Task concerns whether a governance decision, once made, can be enforced at all, be it before deployment, throughout operation, or after material change. The conditions under which a capability is retired, and the authority to decide, are identified under Implementation 13.1.1: Identify retirement triggers, including those outside the organization's control and recorded, with the deciding authority, under Implementation 3.9.2: Define Decision	3.9.2: Define Decision Authority and Reassessment Triggers Document who has authority to accept risk, restrict deployment or operation, suspend use, require remediation, roll back the capability, or reduce its delegated authority. Define the scope and limits of that authority in relation to the potential consequences associated with the capability and its operating context. The depth of governance should scale with both the authority granted to the AI-enabled capability and the potential consequence of its actions. Establish conditions that trigger reassessment of organizational readiness following material changes to the AI-enabled capability, use case, delegated authority, operating environment, dependencies, or potential consequences. Where a material change means the organization can no longer confirm that previously established governance or enforcement paths remain effective, re-open the readiness determination rather than assuming that the prior determination remains valid. Two other parts of the profile define re-evaluation triggers: Implementation 2.3.4: Recurrent Risk Evaluations, and Implementation 3.8.3: Dynamic Risk Surface Coupling Analysis. Where either trigger activates for a capability whose governance rests on a prior readiness determination, treat it as a material change for the purposes of this Implementation. The authority tiers

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	Authority and Reassessment Triggers. Main Trustworthiness Contributions: Accountable: Contributes the demonstration that a governance decision reaches the system's operating state: that restriction, suspension, rollback or reduction of delegated authority takes effect, within a window set against consequence, confirmable without relying on the capability's own report, and holding until an authorized decision changes it. It does not cover intervention in a single machine-speed action as it happens. Task 4.1: Establish "break-glass" intervention procedures covers procedures while Task 4.5: Define operational regimes for human-on-the-loop and human-out-of-the-loop operation covers the feasibility of intervention. Valid: Contributes a readiness determination made for this capability in this operating context, re-opened when the capability, use case, delegated authority or environment materially changes, so the determination does not outlive the conditions it was made under. It does not determine whether the AI system suits the deployment, which Task 1.3: Implement evaluation and test plans, including TEVV, across the AI lifecycle covers. Trustworthiness Effects to Consider: Reliable: Demonstrating that a suspension or a rollback takes effect means exercising it, and exercising it on a live deployment interrupts the function it governs. Implementation 1.3.2: Categorization of Testing Environments categorizes the environments in which such exercises belong, and names the applications for which an authorized outage window is the safer place. Trustworthiness Tensions to Balance: Accountable versus Resilient: Where the restricted capability is not the one keeping a service running, authority that holds until an authorized decision reverses it is the protection intended. Where it is, a restriction that cannot be lifted quickly extends the loss of that service. One resolution is to settle the restoration decision and its authority at the same time as the restriction, so reversal is an authorized path rather than an exception; others include scoping the restriction to the function at issue rather than the whole capability, which the range of decisions in Implementation 3.9.5: Demonstrate	referred to here should be consistent with those established in Implementation 4.1.2: Establish tiered intervention procedures, training, and authorization. 3.9.3: Establish Escalation to Empowered Authority Define escalation paths that move AI risk information to a role with sufficient authority to make the required governance decision. Identify escalation points for circumstances in which the risk, consequence, scope, or required response exceeds the decision authority of the person or function initially receiving or identifying the issue. Test or otherwise validate that escalation paths terminate with a role empowered to act rather than solely with a role responsible for receiving or documenting the issue. Where the escalation concerns an in-progress operational anomaly rather than a governance decision, Implementation 4.1.2: Establish tiered intervention procedures, training, and authorization applies. This Implementation covers escalation of the governance decision itself. 3.9.4: Assess Operational Capability Assess whether existing organizational functions collectively provide sufficient capability to execute the governance requirements applicable to the AI-enabled capability. Consider whether accountability, decision authority, escalation, lifecycle responsibilities, monitoring, and control execution operate together sufficiently for the intended use and operating context. Where these conditions are met, existing governance structures may be extended to cover the AI-enabled capability. Where authority, accountability, lifecycle coverage, or operational capability is fragmented or absent, establish additional governance mechanisms as necessary. Where the assessment turns on whether a governance decision could actually be carried out, use the five properties in Implementation 3.9.5: Demonstrate Operational Enforceability as the test, rather than a general judgment of sufficiency. Where the assessment turns on whether personnel can actually perform the roles assigned to them, apply the role-specific training and competency requirements in Implementation 9.2.1: Include role-specific training on "AI failure modes" and the simulation training in Implementation 9.2.2: Implement realistic incident simulation training. Organizational capability includes the people who must exercise it. 3.9.5: Demonstrate Operational Enforceability Before deployment and following material changes that could affect established enforcement paths, demonstrate that a governance decision to restrict, suspend, roll back, or reduce the delegated authority of an

Practice	Task	Implementation
	Operational Enforceability anticipates, or carrying the service on the continuity arrangements in Practice 11: Maintain AI-aware mission continuity and disaster recovery planning while the restriction holds. Related AI RMF subcategories include: GOVERN 2.1 (on establishing roles and responsibilities): This Task identifies an accountable owner for the AI-enabled capability, and tests that escalation paths terminate with a role empowered to act rather than only to receive or record; it does not cover the operator-level pathways for responding to individual AI outputs. For those, see Implementation 3.3.3: Actionable Operator Decision & Escalation Pathways. GOVERN 1.3 (on establishing risk management processes): This Task scales the depth of governance to the authority delegated to a capability and to the consequence of its actions, and re-opens the readiness determination on material change; it does not set the thresholds that place a capability in a consequence class. For those, see Implementation 3.1.3: Define acceptable risk thresholds and associated control responses. MANAGE 2.4 (on decommissioning or superseding AI systems): This Task requires evidence, before deployment, that a decision to restrict, suspend, revert or reduce a capability's delegated authority can be made effective, verifiable and durable in the running system; it does not cover the orderly removal of an AI component at end of life. For that, see Task 13.2: Withdraw authority completely and confirm that it is withdrawn. GOVERN 1.5 (on establishing monitoring and review processes): This Task defines the material changes that should re-open a readiness determination, which gives the review an event trigger rather than only a calendar; it does not set a frequency for periodic review.	AI-enabled capability can be translated into an actual change in the system's operational state, not only recorded as policy or intent, and that the change is: (a) Effective: the decision produces the intended change in what the system is permitted to do or continues to do. (b) Timely relative to consequence: the change takes effect within a window that the organization defines and documents in advance, proportionate to the consequence class of the capability and the operational risk it presents, determined using the threshold criteria in Implementation 3.1.3: Define acceptable risk thresholds and associated control responses. (c) Verifiable: the organization can confirm the change actually took effect, rather than relying exclusively on the capability's self-attestation that it complied. (d) Durable: once enforced, the restricted or reduced authority holds until a new authorized decision changes it; the capability cannot silently resume, re-expand, or reacquire the withdrawn authority. (e) Sufficient in scope: enforceability covers the range of decisions the governance structure may need to make (restriction, suspension, rollback, and reduction of delegated authority), not a single all-or-nothing stop. The evidence needed to confirm (c) and (d) should come from the operating records required under Practice 10: Implement multi-tiered AI system logging and audit capabilities and, where the decision is an incident response, the incident records under Practice 8: Incorporate AI-aware incident analysis and response procedures, rather than from a separate attestation process.
4: Define procedures for emergency avoidance override, recovery, and situation awareness Establish and maintain documented procedures that allow	4.1: Establish “break-glass” intervention procedures Define procedures by which authorized, trained personnel	4.1.1: Ensure that AI systems can be reliably overridden Ensure that technical processes for intervening in the AI system's operation are reliably implemented at appropriate points. This Implementation is likely

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
operators to intervene in, suspend, or override AI system actions that are unreliable, unexpected, or potentially harmful to critical operations. (See Practice 11: Maintain AI-aware mission continuity and disaster recovery planning for sustained manual operations). Search Keywords: break-glass override, emergency intervention, emergency stop (e-stop), kill switch, manual takeover, disengagement, out-of-band control, situational awareness, alarm management, alarm flood mitigation, alert fatigue, cognitive overload, calm technology, visual confidence bands, human-on-the-loop, human-out-of-the-loop, human response time, state-at-handoff display, explanation fidelity, rationale display Main Trustworthiness Contributions: Safe: Contributes the human intervention path: stopping, overriding or falling back when the system's own constraints have not prevented a hazard. It does not supply those constraints, which Practice 3: Define risks, policies, and oversight for automated AI and agentic behavior supplies. Resilient: Contributes the human-mediated fallback: suspending, overriding or reverting the AI-enabled function so operation can continue while the AI system is not trusted. It does not supply sustained manual operation, which Practice 11: Maintain AI-aware mission continuity and disaster recovery planning covers. Explainable & Interpretable: Contributes the situation awareness an intervening person needs at the moment of acting: what the AI system is doing, and what response that calls for. It does not supply the underlying telemetry, which Practice 10: Implement multi-tiered AI system logging and audit capabilities covers. Trustworthiness Effects to Consider: Secure: Creates privileged routes into the control system. Every intervention tier, out-of-band channel and emergency mode defined here bypasses the normal control path, and Implementation 4.1.2: Establish tiered intervention	can safely override AI-driven actions in a timely manner during an emergency situation, similar to how a "break-glass" button provides the ability to override access control in the event of a fire or other emergency. Note that in many applications, simply disabling the AI system, for example with a kill switch that cuts it off without a defined handover, can leave the overall system in an unsafe state. This task should establish overall procedures for personnel to obtain appropriate situational awareness (Task 4.2: Ensure that personnel are able to gain and maintain situational awareness), and decide on the appropriate action to take. These should align with the fallback behaviors in Task 3.2: Implement independent guardrails ("safety wrappers") for AI outputs. Main Trustworthiness Contributions: Safe: Contributes the executable override path: intercept points that are reliably implemented (Implementation 4.1.1: Ensure that AI systems can be reliably overridden), and a ladder of tiers so that intervention need not be all or nothing. It does not supply the fallback states entered on override, which Task 3.2: Implement independent guardrails ("safety wrappers") for AI outputs defines. Accountable: Contributes authorization allocated in advance: which tier a role may invoke, where a second authorizer is required, and who decides when the cause of an anomaly is not yet clear. It does not supply the ability to enforce that decision, which Task 3.9: Assess and document organizational readiness for each AI-enabled capability covers. Trustworthiness Effects to Consider: Reliable: Exercising the override path is itself an operational action, and rehearsal on a production system can trip or suspend the function it protects. Implementation 4.1.3: Regularly practice and evaluate intervention processes directs that testing to the environments categorized in Implementation 1.3.2: Categorization of Testing Environments. Trustworthiness Tensions to Balance: Safe versus Secure: Where intervening personnel are pre-credentialed and the tier has been rehearsed, authorization and speed move together. Where the intervening party is an external responder arriving	to align with Implementation 3.2.1: Identify AI output intercept points. References: >Candidates - suggestions welcome Guidance NIST SP 800-190, Application Container Security Guide, from NIST. Section 2.3.3 describes the orchestrator as the component that deploys images into containers and manages the running containers, with hosts running and stopping them as the orchestrator directs. Section 4.3 sets the countermeasures that govern it: a least privilege access model, tightly controlled cluster-wide administrative accounts, and node trust. For a containerized AI deployment the orchestrator is one of the appropriate points at which an intervention is implemented, and Section 4.3 is what decides who can exercise it. 4.1.2: Establish tiered intervention procedures, training, and authorization Implement or utilize existing tiered training, authorization, and access control for personnel intervening in AI system operation. This may include requiring multiple personnel to be available to authorize particularly high impact interventions. Examples of tiers could include placing the system into "emergency mode," overriding individual actions, partial suspension of operation, and full system isolation. Ensure that sufficient appropriately trained and authorized personnel are available commensurate with the system's designated autonomy level and operational criticality. This is especially important where real-time human intervention is explicitly required as an active risk mitigation control. Consider an "emergency mode" protocol for external emergency response personnel who may need to safely isolate or override the AI system in an emergency situation. This may be important for reasons that include: - Organizational personnel may be unable to safely approach or communicate with the AI system during an emergency. - AI systems may behave in ways that responding personnel may not expect and may not have time or resources to address. - Emergencies and other incidents may generate inputs into the AI system that it does not expect and for which it may not have been tested, resulting in greater probability of erroneous and inappropriate outputs. For example, during a fire or chemical emergency, or in a widespread disaster situation, organizational personnel may be unable to safely approach or communicate with a remote facility. Responders may need out-of-band emergency interfaces, like secured external emergency stop buttons (E-stops) (subject to applicable functional-safety certification requirements,

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
procedures, training, and authorization places tiered authorization on the personnel routes. Trustworthiness Tensions to Balance: Safe versus Resilient: Where the process has a defined safe state that it can be stopped into, a deterministic trip and graceful degradation point the same way. Where stopping is itself hazardous, such as a vehicle or industrial process, they separate: Task 4.1: Establish “break-glass” intervention procedures notes that disabling the AI system can leave the overall system unsafe, so the tiered ladder in Implementation 4.1.2: Establish tiered intervention procedures, training, and authorization exists to let an operator choose a point between a full isolation that halts the process and a partial suspension that keeps it running. Related AI RMF subcategories include: GOVERN 3.2 (on defining human-AI configuration): This Practice contributes the oversight modes, intervention tiers and authorization boundaries that such policies have to differentiate; it does not establish whether the organization can enforce an oversight decision once it is made. For that, see Task 3.9: Assess and document organizational readiness for each AI-enabled capability. MAP 3.5 (on establishing human oversight processes): This Practice defines the human oversight processes used in an emergency and assesses them through exercise; it does not develop the role-specific competencies that those processes assume. For those, see Practice 9: Provide calibrated, needs-based AI risk management training. MANAGE 2.4 (on decommissioning or superseding AI systems): This Practice supplies the mechanisms and the assigned authority by which an AI system is overridden, suspended or disengaged when its behavior is inconsistent with intended use; it does not cover how essential functions are sustained afterwards. For that, see Practice 11: Maintain AI-aware mission continuity and disaster recovery planning. MANAGE 4.1 (on post-deployment risk management): This Practice contributes the override and immediate-recovery limbs of a post-deployment monitoring plan, together with the independent channels that carry	unannounced, each authorization step lengthens the emergency that the break-glass path exists to shorten. Related AI RMF subcategories include: MANAGE 2.4 (on decommissioning or superseding AI systems): This Task establishes how authorized personnel disengage or override an AI system at the moment its behavior becomes unsafe, and the tiers of authority for doing so; it does not supply the situational picture on which that decision rests. For that, see Task 4.2: Ensure that personnel are able to gain and maintain situational awareness. MAP 3.5 (on establishing human oversight processes): This Task defines the intervention procedure itself and assesses it through tabletop exercise under adversarial scenarios; it does not determine which operational contexts admit real-time human oversight at all. For that, see Task 4.5: Define operational regimes for human-on-the-loop and human-out-of-the-loop operation. MAP 3.4 (on defining operator proficiency): This Task sets tiered training, authorization and access control for the personnel permitted to intervene, including external emergency responders; it does not cover the manual operating skills that erode through routine reliance on the AI. For those, see Task 3.6: Mitigate automation complacency and skills degradation. MANAGE 2.3 (on responding to emerging risks): This Task pre-establishes decision authority for anomalies whose underlying cause is not yet clear, so that a responder is not delayed during a machine-speed event; it does not cover the investigation that afterwards determines what the risk was. For that, see Practice 8: Incorporate AI-aware incident analysis and response procedures.	such as IEC 60204-1, independent of any AI-specific considerations), to place AI-enabled systems into a known safe state. For high-consequence systems, consider whether decision-making authority should be pre-established for scenarios where the underlying cause of an anomaly isn't yet clear, so that responders aren't delayed during a machine-speed event, adversarial or otherwise. Task 3.9: Assess and document organizational readiness for each AI-enabled capability covers the prior question of whether the organization can enforce such a decision once it is made; this Implementation covers who is authorized to make it in the moment. 4.1.3: Regularly practice and evaluate intervention processes Conduct tabletop exercises to test intervention procedures from Implementation 4.1.1: Ensure that AI systems can be reliably overridden and Implementation 4.1.2: Establish tiered intervention procedures, training, and authorization under adversarial and unexpected scenarios. To prevent unintended operational triggers during these simulations, testing should be performed on systems in accordance with Implementation 1.3.2: Categorization of Testing Environments. Use established TEVV protocols from Task 1.3: Implement evaluation and test plans, including TEVV, across the AI lifecycle and as extended in Task 2.3: Establish protocols for and regularly perform systematic and achievable Testing, Evaluation, Validation, and Verification (TEVV) to guide intervention procedure testing. Where feasible, at least one exercise per cycle should involve a correlated scenario in which multiple safeguards are degraded together, rather than testing single-point failures only. References: >Candidates - suggestions welcome Guidance NIST SP 800-53r5, Security and Privacy Controls for Information Systems and Organizations, from NIST. Control IR-3, Incident Response Testing, requires the effectiveness of the incident response capability to be tested at a defined frequency, and its discussion names checklists, walk-through and tabletop exercises, and parallel or full-interrupt simulations as the forms that testing takes. Enhancement IR-3(2) coordinates that testing with contingency, continuity and critical infrastructure plans, which is where an exercise of a correlated scenario such as the one in this Implementation would be coordinated.
	4.2: Ensure that personnel are able to gain and maintain situational awareness	4.2.1: Develop situational awareness processes and procedures for personnel who may need to intervene in the AI system's operation

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
them; it does not cover the change management and decommissioning limbs that MANAGE 4.1 also names. GOVERN 4.3 (on enabling AI testing, incident identification, and information sharing): This Practice contributes the exercise regime for intervention procedures and the AI-independent channels through which an incident becomes visible in the first place; it does not cover sharing incident information outside the organization. For that, see Task 8.4: Define external reporting and regulatory disclosure protocols following AI incidents. References: >Candidates - suggestions welcome Guidance NIST SP 800-61r3, Incident Response Recommendations and Considerations for Cybersecurity Risk Management, from NIST. Section 2.1 sets out the incident response life cycle within which an override and the recovery after it sit. Section 2.3 lists what the incident response policy should settle in advance, including which roles hold the authority to confiscate, disconnect or shut down technology assets, which is the authorization question this Practice asks about AI systems. Standard IEC 61508, Functional safety of electrical/electronic/programmable electronic safety-related systems, from the International Electrotechnical Commission, an international standards body for electrical, electronic and related technologies. Defines functional safety for electrical, electronic and programmable electronic safety-related systems, meaning systems whose safety depends on their operating correctly. Standard ISO 26262-1:2018 Road vehicles - Functional safety, from the International Organization for Standardization. The road vehicle sector's functional safety series.	Implement role-appropriate mechanisms for providing personnel with rapid, actionable situational awareness as to the state of the AI system, its task, recent decisions, environment, and anomalies. The goal is to reduce the likelihood of humans making mistakes when overriding the AI system, particularly in chaotic, emergency, unusual, time-sensitive, and high pressure situations. This may take the form of displays, interfaces to existing information management tools, printouts, or a combination that aims to reduce the cognitive latency required for an operator to transition from passive monitoring to active intervention. Risk management should account for the operational latency required to comprehend a machine-speed cascade from a cold start. Prioritize system learnability and transparency in interface design to ensure personnel can rapidly form accurate mental models of AI behavior during both routine operations and emergency transitions. Care should be taken to ensure that the mechanisms do not cause cognitive overload or confusion, particularly for those who may be unfamiliar with the system, such as external responders and maintenance personnel. See Task 4.4: Attention Governance and Alert/Alarm Flood Mitigation for additional considerations. Main Trustworthiness Contributions: Explainable & Interpretable: Contributes the operator-facing layer: what an output means now and what response it calls for, from uncertainty indications to triage cues. It does not determine whether the confidence and rationale it presents reflect how the output was produced. For that, see Task 4.6: Ensure that confidence and rationale shown to personnel reflect how the AI system reached its output. Safe: Contributes the comprehension that makes an intervention correct rather than merely fast, including for external responders meeting a specific deployment for the first time. It does not supply the means of intervening, which Task 4.1: Establish "break-glass" intervention procedures provides. Trustworthiness Tensions to Balance: Explainable & Interpretable versus Safe: Where the audience works with the AI system daily, more rationale	Divide personnel into groups based on the decisions that they will be expected to make in intervening in the AI system (including assessing the need to intervene), and their expected background knowledge. Include personnel who regularly work with the system as well as those who may need to interact with the system at short notice, during an incident, and in an emergency. For example: - Engineers who work with the system day-to-day may require a summary of deviations from normal operation to anticipate and avoid potential incidents. These summaries prevent important information from being buried within "normal" status reports that they may become accustomed to skimming over. - External maintenance engineers, who may be familiar with the equipment family but not the specific installation, may benefit from a combination of printed material and dynamic displays that highlight how this AI system's operational learning has caused its behavior to differ from a generic or freshly deployed system, allowing them to avoid taking actions that would ordinarily be safe but may pose a risk for this specific deployment. - Emergency responders who may be non-technical and need to make decisions under time pressure may only need just enough information to decide which of a pre-set number of emergency modes to put the system in, such as reverting to a "safe" controller or shutting down the system completely. 4.2.2: Regularly evaluate situational awareness mechanisms Test situational awareness mechanisms on a regular basis, to both ensure that they appropriately reflect the underlying state of the AI system, and that their intended audience appropriately understands them. This should be combined with Implementation 4.1.3: Regularly practice and evaluate intervention processes. 4.2.3: Human-Centered Interfaces for AI Uncertainty and Actionable Triggers Design Human-System or Human-Machine Interfaces (HSIs or HMIs), such as operational dashboards, clinical decision-support tools, fraud triage queues, network management displays, or field interfaces, to communicate AI system state and confidence bounds while avoiding cognitive overload. Examples of features that should be considered include: - Calibrated indications of uncertainty: Present recommendations alongside visual confidence bands, data freshness indicators, and out-of-distribution warnings (e.g., flagging unhistorical conditions in finance, novel patient demographics in healthcare, or uncharacteristic network traffic in telecommunications) so personnel can quickly judge how far to rely on the output.

Practice	Task	Implementation
	can improve the decision. Where the audience is a responder under time pressure, it consumes the capacity to act, which is why Implementation 4.2.1: Develop situational awareness processes and procedures for personnel who may need to intervene in the AI system's operation gives responders only enough to choose an emergency mode. Task 4.4: Attention Governance and Alert/Alarm Flood Mitigation handles the volume side of the same limit. Related AI RMF subcategories include: MAP 2.2 (on defining AI system utility and oversight needs): This Task puts the AI system's knowledge limits in front of the operator at the moment of decision, through calibrated confidence bands, out-of-distribution warnings and standardized triage indicators; it does not cover the volume at which that information arrives. For that, see Task 4.4: Attention Governance and Alert/Alarm Flood Mitigation. MEASURE 1.2 (on continuously improving measurement): This Task submits the situational awareness mechanisms themselves to regular evaluation, checking both that they reflect the system's true state and that their intended audience understands them; it does not evaluate the AI system's own performance against its baselines. For that, see Task 2.3: Establish protocols for and regularly perform systematic and achievable Testing, Evaluation, Validation, and Verification (TEVV).	• Actionable Triage Indicators: Provide standardized visual cues that explicitly signal the required human response: Proceed (high confidence, within baseline bounds), Investigate (moderate confidence, novel inputs/telemetry), Escalate (low confidence, cross-system anomaly), or Override Immediately (boundary or policy constraint violation). A Proceed cue indicates that the output falls within the conditions the AI system was validated for, not that it is correct. Displayed confidence metrics and data freshness warnings should be derived from the AI system's decision making process (Implementation 4.6.2: Derive confidence and rationale for learned components from their decision processes). Where the interface also displays a rationale for a recommendation, see Task 4.6: Ensure that confidence and rationale shown to personnel reflect how the AI system reached its output. For TEVV protocols for model calibration and performance baselining, see Task 2.3: Establish protocols for and regularly perform systematic and achievable Testing, Evaluation, Validation, and Verification (TEVV). References: >None yet - suggestions welcome
	4.3: Establish independent (“out-of-band”) communication, monitoring, alerting, and control capabilities Ensure that internal and external personnel who may need to intervene in the AI system's operation have access to the necessary information independent of the AI system's functionality. Akin to the analog gauges present on aircraft that otherwise have fully digital cockpits, these mechanisms allow for situational awareness, control, and risk management even when a fault renders AI-mediated	4.3.1: Inventory channels for situational awareness and control that may be affected by the AI system Trace the critical information flows that feed the situational awareness mechanisms identified in Task 4.2: Ensure that personnel are able to gain and maintain situational awareness and identify locations where associated AI systems may cause accuracy or availability issues. Be aware of potential secondary and tertiary effects. For example, a malfunctioning AI system may generate enough traffic to overload a wireless communications channel, affecting an otherwise independent camera feed that shares the same channel. Similarly, a malfunctioning AI system responsible for intrusion detection may cause the inability to authenticate to

Practice	Task	Implementation
	channels untrustworthy or unavailable. Main Trustworthiness Contributions: Resilient: Contributes the oversight path that survives the failure: monitoring, alerting and control that stay available when the AI system degrades them, down to physically bypassing the automation. It does not keep the function running, which Task 3.2: Implement independent guardrails ("safety wrappers") for AI outputs and Practice 11: Maintain AI-aware mission continuity and disaster recovery planning address. Transparent: Contributes availability of the information rather than its content: Implementation 4.3.1: Inventory channels for situational awareness and control that may be affected by the AI system traces which awareness channels the AI system can degrade, including through shared infrastructure. It does not determine what is captured in the first place, which Practice 10: Implement multi-tiered AI system logging and audit capabilities covers. Trustworthiness Tensions to Balance: Resilient versus Secure: Where the independent channel carries only telemetry, the exposure it adds is small. Where it carries control, as with a satellite or cellular link or a trained manual bypass, each fallback level is a further route into the process, and Implementation 4.1.2: Establish tiered intervention procedures, training, and authorization places tiered authorization on who may use it. One resolution is to hold a control-carrying channel to the same access controls as the primary path; others include limiting it to telemetry and accepting that intervention then takes a slower route. >TBD - Securing the independent channels themselves, as distinct from authorizing the people who use them. Suggestions welcome. Related AI RMF subcategories include: MEASURE 2.4 (on monitoring deployed AI systems): This Task requires that the path by which a system is monitored not depend on the system being monitored, so that a fault cannot conceal itself; it does not define what is monitored or what counts as anomalous. For that, see Task 3.4: Monitor for anomalous AI behavior.	an emergency intervention dashboard. 4.3.2: Implement AI-independent channels Based on Implementation 4.3.1: Inventory channels for situational awareness and control that may be affected by the AI system, establish independent channels separate from monitored AI systems so that notification delivery is not disrupted by the system failures. Depending on the system, having multiple levels of fallback, even down to having personnel available and trained to physically bypass the automated system entirely, along with completely independent channels such as satellite or cell connections, may be necessary. References: >Candidates - suggestions welcome Guidance NIST SP 800-82r3, Guide to Operational Technology (OT) Security, from NIST. Control SC-47, Alternate Communications Paths, asks an organization to determine which systems need an alternate path so that a loss of communication does not lead to an unacceptable loss of view or control, or to a safety event, and gives continuity of command and control during an incident as the reason. Control CP-8, Telecommunications Services, carries the provider side, with enhancements for single points of failure and for separation of primary and alternate providers, which is what keeps a nominally independent second channel from sharing a carrier with the first.

Practice	Task	Implementation
	MANAGE 4.3 (on incident response): This Task keeps the notification path to responders available when AI-mediated channels have become unavailable or untrustworthy, down to satellite, cellular and physical bypass; it does not define what is disclosed outside the organization. For that, see Task 8.4: Define external reporting and regulatory disclosure protocols following AI incidents. MEASURE 3.1 (on tracking known and emerging risks): This Task traces the information flows that oversight depends on and identifies secondary couplings, such as a malfunctioning AI system saturating a channel shared with an otherwise independent camera feed; it does not track the risks arising from the AI system's own outputs. For those, see Task 3.4: Monitor for anomalous AI behavior.	
	4.4: Attention Governance and Alert/Alarm Flood Mitigation Treat human attention as a finite resource that AI systems should use efficiently. AI-driven notification volume can exceed an operator's ability to triage, reducing effectiveness rather than improving it. This may be by overwhelming a domain with no prior experience managing this risk, breaking the assumptions behind a domain's existing alarm flood mitigations, or generating a correlated surge across many systems at once. Automatically filtering AI telemetry using vendor hazard reachability attestations, once independently verified or corroborated (Implementation 6.1.5: Operational AI Hazard Reachability Disclosures), can prevent alert floods by suppressing operational warnings for model anomalies that have already been rendered unreachable by downstream deterministic guardrails (Task 3.2: Implement independent guardrails ("safety wrappers") for AI outputs), allowing operators to focus strictly on actionable operational deviations. This task complements Task 4.2: Ensure that personnel are able to gain and maintain situational awareness by addressing cases where notification volume, not just notification content or clarity, is what threatens an operator's ability to respond effectively.	4.4.1: Recognizing novel AI-driven alert floods in unfamiliar domains Domains with no prior experience managing alarm floods may not recognize the pattern when AI introduces it, or know that established mitigation techniques exist. For example, a fraud-detection system entering a confused state can flood a review queue with false positives; a summarization tool can generate excessive content when it should stay silent; a hospital's AI-assisted clinical decision support can generate alert volumes comparable to those long documented in traditional medical device alarm fatigue, but without the institutional awareness built up around that older problem. Measures to reduce this risk range from training personnel to recognize alert-flood patterns as they emerge in the tool they're using and developing procedures for manual prioritization, to automated triage and consolidation of output (e.g., rate-limiting generated content, grouping duplicate flags).
		4.4.2: Adapting legacy alarm management for AI's non-deterministic failure modes Domains with mature, trusted alarm-management practices may find those practices don't transfer cleanly to some AI systems. Traditional mitigations often assume alarms correspond to discrete, mechanical fault states (e.g., a stuck valve or tripped breaker). Examples of ways in which AI-generated alarms can differ from those in more traditional systems include: • An AI system may report the same underlying error in slightly different ways. • Adaptive AI systems may respond inconsistently to an underlying error, resulting in hidden or inconsistent alarms.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	Main Trustworthiness Contributions: Safe: Contributes the capacity side of intervention: keeping notification volume within what the available people can triage, including when one external event makes many AI systems request attention at once. It does not improve any single notification, which Task 4.2: Ensure that personnel are able to gain and maintain situational awareness covers. Bias Managed: Contributes a bound on one human-cognitive error source, desensitization produced by notification rate, by treating that rate as a designed quantity rather than a byproduct. It does not address over-trust in an output that does arrive, which Task 3.6: Mitigate automation complacency and skills degradation covers. Trustworthiness Effects to Consider: Transparent: Filtering, suppression and consolidation decide what reaches a person, not what is recorded. Whether a suppressed notification remains retrievable afterwards is governed by the logging requirements in Practice 10: Implement multi-tiered AI system logging and audit capabilities. Trustworthiness Tensions to Balance: Safe versus Reliable: Where notifications repeat one underlying condition, consolidation loses nothing and both improve. Where the urgent signal is a single isolated one, Implementation 4.4.4: Applying consolidation and low-cognitive-load design techniques notes that aggressive batching buys operator capacity by delaying the alert that needed to arrive immediately. Related AI RMF subcategories include: MANAGE 2.1 (on allocating resources): This Task treats operator attention as a resource that has to be sized for correlated worst-case surges across every system drawing on the same oversight pool, rather than for average per-system load; it does not consider the viable non-AI alternative systems that MANAGE 2.1 also names. MEASURE 1.2 (on continuously improving measurement): This Task reassesses whether an established alarm-management practice remains effective once AI	- Inconsistent AI alerts may result in only downstream systems alerting while the system that is the root cause stays silent. - Agentic systems can build dependencies dynamically and in ways that may not be documented, so a failure may cause unexpected and seemingly unrelated systems to send notifications of failure. - Machine learned detection algorithms and thresholds may be undocumented and applied inconsistently, making it difficult to determine what any given alert means. The dependency mapping in Implementation 3.5.1: Map direct functional and algorithmic dependencies and Implementation 3.5.2: Identify indirect shared infrastructure and collateral damage exposure can help make these dependency chains more visible in advance, even though it does not resolve the underlying detection problem. Some partial, non-CI-specific and non-AI-specific approaches exist in the broader IT/software observability field, such as similarity-based alert clustering and distributed tracing, but these generally assume mature instrumentation that many current AI deployments, and especially OT environments, may not yet have in place. This is particularly challenging in agentic systems, which can make dependency decisions dynamically and without documenting them. >To the Reviewer: >Mitigating this is still an open research topic, particularly in agentic systems. Are there other partial mitigations, especially for the multi-agent feedback-loop case, that we're missing? 4.4.3: Managing correlated multi-system attention surges A single external event can trigger a simultaneous surge of attention requests across many AI-controlled systems at once, overwhelming a limited pool of human operators even if each individual system's alert volume is otherwise manageable. Reduced staffing is frequently among the expected benefits of adopting an AI system. Where it is, the oversight capacity the AI system depends on is drawn from the same pool that the expected benefit reduces, and sizing the two separately can produce a shortfall that neither decision would have chosen. For example, a widespread power failure or loss of traffic signals can cause an entire autonomous vehicle fleet to simultaneously request remote operator attention, exceeding the capacity of the remote operations center. Measures to address this risk include: - Identifying which AI-driven systems draw on the same oversight capacity, and estimating what external events could cause them to request attention simultaneously. - Designing and resourcing oversight capacity and escalation procedures explicitly for correlated worst-case surges, not just

Practice	Task	Implementation
	introduces non-deterministic failure modes; it does not evaluate whether a given display is understood by the audience that reads it. For that, see Task 4.2: Ensure that personnel are able to gain and maintain situational awareness. References: >Candidates - suggestions welcome Guidance Health and Safety Executive (2000) Better alarm handling, Chemicals Sheet No 6, from Great Britain's workplace health and safety regulator. States target alarm rates for process plant: no more than one every ten minutes in normal operation, and no more than ten in the first ten minutes after a major upset. Guidance EEMUA Publication 191, "Alarm Systems: A Guide to Design, Management and Procurement", from the Engineering Equipment and Materials Users' Association, a UK association of industrial plant owner-operators. The underlying baseline for alarm metrics in process industries, and the source of the targets above. Incident Report Health and Safety Executive (1997) The Explosion and Fires at the Texaco Refinery, Milford Haven, 24 July 1994. In the final 10.7 minutes two operators had to recognize, acknowledge and act on at least 275 alarms, arriving at one every two to three seconds, and the report records operators cancelling alarms for their nuisance value without recognizing what they meant. Guidance The Joint Commission (2013) Sentinel Event Alert 50: Medical device alarm safety in hospitals, from the US non-profit that accredits healthcare organizations, issued on the basis of aggregated reported events. Documents the same failure in a sector with entirely different equipment. Research McFarlane, D.C. (1999). "Coordinating Interruptions in Human-Computer Interaction". The first empirical comparison of the four ways a system can time an interruption, immediate, negotiated, mediated and scheduled, which is the evidence behind Implementation 4.4.4: Applying consolidation and low-cognitive-load	average or independent per-system load. - Accounting for oversight capacity as a cost of the AI system rather than as a resource already available, so that it enters the tradespace of benefits and control costs that Practice 1: Establish requirements for success, Practice 2: Define AI Robustness, Resilience, and Quality of Service expectations, and Practice 3: Define risks, policies, and oversight for automated AI and agentic behavior define. - Developing automated alert triaging mechanisms so that limited operator attention is not spent sorting through large quantities of alerts or addressing low priority issues. - Re-checking oversight capacity when staffing levels, shift patterns, training, or authorizations change, rather than only when the AI systems drawing on it change. 4.4.4: Applying consolidation and low-cognitive-load design techniques Once alarm flood risks are identified, apply techniques that reduce the rate and cognitive cost of notifications without hiding genuinely urgent, isolated signals. Examples of measures to consider include: - Implementing basic consolidation, such as grouping repeated identical alerts into a single notification. - Applying user-interface design choices that reduce distraction (often referred to as calm technology or mixed-initiative interfaces) such as exception batching, trend dashboards, dynamic deadbands, time-delay hysteresis, matched to the specific application, oversight mode, and the range of personnel familiarity likely to encounter these notifications, from regular operators to occasional external responders. Note that there is a trade-off between many of these measures. For example, aggressive batching reduces fatigue but risks delaying a genuinely urgent, isolated signal.

Practice	Task	Implementation
	design techniques's discussion of batching rather than deliver immediately. Research Simon, H. (1971), "Designing Organizations for an Information-Rich World". The origin of the framing this Task opens with, that a wealth of information creates a poverty of attention. >To the Reviewer: >This is still rather a nascent field and, while there are academic publications specific to the topic of AI-induced cognitive overload and similar issues, we're having some trouble finding good references that would speak to an end-user audience. Would pointing to more academic references where there is a lack of industry publications be useful here or would it be more likely to cause confusion?	
	4.5: Define operational regimes for human-on-the-loop and human-out-of-the-loop operation Identify operational contexts where real-time, manual human-in-the-loop (HITL) oversight is physically or technically infeasible due to tight system time constants (such as stability anomalies operating in milliseconds, real-time industrial control loops, or machine-speed cyber defense events). Oversight of any mode degrades into a purely nominal or superficial check where the unfolding event outruns what the operator can be relied upon to do about it, particularly in situations where fatigue or stress are factors; the oversight thresholds established under Implementation 4.5.1: Define engineering time-constant thresholds are what make this testable rather than assumed. For these regimes, formally define the boundaries where the human-on-the-loop oversight mode (action proceeds, with intervention capability retained) or the human-out-of-the-loop oversight mode (autonomous execution with retrospective post-hoc review) should substitute for the human-in-the-loop mode, and specify the deterministic automated protections required to support them. Operating in a less direct oversight mode does not remove human decision-making; it moves it earlier and later. Even where real-time intervention is infeasible, a specific role decides whether the system may operate in	4.5.1: Define engineering time-constant thresholds Audit automated processes to identify paths where the window between an AI anomaly and an irreversible consequence is shorter than what human intervention can be relied upon to achieve. For these paths, document that real-time human intervention is not a primary risk mitigation control. What can be relied upon depends on the time available and on what the operator has to do with it. Where the time is measured in minutes, an operator may be able to detect, diagnose, and act. Where it is measured in seconds, a memorized response to an unambiguous trigger is the most dependable option. For example, FAA guidance on standard operating procedures (see FAA AC 120-71B) advises avoiding such responses wherever possible and limiting unavoidable ones to fewer than three items containing no conditional decision steps. Judging whether an AI-selected action is appropriate is likely to be a conditional decision that does not meet that bound. Time is not the only limit. An operator can rarely be expected to verify in real time that a complex AI system is following its rules, and can judge only whether its actions, perhaps with an accompanying explanation, appear acceptable (see Bainbridge 1983). Where the system was adopted because it handles cases human judgment handles poorly, that judgment is what the oversight arrangement relies on. This even applies to an attentive operator, and is compounded where automatic control masks a developing problem by compensating for it up until the point where human intervention becomes necessary. See Task 3.2: Implement independent guardrails ("safety wrappers") for AI outputs for automated controls, as well as Implementation 4.2.3: Human-Centered Interfaces for AI Uncertainty and Actionable Triggers, Task 4.6: Ensure that confidence and rationale shown to personnel reflect how the

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	that mode, on what conditions, and when to suspend or roll it back (Implementation 3.9.2: Define Decision Authority and Reassessment Triggers). This task separates the paths where human intervention can be relied upon from those where it cannot, so that automated boundaries carry the role where a person cannot. Search Keywords: human-on-the-loop, human-out-of-the-loop, human-in-the-loop, supervisory control, closed-loop control, system time constant, control loop rate, human reaction time, operator response time, response time budget, automated fail-safe, infeasible oversight, autonomy regime Main Trustworthiness Contributions: Safe: Contributes the test that decides whether human intervention counts as a safety control: whether what the operator would have to do is something a person can be relied upon to do in the time available, and documenting the paths where it cannot. It does not supply the replacement protection, which Task 3.2: Implement independent guardrails (“safety wrappers”) for AI outputs defines. Accountable: Contributes the human decision that remains when real-time intervention is infeasible: a named role decides whether a regime may be entered, on what conditions, and when to suspend it. It does not define that authority, which Implementation 3.9.2: Define Decision Authority and Reassessment Triggers does. Trustworthiness Effects to Consider: Transparent: Out-of-the-loop operation moves the whole review to afterwards. Implementation 4.5.2: Establish deterministic boundary constraints for automated regimes requires a log when a deterministic boundary blocks a command, but autonomous actions that stay within bounds depend on telemetry captured under Practice 10: Implement multi-tiered AI system logging and audit capabilities. Trustworthiness Tensions to Balance: Accountable versus Safe: Where the operator can be relied upon to act, keeping a person in the loop	AI system reached its output, Task 4.4: Attention Governance and Alert/Alarm Flood Mitigation, and Implementation 11.2.3: Human Factors and Cognitive Transition Protocols for Control Handoffs for further details. References: >Candidates - suggestions welcome Research Lisanne Bainbridge, "Ironies of Automation". Automatica volume 19 number 6, 1983, pages 775 to 779. Automatica is the journal of the International Federation of Automatic Control, an international body whose members are national control engineering organizations. A seminal paper on the human factors of automated process control. Its subject is the process-control computers of 1983, and the mechanisms it identifies are relevant to AI systems. Section 1.1.3 sets out why an operator cannot verify in real time that an automated system is following its rules. Guidance FAA AC 120-71B, Standard Operating Procedures and Pilot Monitoring Duties for Flight Deck Crewmembers, 10 January 2017, from the United States Federal Aviation Administration, the civil aviation authority of the United States. The AC states that it is not mandatory and does not constitute a regulation. Paragraph 4.2.5 gives the conditions under which a response may be relied on from memory: avoided wherever possible, clearly identified, emphasized in training, fewer than three items, and containing no conditional decision steps. 4.5.2: Establish deterministic boundary constraints for automated regimes Identified human-out-of-the-loop operational regimes should include independent, non-AI deterministic safety wrappers detailed in Task 3.2: Implement independent guardrails (“safety wrappers”) for AI outputs. Ensure that these physical process boundaries have total authority to block unsafe autonomous commands, execute fallback states per Implementation 3.2.3: Specify fail-safe states and fallback behavior, and log the event prior to subsequent human administrative review.

Practice	Task	Implementation
	contributes both accountability and safety. Where they cannot, the two separate; human oversight may identify a responsible party without addressing safety. One resolution is to move the human decision to a point where there is sufficient time and information to make it well, such as deciding in advance whether the system may run in this mode and on what conditions. Others include changing the process so that intervention becomes feasible, or not operating in that mode. Related AI RMF subcategories include: GOVERN 3.2 (on defining human-AI configuration): This Task differentiates the human-in-the-loop, human-on-the-loop and human-out-of-the-loop oversight modes and fixes the boundaries between them; it does not define the intervention procedure that applies once a person is in the loop. For that, see Task 4.1: Establish "break-glass" intervention procedures. MAP 1.1 (on defining operating context): This Task adds the process time constants to the documented operating context, so that the feasibility of real-time human oversight is established rather than assumed; it does not cover the intended purposes and user expectations that MAP 1.1 also names. MEASURE 2.6 (on measuring safety): This Task supplies the human reaction and execution times that a response-time safety metric has to be set against, and requires deterministic boundaries able to execute a fallback state with no human present; it does not produce evidence that those boundaries hold. For that, see Task 2.3: Establish protocols for and regularly perform systematic and achievable Testing, Evaluation, Validation, and Verification (TEVV). References: >Candidates - suggestions welcome Guidance Principles for the Secure Integration of Artificial Intelligence in Operational Technology, December 2025, joint guidance from nine national cybersecurity agencies across seven countries, led by the United States Cybersecurity and Infrastructure Security Agency. Section 4.2, Embed Safety and Failsafe Mechanisms, asks that AI systems be able to fail gracefully without disrupting critical operations, and that the new failure states an AI system	

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	introduces, including how to bypass or replace it, be written into existing functional safety and incident response procedures. Those are the deterministic protections this Task requires where real-time human intervention is infeasible. Standard ISA-84 / IEC 61511, Functional Safety: Safety Instrumented Systems for the Process Industry Sector (defining automated protective layers independent of human operator loops).	
	4.6: Ensure that confidence and rationale shown to personnel reflect how the AI system reached its output Establish requirements that any confidence indication or rationale shown to personnel is derived from the process by which the AI system produced its output, and that rationale displays are designed and tested for whether they help personnel decide. This applies to routine decision support as well as to intervention. A rationale can be persuasive without being accurate as an explanation: an explanation constructed after the fact can look reasonable without corresponding to how the output was produced. Rationale displays have also been found to increase acceptance of incorrect recommendations as well as correct ones (Implementation 4.6.1: Design rationale displays that give personnel something to check). How accurately a rationale can reflect the AI system's process depends on how the AI system reasons. For learned components, confidence and rationale can be derived from calibrated probabilities and decision-level telemetry (Implementation 4.6.2: Derive confidence and rationale for learned components from their decision processes). Where the AI system, or part of it, reasons symbolically or is a self-interpretable model, the rationale can be a trace of the steps it actually applied (Implementation 4.6.3: Display execution traces from symbolic, hybrid, and self-interpretable components). In either case, a rationale shows at most how the AI system reached its output, not that the output is correct. This task complements Task 4.2: Ensure that personnel are able to gain and maintain situational awareness and Task 4.4: Attention Governance and Alert/Alarm Flood Mitigation, which address what information reaches personnel and in what volume, by addressing whether the confidence and rationale in that information reflect how the output was	4.6.1: Design rationale displays that give personnel something to check Where rationale is displayed, offer concise, "one-click" or hoverable rationale summaries highlighting the primary inputs, telemetry feeds, patient factors, transaction parameters, or business rules that drove the AI recommendation. Where a summary points to evidence that personnel can check for themselves, such as a sensor reading they can confirm against a second instrument, a transaction detail they can look up, or a rule they can compare with the governing procedure, it can help them judge a recommendation under time pressure without parsing raw logs. Rationale displays can help or hinder decisions, depending on the situation. A rationale can make a recommendation more convincing without making it easier to tell when it is wrong, and rationale displays have been found to increase acceptance of incorrect recommendations as well as correct ones (see Bansal 2021). Interface designers should therefore aim for rationale that gives personnel something to check rather than something to believe. They should also consider the time available to act: for responders who need only enough information to choose an emergency mode, see Implementation 4.2.1: Develop situational awareness processes and procedures for personnel who may need to intervene in the AI system's operation. Where rationale is displayed to support decisions in the moment, consider testing under Task 1.3: Implement evaluation and test plans, including TEVV, across the AI lifecycle whether it improves decisions for the personnel who will use it, including whether they still reject incorrect recommendations. For training personnel on the effect of rationale on reliance, see Task 9.2: Deliver specialized training on human-AI interaction and automation bias. References: Research Bansal, G. et al., "Does the Whole Exceed its Parts? The Effect of AI Explanations on Complementary Team Performance". Proceedings of the 2021 CHI Conference on Human Factors in Computing Systems. A study of crowdworkers deciding with the help of AI recommendations on text classification and reasoning tasks. Explanations were either generated post-hoc (using LIME) or written by an expert, and neither reflected the model's actual reasoning. They tended to raise accuracy when the AI was

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiqiprnf@nist.gov.

Practice	Task	Implementation
	produced. Search Keywords: explanation fidelity, faithful explanation, explanation accuracy, introspective explanation, post-hoc explanation, SHAP, LIME, rationale display, decision support, confidence calibration, reasoning trace, rule trace, interpretable model, self-interpretable model, decision tree, hybrid AI, neuro-symbolic AI, over-reliance, automation bias Main Trustworthiness Contributions: Explainable & Interpretable: Contributes explanation accuracy (see NIST IR 8312): the confidence and rationale that personnel see are derived from the process that produced the output, or are treated as presentation where they are not. It does not decide how that information is laid out or when it reaches personnel. For that, see Task 4.2: Ensure that personnel are able to gain and maintain situational awareness. Safe: Contributes a check against rationale displays that make incorrect recommendations more convincing: rationale is designed to be checked, and can be tested for whether personnel still reject incorrect recommendations. It does not supply the means of intervening. For that, see Task 4.1: Establish "break-glass" intervention procedures. Trustworthiness Tensions to Balance: Accurate versus Explainable & Interpretable: Where the knowledge a decision depends on can be stated as rules, constraints, or a self-interpretable model, the two need not separate: a symbolic or hybrid design can make the rationale an operator sees the reasoning the AI system actually used (Implementation 4.6.3: Display execution traces from symbolic, hybrid, and self-interpretable components). Where that knowledge cannot readily be stated, a learned model may perform better, and its rationale can be checked only indirectly (Implementation 4.6.2: Derive confidence and rationale for learned components from their decision processes). Whether interpretable models must in general give up accuracy is disputed (see NIST IR 8312), and the answer depends on how much of the domain can be stated, the same condition behind the tension in Task 1.4: Establish the AI System's Domain Knowledge and Linguistic Alignment Requirements. One resolution, where the	correct and lower it when it was wrong, with no net gain over showing a calibrated confidence score. The authors note the results may not generalize to expert users in high-stakes domains. 4.6.2: Derive confidence and rationale for learned components from their decision processes To avoid misinforming personnel with uncalibrated confidence scores or plausible-sounding explanations that do not reflect reality, displayed confidence metrics, data freshness warnings, and rationale summaries should be derived from the underlying AI system's decision making processes. For learned components, examples include calibrated model probabilities and tamper-evident, decision-level runtime telemetry captured at inference time. Natural-language summaries generated by a language model should be treated as user-facing presentation layers rather than as evidence of model decision logic. Interface designers and system leads should not rely on post-hoc, perturbation-based explanation tools (such as SHAP or LIME) as primary sources for rationale displays, as these generate post-hoc hypotheses that need not correspond to the AI system's actual decision logic or internal state. For further discussion on capturing decision-level telemetry, see: • Implementation 8.1.2: Identify AI systems that may not satisfy root cause analysis requirements (Forensic interpretability gaps and limitations of post-hoc attributions). • Implementation 10.1.2: Immutable Runtime Telemetry and Artifact Tracking (Capturing decision-level runtime telemetry rather than relying on post-hoc explanations). • Implementation 12.1.2: Provenance and Traceability (Linking generated logic strictly to hard inference-context metadata for audit paths). References: >None yet - suggestions welcome 4.6.3: Display execution traces from symbolic, hybrid, and self-interpretable components Where the AI system, or part of it, reasons symbolically, for example by applying encoded rules, constraints, or a knowledge base, or is a self-interpretable model such as a decision tree, the displayed rationale can be a trace of the steps it actually applied rather than a hypothesis constructed after the fact (see Sheh 2021). In a hybrid system, such a trace is an accurate explanation only of the symbolic part: facts supplied by learned components, such as a classification of a vibration signature as a bearing fault, enter the trace as premises and should be displayed with their own uncertainty (Implementation 4.6.2: Derive confidence and rationale for learned components from their decision processes). Such a trace shows how the AI system reached its output, not that its rules are correct. Where a trace is too

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	choice of approach is still open and operators must be able to check the reasoning at the moment of decision, is to weigh a symbolic or hybrid design for the part of the decision that can be stated. Others include relying more heavily on verifying the outputs of a learned model, or limiting its role to recommendations that personnel can check against independent evidence. Related AI RMF subcategories include: MEASURE 2.9 (on measuring interpretability and explainability): This Task requires that confidence and rationale shown to personnel derive from the process that produced the output, and rules out post-hoc attribution tools as the primary source; it does not cover capturing the decision-level telemetry that such a display depends on. For that, see Implementation 10.1.2: Immutable Runtime Telemetry and Artifact Tracking. References: Guidance NIST IR 8312, Four Principles of Explainable Artificial Intelligence. Section 2.3 distinguishes explanation accuracy (whether an explanation reflects how the system reached its output) from decision accuracy, and Section 2.4 describes knowledge limits (a system identifying cases it was not designed for or cannot answer reliably). Section 6.1 describes self-interpretable models, which are themselves the explanation, and records that whether they trade accuracy for interpretability is disputed. It covers models such as decision trees, decision lists, and regression, not knowledge-based or hybrid systems.	long to use under time pressure, it can be condensed by a deterministic approximation with known error, and the display should indicate that it has been condensed. For when such a design might be weighed against a learned model, see Task 4.6: Ensure that confidence and rationale shown to personnel reflect how the AI system reached its output. References: Research Sheh, R., "Explainable Artificial Intelligence Requirements for Safe, Intelligent Robots", Proceedings of the 2021 IEEE International Conference on Intelligence and Safety for Robotics (ISR), pages 382 to 387. A position paper on specifying explainability requirements for safety-critical robots. It distinguishes introspective explanations, drawn from the process that made the decision, from post-hoc explanations, and argues that local post-hoc methods such as LIME and SHAP hold only near the case being explained, within bounds that are hard to determine. It identifies decision trees, inductive logic programming, and models built on domain knowledge as able to give introspective explanations, argues that the trade-off against accuracy should be made deliberately, and notes that each stage of a system, from sensing to decision making, can have different explainability requirements. It does not address how explanations should be presented to operators.
5: Implement identity and access management (IdAM) for AI agents, systems, and tools Establish IdAM controls for AI agents and tools appropriate to their roles, auditability, risk, and oversight, at points in the AI system lifecycle from deployment through to decommissioning. Establishing these boundaries reduces the risk of malicious or unauthorized actions reaching risk-sensitive processes, and limits the impacts across the operational environment. It reduces both the attack surface (by eliminating unauthorized access points and lateral pathways) and the overall risk surface (by bounding an agent's autonomous authority, operational scope, and "blast radius") as defined	5.1: Establish identities and authentication for AI entities Inventory AI entities and define authentication requirements that uniquely identify each AI entity, including those that are ephemeral, and ensure those identities are distinct across system boundaries, operational roles, and multi-agent deployment. In this task, an AI entity refers to an invocation of an AI agent or tool that performs atomic tasks, at a suitable level of granularity, and whose behavior should be meaningfully traced and disambiguated from the behavior of other invocations of the same or similar AI agents and tools. If the AI entity is compromised or otherwise found to	5.1.1: Audit for and replace shared credentials, service accounts, secrets, passwords, and API keys Technically enforce distinct, cryptographically verifiable non-human identities (NHIs - credentials designed to be issued to software/AI agents rather than people) for every autonomous sub-agent, micro-service hook, or transient tool invocation, particularly in AI systems built from multiple independent parts that each act and access resources on their own, including agentic AI systems. Where technically feasible, avoid the reuse of a single, shared enterprise API key or master service account across multiple independent agent nodes. For compute-constrained or legacy assets where unique cryptographic identities cannot be natively generated, enforce compensating controls at an alternative point in the system.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
in Task 3.5: Define and control risks to adjacent and related systems and Task 3.8: Scope and map the expanded AI Attack Surface and Risk Surface. This applies zero trust principles to AI entities: an authenticated AI agent is not thereby trusted with every action it can request, because an agent can act outside its intended scope without being compromised. Controls modelled after human user permissions are a starting point but access should be further restricted based on actual need of individual AI agents and tools. Access controls rely on effective asset visibility. Unauthorized "Shadow AI", including open-source models deployed without authorization, operates outside credential directories, bypassing identity controls and defeating least-privilege protections. While the preventative site-access gates and procurement policies for these transient assets reside within the governance structures of Task 3.7: Govern and mitigate risks from unauthorized, transient, and "Shadow AI" systems, the IdAM framework should actively interface with the network monitoring telemetry defined in Task 5.4: Implement continuous security monitoring for AI entity actions. It should automatically detect, flag, and deny directory access to unauthorized AI entities attempting cross-segment authentication, whether a physical rogue device connected directly to an OT network port, or a localized open-source foundational model executing within an unvetted cloud container, virtualized shadow-IT tenant, or transient API instance. >To the Reviewer: >We welcome suggestions for other ways to bring cybersecurity concepts into this document without duplicating cybersecurity-specific guidance. Search Keywords: non-human identity (NHI), service account, workload identity, least agency, least privilege, excessive agency, action-level authorization, task-bounded authority, cryptographically verifiable identity, machine-to-machine authentication, proxy agent, encapsulated tools, secrets management, credential rotation, just-in-time access, API key isolation, SOC behavioral monitoring, zero trust	be behaving in an undesired manner, the level of granularity should be sufficient to identify and revoke access while minimizing the effect on other AI entities. The end of an identity's lifecycle, where it is withdrawn permanently rather than revoked in response to a problem, is in Task 13.2: Withdraw authority completely and confirm that it is withdrawn. The appropriate level of granularity will vary depending on variables that include: • Available resources (finance, time, expertise). • Expected threat level. • Expected impact. • Other mitigating controls. • Scale. • Vendor co-operation. • Application complexity. Organizations should implement this task flexibly, to allow for changes in granularity as these variables change. Where cryptographic authentication is not possible, such as with legacy or compute-constrained OT devices, alternative controls may be necessary and enforced at an alternative point in the system. Main Trustworthiness Contributions: Accountable: Contributes attribution at the granularity at which behavior needs to be disambiguated: a distinct identity for each AI entity, including ephemeral invocations, so an action traces to one invocation rather than to a shared service account. It does not record what that entity then did, which Task 5.4: Implement continuous security monitoring for AI entity actions logs at the access layer and Practice 10: Implement multi-tiered AI system logging and audit capabilities at the decision layer. Secure: Contributes mutual, cryptographically verifiable authentication between an AI entity and the system it calls, so a spoofed component is kept from presenting itself as a trusted agent, and a compromised one can be cut off by revoking its credentials. One entity's credentials can be revoked without withdrawing those the rest of the deployment depends on. It does not determine what an	Relying on shared accounts or group credentials heavily degrades situational awareness and complicates post-incident forensics because it obscures the true root cause of an action. In a complex or chained multi-agent system, being able to trace actions back to a unique, non-shared programmatic identity is essential for granular attribution and containment. Appropriately implementing granular NHIs helps ensure that if an individual model node experiences behavioral drift, runtime errors, or prompt compromise, its specific access tokens, API keys, session credentials, or similar can be isolated and revoked by the Security Operations Center (SOC) without invalidating the wider multi-tiered asset application architecture. References: >Candidates - suggestions welcome Guidance NIST SP 800-82r3, Guide to Operational Technology (OT) Security, from NIST. Section 6.2.1, Identity Management and Access Control, covers credential issuance, revocation and update for users, devices and services in an OT environment, and the compensating countermeasures to select where equipment cannot support authentication. Within it, section 6.2.1.4.5 states that shared credentials limit the ability to positively identify the person, process or device that accessed a protected resource, which is the attribution loss this Implementation acts on. 5.1.2: Establish unique identities for AI service accounts and agents Assign each AI service account or agent a unique, non-shared identifier at deployment, distinct from any human user account it may act on behalf of. For example, a grid-optimization agent and a chatbot summarizer running on the same server should never share a single service account, since doing so makes it impossible to attribute an anomalous action to a specific system during a review. Similarly, an AI assistant working on behalf of a person should be assigned a separate identity that allows its behavior to be logged and permissions managed separately from the person. References: >None yet - suggestions welcome 5.1.3: Implement cryptographically verifiable identities and automated mutual authentication Require AI entities to authenticate using cryptographic credentials (such as certificates or signed tokens) rather than static passwords, and require the receiving system to verify the AI entity's identity in return before exchanging data or commands. This helps prevent a spoofed component from posing as a trusted AI agent (this is a gap that default or reused credentials on exposed devices can open). >TBD - mini case study on these incidents References:

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
Main Trustworthiness Contributions: Secure: Contributes identity and access boundaries for the AI agents and tools themselves, so that each one is recognized, held to the access its role needs, and cut off when it acts outside that role. It does not keep unvetted AI systems out of the operating environment, which Practice 3: Define risks, policies, and oversight for automated AI and agentic behavior governs. Safe: Contributes a limit on how far a malfunctioning or compromised AI agent can reach into risk-sensitive processes, so consequence is bounded whether the cause is an attack or an error. It does not provide the means for people to intervene once an action already permitted is going wrong, which Practice 4: Define procedures for emergency avoidance override, recovery, and situation awareness establishes. Accountable: Contributes attribution: identities distinct enough that an action can be traced to the agent or tool that took it, allocated before deployment rather than reconstructed after an event. It does not capture the decision-level record of how the AI system arrived at that action, which Practice 10: Implement multi-tiered AI system logging and audit capabilities covers. Trustworthiness Tensions to Balance: Secure versus Reliable: Where an AI agent's role is settled and its needs are known, confining it to that role costs little in operation. Where an operational need appears outside what was anticipated, or the decision to grant access cannot be reached in time, the same confinement stops legitimate work. One resolution is to settle in advance what the AI system should do when its authority cannot be confirmed, so the outcome is a designed behavior rather than an arbitrary one. Others include granting authority for a bounded period and renewing it as needed, or reducing what the operation depends on the AI agent to do. Related AI RMF subcategories include: GOVERN 3.2 (on defining human-AI configuration): This Practice contributes the machine side of that configuration: which actions an AI entity may take on its own, and which need human approval; it does not define the oversight modes in which people supervise. For those,	authenticated entity may reach, which Task 5.2: Determine and implement specific access requirements determines. Trustworthiness Tensions to Balance: Accountable versus Reliable: Where AI entities are software invocations on capable hosts, splitting identity finely improves attribution at modest cost. Where the entity runs on legacy or compute-constrained equipment, per-invocation cryptographic credentials may exceed what the device can carry, and issuing them can degrade the function the device performs. One resolution this Task names is to enforce the identity at an alternative point in the system and accept coarser attribution at the device. Others include revisiting the granularity as resources, scale or expected threat change, which this Task asks organizations to plan for. Related AI RMF subcategories include: GOVERN 1.6 (on building the AI inventory): This Task inventories AI entities at the granularity of a single agent or tool invocation, which is the unit at which an action can be attributed; it does not cover the system-level register of deployed AI. For that, see Task 7.1: Maintain an Internal Registry of AI Deployments. MANAGE 2.4 (on decommissioning or superseding AI systems): This Task sets the identity granularity that lets one compromised entity be revoked while the others keep running; it does not bound how long an authority lasts when nothing has gone wrong. For that, see Task 5.3: Implement principles of least agency and least privilege for AI entities.	>None yet - suggestions welcome
Related AI RMF subcategories include: GOVERN 3.2 (on defining human-AI configuration): This Practice contributes the machine side of that configuration: which actions an AI entity may take on its own, and which need human approval; it does not define the oversight modes in which people supervise. For those,	5.2: Determine and implement specific access requirements Define specific systems, data sources, and tools each AI entity is authorized to access, and ensure those permissions are technically enforced and auditable against the scope of deployment and operational context.	5.2.1: Map and document AI agent access to operational and data assets Create and maintain a record of the systems, data sources, and physical assets each AI agent can reach, updated whenever an agent's role or deployment changes. This map is the prerequisite for enforcing least privilege in Task 5.3: Implement principles of least agency and least privilege for AI entities and for scoping what a compromised agent could actually affect. References: >None yet - suggestions welcome

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
see Task 4.5: Define operational regimes for human-on-the-loop and human-out-of-the-loop operation. MAP 4.2 (on establishing risk controls for AI system components): This Practice treats identity, authorization and privilege limits as the internal controls applied to each AI component; it does not cover the deterministic constraints enforced at the physical process boundary. For those, see Task 3.2: Implement independent guardrails ("safety wrappers") for AI outputs. GOVERN 1.6 (on building the AI inventory): This Practice extends the inventory to the credentialed AI entity, so that an entity missing from the directory is detected and denied at authentication; it does not cover the procurement gates that keep unvetted AI out. For those, see Task 3.7: Govern and mitigate risks from unauthorized, transient, and "Shadow AI" systems. MANAGE 2.4 (on decommissioning or superseding AI systems): This Practice makes credential revocation the mechanism by which one misbehaving AI entity is disengaged without disturbing the rest of the architecture; it does not cover retiring an AI asset at end of life. For that, see Task 13.2: Withdraw authority completely and confirm that it is withdrawn. References: >Candidates - suggestions welcome Guidance NIST SP 800-82r3. Guide to Operational Technology (OT) Security, from NIST. Section 6.1.1, Asset Management, sets out the inventory that access control depends on: unique identifiers, hardware and software inventory, and the vendor and ownership information attached to each asset. Section 6.3.2.1, Network Monitoring, covers the telemetry side, including baselining device-to-device communication and identifying misconfigurations and malfunctions of networked devices, so it reaches non-adversarial hazards as well as attacks. Working Document Accelerating the Adoption of Software and AI Agent Identity and Authorization, a concept paper from the National Cybersecurity Center of Excellence at	Main Trustworthiness Contributions: Secure: Contributes the enforced boundary between an authenticated AI entity and the assets it may reach, recorded in a map kept current as roles and deployments change, so the reach of a compromised entity is a known quantity. It does not detect an entity misusing access it legitimately holds, which Task 5.4: Implement continuous security monitoring for AI entity actions monitors. Safe: Contributes authorization of the individual action at the moment of execution, against the requesting entity's task scope, parameter limits and operational state, so an authenticated session carries no blanket permission for the consequential commands that follow. It does not define the state the process enters when an action is refused, which Implementation 3.2.3: Specify fail-safe states and fallback behavior specifies. Trustworthiness Tensions to Balance: Safe versus Safe: Where the refused action is one the process can proceed without, blocking it is the safe outcome and the trade does not arise. Where the entity is part-way through a sequence, refusal can leave the process in a state that is itself hazardous, and Implementation 3.2.3: Specify fail-safe states and fallback behavior notes that a fail-safe state is not necessarily simply stopping. One resolution is to design what refusal means for each consequential action, so a blocked command lands in a defined state rather than in whatever state the process was in. Others include placing the authorization check before a sequence begins rather than at each step within it, or scoping the grant to the whole sequence where the steps cannot be safely separated. Related AI RMF subcategories include: MAP 4.2 (on establishing risk controls for AI system components): This Task records which systems, data sources and tools each AI entity may reach, and requires that record to be technically enforced and auditable; it does not pare those permissions back to the minimum. For that, see Task 5.3: Implement principles of least agency and least privilege for AI entities. GOVERN 3.2 (on defining human-AI configuration): This Task puts the human approval point inside the runtime authorization decision, so that a consequential	5.2.2: Action-level, context-aware authorization policies Evaluate and authorize individual AI actions (such as invoking tools, modifying setpoints, or executing financial transactions) at runtime before execution. Authorization checks should evaluate the requesting AI agent's identity, current task scope, parameter limits, operational state, and any required human approvals. An authenticated session or prior authorization should not grant blanket permission for subsequent commands. If an action is unauthorized or authority cannot be verified, the system should block the request or transition to a pre-defined safe state (see Implementation 3.2.3: Specify fail-safe states and fallback behavior). This helps ensure that an authenticated AI agent with general system access is explicitly authorized for each specific consequential command. This Implementation decides whether a specific proposed action is permitted at the moment of execution. That is a different question from whether the requesting entity is permitted to interact with the system at all, which is established elsewhere in Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools, and in Task 7.4: Define Authorization and Access Controls for AI Modifications for people modifying AI systems. References: >Candidates - suggestions welcome Guidance NIST SP 800-207. Zero Trust Architecture, from NIST. Section 2 defines zero trust around least privilege per-request access decisions taken in a network treated as compromised. The tenets in Section 2.1 include that authentication and authorization to one resource will not automatically grant access to a different resource, which is the principle that this Implementation extends to individual actions within an authenticated session. Guidance NIST SP 800-162. Guide to Attribute Based Access Control (ABAC) Definition and Considerations, from NIST. Section 2.2 gives the working definition: an access decision computed by matching subject attributes, object attributes and environment conditions against a policy. Environment conditions are the dynamic factors independent of subject and object, which is the mechanism by which operational state enters a decision taken at the moment of the request. 5.2.3: Determine the appropriate level of agent, asset, and permission granularity Define how finely access should be split, for example, whether a single agent identity should cover: • Control of an entire pipeline segment versus individual valves. • Edit rights to an entire workspace versus individual documents.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
NIST. Sets out the problem this Practice addresses and the state of work on it, rather than controls to apply. Guidance Agentic Identity and Access Management, Workstream 4: Secure Design Patterns for Agentic Systems, version 1.0, 20 March 2026, from the Coalition for Secure AI, an OASIS Open Project. Addresses this Practice's subject directly. Section 3.1 holds that enterprises must treat agents as first-class identities, distinct from both human users and traditional service accounts, each with a unique persistent identity that survives its lifecycle and static and dynamic claims attached to it. Section 3.4 covers authorization and delegation, including the case of an agent acting on behalf of a user whose identity and intent are carried into the workflow, and separating an agent's own baseline rights from the rights it exercises on that user's behalf.	action is checked individually rather than granted by an authenticated session; it does not cover authorizing the people who modify AI systems. For that, see Task 7.4: Define Authorization and Access Controls for AI Modifications.	Single-signon access to post emergency updates via all social media accounts versus individual accounts. This should be based on the consequence tier of the asset and the resources available to manage that granularity. Legacy or compute-constrained OT devices may require coarser groupings with compensating controls, while high-consequence assets may warrant the finest practical split. References: >None yet - suggestions welcome
	5.3: Implement principles of least agency and least privilege for AI entities Least agency requires that the system's capability to initiate independent actions or invoke external operational tools is minimized to only what is strictly necessary for its defined function. This is distinct from least privilege which restricts what it is allowed to do should access be attempted. This helps ensure that systems are restricted from being granted permanent access to control systems, configuration interfaces, or operational tools beyond the active operational need, and that they avoid accessing these unnecessarily even when access exists. Minimize access permissions defined under Task 5.2: Determine and implement specific access requirements to only what is strictly necessary for the AI entity's defined function. Controls based on those applied to human users are a suitable point to build from, with additional controls put in place to account for AI agents and systems that may: - Have limited needs and whose access should be further compartmentalized. - Be influenced by multiple people beyond those notionally responsible. - Interact with other AI agents and systems, resulting in potential emergent behavior. - Operate at speeds beyond those expected of humans. - Be unable to provide meaningful explanations for their actions. Where authority is withdrawn permanently rather than bounded, Implementation 13.2.2: Revoke authority delegated to other entities, and record what could not be confirmed suggests that the withdrawal reaches every level of delegation and that anything which cannot be	5.3.1: Determine the practical minimum necessary permissions for a specific task and apply them to the AI system Starting from the access map in Implementation 5.2.1: Map and document AI agent access to operational and data assets, pare each AI agent's permissions down to only what its current task requires, removing standing access to systems it does not actively need. For example, an AI system that only reads sensor telemetry should never retain write access to control setpoints, even if it was granted that access during initial testing. >TBD: Add tension with possible unusual needs References: >None yet - suggestions welcome
		5.3.2: Task-Bounded and Revocable Agent Authority Bound an AI agent's authority to a specific task, operational mode, or time window rather than granting permanent standing privileges. When an AI system delegates execution to downstream tools or sub-agents, authority should be explicitly scoped per task. If a downstream agent or tool possesses specialized privileges as described in Implementation 5.3.3: Separate privilege via encapsulated downstream agents and tools, strict, deterministic validation and hard-coded operational boundaries should be enforced to prevent execution beyond its intended design. Systems should support rapid authority revocation and automatic expiration. In partitioned or remote environments where real-time authority checks may fail, systems should revert to pre-engineered, local fallback behaviors (Implementation 3.2.3: Specify fail-safe states and fallback behavior) rather than maintaining unverified standing authority.
		5.3.3: Separate privilege via encapsulated downstream agents and tools Avoid granting complex, probabilistic, adaptive AI agents and systems, and those with exposure to untrusted inputs, direct access to high-consequence actions on sensitive assets (e.g., write access to PLCs, databases, or emergency controls). Instead, such AI agents or systems should issue structured requests to specialized downstream "proxy" tools or agents that hold the necessary

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	confirmed revoked is recorded. Main Trustworthiness Contributions: Safe: Contributes a structural limit on what an AI system can set in motion: the capability to invoke operational tools is held to the defined function, and high-consequence actions are reached through a deterministic intermediary holding the execution credentials. It does not supply the validation logic and parameter collars that intermediary applies, which Task 3.2: Implement independent guardrails ("safety wrappers") for AI outputs supplies. Secure: Contributes the removal of standing authority: permissions bounded to a task, mode or time window, with expiration and rapid revocation, so a compromised entity holds less at any moment than permanent access would give it. It does not establish the identity whose authority is being bounded, which Task 5.1: Establish identities and authentication for AI entities establishes. Trustworthiness Effects to Consider: Accountable: Where a complex AI system reaches an asset through an encapsulated downstream agent, the credential presented at the asset belongs to that intermediary rather than to the system that asked for the action. Tracing the action back to the requesting entity then depends on that entity's own identity under Task 5.1: Establish identities and authentication for AI entities appearing in the record, and on the access event logging in Task 5.4: Implement continuous security monitoring for AI entity actions. Trustworthiness Tensions to Balance: Resilient versus Secure: Where the authority service is reachable, task-bounded and revocable authority and continued operation move together. Where a site is partitioned, keeping an entity working means letting it act on authority that nobody present can withdraw. One resolution, which Implementation 5.3.2: Task-Bounded and Revocable Agent Authority takes, is to revert to pre-engineered local fallback behavior rather than maintain unverified standing authority. Others include siting an authority service where the partition leaves it reachable, or narrowing in advance what an entity may do while partitioned.	execution credentials and maintain their own independent validation logic, parameter collars, state checks, and safety constraints described in Task 3.2: Implement independent guardrails ("safety wrappers") for AI outputs. This structural separation helps to prevent an AI model hallucination or prompt compromise from resulting in out-of-bounds physical or digital actions, as execution authority is mediated by a deterministic, single-purpose boundary. For shared assets, it also avoids relying on the guardrails of each upstream AI agent or system.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	Related AI RMF subcategories include: MANAGE 2.4 (on decommissioning or superseding AI systems): This Task makes authority expire by default, bounding it to a task, mode or time window so that standing privilege lapses without anyone intervening; it does not establish the identities that make selective revocation possible. For that, see Task 5.1: Establish identities and authentication for AI entities. MANAGE 2.1 (on allocating resources): This Task substitutes a deterministic, single-purpose proxy tool for the probabilistic agent at the point where a high-consequence action is executed, which is a non-AI alternative applied narrowly; it does not consider replacing the AI function as a whole. References: >Candidates - suggestions welcome Guidance OWASP Top 10 for Agentic Applications, Version 2026, published December 2025 by the Agentic Security Initiative of the OWASP Gen AI Security Project, a volunteer community project of the Open Worldwide Application Security Project rather than a standards body or a public authority. Entry ASI02, Tool Misuse and Exploitation, carries this Task's first principle under its own name: the leading mitigation is titled Least Agency and Least Privilege for Tools, and asks for per-tool profiles setting scopes, maximum rate and egress allowlists, with read-only database queries and summarizers holding no send or delete rights as worked examples. Entry ASI03, Identity and Privilege Abuse, carries the second: un-scoped privilege inheritance down a delegation chain, and authorization that was valid when a workflow began but not when it executed, answered by task-scoped and time-bound permissions with automated revocation. The document holds the two apart as this Task does, with ASI02 covering an agent that misapplies a tool inside the privileges it already holds and ASI03 covering an agent that acquires privileges it should not have.	
	5.4: Implement continuous security monitoring for AI entity actions	5.4.1: Establish logging and periodic review of AI agent authentication and access events

Practice	Task	Implementation
	Continuously monitor AI entity actions against defined access boundaries to detect out of scope actions, unauthorized access attempts, and privilege escalations. Main Trustworthiness Contributions: Secure: Contributes detection of the entity that authenticates correctly and then acts beyond its boundary, through monitoring against defined access boundaries and against an established pattern of access. It does not set the boundaries a deviation is measured against, which Task 5.2: Determine and implement specific access requirements and Task 5.3: Implement principles of least agency and least privilege for AI entities set. Transparent: Contributes a record of AI entity authentication and access events, including the attempts that failed, together with a defined cadence at which a person examines it. It does not capture the inputs, prompts and model context needed to reconstruct why an action was taken, which Practice 10: Implement multi-tiered AI system logging and audit capabilities covers. Trustworthiness Effects to Consider: Safe: Detection at machine speed produces notifications, and an entity population that is partly ephemeral produces deviations from an established pattern as a matter of course. Where those notifications reach the same people who watch operations, Task 4.4: Attention Governance and Alert/Alarm Flood Mitigation treats notification volume as a designed quantity rather than a byproduct. Related AI RMF subcategories include: MEASURE 2.4 (on monitoring deployed AI systems): This Task monitors AI entity actions in production against defined access boundaries, and alerts in real time where a later log review would arrive too late; it does not monitor the quality of what the AI produces. For that, see Task 3.4: Monitor for anomalous AI behavior. MEASURE 2.7 (on measuring security and resiliency): This Task supplies continuous runtime evidence of security posture, in the form of authentication, access and privilege-escalation events; it does not evaluate the resilience that MEASURE 2.7 also names. For that, see	Log every authentication attempt and access request made by an AI entity, including failures, and assign a defined cadence (such as weekly or after any privilege change) for a person to review this log for irregular patterns. This helps to narrow the gap that opens where access is technically logged but never actually reviewed until after significant damage has occurred. References: >None yet - suggestions welcome 5.4.2: Deploy real-time behavioral anomaly detection for AI agent activity within the Security Operations Center (SOC) Extend the periodic review in Implementation 5.4.1: Establish logging and periodic review of AI agent authentication and access events with automated, real-time alerting when an AI agent's access pattern deviates from its established baseline, such as an unusual login time, an unfamiliar source location, or a spike in request volume. This matters most in machine-speed environments where a human reviewing logs after the fact may be too late to prevent harm. References: >None yet - suggestions welcome

Practice	Task	Implementation
	Practice 2: Define AI Robustness, Resilience, and Quality of Service expectations. References: >Candidates - suggestions welcome Guidance MITRE ATLAS, from MITRE, a United States not-for-profit corporation that operates federally funded research and development centers. A public catalog of adversary tactics and techniques observed against AI systems, used here to categorize runtime telemetry anomalies and to guide post-incident triage.	
6: Integrate visibility of the external supply chain of AI into vendor and 3rd party risk management Apply pre-acquisition and procurement-phase governance over external vendor dependencies and third-party assets. Managed primarily by Procurement, Legal, and Third-Party Risk Management teams, this practice extends traditional supply chain oversight to account for AI's unique external concerns. These include: • Data provenance • Data drift • Model integrity • Supervision of retrieval augmentation (systems that retrieve data to help generate their outputs) • Supervision of agentic systems The latter two have their own autonomy over the data they consider, and the flow of privileged information among numerous AI agents and tools. This practice addresses the governance of external vendor dependencies and third-party assets. It outlines supply chain mechanisms, specifically machine-readable AI Bills of Materials (AIBOMs) and the disclosures of Implementation 6.1.5: Operational AI Hazard Reachability Disclosures, needed to verify whether upstream third-party model hazards actively expand the enterprise's reachable risk surface (Task 3.8: Scope and map the expanded AI Attack Surface and Risk Surface) or have been rendered operationally unreachable by other controls. For post-acquisition operator controls over internal data and localized assets, see Practice 7: Manage internal AI supply chain and data provenance. <i>Note on Supply Chain Transparency:</i> While Software Bills of Materials (SBOMs) pair with VEX by referencing	6.1: Develop policies for AI supply chain requirements Establish organizational policies that, for each application of AI, define minimum trustworthiness and visibility requirements for AI-related vendors and assets. These policies should provide a scalable framework where the rigor of due diligence, such as requirements for AIBOMs, model cards, data provenance attestations, and adversarial robustness testing, is based on the system's criticality and the organization's risk tolerance. By formalizing these expectations in procurement and service-level agreements, the organization helps ensure a consistent baseline for trust while remaining adaptable to varying resource levels and application threat profiles. Main Trustworthiness Contributions: Valid: Contributes procurement tests of fit for this deployment: attested representation of similar environments in the training data (Implementation 6.1.2: Require AIBOM for mission-critical applications) and demonstrated proficiency in sector terminology and standards (Implementation 6.1.3: Domain-Specific Terminology and Contextual Attestation). It does not confirm fit in operation, which Task 1.3: Implement evaluation and test plans, including TEVV, across the AI lifecycle and Implementation 2.3.1: Baseline AI system performance do. Robust: Contributes upstream characterization of behavior beyond expected conditions, in failure envelopes, boundary constraints and vendor-supplied test vectors (Implementation 6.1.4: Manufacturer	6.1.1: Add AI disclosure to existing procurement policies Leverage existing legal/contractual workflows to provide baseline visibility into hidden AI dependencies in standard IT/OT/ICS software, particularly when AI features are added during otherwise routine updates. Procurement policies should explicitly require AI vendors to disclose: • The nature and frequency of model updates, including updates that do not require operator action to take effect (especially 'silent' updates and cloud-side changes). • The provenance and version of training data used in each model release. • Any changes to safety-relevant model behavior introduced in each update. Where feasible, establish contractual rights to suspend automatic updates pending internal review for any AI system that influences safety-critical CI operations. Organizations should carefully balance this suspension mechanism against the competing risk of delaying critical security patches or performance fixes, helping ensure that any update deferral is strictly time-bound, risk-assessed, and accompanied by enhanced temporary monitoring. Where such contractual obligations are unfeasible, organizations should substitute equivalent technical compensating controls to contain update risk. These alternative controls may include: • Isolated Perimeter Staging: Route all incoming software updates or vendor endpoint connections through isolated staging networks, hardware-in-the-loop (HIL) test rigs, or digital twins to execute initial behavioral verification before promoting the update to the active production path. • Network Egress and API Gates: Deploy strict network filtering or proxy blocks that restrict the AI application's ability to pull silent, cloud-side model changes or unvetted external dependencies at runtime until the connection is manually authorized by an

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
centralized vulnerability databases (CVEs), AI Bills of Materials (AIBOMs) catalog probabilistic model components where no universal vulnerability database exists. This profile explicitly separates traditional software VEX (for underlying ML code libraries) from Contextual Hazard Reachability (which evaluates whether probabilistic model failure modes can reach physical control paths). Search Keywords: AI bill of materials (AIBOM), software bill of materials (SBOM), supply chain risk management (SCRM), third-party risk management (TPRM), fourth-party risk, vendor due diligence, procurement requirements, contractual flow-down, model card, model provenance attestation, contextual hazard reachability, VEX for AI, silent update risk, resilient-by-design, data egress monitoring Main Trustworthiness Contributions: Transparent: Contributes the pre-acquisition disclosure set for components the operator cannot instrument from the inside: AIBOMs, model cards, provenance attestations and hazard reachability statements, obtained by contract rather than by logging. It does not cover assets under direct organizational control, which Practice 7: Manage internal AI supply chain and data provenance covers. Accountable: Contributes allocation of responsibility to the vendor in advance, through procurement terms and service-level agreements, rather than after an incident. It does not make a vendor's attestations true: the operator still has to corroborate each before relying on it. Trustworthiness Effects to Consider: Secure: The disclosures this Practice requires list what a system is made of, how it fails, and what stands in the way of each hazard. Protecting those documents is a matter for the organization's existing information classification and handling practice. Related AI RMF subcategories include: GOVERN 6.1 (on establishing third-party risk management processes): This Practice contributes the AI-specific disclosures, attestations and inventory that such processes need to	Accountability and AI Resilient-by-Design), placing the initial profiling burden on the manufacturer. It does not set the robustness expectations those envelopes are judged against, which Practice 2: Define AI Robustness, Resilience, and Quality of Service expectations sets. Trustworthiness Effects to Consider: Reliable: Due-diligence rigor is set once, from criticality assessed at acquisition, while Implementation 6.1.1: Add AI disclosure to existing procurement policies notes that AI features arrive during otherwise routine updates, so a component can drift away from the profile it was scoped against. Task 6.2: Align AI and existing CI asset lifecycle management carries the re-evaluation trigger. Related AI RMF subcategories include: GOVERN 6.1 (on establishing third-party risk management processes): This Task sets the minimum trustworthiness and visibility that a third-party AI policy should require, tiered by criticality; it does not cover enforcement once a vendor is engaged. For that, see Task 6.2: Align AI and existing CI asset lifecycle management. MAP 4.1 (on understanding AI component-level risks): This Task makes AIBOMs, model cards and provenance attestations the mechanism by which third-party component risk is mapped; it does not perform that mapping for a given system. For the mapping itself, see Task 3.8: Scope and map the expanded AI Attack Surface and Risk Surface. MAP 1.5 (on documenting risk tolerances): This Task consumes documented risk tolerances to set proportionate due-diligence tiers; it does not determine those tolerances. For those, see Implementation 3.1.3: Define acceptable risk thresholds and associated control responses.	administrator. Temporary Safety Wrapper Tightening: Temporarily apply stricter, pre-authorized threshold margins on independent safety wrappers (defined in Task 3.2: Implement independent guardrails ("safety wrappers") for AI outputs) during the initial post-update deployment window. This step helps ensure that unexpected or erratic behavior introduced by the silent update can be blocked at the process boundary before it can cause operational harm. This implementation mitigates hazard risk of a compromised AI vendor update pipeline, where a trusted vendor's software update mechanism is breached, delivering malicious updates to AI systems across multiple CI operators simultaneously, as occurred with conventional software in the compromise described in CISA advisory AA20-352A. In this scenario, the direct CI analog is an AI model that receives a silent update changing its detection behavior, classification thresholds, or safety logic without the operator's knowledge or review. Trustworthiness Tensions to Balance: Secure versus Secure: Where an update carries a feature or model change, suspending it pending review guards against a compromised vendor update pipeline at negligible security cost. Where the same channel carries a critical security patch, the hold extends exposure, so any deferral should be time-bound, risk-assessed and monitored. Secure versus Reliable: Where a vendor ships fixes separately from behavioral changes, a review hold costs little. Where one release carries both, holding it to review a silent model change keeps a known performance defect in service; isolated staging and tightened safety wrappers instead let the update land under containment. References: >Candidates - suggestions welcome Guidance NIST SP 800-161 Revision 1, Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations, from NIST. Control SR-8, Notification Agreements, is the established form of what this Implementation asks of AI vendors: requiring suppliers to establish notification agreements with entities in the supply chain that have a role in a critical service or product. The base control covers notification of supply chain compromises, assessment results, or other organization-defined information, which an organization can define to include model changes. Control SR-4, Provenance, asks that provenance be documented for systems, components and associated data throughout the development lifecycle, and that software bills of materials be produced and digitally signed, which is the counterpart to the training data provenance and per-release version disclosures required here.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
require; it does not address the intellectual property and rights infringement that GOVERN 6.1 also names. GOVERN 6.2 (on establishing contingency plans for critical third parties): This Practice provides the pre-acquisition visibility that makes a third-party failure detectable and an exit possible; it does not define the contingency response itself. For incidents see Practice 8: Incorporate AI-aware incident analysis and response procedures, Practice 11: Maintain AI-aware mission continuity and disaster recovery planning. GOVERN 1.6 (on building the AI inventory): This Practice extends the asset inventory to externally sourced models, tools and services; it does not cover AI assets under direct organizational control. For those, see Practice 7: Manage internal AI supply chain and data provenance. References: >None yet - suggestions welcome		Incident Report Advanced Persistent Threat Compromise of Government Agencies, Critical Infrastructure, and Private Sector Organizations, advisory AA20-352A from the United States Cybersecurity and Infrastructure Security Agency, the federal agency responsible for civilian cybersecurity. A malicious binary was inserted into the vendor's software lifecycle and then signed by that vendor's legitimate code signing certificate, reaching government agencies, critical infrastructure entities and private sector organizations through the normal update path. This is the hazard this Implementation transposes to a silent model update. 6.1.2: Require AIBOM for mission-critical applications AIBOM should be at an appropriate level of detail, from vendors for the current and each subsequent model release so that their AI system's supply chain is documented. Ideally this should be machine readable. It should include model(s) in use, primary training data sources, data retrieved at runtime, and software used at training and run time including any significant third-party dependencies. Purposes for such an AIBOM include: - Monitoring for application and/or environment drifting outside the support of the training data and background information. - Detecting the presence of input data and information that becomes or is later found to be inaccurate or invalid. - Tracing errors, vulnerabilities, and threats. The concept of AIBOM is still in its infancy and as of writing, formal specifications are still being developed (see CISA 2026 SBOM Minimum Elements). Operators should consider their application's risk profile in deciding on the level of detail that they should request of their vendors. For example, a vendor providing an AI system that relies on environmental sensor data as part of its mission-critical decision making should, at a minimum, be obliged to attest that the AI system's training data includes an appropriate representation from similar environments. If a vendor is unable to provide an appropriate AIBOM for a high-consequence application, the operator faces a hidden residual risk profile. Rather than treating this as an all-or-nothing requirement, organizations should request the most complete documentation available, then apply compensating controls proportional to the gaps, such as enhanced runtime monitoring, guardrails and watchdogs as described in Task 3.4: Monitor for anomalous AI behavior and Implementation 2.2.2: Deploy "watchdog" controllers, and more frequent recurrent risk and TEVV evaluations as described in Implementation 2.3.4: Recurrent Risk Evaluations. Any gaps in meaningful supply chain documentation that cannot be compensated for should themselves be treated as a documented risk, escalated and factored into the organization's go/no-go deployment decision.

Practice	Task	Implementation
		>To the Reviewer: We've framed this above as a gradient of compensating controls rather than a hard requirement, since we recognize AIBOM standards are still emerging and few vendors can fully meet this today. Does this framing strike the right balance for your procurement process, or would a different structure (e.g., minimum mandatory disclosures vs. best-effort extras) work better for your sector? References: >Candidates - suggestions welcome Guidance 2026 Minimum Elements for a Software Bill of Materials (SBOM), published 29 July 2026 by the United States Cybersecurity and Infrastructure Security Agency. Sets out what a software bill of materials has to carry and is deliberately format-neutral, asking organizations to accept any widely used, interoperable and machine-processable format, and naming SPDX (ISO/IEC 5962:2021) and CycloneDX (ECMA-424) as the two in wide use. The section titled SBOM for AI Software Systems, at page 15, is the part that bears on this Implementation: it holds that because AI is software the minimum elements already illuminate many of its components, that there may be additional useful supply chain data for AI, for example what practitioners discuss as model cards and data cards, and that the document does not itself introduce elements for AI systems. Standard NERC CIP-013-2, Supply Chain Risk Management for High and Medium Impact BES Cyber Systems, from the North American Electric Reliability Corporation, the body that develops reliability standards for the North American bulk power system and enforces them on registered entities. The requirements at R1 and R2 apply to supply chain risk management for the high and medium impact BES Cyber Systems the title names. Energy sector only. Standard System Package Data Exchange (SPDX), a project of the Linux Foundation, published as ISO/IEC 5962:2021. A bill of materials format for software components. Its coverage of AI-specific components is limited in the ratified version, and AI content is being developed for a later release of the specification. Standard CycloneDX, a flagship project of the Open Worldwide Application Security Project, published as ECMA-424, CycloneDX Bill of Materials Specification, December 2025. A bill of materials format covering software, hardware and machine-learning components, with a machine learning bill of materials form already defined, and AI content under continued development. Guidance Establish Risks and Controls for the AI Supply Chain, version 1.0, 12 June 2025, from Workstream 1, Software Supply Chain Security for AI Systems, of the Coalition for Secure AI, an OASIS Open Project whose other workstreams address adjacent parts of this profile's subject. Its Supply Chain Documentation Requirements section, at page 10, enumerates the runtime half of the inventory this Implementation asks for: retrieval-augmented generation infrastructure including embedding models and retrieval

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
		algorithms, vector database providers and their isolation mechanisms, caching systems with isolation and encryption, the tools and external systems reachable during inference, and dependency trees with their integrity verification methods. 6.1.3: Domain-Specific Terminology and Contextual Attestation Establish procurement policies that require vendors to provide formal attestations or evidence, such as via Model Cards or AIBOM, demonstrating that pre-trained AI systems are proficient in the industry terminology, technical standards, and community-specific linguistic nuances of the target critical infrastructure sector. This helps ensure that systems, particularly those used for report summarization, predictive maintenance, or customer interaction, accurately interpret the specialized "language of the mission" before they are introduced into the operational environment. 6.1.4: Manufacturer Accountability and AI Resilient-by-Design Specify AI-specific "Resilient-by-Design" principles, that build upon conventional "Secure-by-Design" guidance during procurement. Vendors should be required to deliver pre-tested model boundary constraints and standardized behavioral validation datasets (test vectors) tailored to the operational context. Because probabilistic machine learning models cannot be made entirely deterministic or immune to unexpected inputs, policies should mandate that manufacturers explicitly document how their systems behave under stress, such as failure envelopes for contextual drift, adversarial prompting, or data schema variance. Vendors should provide clear instructions on how the model safely degrades or transitions to backup logic when these boundaries are exceeded, shifting the burden of initial behavioral profiling upstream to the manufacturer. References: >Candidates - suggestions welcome Guidance Guidelines for Secure AI System Development, 2023, published by the United Kingdom National Cyber Security Centre and the United States Cybersecurity and Infrastructure Security Agency with twenty-one further national agencies. Organizes secure-by-design practice across four stages of the AI system lifecycle. Section 1, Secure design, covers integrating the most secure settings into a system by default and applying restrictions to the actions an AI component may trigger, including non-AI fail-safes. Section 2, Secure development, asks that documentation cover intended scope and limitations, guardrails, cryptographic hashes or signatures, and potential failure modes. Section 3, Secure deployment, covers computing and sharing hashes or signatures of model files and datasets so that consuming systems

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
		can validate them, and being clear to users about known limitations and potential failure modes on release. Guidance ISO/IEC TR 5469:2024, Artificial intelligence: functional safety and AI systems, a Technical Report published jointly by ISO and IEC. Addresses the use of AI within functions that carry a safety role, which is the question an operator faces when a vendor's probabilistic component sits alongside deterministic protection. 6.1.5: Operational AI Hazard Reachability Disclosures AI vendors and system integrators should supply machine-readable hazard reachability attestations, adapting Vulnerability Exploitability eXchange (VEX) workflows, alongside AIBOM disclosures. Organizations should recognize a fundamental distinction between software-level vulnerabilities and model-level behavioral risks: • Deterministic Software Dependencies (Standard VEX): For traditional software libraries, machine learning frameworks (e.g., PyTorch, CUDA, vLLM), and execution drivers listed in the AIBOM, vendors should supply standard Vulnerability Exploitability eXchange (VEX) statements (e.g., CSAF or CycloneDX) that cross-reference known CVE databases to declare whether software flaws are reachable in the compiled product. • Probabilistic Model Behaviors (Contextual Hazard Reachability): Because no centralized, indexed vulnerability database (equivalent to CVE/NVD) exists for the stochastic failure modes of AI models (e.g., hallucination propensities, context window corruption, or distribution drift sensitivity), traditional VEX database lookups cannot be directly applied to AI model weights. Instead, vendors should adapt VEX workflow principles by providing a Contextual Hazard Reachability Attestation. This attestation documents whether a known model limitation identified during TEVV (Practice 1: Establish requirements for success and Practice 2: Define AI Robustness, Resilience, and Quality of Service expectations) or mapped during risk-surface scoping (Task 3.8: Scope and map the expanded AI Attack Surface and Risk Surface) is rendered operationally unreachable within the specific deployment architecture. Vendors declaring a model hazard as "Not Affected" should supply the machine-readable justification, such as independent safety wrappers (Task 3.2: Implement independent guardrails ("safety wrappers") for AI outputs), execution sandboxing (Implementation 3.5.3: Impact compartmentalization (sandboxing)), or strict least-agency tool restrictions (Task 5.3: Implement principles of least agency and least privilege for AI entities). The existing VEX justification "Inline mitigations already exist" (see CISA 2023) is limited to protections built into the product that the user cannot configure or disable, so controls that the operator deploys around the AI system would need to be stated as a separate justification. These measures are intended to break the reachability path between the AI flaw and physical or mission consequences. Contextual Hazard Reachability Attestations used to trigger auto-suppression

Practice	Task	Implementation
		under Task 4.4: Attention Governance and Alert/Alarm Flood Mitigation should require either independent verification by the operator (e.g., reproducible test cases run against the actual deployment architecture) or corroboration against the operator's own TEVV evidence (Task 1.3: Implement evaluation and test plans, including TEVV, across the AI lifecycle, Implementation 2.3.1: Baseline AI system performance) before being trusted to silence an alert. Vendor self-attestation alone should not be treated as sufficient to suppress a warning. In traditional software, where the shared vulnerability database described above does exist, the tools that generate VEX data still show substantial disagreement about which vulnerabilities are present (see Churakova et al. 2026). Absent that database, a contextual attestation is harder to corroborate rather than easier. References: The application of VEX workflows and concepts to AI risk reachability is still a topic of active work. The first two references describe the state of VEX practice in traditional software, which is the basis for the caution above. The remainder are cybersecurity-specific VEX resources that may be useful as a guide for how to incorporate these principles more broadly. Research Churakova, Y., Ekstedt, M., and Schmid, L., <i>Vexed by VEX Tools: Consistency Evaluation of Container Vulnerability Scanners</i>, in <i>Foundations and Practice of Security: 18th International Symposium, FPS 2025, Revised Selected Papers, Part I</i>, Lecture Notes in Computer Science volume 16402, Springer, 2026, pages 139 to 156. Open access preprint at arXiv:2503.14388. Research from KTH Royal Institute of Technology. Compares seven VEX-generation tools across 48 container images and finds a highest pairwise similarity of 69%, with most five-tool combinations agreeing on nothing at all and the best reaching 3.4%. It measures consistency between the tools that generate VEX data rather than the accuracy of any supplier's claim, so it bears on how much weight a single unchecked attestation can carry. Commentary Signal in the Noise: An Industry-Wide Perspective on the State of VEX, from the Open Source Security Foundation, a cross-industry body hosted by the Linux Foundation, drawing on contributions from Amazon, Aquasec, Chainguard, Cisco, Debian, Ericsson, Freexian, Google, Microsoft, Red Hat and OpenSUSE. Reports that <i>"the reality today is that VEX feels more like a promise than a practice"</i>, and that for many enterprise consumers trust is <i>"currently based on where the file is hosted rather than cryptographic proof"</i>. Guidance CISA (2023) Minimum Requirements for Vulnerability Exploitability eXchange (VEX), from the United States Cybersecurity and Infrastructure

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
		Security Agency, the federal agency responsible for civilian cybersecurity. Specifies the minimum elements a VEX document must carry, independent of format, including the justifications a supplier gives for a "Not Affected" status. That is the model Contextual Hazard Reachability Attestations adapt. Guidance CISA (2022) Vulnerability Exploitability eXchange (VEX) - Use Cases, from the same agency. Sets out scenarios with proposed implementations, showing how the minimum data elements are assembled in practice. Commentary Friedman, A. (2026) Practical Guidance for Managing VEX Workflows, published by FOSSA, a commercial supplier of software composition analysis tooling that sells VEX workflow automation. Friedman led the SBOM and VEX communities at NTIA and then CISA and now advises independently, so this is one of VEX's principal advocates describing what running it actually requires, and observing that adoption is still catching up to SBOM.
	6.2: Align AI and existing CI asset lifecycle management Externally sourced AI components should be integrated into existing asset lifecycle management processes, helping ensure that authorized updates are formally managed via change control, while runtime telemetry is utilized to catch and isolate unannounced behavioral shifts resulting from silent third-party model modifications. Main Trustworthiness Contributions: Reliable: Contributes the record that keeps qualification evidence attached to a known configuration: model version, training data provenance and inference endpoint routed through change control, with re-evaluation on change (Implementation 6.2.2: Track vendor updates and third-party entity changes through change management process). It does not cover drift within an unchanged model, which Implementation 2.3.4: Recurrent Risk Evaluations and Task 3.4: Monitor for anomalous AI behavior discuss. Accountable: Contributes tracking of the counterparty itself, including acquisition, sub-processor change and end of support (Implementation 6.2.2: Track vendor updates and third-party entity changes through change management process), so the party carrying the procurement obligations stays identified. It does not	6.2.1: Register externally sourced AI components in asset management systems Add every externally sourced AI model, tool, or service to the organization's existing asset management system at the point of acquisition, capturing vendor, version, and purpose so it is visible alongside traditional IT and OT assets rather than tracked separately or not at all. References: >None yet - suggestions welcome
		6.2.2: Track vendor updates and third-party entity changes through change management process Where possible, route vendor-issued updates and third-party configuration changes through the organization's standard change management process, helping ensure updates are reviewed and approved before deployment rather than applied silently. Where the deployment model does not permit an update to be gated, such as for cloud-hosted and vendor-managed models or where associated delays are deemed to incur an unreasonable risk, document that as a known limitation. Combine required disclosures, as discussed in Implementation 6.1.1: Add AI disclosure to existing procurement policies, with runtime monitoring and telemetry, as discussed in Task 3.4: Monitor for anomalous AI behavior, to detect unannounced behavioral shifts after the fact, rather than treating the component as static.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	create those obligations, which Task 6.1: Develop policies for AI supply chain requirements creates. Trustworthiness Tensions to Balance: Reliable versus any characteristic the release improves, including itself: Where a vendor release is a feature or model change, reviewing it before deployment may add little risk. Where it carries a fix, such as to safety, security, accuracy or reliability, holding it defers that benefit, so Implementation 6.2.2: Track vendor updates and third-party entity changes through change management process permits ungated deployment where delay is judged an unreasonable risk, recorded as a known limitation. Related AI RMF subcategories include: GOVERN 1.6 (on building the AI inventory): This Task registers externally sourced models, tools and services in the existing asset management system at acquisition; inventory alone does not detect change, so this Task pairs registration with change control and telemetry. MANAGE 3.2 (on monitoring pre-trained model risks): This Task routes vendor model updates through change control and watches for unannounced version shifts; it does not cover behavioral drift within an unchanged model. For that, see Task 3.4: Monitor for anomalous AI behavior. MAP 4.2 (on establishing risk controls for AI system components): This Task treats change management and runtime telemetry as the internal controls applied to third-party components; it does not cover controls at the physical process boundary. For those, see Task 3.2: Implement independent guardrails ("safety wrappers") for AI outputs.	Changes to track include model version, training data provenance, inference endpoint, and change to the third-party entity itself, such as acquisition, sub-processor change, or end of support. Changes should trigger re-evaluation under Implementation 2.3.4: Recurrent Risk Evaluations. In particular, newly released or substantially revised models and other system components, AI or otherwise, warrant elevated monitoring and testing for a defined period after adoption. Treat these as a distinct category with a documented exit criterion for returning them to routine monitoring. Implementation 7.4.1: Define and implement requirements for approvals and logging of updates and changes to AI systems sets the equivalent requirement for changes to internally sourced components. References: >None yet - suggestions welcome
	6.3: Identify and control dataflows across the AI supply chain Define and maintain visibility over the dataflows between AI systems and external vendors, platforms, and services	6.2.3: Manage end-of-life transitions for externally sourced AI components Define a formal offboarding process for externally sourced AI components reaching end-of-life or vendor discontinuation, including secure decommissioning and confirmation that no dependent systems are left relying on an unsupported component. Vendor discontinuation is one of the external triggers for retirement recorded under Implementation 13.1.1: Identify retirement triggers, including those outside the organization's control, and the withdrawal of the component's authority follows Task 13.2: Withdraw authority completely and confirm that it is withdrawn. References: >None yet - suggestions welcome
	6.3.1: Catalog data egress points and third-party processing destinations Identify every point where organizational data leaves the environment to reach a third-party AI vendor or service, and document what data is sent,	

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	they connect to. Ensure that data exchanged with these external dependencies, including telemetry, inference requests (a trained AI model producing an output for a given input), model updates, and any operational or sensitive information transmitted outside the organization is authorized, monitored, and bound by data handling policies. Main Trustworthiness Contributions: Privacy-Enhanced: Contributes containment of what leaves continuously rather than as a one-off transfer: inference requests and operational telemetry, cataloged in Implementation 6.3.1: Catalog data egress points and third-party processing destinations and routed through restricted enclaves in Implementation 6.3.2: Implement egress monitoring and isolated, access-restricted enclaves for AI training and telemetry. It does not address privacy risk arising from the AI system's own outputs, which Implementation 7.5.3: Integrate Privacy Impact Assessments (PIA) into Update Cycles addresses in part, through privacy impact assessment at each significant update. Secure: Contributes exfiltration detection at the AI egress path, watching cataloged destinations for unexpected volume or destination change (Implementation 6.3.2: Implement egress monitoring and isolated, access-restricted enclaves for AI training and telemetry), which is how loss of a model, training data or telemetry through a vendor endpoint becomes visible. It does not authenticate the requesting AI entities, which Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools does. Trustworthiness Tensions to Balance: Privacy-Enhanced versus Reliable: Reliability may depend on 3rd party remote monitoring, such as by a vendor with specialized knowledge. Restricting telemetry may impair system reliability as the vendor may be unable to respond to degradation appropriately. Related AI RMF subcategories include: MANAGE 3.1 (on monitoring and responding to third-party risks):	why, and where it is processed, so the organization has a complete picture of its external data exposure. References: >None yet - suggestions welcome 6.3.2: Implement egress monitoring and isolated, access-restricted enclaves for AI training and telemetry Monitor the egress points cataloged in Implementation 6.3.1: Catalog data egress points and third-party processing destinations for unexpected volume or destination changes, and route sensitive data used for AI training or telemetry through isolated, access-restricted environments rather than general-purpose network paths. References: >None yet - suggestions welcome

Practice	Task	Implementation
	This Task monitors what leaves the organization to reach third-party AI services and applies egress controls; it does not monitor the third party's own behavior or performance. For that, see Task 6.2: Align AI and existing CI asset lifecycle management. MEASURE 2.10 (on measuring privacy): This Task supplies the data-exposure inventory that a privacy-risk examination depends on; it does not perform that examination or assess privacy risk arising from the system's own outputs.	
7: Manage internal AI supply chain and data provenance Establish post-acquisition operational oversight for AI assets under direct organizational control. Managed primarily by Internal IT, Engineering, and Data Governance teams, this practice focuses on the internal mechanics of deployed systems, including local fine-tuning, retrieval-augmented data repositories, version control for safety wrappers, local data provenance and flow, and localized AI model and system configurations. This practice also provides the visibility needed to mitigate 'Shadow AI' risks and helps ensure that internal modifications to automated logic remain traceable and mission-aligned. In addition, it provides actionable measures to implement Task 3.7: Govern and mitigate risks from unauthorized, transient, and "Shadow AI" systems and informs the need to update the AI attack and risk surface as discussed in Task 3.8: Scope and map the expanded AI Attack Surface and Risk Surface. For pre-acquisition vendor vetting and procurement controls, see Practice 6: Integrate visibility of the external supply chain of AI into vendor and 3rd party risk management. Search Keywords: data provenance, data lineage, master AI asset list, AI asset inventory, model registry, fine-tuning, retrieval-augmented generation (RAG), vector store, prompt versioning, configuration management, policy-as-code, policy lock, online learning governance, champion-challenger testing, catastrophic forgetting, privacy impact assessment (PIA), substrate substitution,	7.1: Maintain an Internal Registry of AI Deployments Catalog internal instances, versions, and specific use-cases of AI systems deployed across different departments, and the authorization associated with each (including legacy AI systems that predate formal authorization). This task helps ensure that internal stakeholders have a clear inventory of "where" AI is operating within the organization, enabling consistent oversight and maintenance even when models are embedded in departmental workflows.	7.1.1: Create and maintain a "Master AI Asset List" Document the names, versions, vendors, hosts (cloud vs on-premises), responsible contacts, dependencies (such as required authorizations, data, compute, and other resources), operational purpose, and risk management controls for all AI systems and models. This includes AI systems used for logistical or administrative purposes, such as chatbots, meeting transcribers, and document summarization tools. Document model lineage and component hierarchy, tracking parent-child relationships between base foundation models, fine-tuned adapters (e.g., LoRAs), vector index embeddings, and quantized runtime distributions. 7.1.2: Maintain a data inventory Document organizational data sources that are, or may be, used in AI systems. Use may include training, fine-tuning (further training an existing AI model on an organization's own data to adapt it), retrieval augmentation, or agentic use. Data sources may be static knowledge bases, historic, and/or real-time feeds. The inventory should identify the data's: • Source and provenance, including its origin and chain of custody. See Task 7.2: Validate data provenance for model inputs. • Role within the AI system, such as for training or retrieval augmentation. • Data type and classification, including format and sensitivity level. • Metadata and versioning, including verification of integrity such as hashes. • Licensing, terms, and other restrictions on usage. • Lineage and transformations performed, including cleaning, masking, and synthetic data generation. • Quality and integrity metrics and checks performed. • Ownership and accountability, including contacts for incident response.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
model archiving, data poisoning prevention Trustworthiness Characteristics: >None yet - suggestions welcome Related AI RMF subcategories include: >None yet - suggestions welcome References: >None yet - suggestions welcome		• Security and access controls, including identity and access management, logging, and encryption requirements. • Hosting and storage location, including redundancy and backups.
		7.1.3: Integrate automated internal software and AI bill of material management Develop policies for regular scanning of internal networks for AI systems and behavior. This integrates with information obtained in Practice 6: Integrate visibility of the external supply chain of AI into vendor and 3rd party risk management.
	7.2: Validate data provenance for model inputs Document the source, cleaning process, permitted use policies, and authorization of internal datasets (e.g., maintenance logs, sensor telemetry) used to fine-tune or prompt AI models. This task improves visibility into the risk of internal "data silos" that introduce biased or unvetted information into AI systems, whether for training or in retrieval-augmented or agentic systems. This visibility can also highlight opportunities to leverage data across departments while maintaining appropriate protections for that data. The outputs of this task should be documented as set out in Implementation 7.1.2: Maintain a data inventory. References: >Candidates - suggestions welcome NIST AI 100-2e2025 (contextualizing data supply-chain integrity controls against malicious training data poisoning or telemetry manipulation).	7.2.1: Implement data quality monitoring Appropriately knowledgeable and resourced personnel should certify that organizational data to be used in an AI system, such as to train a model or to enable retrieval-augmented or database functionality, is appropriate for the task.
		7.2.2: Verify data provenance Tools such as cryptographic hashing and data lineage tools should be used to maintain an immutable audit trail for tracing critical data from source to final AI system output.
		7.2.3: Assess the conditions under which source data is created Extend provenance validation upstream of ingestion to the point of capture. Data quality certification performed under Implementation 7.2.1: Implement data quality monitoring can only assess data that successfully arrived; it cannot reveal records that were degraded, overwritten, or never transferred during collection. Document the field conditions, tooling, and manual steps involved in creating source data, and identify where those conditions systematically introduce loss or inconsistency. Potential failure modes include multi-stage transfer chains in which field personnel must move data from local device storage to intermediate media and then to a central or cloud repository, where an incomplete stage silently drops records; inadvertent overwriting of stored data during subsequent collection cycles; and loss or inconsistency introduced by migration between maintenance management systems (for example, CMMS platforms) or by limitations within them. Where a manual step cannot be removed, consider monitoring how completely it is performed, for example the proportion of expected records that reach the central repository. Where the capture environment is intermittently connected or resource-constrained, coordinate with Implementation 10.1.4: Asynchronous Telemetry and Inference Logging for Constrained Edges. Findings should be recorded against the relevant entries in the data inventory maintained under Implementation 7.1.2: Maintain a data inventory, and

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
		should inform training delivered under Implementation 9.1.3: Include data-originating roles in competency mapping. References: Research Kang, J. et al., "A data quality management framework for equipment failure risk estimation: Application to the oil and gas industry", <i>Engineering Applications of Artificial Intelligence</i> 136 (2024) 108834. A framework for deciding whether field data is of sufficient quality for an equipment failure risk estimation model, with a case study of electronic boards in downhole drilling tools. Section 3.4.2 briefly identifies root causes of poor field data, including manual transfer steps that field personnel skip, inadvertent overwriting, and loss or inconsistency from maintenance management system migrations, and suggests training and data collection KPIs as remedies.
	7.3: Manage Version Control and Logging for Internal AI Safety Mechanisms Establish rigorous configuration management and logging for the internal "wrappers," system prompts, and safety filters built around both internal and external AI systems. This task helps ensure that the mechanisms used to constrain AI behavior, including those that relate to other practices, are documented, traceable, reversible, auditable, and protected from unauthorized internal modification.	7.3.1: Maintain a registry of AI systems and changes This registry should uniquely identify the specific versions of the AI systems and models, versions of prompt templates, and the specific "if/then" safety logic used for output filtering. Document every change to these safety parameters in a centralized change log that identifies the person who authorized the change and the technical justification.
		7.3.2: Automate Policy-as-Code Translate safety and operational policies into automated, machine-readable logic rules embedded directly within the deployment workflow (often referred to as Policy-as-Code, utilizing tools like Open Policy Agent). Inference requests that possess mission impact should be logged with their full context, including version identifiers of safety filters and any triggered rules (e.g., "Blocked: Safety Boundary Violation"). All changes to underlying safety logic should require cryptographic signatures, appropriate approval oversight, and automated regression testing (informed by Practice 2: Define AI Robustness, Resilience, and Quality of Service expectations) to ensure updates do not inadvertently degrade system availability.
		7.3.3: Implement Logical Policy Locks for Adaptive and Online-Learning Models For AI systems utilizing online learning (including reinforcement learning), continuous local fine-tuning, dynamic prompt optimization, real-time retraining, or other forms of adaptation at runtime, implement an automated "Policy Lock" that programmatically freezes all changes to the system during operational windows. This may include model weights (the model's internal, learned parameters) as well as other online adaptation configuration parameters such as hyper-parameters (pre-defined configuration settings that control how the

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiqiprot@nist.gov.

Practice	Task	Implementation
		model learns or operates), and boundary logic (the programmatic code defining the safe operating limits the system should stay within, as established in Task 3.2: Implement independent guardrails ("safety wrappers") for AI outputs). Shifting a deployed model from a static runtime state into a tuning cycle should require a physical confirmation step or an out-of-band administrative governance mechanism. This prevents streaming production data or unvetted operational telemetry from silently altering the model's learned behavioral thresholds outside of formal configuration change control channels. References: >Candidates - suggestions welcome NIST SP 800-82r3 (Section 6.2.4.2 on Configuration Change Control)
	7.4: Define Authorization and Access Controls for AI Modifications Establish strict identity-based access controls for individuals authorized to modify internal AI models, systems, AI safety mechanisms, datasets, or configurations. This task implements and extends the principle of least privilege to ensure that only qualified personnel can alter the behavior of critical functions, reducing the risk of accidental or malicious internal interference. The controls in this Task determine who may act on the system. Whether a specific proposed action is permitted at the moment of execution is a separate question, addressed in Task 3.2: Implement independent guardrails ("safety wrappers") for AI outputs and Implementation 5.2.2: Action-level, context-aware authorization policies.	7.4.1: Define and implement requirements for approvals and logging of updates and changes to AI systems Approvals and logging are particularly important for changes to models, knowledge bases, and guardrails, especially for applications operating in a reduced oversight mode, or where automation bias is a known risk and thus where changes in behavior may not be immediately noticed. Record for each change what was altered, who approved it, and the evidence the approval rested on, so that a later potential investigation can reconstruct why the change was judged safe. Where a change alters model behavior rather than configuration alone, treat it as a trigger for re-evaluation under Implementation 2.3.4: Recurrent Risk Evaluations, the same treatment a disclosed vendor update receives for an externally sourced component (Implementation 6.2.2: Track vendor updates and third-party entity changes through change management process). An internal change reaching production unreviewed is the internally sourced equivalent of a silent vendor update, and would otherwise be caught, if at all, only by Task 3.4: Monitor for anomalous AI behavior.
		7.4.2: Implement regular "integrity checks" for systems that interface with external AI services These should verify that external AI systems and services have not been unexpectedly altered. This may incorporate TEVV protocols such as those from Task 2.3: Establish protocols for and regularly perform systematic and achievable Testing, Evaluation, Validation, and Verification (TEVV).
	7.5: Conduct Impact Assessments and Risk Management for AI System and Model Updates Establish procedures for and perform structured risk and performance assessment before deploying any internal updates to AI systems, such as model prompts,	7.5.1: Perform pre-update validation and re-calibration Validation and re-calibration should be performed before deploying any updates to models, system prompts, databases, and other components of AI systems that affect performance and safety. This should be informed by Practice 1: Establish requirements for success and Practice 2: Define AI Robustness, Resilience, and Quality of Service expectations.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	configuration changes, data inputs, or safety wrappers. Where increases in risk are identified, if the deployment proceeds then mitigating controls should be identified and implemented. This task verifies that "minor" internal adjustments do not unintentionally degrade overall system resilience or violate established functional safety benchmarks and requirements (see Practice 2: Define AI Robustness, Resilience, and Quality of Service expectations), be it through unintentional side effects of new behaviors or "catastrophic forgetting" (AI losing previously learned correct behavior after update or retraining) of previous good behavior. This task also applies where a change in operating context alters rules that are encoded in the AI system, such as in its prompts, retrieval corpus, or guardrails, even though nothing in the AI system itself has changed (see Implementation 1.1.3: Establish triggers for re-validating requirements on change of operating context).	Changes to performance should be documented and, where necessary, mitigating controls should be put in place prior to deployment. For example, a new model for an AI system that summarizes and prioritizes equipment condition reports for maintenance scheduling might have improved accuracy overall. Pre-update validation might reveal an unacceptably higher false negative rate for specific types of equipment that could not be addressed by re-calibrating thresholds. Mitigating controls can then be put in place, such as having the AI system fall back onto the previous model for reports from these types of equipment. 7.5.2: Perform automated "champion-challenger" and drift assessment This should be done by concurrently running existing production AI systems ("champion") alongside the prospective updated AI system ("challenger") in a "shadow mode" to determine the differences in behavior. The "challenger" system should demonstrate appropriate improvements in performance, as measured in Practice 1: Establish requirements for success and Practice 2: Define AI Robustness, Resilience, and Quality of Service expectations, utilizing evaluation metrics that align with Task 1.3: Implement evaluation and test plans, including TEVV, across the AI lifecycle, and mitigating controls established, prior to switch-over to the new system. This process also supports Practice 9: Provide calibrated, needs-based AI risk management training in training those interacting with the system, should this be required by any change in the behavior of the new system. 7.5.3: Integrate Privacy Impact Assessments (PIA) into Update Cycles Conduct a PIA for all significant model or system updates to identify risks related to data minimization, re-identification, and inference. Ensure that updates do not bypass existing privacy controls. References: >Candidates - suggestions welcome NIST Privacy Framework NIST SP 800-53 Rev 5: Control RA-8, Privacy Impact Assessments, which applies where the AI system processes personally identifiable information; see also the Personally Identifiable Information Processing and Transparency (PT) family. 7.5.4: Audit Interoperability for Hardware or Data Substrate Substitution

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
		Establish a change-management trigger within the internal supply chain for when physical operational components or software data feeds (e.g., valves, pumps, switches, or sensors, or API schemas, electronic health record modules, or transaction journals) are replaced with equivalents from a different vendor or manufacturer. Even if the replacement part complies perfectly with existing engineering specifications, the internal supply chain process should mandate a regression test of any governing AI systems to ensure the vendor swap does not invalidate undocumented physical dependencies embedded within the AI system's learned model as discussed in Task 2.5: Verify and Ensure Policy Robustness Against Component, Hardware, and Data Schema Variance. If mandating full regression testing for every replacement-in-kind substitution is not feasible given the volume of routine component swaps in normal maintenance, organizations can consider the following guidance for action: • If the substituted component has no plausible link to the AI system, such as an unrelated office HVAC sensor, standard engineering sign-off is sufficient. If the component sits within the AI system's operating envelope but outside any safety-critical path, such as a sensor on a non-critical secondary line, flag it for engineering review under Task 2.5: Verify and Ensure Policy Robustness Against Component, Hardware, and Data Schema Variance rather than a full regression test • If the component sits within a safety-critical control path, such as a valve actuator on a shutdown system or a sensor feeding a chemical batch temperature loop, require full regression testing before deployment.
	7.6: Establish processes for internal AI component deprecation and decommissioning Establish secure, structured protocols for the sunsetting, deprecation, and decommissioning of internally developed AI agents, systems, tools, models, training datasets, and associated software dependencies. This task helps ensure that when internal AI assets reach end-of-life, they are safely removed from production environments without breaking legacy system dependencies or leaving behind unmonitored attack surfaces. This Task covers the artifacts: the models, datasets, pipelines and tools themselves. The withdrawal of an operating AI system's authority, the preservation of what it knew, and the decisions recorded for everything that depended on it are in Practice 13: Establish procedures for retiring AI systems and withdrawing their authority.	7.6.1: Internal Dependency Mapping (Orphan System Prevention) Before decommissioning an internal AI agent, system, tool, model or API, organizations should conduct a comprehensive audit of the internal supply chain to identify all downstream IT, OT, or ICS systems that rely on its outputs. Establish strict "deprecation timelines" and notifications to ensure dependent systems are safely refactored or reverted to deterministic fallbacks before the model is turned off. The process of mapping dependencies is common to Implementation 3.5.2: Identify indirect shared infrastructure and collateral damage exposure. If that mapping has already been performed and kept current, much of the groundwork for decommissioning will already be in place. Implementation 13.3.3: Determine and record what happens to everything that depended on the system requires that a decision is recorded for each dependent identified here, including where that decision is to make no provision. 7.6.2: Secure Archiving and Destruction of Model and Other AI Artifacts Define destruction (cryptographically secure as appropriate) or secure archiving standards for retired models, training pipelines, and datasets. This

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
		prevents "zombie models" from being accidentally used, resurrected or exfiltrated. This may be particularly important for models that were found to behave inappropriately, do not comply with regulations, are found to contain illegal or otherwise undesirable content, or found to be susceptible to reverse engineering and leakage of confidential or proprietary information. 7.6.3: Legacy Logic Vulnerability Management For AI systems that cannot be immediately decommissioned due to legacy constraints (e.g., dependent systems that cannot be updated), establish an "Extended Isolation Protocol." This requires appropriate controls, such as redeployment onto isolated systems, additional monitoring, or stricter fail-over conditions, to contain risks associated with continuing to use an otherwise deprecated system.
8: Incorporate AI-aware incident analysis and response procedures Develop and implement protocols for responding to and investigating AI-related failures, addressing the unique challenges posed by probabilistic and non-deterministic system behaviors in operational environments. This practice provides the forensic clarity necessary to support regulatory oversight, safety investigations, and situational awareness during ongoing incident response, helping ensure that AI-driven incidents do not compromise organizational accountability or the reliable operation of CI. Cybersecurity-focused playbooks for incident response should be expanded to cover the broader AI Risk Surface discussed in Task 3.8: Scope and map the expanded AI Attack Surface and Risk Surface. Responders need to determine whether an anomaly was caused by an active exploit, or by non-adversarial risks across the trustworthiness characteristics, such as unannounced model drift, context window poisoning, dynamic multi-agent feedback loops, or plausible hallucinations in generated logic. This practice focuses on governance and resourcing to satisfy transparency and regulatory requirements. It dovetails with Practice 2: Define AI Robustness, Resilience, and Quality of Service expectations, which focuses on technical and functional requirements, and Practice 11: Maintain AI-aware mission continuity and disaster recovery planning, which focuses on maintaining operations.	8.1: Identify scenarios requiring deterministic root cause analysis and incident reconstruction Define the specific applications, operational thresholds, and safety-critical triggers that mandate a comprehensive, deterministic reconstruction of an AI-driven failure, for both post-event investigation as well as to provide situational awareness for immediate-term incident response. Incident response criteria should explicitly account for the full AI Risk Surface (Task 3.8: Scope and map the expanded AI Attack Surface and Risk Surface), helping ensure triage procedures can differentiate between adversarial cyber exploits and non-adversarial failures. This task helps ensure that applications requiring forensic root cause analysis are performed by AI systems that support such investigations. It also helps ensure that forensic resources are prioritized for high-impact events and that the organization meets the evidentiary standards required for regulatory and safety oversight.	8.1.1: Evaluate AI applications Evaluate AI applications to identify the extent of root cause analysis required to satisfy risk management and regulatory requirements. This evaluation should explicitly screen for process paths where deterministic forensic reconstruction is a safety or operational requirement. Where a proposed AI system cannot satisfy these specific analytical demands, organizations should either substitute systems inherently capable of true root cause analysis, demonstrably close the gap via validated compensating controls, or implement deterministic boundaries to ensure execution hands over to manual or legacy systems capable of the required analysis. 8.1.2: Identify AI systems that may not satisfy root cause analysis requirements Identify specific AI system classes that carry inherent forensic gaps that cannot be fully closed by techniques like runtime telemetry. These include large language models with non-deterministic sampling, agentic systems with ephemeral context, and remote-hosted inference services without preserved telemetry. In addition, some architectures and systems rely on inherent operational randomness that may not be able to be meaningfully replayed. Post-hoc explainability tools such as those based on SHAP and LIME should not be treated as forensic proof of how or why an incident occurred. Such techniques test a system with altered inputs and infer, after the fact, one hypothesis for what likely drove the system's output, without consideration for the system's actual decision making process. Where such systems are identified, technical managers should cross-reference with Task 8.2: Identify additional controls that may be required in scenarios where deterministic root cause analysis is not possible to implement appropriate safety margins or alternative validation frameworks.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiqiprf@nist.gov.

Practice	Task	Implementation
Search Keywords: AI incident response, incident investigation, root-cause analysis (RCA), safety investigation, just culture, near-miss reporting, non-punitive disclosure, evidence preservation, chain of custody, multi-agent cascade reconstruction, forensic interpretability gap, post-hoc attribution limitations, attack vs. risk surface triage, AI incident response team (AIRT), regulatory notification, de-identified incident sharing, lessons learned, after-action review (AAR) Trustworthiness Characteristics: >None yet - suggestions welcome Related AI RMF subcategories include: >None yet - suggestions welcome References: >None yet - suggestions welcome		References: >Candidates - suggestions welcome Swidey, E. (2026). "Utilities must ask AI vendors these questions to meet critical infrastructure protection standards" Utility Dive. (Argues that vendor "explainability" features are post-hoc rationalisations rather than audit trails, and that auditors treat reconstructed explanations the way they treat backdated logs. Written for NERC CIP-015-1; transfers wherever forensic reconstruction is a regulatory obligation.) Cybersecurity and Infrastructure Security Agency (CISA) and International Partners (2025). "Principles for the Secure Integration of Artificial Intelligence in Operational Technology." CISA. (Emphasises the need for a true "why" and "how" decisions are made.) Haha, M. A. B., Bohli, A., Haddour, N., & Bouallegue, R. (2026). "A Systematic Review of Industrial IoT Anomaly Detection and the Forensic Interpretability Gap." MDPI Electronics. (Examining wastewater, manufacturing, and energy use cases, this review provides a global template for industrial operators by distinguishing model-centric post-hoc attributions from system-centric forensics, showing why standard correlational explainers mistake downstream symptoms for root causes.) Slack, D., Hilgard, S., Jia, E., Singh, S., & Lakkaraju, H. (2020). "Fooling LIME and SHAP: Adversarial Attacks on Post hoc Explanation Methods." AAAI/ACM Conference on AI, Ethics, and Society (AIES). (Addressing cybersecurity threat hunters and auditors across critical networks, this study proves that perturbation-based explainers can be fooled by adversarial "scaffolding" wrappers that detect synthetic inputs and fake clean explanations during active system tampering.) causalLens (2023). "Explainable AI (XAI) Doesn't Explain Enough." causalLens. (Details why correlational explainers fail to support high-risk operational decisions because they highlight superficial statistical associations rather than the causal dynamics of the system.) 8.1.3: Update existing incident response policies and playbooks Include documenting the state of AI systems at the time of the incident, such as information from Task 7.1: Maintain an Internal Registry of AI Deployments. 8.1.4: Conduct incident reconstruction drills Such drills should be conducted within digital twins or high fidelity simulators to ensure that the resulting root cause analysis process and outputs are both accurate and accurately understood by responding personnel. Regular drills also detect shifts in the capabilities of underlying systems to enable root cause analysis, particularly where AI functionality is provided by external parties. This is particularly important in applications where such analysis is required in

Practice	Task	Implementation
		real-time to inform ongoing, time-sensitive incident response activities.
		8.1.5: Multi-agent cascade reconstruction capabilities For deployments involving multiple cooperating or nested AI agents, establish logging and telemetry requirements that explicitly span agent boundaries. Telemetry should capture inter-agent communications, dynamic delegation chains, and context window handoffs. This tracking is necessary to trace how errors propagate through an ecosystem, helping ensure forensic investigators can accurately distinguish an originating system anomaly from downstream algorithmic amplification. References: >Candidates - suggestions welcome OWASP Top 10 for Agentic Applications (Version 2026) (particularly ASI06 (Memory and Context Poisoning) to govern context integrity across chained agent handoffs). MITRE ATLAS (utilizing the framework's multi-stage attack paths to model how localized agent failures or exploits cascade across adjacent automated systems).
		8.1.6: Incident Triage Across the Dual Attack/Risk Surface Incorporate explicit triage pathways in incident playbooks to systematically isolate whether an AI anomaly originated on the Attack Surface (e.g., unauthorized access, API key abuse, or malicious prompt injection) or within the non-adversarial Risk Surface (e.g., sensor schema variance, distribution drift, or multi-agent cascade failure). This helps ensure forensic resources are directed toward the true root cause rather than misclassifying systemic algorithmic errors as external cyber intrusions, or vice versa.
	8.2: Identify additional controls that may be required in scenarios where deterministic root cause analysis is not possible Establish formal risk-based protocols and alternative verification standards for scenarios where the non-deterministic nature of AI prevents a precise root-cause identification. This provides a governance framework for making informed, defensible decisions regarding initial system deployment and re-commissioning. Such systems should not be deployed in applications where forensic root cause analysis is required by regulation or safety obligation unless compensating controls demonstrably close the gap; otherwise, organizations should substitute systems inherently	8.2.1: Identify applications and situations for which root cause analysis requirements may be relaxed Relaxing these requirements should only be done where appropriate compensating risk management controls are in place. For example, a load-balancing optimization application might typically require forensic root-cause analysis for all actions. It may be acceptable to revise this so that it does not require forensic root-cause analysis for actions that differ by no more than a margin the organization defines and documents from a verified-safe (but sub-optimal) legacy system.
		8.2.2: Identify opaque systems and appropriate safety margins within which they will operate to acceptably minimize the likelihood of failures for which root-cause analysis cannot be performed. These margins may be relative to other systems, as per Implementation 8.2.1: Identify applications

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	capable of satisfying root cause analysis requirements.	and situations for which root cause analysis requirements may be relaxed. Beyond these safety margins, establish appropriate procedures for hand-off to deterministic or legacy systems, or for manual oversight.
	8.3: Designate roles for AI incident governance Formulate a cross-functional AI Incident Response Team (AIRT) that includes representatives from legal, technical, risk management, and communications. This task helps ensure that the high-level management of an incident is supported by a "digital chain of command" capable of making informed decisions regarding liability, public safety, and mission continuity.	8.3.1: Identify internal incident management points of contact for every AI system that can affect the organization's mission, and ensure that they are resourced and well-practiced to foresee, prepare for, and manage incidents relating to their AI system(s). This includes both internally hosted AI systems and purchased-as-a-service systems. Before an incident occurs, they maintain documentation of their system's mission-criticality, organizational impacts, fail-over options, and dependencies. During an incident, they lead evidence-based prioritization efforts to restore the most mission-critical functions first, while external resources are being brought online.
		8.3.2: Form a permanent AI incident governance team that includes appropriate organizational and leadership, such as the CISO, technical, and legal staff with expertise in AI, and operations management to oversee the recovery and recommissioning of AI systems following an incident.
	8.4: Define external reporting and regulatory disclosure protocols following AI incidents Establish formal procedures and relationships with external organizations for notifying sector-specific regulators and the public following an AI-related anomaly. This task helps ensure that the organization meets its legal and transparency obligations, helping to maintain community trust and contribute to broader sector-wide threat intelligence.	8.4.1: Integrate AI-specific triggers into existing incident disclosure and reporting protocols Add specific triggers to the organization's existing incident reporting protocols that call out AI-driven causes, such as model drift or automated decision error, helping ensure these events are captured as completely as a traditional cybersecurity incident would be, addressing the kind of incomplete disclosure seen in past autonomous vehicle reporting failures. References: >None yet - suggestions welcome
		8.4.2: Establish automated notification and detailed impact disclosure for sector-specific authorities Where regulatory timelines require rapid notification, automate the initial alert to relevant sector authorities based on the triggers defined in Implementation 8.4.1: Integrate AI-specific triggers into existing incident disclosure and reporting protocols , followed by a more detailed impact disclosure prepared by the incident response team. References:

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
		>None yet - suggestions welcome
	8.5: Pre-arrange specialized resources for investigating and recovering from AI incidents Ensure that the organization has at least pre-identified, and ideally pre-arranged, access to the specialized personnel and budgetary resources needed for complex investigations, such as third-party AI forensic auditors or specialized legal counsel. The market for third-party AI forensic auditors is currently nascent. Interim approaches include developing internal capability through targeted training, establishing sector-level mutual aid via ISACs and Sector Coordinating Councils, and forming partnerships with academic centers conducting AI security and forensics research. This task addresses potential internal skill gaps and helps ensure that the investigation of and recovery from non-deterministic AI failures is adequately funded and supported.	8.5.1: Identify third-party AI forensic and legal experts for contingency access Identify and pre-qualify external AI forensic specialists and legal counsel experienced in AI-related incidents before one occurs, since this market is still nascent and locating qualified help during an active incident wastes critical response time. References: >None yet - suggestions welcome
		8.5.2: Establish formal retainer-style relationships with specialized AI incident responders and auditors Where budget allows, convert the contacts identified in Implementation 8.5.1: Identify third-party AI forensic and legal experts for contingency access into formal retainer agreements, guaranteeing priority access to specialized responders rather than competing for their availability during a live incident. References: >None yet - suggestions welcome
	8.6: Establish non-punitive reporting for AI-related near-misses Establish channels through which personnel can report AI-attributable near-misses, degradation, and anomalous behavior without bearing personal or organizational cost for the disclosure. Where the recipient of a report needs to be independent of the function responsible for the deployment, that channel may sit outside the organization; see Implementation 8.6.2: Protect reporter identity through an independent reporting route . References: The Shared AI Findings Exchange (SAFE) Working Group was published by the Open Secure AI Alliance and is a proposed non-regulatory framework for sharing AI incidents and near-misses across organizations, with specific notification timelines.	8.6.1: Separate benefit-claiming from risk-reporting Identify, for each AI deployment, which organizational function claims its operational or efficiency benefit, and ensure that function is not the sole route through which risks and degradation associated with that deployment are escalated. 8.6.2: Protect reporter identity through an independent reporting route Provide a reporting route that does not require the reporter to disclose their identity to the function responsible for the deployment. Where internal anonymity is impractical, or where the deployment function has influence over the reporter's role, work or standing, route reporting to a recipient outside the organization, consistent with the sector-level pooling approach already described in Task 8.5: Pre-arrange specialized resources for investigating and recovering from AI incidents . 8.6.3: Ensure supplier terms do not penalize degradation disclosure Review procurement terms and service-level agreements to confirm they do not create financial or contractual disincentives for vendors to disclose model degradation, behavioral change, or known limitations. This complements the

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
		disclosure requirements in Implementation 6.1.1: Add AI disclosure to existing procurement policies and the hazard reachability attestations in Implementation 6.1.5: Operational AI Hazard Reachability Disclosures, both of which currently rely on vendor self-report. 8.6.4: Share de-identified incident records for collective defense Where reports captured under Implementation 8.6.2: Protect reporter identity through an independent reporting route reveal failure modes with cross-organizational relevance, contribute a de-identified version to a trusted sharing community so peer operators can learn from a failure mode before it recurs elsewhere. This differs in purpose from the mandatory regulatory disclosure in Task 8.4: Define external reporting and regulatory disclosure protocols following AI incidents: sharing here is voluntary, structural knowledge transfer intended to raise collective resilience, and it draws on the reporting channel established in Implementation 8.6.2: Protect reporter identity through an independent reporting route without replacing it. Specify a minimum useful shared record (the AI system's role and consequence class, the failure mode, contributing factors, how it was detected, and which control did or did not hold) and a de-identification standard that strips the reporting organization's identity, proprietary model internals, and customer or safety-sensitive data while preserving the pattern that makes the report useful to peers. Because this record derives from information captured under Implementation 8.6.2: Protect reporter identity through an independent reporting route, its de-identification standard should be at least as protective of the original reporter as the originating channel that produced it. Route sharing through a trusted intermediary rather than new bilateral arrangements, such as a sector ISAC or Sector Coordinating Council where one exists, or a cross-sector AI incident clearinghouse where none exists. Define how the organization reciprocally ingests peer reports back into its own MAP and MEASURE activity, for example, updating guardrails or drift thresholds in response to a failure mode others have shared. Note: Practice 10: Implement multi-tiered AI system logging and audit capabilities governs what the system records, which governs whether a person who observes something the system did not record has a viable route to say so. It is the input stage for this Implementation. Cross-organizational sharing depends on incidents having been reported within organizations first.
9: Provide calibrated, needs-based AI risk management training Establish a systematic program for AI risk management	9.1: Perform role-based AI risk competency mapping Identify specific AI-related knowledge and skills required for different organizational roles, from executive level to	9.1.1: Identify required AI literacy and risk awareness levels for existing operational roles For each operational role that interacts with, supervises, or can override an AI system, define the specific AI literacy and risk awareness that role requires,

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiqiprot@nist.gov.

Practice	Task	Implementation
training tailored to specific operational roles and decision-making responsibilities. This practice helps ensure that stakeholders across the organization possess the calibrated knowledge necessary to identify AI risks and maintain mission continuity. It also assists in preventing the safety and security gaps that arise from over- or under-trust of automated systems. Search Keywords: automation bias, automation complacency, calibrated trust, mental model calibration, AI literacy, human factors, role-based competency matrix, incident simulation training, simulator training, skill fade, skills degradation, manual proficiency, manual control retention, over-trust mitigation, under-trust mitigation, workforce readiness, reporting disincentive awareness Trustworthiness Characteristics: >None yet - suggestions welcome Related AI RMF subcategories include: >None yet - suggestions welcome References: >None yet - suggestions welcome	front-line operations. This task helps ensure that training is targeted to the specific risks encountered in each role and provides those responsible for mission continuity with relevant, actionable information and practice.	distinguishing between what a front-line operator needs to know and what an executive decision-maker needs to know. References: >None yet - suggestions welcome
		9.1.2: Develop a comprehensive AI risk competency matrix and personalized learning paths Turn the role requirements from Implementation 9.1.1: Identify required AI literacy and risk awareness levels for existing operational roles into a structured competency matrix mapping each role to specific training modules, and build individualized learning paths so personnel are trained on what their specific role requires rather than a one-size-fits-all curriculum. References: >None yet - suggestions welcome
	9.2: Deliver specialized training on human-AI interaction and automation bias Provide operational personnel with the skills to recognize and mitigate “automation bias”, the tendency to over-trust automated outputs, and other psychological factors that lead to miscalibrated over or under trust. This task reduces the risk of human error during AI-driven anomalies and helps ensure that manual overrides remain an effective and timely safety-net for critical infrastructure functions. Training programs should explicitly cultivate accurate	9.1.3: Include data-originating roles in competency mapping Include personnel who create or record source data: field engineers, maintenance technicians, and operators completing work orders or condition reports in the role-based mapping performed under Task 9.1: Perform role-based AI risk competency mapping, even where those roles do not directly use or supervise an AI system. Training should cover which specific fields are consumed by downstream AI systems and analytics, what makes an individual entry usable or unusable for that purpose (for example, free text where a coded value is expected, blank fields silently treated as a default, or entries reconstructed from memory after the fact), the operational impact of a degraded record on the teams and systems that depend on it, and the correct handling of any manual transfer or synchronization step required to preserve the data. Where data capture depends on such a step, it should be treated as part of the task rather than as an administrative afterthought. 9.2.1: Include role-specific training on “AI failure modes” This training should be incorporated into standard regular (e.g., annual) technical or cybersecurity training. It should include identifying applications and situations in which personnel in that role may use, interact with, or supervise AI systems; the potential mission impact of AI system failures; situations in which AI systems should be overridden; the procedure for safely doing so; how to obtain the necessary situational awareness; and communication, reporting, and documentation requirements. Training should also address how operating conditions that have implications for human cognitive fatigue (such as extended shift lengths, remote or isolated duty stations, and non-native-language communication) can reduce an individual's capacity to catch an AI-generated error. This includes both OT

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	mental models of AI behavior across all operational roles, from grid dispatchers and plant operators to clinicians, fraud analysts, and network engineers. Personnel should be trained not only on how the AI functions during ideal conditions, but on its known operational limitations, edge-case failure modes, and boundary behaviors. Hands-on simulation drills (Implementation 9.2.2: Implement realistic incident simulation training) should periodically expose personnel to ambiguous, out-of-distribution, or low-confidence AI outputs, building tactical muscle memory for evaluating uncertainty, performing spot-check investigations, and executing timely overrides under realistic time pressure. Training should also address the effect of explanation and rationale features on reliance, so that personnel do not treat a plausible rationale as evidence that a recommendation is correct (see Implementation 4.6.1: Design rationale displays that give personnel something to check).	and IT applications, such as those from a general-purpose assistant summarizing or drafting operationally relevant material. Role-specific guidance should be provided for compensating for these conditions. This implementation mitigates hazard risk of an operator accepting an incorrect AI recommendation without independent verification, because repeated correct outputs have conditioned them to treat AI recommendations as authoritative. This is an emerging human factors failure mode specific to AI-driven automation and assistants, and as such is not yet well addressed by traditional security frameworks and guidance. It applies wherever personnel supervise, interact with, or can override AI systems in CI operational environments. Because established frameworks offer limited pre-built guidance, organizations should proactively extend existing TEVV protocols (Task 1.3: Implement evaluation and test plans, including TEVV, across the AI lifecycle) to probe for this specific failure mode, use qualified engineering and operational judgment to anticipate how automation bias might manifest in their particular application before an incident forces the question, and incorporate the results into ongoing training. References: >Candidates - suggestions welcome CISA, Principles for the Secure Integration of Artificial Intelligence in Operational Technology, Sections 1.3, 4.1 and 2.4. NERC, Artificial Intelligence and Machine Learning in Real-Time System Operations, Chapter 3. 9.2.2: Implement realistic incident simulation training Personnel who play a significant AI risk management role, such as those supervising or expected to take over from AI systems, should undertake such training. This may include the use of digital twins and realistic simulation environments, both to generate test scenarios and to determine the kinds of failures that are realistic. Particular care should be taken in situations where the existence or nature of an AI system failure or error may be hidden or non-obvious, particularly due to other errors in related AI systems. For example, hallucinations in an AI-based summarization or dashboard system may result in early reports of failure from upstream systems being downplayed, omitted, or presented in a confusing or misleading manner, particularly where those reports are very unusual. 9.2.3: Recognizing disincentives to reporting AI degradation

Practice	Task	Implementation
		Include, in role-specific training for personnel who supervise, rely on, or can override AI systems, explicit coverage of conditions under which an individual may be discouraged from reporting observed AI degradation, near-misses, or anomalous outputs. Implementation 9.2.1: Include role-specific training on "AI failure modes" addresses automation bias, in which personnel trust an AI output more than it warrants. This implementation addresses a related but distinct condition: personnel who correctly identify an AI failure but face organizational disincentives to report it. Examples include cases where the deployment is attributed as an efficiency gain to the reporting individual's own business unit; where reporting is likely to trigger scrutiny of a colleague's or supervisor's work; or where individual or team performance metrics are tied to the AI system's continued adoption, availability, or utilization rate. Training should ensure that personnel can recognize when they are in such a position, know which reporting channel is available to them and what protections attach to it, and understand that a near-miss involving no realized harm remains reportable. This is particularly relevant for degradation that accumulates gradually, where no single observation appears individually significant enough to justify the cost of reporting it. Training alone does not resolve this condition. Where an organization's reporting structure makes disclosure individually costly, personnel who have been trained to report will still under-report. This implementation should therefore be paired with the structural measures in Task 8.6: Establish non-punitive reporting for AI-related near-misses, and organizations should treat persistent under-reporting as evidence of a <i>structural</i> rather than a <i>training</i> deficiency.
	9.3: Establish audit-ready systems for verifying workforce readiness Create formal mechanisms to assess and document the effectiveness of AI risk training through structured assessments, tabletop simulations, and periodic drills. This task provides the verifiable evidence of "Workforce Readiness" required for regulatory compliance and helps ensure that personnel maintain the calibrated judgment necessary for high-stakes decision-making across the AI lifecycle.	9.3.1: Maintain logs of completed AI training and basic proficiency assessment scores Keep a centralized, auditable record of who has completed required AI risk training and their assessment scores, so the organization can demonstrate workforce readiness to regulators and identify gaps in coverage before an incident exposes them. References: >None yet - suggestions welcome
		9.3.2: Implement periodic "readiness drills" and validated skills certifications for critical roles For personnel in roles carrying the highest AI oversight responsibility, require periodic hands-on readiness drills and formal certification renewal, rather than relying on one-time training completion to demonstrate ongoing competence.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
		References: >None yet - suggestions welcome
10: Implement multi-tiered AI system logging and audit capabilities Establish a framework for the systematic capture and preservation of operational telemetry across the AI lifecycle to ensure decision-making logic remains transparent and verifiable. This practice establishes the evidentiary foundation required to audit actions across the entire AI Risk Surface (Task 3.8: Scope and map the expanded AI Attack Surface and Risk Surface). While traditional logging captures network perimeter events to monitor the Attack Surface, AI-aware logging captures decision-level context, including prompts, model parameters, context window states, and guardrail interactions, necessary to reconstruct non-deterministic operational failures. This practice supports the development of audit-ready systems that support forensic investigations and regulatory compliance, providing the foundational data required to maintain organizational accountability for automated actions in critical infrastructure. Search Keywords: decision-level logging, audit trail, data historian, runtime telemetry, edge telemetry, observability, inference receipt, immutable audit log, tamper-evident storage, prompt history tracking, log partitioning, metadata retention, model drift auditing, post-hoc explanation gap, chain of custody, evidentiary record Trustworthiness Characteristics: >None yet - suggestions welcome Related AI RMF subcategories include: >None yet - suggestions welcome References: >Candidates - suggestions welcome	10.1: Define decision-level logging and metadata retention policies Specify the AI systems and applications for which information, including system inputs, outputs, system prompts, and version-specific metadata, will be captured to ensure automated actions are deterministically reconstructable or statistically reproducible, and overall performance is continuously monitored. Logging policies should extend beyond traditional network event logs to capture telemetry across the entire AI Risk Surface (Task 3.8: Scope and map the expanded AI Attack Surface and Risk Surface), helping ensure forensic investigators can evaluate safety violations, explainability gaps, and accuracy degradation across the asset lifecycle. This task establishes the essential evidentiary foundation for transparency, helping ensure the organization possesses the necessary runtime context to perform the forensic root-cause analysis required by Practice 8: Incorporate AI-aware incident analysis and response procedures , support the success metrics of Practice 1: Establish requirements for success , and verify the bounds described in Practice 2: Define AI Robustness, Resilience, and Quality of Service expectations .	10.1.1: Identify AI systems that may take or directly influence mission-critical actions Ensure that they are appropriately inventoried (Implementation 7.1.1: Create and maintain a "Master AI Asset List") and that logs of inputs, outputs, and other data to reconstruct their decisions are stored in accordance with data retention and regulatory requirements. Where this information is already logged (e.g., by other OT/ICS systems) ensure that appropriate metadata is also logged and retention policies synchronized to ensure that this information can be merged after-the-fact. 10.1.2: Immutable Runtime Telemetry and Artifact Tracking Capture immutable runtime telemetry at an appropriate level of abstraction. For generated execution artifacts (such as code, Programmable Logic Controller (PLC) logic, configurations, or automated procedures), logs should uniquely link the output to the specific model version and prompt context. For AI systems providing operational decision support or diagnostics from structured data, runtime telemetry should capture an 'inference receipt', logging the specific data elements selected, active threshold criteria, and versioned configuration parameters that generated the output, alongside any execution artifacts. Where the AI system applies encoded rules or a self-interpretable model, the receipt can also record the rules or branches that were applied, which provides the trace displayed under Implementation 4.6.3: Display execution traces from symbolic, hybrid, and self-interpretable components . This provides the technical evidence necessary to validate static governance records during audits or post-incident reviews. Statistical hypotheses generated after the fact by post-hoc evaluation tools (such as LIME or SHAP) should not be relied on as a substitute for true decision-level logs. See Implementation 8.1.2: Identify AI systems that may not satisfy root cause analysis requirements for further details.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
OMB M-26-14 Ensuring Effective and Efficient Agency Logging and Network Visibility to Defend Against Evolving Cyber Threats		10.1.3: Forensic Integrity and Privacy-Preserving Log Partitioning Incorporate automated data-masking, encryption, and sanitization boundaries to ensure log collection does not inadvertently retain protected privacy data within open, day-to-day operational repositories. Where a structural conflict exists, organizations should explicitly define which data fields are essential to root-cause reconstruction (Practice 8: Incorporate AI-aware incident analysis and response procedures) and restrict masking only to non-essential elements to preserve actionable incident utility. For high-consequence applications processing sensitive person-centric data, such as healthcare clinical support decisions or financial transaction journals, the "immutable" tracking guidance of Task 10.2: Establish data integrity and tamper-evidence controls for AI telemetry and logging should be achieved by routing the raw, unredacted text and prompt history (the exact model inputs and outputs) directly into highly secured, tamper-evident storage environments that are logically separated from routine operational visibility. This helps ensure strict compliance with data privacy boundaries without compromising the availability or validity of the audit trail.
		10.1.4: Asynchronous Telemetry and Inference Logging for Constrained Edges For bandwidth-constrained, remote, or legacy edge environments where continuous, high-volume raw transfer is unfeasible, satisfy the immutable tracking mandate via edge-side log compression or secure local storage paired with delayed, off-peak batch telemetry transfers to the central log management infrastructure, or high-level metadata reviews.
	10.2: Establish data integrity and tamper-evidence controls for AI telemetry and logging Implement appropriate access controls and security protocols to ensure the immutability and reliability of captured AI system logs.	10.2.1: Ensure that logs are stored in an immutable manner If existing logging facilities are being used, ensure that they can handle the potential additional bandwidth and storage capacity requirements of AI systems without interfering with other logging activities. For example, it is necessary to ensure that AI logging bandwidth does not

Practice	Task	Implementation
	This task protects the "digital chain of custody," helping prevent unauthorized modification of operational records and helping ensure that audit data remains a trustworthy source of truth for regulatory oversight and liability management.	"flood out" logging from other devices, such as edge devices, and that the additional storage requirements do not result in logs being deleted earlier than is required. See Implementation 10.1.4: Asynchronous Telemetry and Inference Logging for Constrained Edges for bandwidth-constrained, remote, or legacy edge environments where this is not feasible.
	10.3: Implement systematic audit review and performance trend analysis Define formal procedures for the periodic review of AI system logs to identify model drift, emerging biases, or performance anomalies. This task transforms raw telemetry into actionable oversight, allowing technical management to detect degrading model reliability or "silent" failures before they escalate into mission-critical incidents or cause quality of service issues.	10.3.1: Conduct periodic manual reviews of AI logs for performance issues or drift Assign a defined cadence for qualified personnel to manually review AI system logs captured under Task 10.1: Define decision-level logging and metadata retention policies, looking specifically for signs of performance degradation or drift that automated monitoring may not yet be tuned to catch. References: >None yet - suggestions welcome
		10.3.2: Implement automated trend analysis and dashboarding for continuous audit oversight Build automated dashboards that surface performance trends from the logs over time, reducing reliance on manual review alone and giving technical managers continuous visibility into slow-developing issues between formal audit cycles. References: >None yet - suggestions welcome
11: Maintain AI-aware mission continuity and disaster recovery planning Establish a strategic framework for mission continuity to manage the immediate term alternative operating modes, and the longer-term recovery and restoration of essential functions following a significant AI failure. This practice highlights the need to pre-allocate recovery resources and deliberately prioritize service restoration to ensure organizational resilience. This practice focuses on the "Plan B" when an incident occurs. It dovetails with Practice 4: Define procedures for emergency avoidance override, recovery, and situation awareness, which focuses on technical aspects that	11.1: Identify and prioritize AI-dependent essential functions Catalog all infrastructure services that rely on AI components and rank them based on their impact on mission continuity and public safety. This task helps ensure that "Restoration Priorities" are established as a matter of policy, directing limited recovery resources toward the most critical life-safety and service-delivery functions first. It also prioritizes the allocation of resources to maintain non-AI backup systems for critical functions.	11.1.1: Rank operational processes based on the impact of AI failure or unavailability Score each AI-dependent process by the severity of consequence if the AI component became unavailable, from life-safety and service-continuity impacts down to minor administrative inconvenience, and use this ranking to direct recovery resources during an actual outage. This gives the organization a documented basis for deciding, in the moment, which system gets restored first. References: >None yet - suggestions welcome 11.1.2: Conduct comprehensive AI dependency mapping across all

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
support this practice, and Practice 8: Incorporate AI-aware incident analysis and response procedures, which focuses on governance obligations. Search Keywords: mission continuity, business continuity planning (BCP), disaster recovery, recovery time objective (RTO), manual fallback playbook, fail-to-manual, manual mode, degraded mode, cold start mitigation, isolated standby infrastructure, restoration priority, tabletop exercise, return to service, shadow mode re-validation, graceful degradation, state-at-handoff display Trustworthiness Characteristics: >None yet - suggestions welcome Related AI RMF subcategories include: >None yet - suggestions welcome References: >None yet - suggestions welcome		sector-critical functions Extend the ranking in Implementation 11.1.1: Rank operational processes based on the impact of AI failure or unavailability into a full map of which sector-critical functions rely on which AI components, directly or indirectly, so that a single AI failure's downstream reach is understood before an incident forces the question. References: >None yet - suggestions welcome
	11.2: Define manual and alternative operating procedures for long-term mission continuity Develop and document comprehensive "Manual Mode" instructions for running essential functions for extended periods without AI support. These playbooks should define orchestrated fallback pathways tailored to the system's operational timeline: - For critical systems requiring 24/7 availability, they should dictate the process for a safe transition to a legacy deterministic systems without interrupting availability. - For critical systems that do not need to be realtime (such as financial fraud queues, non-emergency triage systems, or administrative compliance tools), they should outline the protocols to safely pull the AI infrastructure offline while minimizing other risks, such as security and data corruption, and route accumulated tasks into structured manual workflows. This task complements those of Practice 4: Define procedures for emergency avoidance override, recovery, and situation awareness by providing the operational playbook for sustained, non-automated service delivery during a prolonged outage. References: >Candidates - suggestions welcome NIST SP 800-82r3 (Section 6.2.4.5 on Response and Recovery Plans, featuring "graceful degradation" and the need to safely accumulate backlogs)	11.2.1: Document basic manual fallback procedures for AI-dependent control points Write down the specific manual steps operators would take to keep a process running if its AI component became unavailable, at a level of detail someone unfamiliar with day-to-day operation of that specific system could still follow under pressure. References: >None yet - suggestions welcome
		11.2.2: Develop a validated "Safe Operating Mode" that runs independently of AI infrastructure Beyond documenting manual steps, build and test a defined operating mode that does not depend on the AI system at all, confirming it can sustain essential function, even at reduced capacity, for as long as a realistic outage might last. References: >None yet - suggestions welcome
		11.2.3: Human Factors and Cognitive Transition Protocols for Control Handoffs Establish standardized interface and procedural protocols for transitioning operational authority from automated, agentic, or advisory AI systems to manual human control during emergencies, system outages, or recovery scenarios. To prevent "cold start" cognitive shock, where personnel taking over from an AI system lack immediate context regarding current system state, such as accumulated transaction backlogs, clinical patient trends, or recent automated decisions, consider the following in handover protocols: Generate a State-at-Handoff Summary Display: Automatically render a concise "State-at-Handoff" screen summarizing recent AI actions, active

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
		system trends, accumulated task queues, unacknowledged alerts, and open physical or policy constraints. Enforce Bounded Handoff Pacing: Where execution time constants permit (Task 4.5: Define operational regimes for human-on-the-loop and human-out-of-the-loop operation), provide a structured step-through sequence that requires personnel to review and explicitly acknowledge current operational states (e.g., active setpoints, pending financial approvals, or clinical triage statuses) before manual control fully engages. Support Incremental De-escalation: Allow personnel to assume manual control over specific sub-systems, transaction queues, or decision branches while leaving adjacent automated safety or policy interlocks active, avoiding unnecessary "all-or-nothing" operational disruptions where feasible.
		11.2.4: Unplanned Shutdown and Controlled Isolation Protocols Establish documented, practiced protocols for executing controlled, rapid shutdowns of AI-dependent operational processes when automated or manual safety boundaries are intersected but where there are insufficient resources or time to continue operations on fallback legacy or manual systems. This prevents secondary process hazards (such as thermal or pressure excursions) during abrupt operational halts.
	11.3: Pre-allocate operational resources for alternative service delivery Ensure the availability and maintenance of physical tools, trained standby personnel, and budgetary reserves required to perform fail-over to non-AI backup systems, which may be less efficient and require additional resources and oversight. While Task 8.5: Pre-arrange specialized resources for investigating and recovering from AI incidents secures investigation experts, this task secures the operational resources needed to keep the water flowing or the power on while the AI is offline.	11.3.1: Identify standby personnel and physical tools required for manual operations Name specific trained personnel and the physical tools or spare equipment needed to execute the manual fallback procedures from Task 11.2: Define manual and alternative operating procedures for long-term mission continuity, and confirm their availability on a defined schedule rather than assuming they will be reachable when an incident occurs. References: >None yet - suggestions welcome
		11.3.2: Maintain Isolated Standby Infrastructure and Allocated Reserves Set aside dedicated backup infrastructure and budget reserves for fail-over to non-AI systems, and periodically confirm this infrastructure still functions and remains isolated from the primary AI system's failure modes. References: >None yet - suggestions welcome
	11.4: Establish system integrity re-validation and re-commissioning protocols	11.4.1: Define a checklist for validating system safety before re-engaging AI control

Practice	Task	Implementation
	Define the technical benchmarks and safety tests a system should pass before it is allowed to transition from manual mode back to automated operations. Re-validation testing pathways should explicitly reference and execute the TEVV protocols established in Task 1.3: Implement evaluation and test plans, including TEVV across the AI lifecycle. This helps ensure that "turning the AI back on" does not introduce new cascading risks and is supported by verifiable, auditable evidence of system health.	Create a specific, itemized checklist to be completed and signed off before returning a process from manual mode back to AI control, confirming the root cause of the original outage has been addressed and the system behaves as expected against known baselines. References: >None yet - suggestions welcome
		11.4.2: Implement "Shadow Mode" validation and essential safety-interlock checks for AI re-commissioning Before fully returning control to the AI system, run it in shadow mode alongside the manual process to compare outputs and confirm safety interlocks respond correctly, catching problems before the AI system resumes live authority. References: >None yet - suggestions welcome
	11.5: Execute periodic mission continuity simulations and stress tests Conduct regular "fail-to-manual" exercises to verify that alternative operating procedures are effective and that personnel are capable of maintaining the mission under stress. This provides the audit-ready evidence of organizational preparedness required for regulatory oversight and identifies gaps in the continuity framework.	11.5.1: Conduct "fail-to-manual" tabletop exercises for key personnel Run at least annual (or another frequency aligned with organizational failover testing policies) tabletop exercises walking key personnel through a simulated AI outage, testing whether the procedures in Task 11.2: Define manual and alternative operating procedures for long-term mission continuity and the standby resources in Task 11.3: Pre-allocate operational resources for alternative service delivery actually work as documented, and updating the plans based on what the exercise reveals. References: >None yet - suggestions welcome
	These exercises should be performed both during development, to ensure that resilience is "baked in," and when in operation, to ensure that resilience is maintained despite changes in the operating environment, task, and condition of the system.	11.5.2: Execute high-fidelity simulation drills involving total AI infrastructure loss and recovery Beyond tabletop exercises, periodically run a full simulation of total AI infrastructure loss using digital twins or dedicated test environments. Include at least one scenario where the underlying cause is not immediately apparent, to confirm personnel can maintain continuity while the nature of the failure, accidental or deliberate, is still being determined. References: >None yet - suggestions welcome

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
12: Independently verify AI-generated operational logic and artifacts across their lifecycle Establish rigorous validation and verification protocols for AI-generated artifacts, including code, configurations, and procedures, that direct or influence the execution of critical infrastructure operations. This practice helps ensure that machine-authored code, configurations, and procedures are scrutinized against formal specifications and tacit institutional knowledge, preventing the deployment of 'plausible but inaccurate' logic in high-consequence IT, OT, and ICS environments. Search Keywords: machine-authored code, AI-generated configurations, infrastructure as code (IaC), direct-execution logic, human-mediated logic, independent verification and validation (IV&V), four-eyes, peer review, subject matter expert (SME) review, static code analysis, sandbox verification, acceptance testing, plausible hallucination verification, tacit knowledge validation, artifact provenance, latent defect, known-good rollback Trustworthiness Characteristics: >None yet - suggestions welcome Related AI RMF subcategories include: >None yet - suggestions welcome References: >None yet - suggestions welcome	12.1: Establish Governance and Accountability for AI-Generated Execution Artifacts Define the policy framework and responsibility structures for the creation, classification, and authorization of AI-generated logic. This task helps ensure that every machine-authored artifact, from code to procedural summaries, is assigned a consequence based risk tier (see Implementation 3.1.3: Define acceptable risk thresholds and associated control responses) and a clear human owner responsible for its final approval and operational deployment. The general requirement to identify an accountable owner, and to establish that the organization can act on that accountability, is in Task 3.9: Assess and document organizational readiness for each AI-enabled capability.	12.1.1: Artifact Risk Classification Categorize AI-generated logic and outputs (artifacts) based primarily on consequence severity (see Implementation 3.1.3: Define acceptable risk thresholds and associated control responses). Proximity to execution and influence on human decisions should be used to determine the validation procedures. To ensure appropriate validation velocity, organizations should explicitly distinguish between 'Direct-Execution Logic' (which directly commands physical or digital assets like Programmable Logic Controller (PLC) code or system configurations, requiring automated validation gates) and 'Human-Mediated Logic' (which influences human choices like procedural summaries or diagnostic reports, relying on structured expert review workflows). Artifacts such as PLC code, Supervisory Control and Data Acquisition (SCADA) configurations or automated control parameters may carry the highest execution risk as they have close proximity to execution. For example: • AI-generated valve control logic is likely to be classified as a High Risk, Direct Execution artifact. • Artifacts such as procedure summaries, condition reports or operational recommendations carry risk in proportion to the consequence of human actions they may influence. ◦ AI-generated summary of a maintenance procedure should be classified as High Risk Human Mediated artifacts due to safety consequences if incorrect. ◦ A draft internal email summary of this same procedure that is subject to ongoing human brainstorming and refinement might be classified as Low Risk.
		12.1.2: Provenance and Traceability (Referencing Task 10.1: Define decision-level logging and metadata retention policies) Establish metadata requirements that uniquely link any generated code or procedure to the specific model version, prompt, and "inference context" used to create it. Validation leads should rely strictly on this hard configuration data for audit paths, rather than relying on post-hoc explanation tools which can mistake downstream symptoms for the root cause of an artifact error. See Implementation 8.1.2: Identify AI systems that may not satisfy root cause analysis requirements for further details.
		12.1.3: Authorization of Machine-Authored Logic Define which roles (e.g., Lead Engineer, Site Supervisor) are authorized to "promote" AI-generated logic from a draft state to a production-ready operational artifact. These roles should sit within the decision authority

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
		documented under Implementation 3.9.2: Define Decision Authority and Reassessment Triggers , rather than being defined only for this artifact class.
	12.2: Implement Multi-Layered Validation of Machine-Authored Logic Deploy a hybrid verification strategy that subjects AI-generated outputs to both deterministic automated testing and expert human scrutiny. By checking artifacts against formal specifications and tacit domain knowledge, this task helps ensure that machine-generated instructions remain within safe operational boundaries and are free from 'plausible hallucinations'. References: >Candidates - suggestions welcome NIST AI 600-1 (guiding validation frameworks to address safety, accuracy, and hidden tech-debt risks inherent to generative AI-authored logic and code).	12.2.1: Deterministic and Rule-Based Guardrails (Referencing Task 3.2: Implement independent guardrails ("safety wrappers") for AI outputs) Verify that all AI-generated executable artifacts (like network configurations or PLC logic) pass through non-AI, deterministic verifiers, such as static code analyzers or schema validators, to ensure they meet hard-coded safety constraints. Appropriate meta-safeguards should be in place if these non-AI, deterministic verifiers are, themselves, written with the assistance of AI.
		12.2.2: Subject Matter Expert (SME) Review of Procedures For non-executable but safety-critical artifacts (like procedural summaries), conduct a "red-team" review by SMEs to ensure no "plausible hallucinations" have introduced safety risks or omitted critical warnings (as discussed in Implementation 2.4.3: Technical Accuracy and "Plausible Hallucination" Audits).
		12.2.3: Validation against Tacit and Formal Requirements (Referencing Implementation 1.4.4: Requirements for AI-Generated Code, Configurations, Procedures, and Other Logic) Ensure the validation process explicitly checks the generated logic against both codified technical standards and the "unwritten" operational norms of the specific facility.
	12.3: Manage Operational Continuity and Resilience for Generated Artifacts Establish safeguards to protect system availability and safety throughout the lifecycle of AI-generated logic. This includes utilizing isolated testing environments, maintaining strict version control for machine-authored artifacts, and maintaining human-verified 'known-good' configurations for rapid rollback and recovery.	12.3.1: Isolated Execution Testing (Sandboxing) Where feasible, test AI-generated configurations or code in a digital twin or isolated simulation environment before deployment to production systems.
		12.3.2: Version Control and Rollback Procedures Maintain a strict version history of all AI-generated operational logic. Ensure that a "known-good" human-verified configuration or procedure is always available as a fallback in the event of an AI-generated logic failure.
		12.3.3: Monitoring for latent failures Establish monitoring for systems running on AI-generated configurations to detect "drift" or latent errors that may not be apparent during the initial validation phase.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
13: Establish procedures for retiring AI systems and withdrawing their authority Plan for the permanent removal of an AI capability from operation, including the withdrawal of its authority, the preservation of what it knew, and the transfer or deliberate abandonment of what depended on it. Retiring an AI system is not an extreme form of updating one. An update transfers trust from one version to the next and seeks continuity; retirement severs authority, removes a capability that other things may have come to rely on, and destroys operational knowledge that may exist nowhere else. Retirement may also be imposed rather than chosen, by a withdrawn vendor, a deprecated model, a failed dependency, or a regulatory decision, and it may have to be carried out on a system that can no longer be run. The preparation this Practice requires therefore belongs in the stages where the system still works, rather than at the point of retirement. (See Task 7.6: Establish processes for internal AI component deprecation and decommissioning for the deprecation, archiving and destruction of internally developed AI artifacts.) Where an AI system is returned to service after retirement, it is admitted as a new deployment subject to the requirements of Practice 1: Establish requirements for success, rather than resuming its former authority and identity. Search Keywords: decommissioning, retirement, end of life, EOL, sunset, offboarding, disposal, media sanitization, certificate of sanitization, data destruction, teardown, revocation, orphaned credentials, zombie agent, non-human identity offboarding, knowledge retention, successor system Main Trustworthiness Contributions: Secure: Contributes the removal of standing authority at the end of a system's life: credentials, triggers, registered interfaces and delegated authority withdrawn and confirmed withdrawn, so that a system recorded as retired cannot still act. It does not establish the identities and revocation mechanisms being exercised, which Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools establishes.	13.1: Prepare for retirement while the system is still running Establish, during design and operation, the records and capabilities that a future retirement will require. This includes knowing what would trigger retirement, maintaining a current account of what the system actually does rather than what it was specified to do, and retaining the ability to extract the operational knowledge it holds. These are continuing obligations rather than a closing task, because retirement can arrive without notice and can arrive after the system has stopped working, at which point none of them can be performed. Search Keywords: exit planning, design for decommissioning, retirement triggers, behavioral drift documentation, as-built documentation, knowledge extraction, data portability, vendor lock-in, vendor insolvency, model deprecation Main Trustworthiness Contributions: Accountable: Contributes the conditions under which retirement becomes required and the authority that decides, recorded before either is needed, so that an imposed retirement is executed against a prior decision rather than improvised. It does not establish the decision authority itself, which Implementation 3.9.2: Define Decision Authority and Reassessment Triggers establishes. Transparent: Contributes a maintained account of what the system does in operation, reconciled against what it was specified to do, so that the difference is known at the point the system is removed. It does not cover detecting the drift that produces the difference, which Implementation 2.3.4: Recurrent Risk Evaluations and Task 3.4: Monitor for anomalous AI behavior cover. Trustworthiness Effects to Consider: Privacy-Enhanced: Retaining an extractable account of what a system learned keeps material alive beyond the system that produced it, and that material may carry the properties of the data it was derived from. Practice 7: Manage internal AI supply chain and data provenance	13.1.1: Identify retirement triggers, including those outside the organization's control Record the conditions that would initiate retirement of each AI capability, and who holds the authority to decide, under Implementation 3.9.2: Define Decision Authority and Reassessment Triggers. Internal triggers include a sponsor decision, a policy change, or an incident. External triggers are the ones most easily overlooked: deprecation of a foundation model, withdrawal of a third-party interface, insolvency of a vendor, or a regulatory prohibition. An externally imposed trigger compresses the timeline and may remove the option of an orderly shutdown. References: >None yet - suggestions welcome 13.1.2: Maintain a current account of system behavior, not only its specification Maintain documentation of how the AI system behaves in operation, reconciled periodically against the behavior it was specified and accepted for. Behavior may diverge over time through adaptation, data drift, or changes in upstream systems, and the divergence is not always recorded. At retirement, the difference between the two determines what is actually being removed, and it cannot be reconstructed after the system stops running. References: >None yet - suggestions welcome 13.1.3: Retain the ability to extract operational knowledge before it is needed Establish and periodically exercise a means of recovering the operational knowledge an AI system has accumulated, in a form usable without the system itself. This may include thresholds, learned patterns, exception cases, and the conditions under which the system departs from its normal behavior. For systems whose behavior is derived rather than specified, this capability has to be built in and maintained; it cannot be added at the point of retirement. References: >Candidates - suggestions welcome Guidance NIST SP 800-88r2, Guidelines for Media Sanitization, from NIST. Section 4.3.1 makes the same argument for sanitization that this Implementation makes for knowledge: the need and the method should be

Practice	Task	Implementation
Accountable: Contributes a named decision and a record of what was removed, so that retirement is an authorized act with an owner rather than an administrative consequence of something else. It does not establish who holds that authority in the first place, which Task 3.9: Assess and document organizational readiness for each AI-enabled capability establishes. Transparent: Contributes a record of what the system had become and what its removal takes away, captured while the system can still be interrogated. It does not cover the routine operational logging that record draws on, which Practice 10: Implement multi-tiered AI system logging and audit capabilities covers. Trustworthiness Effects to Consider: Reliable: Removing a capability that other processes and people have adapted to degrades their performance whether or not the retirement itself is clean, and the effect is largest where the adaptation was informal and undocumented. Implementation 13.3.3: Determine and record what happens to everything that depended on the system requires the dependents to be identified and a decision recorded for each; Practice 11: Maintain AI-aware mission continuity and disaster recovery planning covers continuing to operate without the capability. Trustworthiness Tensions to Balance: Secure versus Transparent: Where the retired system held no sensitive data and performed no protective function, purging everything is the simpler and safer course. Where the same learned material is both the thing that must be purged for data protection and the thing needed to interpret past decisions or to brief a successor, the two requirements act directly against each other on one artifact. One resolution is to separate the artifact from what is derived from it, retaining thresholds, patterns and exception cases in a form that does not carry the underlying data; others include a documented adjudication before teardown, or retention under legal hold with access controls narrower than the system had. Safe versus Secure: Where every delegation can be confirmed revoked, completing the retirement and withdrawing all authority are the same act. Where a delegation cannot be confirmed, often because the failed dependency that forced the retirement is also the means of confirming it, refusing to complete leaves the retirement indefinitely open while treating it as complete leaves	governs the provenance and handling of that data, and any retention should be justified against a specific need. > To the Reviewer: > We are actively looking for examples of record retention guidelines and regulations that may require special handling for AI systems. Related AI RMF subcategories include: GOVERN 1.7 (on decommissioning and phasing out AI systems): This Task contributes the part of those procedures that cannot be performed at retirement time, establishing triggers, behavioral records and knowledge extraction as duties held while the system runs; it does not cover the withdrawal of authority itself. For that, see Task 13.2: Withdraw authority completely and confirm that it is withdrawn. MANAGE 4.1 (on post-deployment monitoring plans including decommissioning): This Task contributes the decommissioning preparation that a post-deployment plan should carry, including triggers originating outside the organization; it does not cover the monitoring activity itself. For that, see Task 3.4: Monitor for anomalous AI behavior.	established before the disposal phase, because the choice of what is used in the system determines what will be possible at the end of its life. 13.1.4: Establish what retirement the product itself supports Determine, for each acquired AI product or AI-enabled device, what its supplier provides for retiring it: whether configuration and operational data can be removed, whether ownership can be transferred without carrying that data with it, and whether the product can be rendered inoperable by logical or physical means. For embedded and field-deployed AI, this is a property of the product rather than a choice available to the operator, and it is settled at acquisition whether or not anyone asked. Where the supplier provides no such capability, record this as a constraint on retirement rather than discovering it at the point of retirement. Disclosure requirements for procurement are in Implementation 6.1.1: Add AI disclosure to existing procurement policies, and the offboarding process for a component that reaches end of life is in Implementation 6.2.3: Manage end-of-life transitions for externally sourced AI components. References: >Candidates - suggestions welcome Guidance NIST IR 8259r1. Foundational Cybersecurity Activities for IoT Product Manufacturers, from NIST. Section 4.3.5, Product Retirement Options, sets out what a manufacturer should communicate about retiring a product, and its questions are the ones an acquirer should be asking in return: whether ownership can be transferred without the user and configuration data going with it, and whether the device can be rendered inoperable, by logical means such as an application or by physical means on the device itself. It is written to manufacturers rather than to operators, which is what makes it useful here as the other side of the same conversation.
	13.2: Withdraw authority completely and confirm that it is withdrawn Remove every means by which a retired AI system can still act, and verify the removal rather than assuming it. This covers credentials and tokens, scheduled and event-driven triggers, authority delegated to other entities, and the compute resources that may still hold any of these. An AI system that retains an active trigger and a valid credential continues to act after it has been recorded as retired. Search Keywords:	13.2.1: Revoke credentials and disable triggers, and confirm the result Revoke the identities, credentials, tokens and keys held by the AI system, and disable the mechanisms that can invoke it, including scheduled tasks, event subscriptions, callbacks and registered interfaces. Confirm each revocation, not only the request, and retain the confirmation. Identity revocation is covered as a capability in Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools; what this Implementation adds is that retirement requires it to be exhaustive and evidenced. References: >Candidates - suggestions welcome

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
authority possibly live. One resolution is to complete on a recorded exception naming what could not be confirmed and what compensating control covers it, so that the residual authority is tracked rather than either ignored or blocking. Related AI RMF subcategories include: GOVERN 1.7 (on decommissioning and phasing out AI systems): This Practice contributes the procedures that subcategory asks for, covering the withdrawal of authority, the preservation of what the system knew, and a decision on what happens to everything that depended on it; it does not cover the decision to retire a system on performance grounds. For that, see Implementation 2.3.4: Recurrent Risk Evaluations for detecting the degradation and Implementation 3.9.2: Define Decision Authority and Reassessment Triggers for who decides. MANAGE 4.1 (on post-deployment monitoring plans including decommissioning): This Practice contributes the decommissioning element of a post-deployment plan, and requires that its preparation is treated as a continuing duty rather than a closing activity; it does not cover the monitoring that would detect the conditions leading to retirement. For that, see Task 3.4: Monitor for anomalous AI behavior. MANAGE 2.4 (on decommissioning or superseding AI systems): This Practice contributes the retirement path for a system that is being withdrawn permanently, including where the trigger is external; it does not cover disengaging a system that is behaving inconsistently with intended use while remaining in service. For that, see Practice 2: Define AI Robustness, Resilience, and Quality of Service expectations. References: >Candidates - suggestions welcome Guidance NIST SP 800-88r2, Guidelines for Media Sanitization, Revision 2, September 2025, from NIST. Section 4.3.1 states the principle this Practice is built on, that the need and methods for sanitization should be identified and developed before the disposal phase is reached rather than at it. Section 3.1 gives the Clear, Purge and Destroy method taxonomy, and its Appendix C	credential revocation, token purge, integration teardown, webhook deregistration, scheduled task removal, delegated authority, cascading revocation, orphaned container, residual access, teardown receipt Main Trustworthiness Contributions: Secure: Contributes the exhaustive and evidenced withdrawal of everything by which a retired system could act, extended through delegated authority and through the resources that may hold credentials independently of the identity being revoked. It does not establish the identities and revocation mechanisms being exercised, which Task 5.1: Establish identities and authentication for AI entities establishes. Accountable: Contributes a record of what was revoked, what was confirmed, and what could not be confirmed, so that residual authority after a retirement is a tracked item rather than an unknown. It does not cover the logging infrastructure that record relies on, which Practice 10: Implement multi-tiered AI system logging and audit capabilities covers. Trustworthiness Effects to Consider: Resilient: Withdrawing authority exhaustively and at once removes the option of a partial or staged retirement, so a dependency discovered afterwards cannot be served by briefly restoring access. Identifying dependents under Implementation 13.3.3: Determine and record what happens to everything that depended on the system before this point is what makes the irreversibility acceptable. Related AI RMF subcategories include: MANAGE 2.4 (on decommissioning or superseding AI systems): This Task contributes the mechanism by which a decommissioned system is actually prevented from acting, including authority it delegated to other entities; it does not cover the decision to decommission or the conditions that prompt it. For that, see Implementation 13.1.1: Identify retirement triggers, including those outside the organization's control. GOVERN 1.7 (on decommissioning and phasing out AI systems): This Task contributes the part of those	Guidance NIST SP 800-88r2, Guidelines for Media Sanitization, from NIST. Its Appendix C provides a sample Certificate of Sanitization, a record naming what was acted on, by what method, by whom, and how the result was verified. It is the established documented form of the confirmed and retained result this Implementation asks for, and transfers directly to credentials and triggers. Guidance Agentic Identity and Access Management, Workstream 4: Secure Design Patterns for Agentic Systems, from the Coalition for Secure AI. The Decommissioning subsection of Section 3.5 states the actions this Implementation requires: revoke the identity and invalidate tokens, securely erase private keys, purge or appropriately handle sensitive data consistent with data-protection obligations, and revoke downstream delegated rights. The paper's Appendix E supplies the corresponding record, an agent registry holding lifecycle state and an agent.decommissioned lifecycle event, which is where the confirmation is retained rather than in the teardown procedure itself. 13.2.2: Revoke authority delegated to other entities, and record what could not be confirmed Where the AI system could delegate authority or create subordinate agents, trace and revoke that authority through every level it reaches. Where a delegation cannot be confirmed revoked, this should be recorded and escalated rather than treated as either success or an indefinite block on completing the retirement. Under an externally imposed trigger the means of confirming revocation may itself have failed, which is precisely when an unresolvable check will occur. References: >Candidates - suggestions welcome Guidance Agentic Identity and Access Management, Workstream 4: Secure Design Patterns for Agentic Systems, from the Coalition for Secure AI. Section 3.5 requires that decommissioning revoke downstream delegated rights, and the paper's Appendix D describes the mechanism that makes this achievable at retirement: short-lived, tightly scoped delegation tokens, a centralized revocation service supporting near real-time invalidation, and runtime components subscribing to revocation events so that they stop accepting revoked tokens rather than waiting for expiry. The paper's Appendix E names delegation.revoked as a logged event, which is what allows a revocation to be shown rather than assumed. 13.2.3: Reclaim resources, not only permissions Identify and reclaim the compute and storage resources associated with the AI system, including containers, sandboxes, scratch storage and cached data. These are distinct from the permissions revoked above and are often

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
provides a Certificate of Sanitization form, which is the established documented form of a confirmed and evidenced teardown. Guidance NIST SP 800-82r3, Guide to Operational Technology (OT) Security, from NIST. Task M-7, System Disposal, places a disposal strategy in the OT risk management lifecycle. Its OT-specific consideration bears directly on retirement timing: planned obsolescence in IT components may not extend to OT components, which are often required to be sustained beyond the availability of the IT components they depend on. Standard ISO/IEC/IEEE 15288:2023, Systems and software engineering: system life cycle processes, published jointly by ISO, IEC and IEEE. Clause 6.4.14, the disposal process, is the systems-engineering counterpart of this Practice and is stated more strongly than the AI-specific sources: its first listed outcome is that disposal constraints are provided as inputs to requirements, architecture, design and implementation, making retirement a design input rather than a closing activity. It also holds that where a system is still useful, the disposal process manages its transition to a new life cycle rather than a continuation of the existing one, and that records of disposal actions and analysis are available. Guidance Agentic Identity and Access Management, Workstream 4: Secure Design Patterns for Agentic Systems, version 1.0, 20 March 2026, from the Coalition for Secure AI, an OASIS Open Project. Section 3.5 treats decommissioning as the closing phase of an agent's identity lifecycle rather than as a separate activity, and sets out what it requires. Its logging appendix bears on the tension above: the per-action log it specifies records the policy version in force at the time, so a decision record remains interpretable only while the policy it was taken under is also retained.	procedures that helps ensure phasing out does not itself increase risk, by treating unconfirmed revocation as a recorded exception rather than as either success or an indefinite block; it does not cover what is preserved before teardown. For that, see Task 13.3: Preserve what is needed and hand over what depended on the system. 13.3: Preserve what is needed and hand over what depended on the system Before an AI system is torn down, capture the evidence that will not survive it, and address what was relying on it. This includes volatile state that exists only while the system is running, the operational function the system was performing for others, and any protective function it was performing that would otherwise disappear without a corresponding record. Search Keywords: forensic preservation, volatile state, working memory, control handover, successor system, downstream dependents, deprecation notice, control regression, data migration, records retention schedule, legal hold Main Trustworthiness Contributions: Transparent: Contributes the capture of state that exists only while the system runs, before the teardown that destroys it, so that an incident-driven retirement does not also destroy the evidence of what prompted it. It does not cover the durable logging that survives teardown on its own, which Practice 10: Implement multi-tiered AI system logging and audit capabilities covers. Secure: Contributes the treatment of a retired detection or filtering capability as a change to controls as well as an asset disposal, so that a protective function is handed	missed because the retirement record is organized around authorizations. An orphaned execution environment may hold a mounted credential that survives the revocation of everything else. What happens to the model, training pipeline and datasets themselves is addressed in Implementation 7.6.2: Secure Archiving and Destruction of Model and Other AI Artifacts. References: >Candidates - suggestions welcome Guidance NIST SP 800-88r2, Guidelines for Media Sanitization, from NIST. Section 3.1 sets out the Clear, Purge and Destroy methods and the basis for choosing between them, which is the decision to be made for each storage resource associated with a retired AI system rather than one choice applied to all of them. 13.3.1: Capture volatile state before teardown Where retirement follows an incident or a suspected failure, capture working memory, in-flight state and intermediate reasoning artifacts before the execution environment is destroyed. Durable logs and stored records are addressed under Practice 10: Implement multi-tiered AI system logging and audit capabilities; this Implementation concerns the state that exists only while the system is running and that teardown destroys permanently. This step should precede teardown and resource reclamation, because those actions can make the state unrecoverable. References: >None yet - suggestions welcome 13.3.2: Treat the retirement of a protective AI capability as a change to controls Where an AI system performs a detection, monitoring, screening or filtering function, its retirement removes a control and should be processed as a control change as well as an asset disposal. Establish what the system was detecting, including behavior it had learned to detect that is not documented elsewhere, and what will perform that function afterward. A replacement that begins without this information starts without the accumulated basis of the one it replaces, and the resulting gap may not be visible from either system's records. References: >None yet - suggestions welcome

Practice	Task	Implementation
	over rather than silently discontinued. It draws on, but does not itself maintain, the account of system behavior kept under Implementation 13.1.2: Maintain a current account of system behavior, not only its specification. Trustworthiness Effects to Consider: Privacy-Enhanced: Preserving volatile state and learned material before teardown retains content that the retirement was in part intended to remove, and volatile state may contain material never intended to persist at all. Practice 7: Manage internal AI supply chain and data provenance governs how that material is then handled, and the tension is set out at Practice 13: Establish procedures for retiring AI systems and withdrawing their authority. Trustworthiness Tensions to Balance: Accountable versus Safe: Where the retirement is planned and the capability is not protective, preserving evidence and handing over the function can both be done at an unhurried pace. Where the retirement follows an incident, the same actions compete: capturing volatile state takes time during which a system suspected of causing harm is still running. One resolution is to separate isolation from teardown, cutting the system's authority and reach first under Task 13.2: Withdraw authority completely and confirm that it is withdrawn while leaving it running long enough to capture state; others include pre-authorizing the capture so it does not require a decision in the moment. Related AI RMF subcategories include: GOVERN 4.2 (on documenting and communicating risks and impacts): This Task contributes the identification of parties that depended on a retired AI system and a recorded decision for each, including where that decision is to make no provision; it does not cover the technical mapping of internal systems consuming its outputs, or the deprecation timeline given to them. For that, see Implementation 7.6.1: Internal Dependency Mapping (Orphan System Prevention). GOVERN 1.7 (on decommissioning and phasing out AI systems): This Task contributes the requirement that phasing out does not decrease trustworthiness by removing a protective function without handover, and that	13.3.3: Determine and record what happens to everything that depended on the system Identify the processes, systems and people that relied on the AI system's output, and record for each whether it will be migrated to an alternative, formally notified and wound down, or left without provision. Abandonment may be a legitimate decision, but it should be a recorded one. Human operators and downstream automation may have adapted to the retired system's particular behavior, so the effect of removal is not limited to the function it formally provided. Where the dependents are internal systems consuming the AI system's outputs, the mapping and the deprecation timeline are in Implementation 7.6.1: Internal Dependency Mapping (Orphan System Prevention); what this Implementation adds is that a decision is recorded for each dependent, including where that decision is to make no provision. References: >None yet - suggestions welcome

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practice	Task	Implementation
	evidence is captured before teardown makes it unrecoverable; it does not cover the withdrawal of authority. For that, see Task 13.2: Withdraw authority completely and confirm that it is withdrawn .	
14, 15, etc.: (TBD) >To the Reviewer: >If you've identified a risk area that doesn't fit naturally as a Task or Implementation under Practices 1–13, we'd welcome your suggestion for a new Practice here, including a short description of the governance-level risk it addresses and why it needs its own Practice rather than sitting under an existing one.		

Acknowledgements

>(TBD - We are grateful to the many contributors who have supported this draft through suggested text, technical review, and subject matter expertise. A full acknowledgements list will be included in a future draft.)

Glossary and Terminology Crosswalk

>(TBD - suggestions and contributions welcome, particularly for terms that have different meanings between sectors that might not be obvious)

- **Human oversight:** An umbrella term for arrangements by which people remain responsible for an AI system's behavior in operation. It denotes a category, not a single control, and comprises four distinct objects defined below: oversight mode, oversight capacity, oversight threshold and oversight authority.
Candidate references: ISO/IEC DIS 42105, *Guidance for Human Oversight of AI Systems*. ISO/IEC TS 8200:2024, *Controllability of Automated Systems*.
 - **Oversight mode:** The regime governing how a person participates in an AI system's decisions: human-in-the-loop (approval required before action), human-on-the-loop (action proceeds, with intervention capability retained), or human-out-of-the-loop (autonomous execution with retrospective review). Task [4.5: Define operational regimes for human-on-the-loop and human-out-of-the-loop operation](#) defines the boundaries between them.
Candidate references: DHS/CISA *Principles for the Secure Integration of AI in Operational Technology*, Section 4.2
 - **Oversight capacity:** The finite human attention available to exercise oversight, measured across all AI systems drawing on the same pool of people rather than per system. Capacity is exhaustible, is consumed concurrently by every system an operator supervises, and can be saturated by a correlated event even where each system's individual demand is manageable.
Candidate references: EEMUA *Publication 191*
 - **Oversight threshold:** The point beyond which a given oversight mode ceases to be effective: where the interval between an anomaly and an irreversible consequence is shorter than what human intervention can be relied upon to achieve. Implementation [4.5.1: Define engineering time-constant thresholds](#) defines how these are established.
Candidate references: ISA-84 / IEC 61511
 - **Oversight authority:** The named, non-delegable authority to set the oversight mode, to step it up or down, and to revoke the operating envelope. Distinct from the ability to intervene in a particular action: authority persists in regimes where real-time intervention is infeasible.
- **Industrial control system (ICS):** A control system that monitors and manipulates physical processes, such as supervisory control and data acquisition (SCADA) systems, distributed control systems (DCS) and programmable logic controllers (PLCs), made up of control components that act together to achieve an industrial objective. ICS are a subset of operational technology (OT), which also includes systems such as building automation and physical access control. In emergency management and public safety, ICS more commonly means the Incident Command System, the standardized incident management structure within the National Incident Management System (NIMS). This profile does not use ICS in that sense.
Candidate references: NIST SP 800-82r3, *Guide to Operational Technology (OT) Security*, Appendix B (Glossary), entries for "industrial control system" and "operational technology".
- **Zero trust:** A cybersecurity approach in which no implicit trust is granted to users, devices or services based solely on their network location or ownership, and access to each resource is authenticated and authorized separately. This profile applies the underlying principle, that trust is verified at each boundary rather than assumed, to AI risk more generally. The extension is in what is not assumed: in cybersecurity, chiefly that a requester is who it claims to be and is permitted to act; here, also that a legitimate, uncompromised AI system is behaving as intended. An AI system's outputs, actions and inputs therefore warrant verification where they cross into other systems, physical processes and human decisions, whether a departure from expected behavior arises from compromise, malfunction or a change in operating conditions. For example, an AI agent holding valid credentials is still authorized action by action (Implementation [5.2.2: Action-level, context-aware authorization policies](#)), and guardrails independent of the AI system check its outputs before they reach a physical process (Task [3.2: Implement independent guardrails \("safety wrappers"\) for AI outputs](#)).
Candidate references: NIST SP 800-207, *Zero Trust Architecture*; *Adapting Zero Trust Principles to Operational Technology* (CISA, DoW, DOE, 2026)

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Appendix A: Trustworthiness Characteristics

> To the Reviewer:

> This appendix will give the source definition of each characteristic, explain the grouping and where it departs from the AI RMF's own groupings, and set out the tensions between characteristics. We would welcome comment on the grouping in Table 2 in the meantime.

Appendix B: Historic Incident-to-Practice Mapping

This appendix presents case studies of several historic AI-related or AI-relevant incidents and maps them to examples of one or more of the 13 TACIP Practices. This includes incidents that may not have inherently involved AI at the time, in which case the mapping was performed for a hypothetical, similar AI-enabled variant. The goal is to provide concrete examples of how each Practice may have contributed to limiting the likelihood and severity of harm, be it in terms of lives, dollars, downtime, or public trust. Note that this mapping is not exhaustive, rather it is intended to demonstrate how practices are relevant to real-world incidents.

> To the Reviewer:

> This mapping is preliminary. We specifically seek feedback on whether these real and hypothetical scenarios are useful, whether the level of abstraction and detail is appropriate, and if this successfully grounds the practices in an operationally relevant manner.

Incident	Practices	Commentary
i1: Medical prediction model (predictive AI clinical tool) A proprietary machine-learning medical condition prediction tool, in widespread use across US hospitals, was found by independent external validation to miss roughly two-thirds of positive cases while generating substantial false-positive alert fatigue. Critical Infrastructure Sector: Healthcare and Public Health JAMA Internal Medicine	Practice 1: Establish requirements for success	AI clinical decision-support model is deployed for risk prediction without verified, real-world performance acceptance criteria, causing clinicians and hospitals to rely on vendor-reported accuracy that does not hold under operational conditions.
	Practice 2: Define AI Robustness, Resilience, and Quality of Service expectations	AI prediction model performs inconsistently across hospitals and care-timing contexts because robustness, calibration, and site-specific quality-of-service expectations were not validated before scaled clinical use.
	Practice 9: Provide calibrated, needs-based AI risk management training	AI-generated alerts had poor positive predictive value, creating alert fatigue and reducing appropriate trust in the model's outputs during high-consequence clinical decision-making.
i2: Health insurer prediction algorithm A Senate investigation found that as a large health insurer automated post-acute-care claims review (including with their AI system), its denial rate for that care more than doubled (10.9% to 22.7%, 2020-2022), and that the insurer explored using AI to target denials least likely to be appealed. A separate federal lawsuit alleges that the tool displaced physicians' clinical judgment. Critical Infrastructure Sector: Healthcare and Public Health NPJ Digital Medicine	Practice 1: Establish requirements for success	An AI-enabled claims-review process is optimized around denial likelihood or cost-control objectives rather than validated patient-care, medical-necessity, and fairness requirements, resulting in automated decisions misaligned with the system's intended healthcare purpose.
	Practice 3: Define risks, policies, and oversight for automated AI and agentic behavior	A high-consequence AI-assisted claims-review workflow issues or supports post-acute-care denials without defined risk thresholds, independent review gates, or oversight controls before the decision affects patient access to care.
	Practice 4: Define procedures for emergency avoidance override, recovery, and situation awareness	AI-generated post-acute-care recommendation is allowed to displace treating-physician judgment, leaving no reliable emergency override or recovery path when the automated output conflicts with clinical judgment.
	Practice 8: Incorporate AI-aware incident analysis and response procedures	AI-assisted claims-review decisions produce systematic patterns of inappropriate care denials, but no procedures exist to investigate AI decision behavior, identify affected patients, assess harm at scale, and coordinate timely remediation before significant patient-care impacts occur.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Incident	Practices	Commentary
	Practice 9: Provide calibrated, needs-based AI risk management training	Business and clinical users are insufficiently trained to recognize when AI-enabled claims-review outputs reflect an objective other than clinical appropriateness, such as cost or the likelihood that a decision will be challenged.
i3: Robotaxi pedestrian-dragging incident An autonomous taxi's own perception and planning system executed a post-collision pullover maneuver while a pedestrian was trapped underneath, dragging the pedestrian about 20 feet. The autonomous taxi company then incompletely reported the crash to federal regulators, leading to the suspension of the company's California operating permits, a voluntary nationwide halt of its driverless fleet, and a \$1.5 million NHTSA fine. Critical Infrastructure Sector: Transportation Systems National Highway Traffic Safety Administration	Practice 2: Define AI Robustness, Resilience, and Quality of Service expectations	Autonomous-vehicle AI system is deployed without targeted validation for rare but severe post-collision failure modes, including scenarios where a pedestrian or object remains beneath the vehicle after impact.
	Practice 3: Define risks, policies, and oversight for automated AI and agentic behavior	Autonomous-vehicle AI planning system continues executing a movement maneuver after detecting a collision, without a deterministic fail-safe state that prevents additional motion when a person or object may be trapped underneath.
	Practice 8: Incorporate AI-aware incident analysis and response procedures	Organization fails to perform and disclose a complete AI-aware incident analysis after an autonomous-vehicle harm event, omitting critical AI behavior needed by regulators to understand the full hazard sequence.
	Practice 12: Independently verify AI-generated operational logic and artifacts across their lifecycle	Autonomous system executes AI-generated direct-control logic for vehicle movement without deterministic verification that the planned maneuver is safe in the current hazardous state.
i4: Facial recognition wrongful arrest City police relied on a facial-recognition match, later shown to be only the ninth-best candidate, as the effective basis for arresting an unrelated person, who spent about 30 hours in custody before being told the computer had gotten it wrong. Critical Infrastructure Sector: Emergency Services American Civil Liberties Union	Practice 1: Establish requirements for success	Facial-recognition system is used to support a custodial arrest without validated accuracy, evidentiary, and consequence-calibrated acceptance requirements for law-enforcement use.
	Practice 2: Define AI Robustness, Resilience, and Quality of Service expectations	Facial-recognition system's false-match performance under degraded real-world image conditions is not tested or validated before its output is relied on in a high-consequence criminal investigation.
	Practice 3: Define risks, policies, and oversight for automated AI and agentic behavior	Probabilistic facial-recognition match is treated as sufficient basis for a suspect identification without mandatory corroborating evidence, defined confidence thresholds, or multi-party oversight before arrest.
	Practice 9: Provide calibrated, needs-based AI risk management training	Investigators over-trust an AI-generated facial-recognition match and treat the system output as determinative rather than as an uncertain lead requiring corroboration and human review.
i5: Airline chatbot hallucination An airline's generative AI customer-service chatbot fabricated a bereavement-fare policy detail that contradicted the airline's actual policy; a Canadian tribunal held the airline liable for the chatbot's misinformation in a first-of-its-kind ruling. Critical Infrastructure Sector: Transportation Systems Civil Resolution Tribunal of British Columbia	Practice 1: Establish requirements for success	No validated contextual-accuracy benchmark existed for the chatbot's handling of the airline's own published policies before it was deployed publicly.
	Practice 2: Define AI Robustness, Resilience, and Quality of Service expectations	AI chatbot fabricated a detail of the airline's bereavement-fare policy (that it could be applied for retroactively) that directly contradicted the airline's actual published policy.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Incident	Practices	Commentary
	Practice 12: Independently verify AI-generated operational logic and artifacts across their lifecycle	AI chatbot produces policy guidance that is not validated against authoritative business rules, causing users to rely on an AI-generated outcome that conflicts with the organization's actual published policy.
i6: National childcare benefits scandal A self-learning machine-learning model used by a national tax authority to flag childcare-benefit fraud used nationality as a risk factor, wrongly flagging tens of thousands of families (mostly non-citizen or dual-national) whose benefits were terminated and full repayment demanded, ultimately triggering the government's resignation in 2021. Critical Infrastructure Sector: Government Services and Facilities Amnesty International	Practice 1: Establish requirements for success	A self-learning ML risk-classification model was fielded by the Dutch tax authority to flag childcare-benefit applications for fraud, using nationality as one of its risk factors, with no pre-deployment fairness or human-rights impact assessment.
	Practice 3: Define risks, policies, and oversight for automated AI and agentic behavior	Once an application was flagged by the model, benefits were automatically discontinued and full repayment demanded, in many cases with minimal further human assessment before the harm to the family occurred.
	Practice 8: Incorporate AI-aware incident analysis and response procedures	AI-driven fraud-risk classifications generate widespread erroneous benefit-enforcement actions, but the organization lacks procedures to detect systemic model-driven harm, reconstruct decision pathways, identify impacted populations, and coordinate corrective action before large-scale public harm occurs.
	Practice 9: Provide calibrated, needs-based AI risk management training	Officials over-trust AI-generated fraud-risk flags and treat them as determinative findings, causing families to be penalized without sufficient independent review, fact-checking, or calibrated understanding of model uncertainty.
i7: Autonomous-vehicle pedestrian fatality An autonomous test vehicle detected a pedestrian ~6 seconds out but misclassified the detection and had its emergency braking suppressed by design; the over-trusting, distracted safety operator did not intervene, and the pedestrian was killed - the first pedestrian fatality involving a self-driving car. Critical Infrastructure Sector: Transportation Systems National Transportation Safety Board	Practice 1: Establish requirements for success	An AI driving system is tested on public roads without an established safety case, acceptance benchmarks, or defined handling of its known functional limitations.
	Practice 3: Define risks, policies, and oversight for automated AI and agentic behavior	The AI classifies the pedestrian inconsistently and its emergency-braking response is suppressed by design, with no bounded safe fallback under uncertainty.
	Practice 4: Define procedures for emergency avoidance override, recovery, and situation awareness	The AI does not alert the human to take over when it cannot handle the situation.
	Practice 9: Provide calibrated, needs-based AI risk management training	The safety operator over-trusts the AI and disengages from monitoring (automation complacency).

Incidents i8 onward re-examine historical cybersecurity events as hypothetical case studies, to illustrate how TACIP practices apply if equivalent disruptions were driven by or otherwise involved AI risk.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Incident	Practices	Commentary
i8: Energy sector pipeline ransomware attack <i>(hypothetical AI scenario)</i> Ransomware on a pipeline operator's IT/billing systems (via a legacy VPN account without MFA) led the operator to precautionarily shut the pipeline, disrupting fuel supply across the US East Coast. Critical Infrastructure Sector: Energy U.S. Government Accountability Office	Practice 2: Define AI Robustness, Resilience, and Quality of Service expectations	AI-mediated pipeline scheduling or operational-support function depends on compromised IT systems without validated resilience expectations, causing loss of confidence in operational integrity and triggering precautionary disruption of fuel-delivery operations.
	Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools	AI system has access to the VPN account or direct access to IT/OT operations. One agent's credential is phished, stolen, or left over-scope, causing disruption in the pipeline.
	Practice 11: Maintain AI-aware mission continuity and disaster recovery planning	AI-supported pipeline operation is taken offline after a compromise, and the absence of AI-aware continuity and trusted-state recovery planning prolongs disruption to mission-critical fuel distribution.
i9: IT management platform compromise <i>(hypothetical AI scenario)</i> Attackers added malicious code to certain versions of an IT management platform, which was downloaded by thousands of private and government organizations; of those, an estimated 100–250 were breached with active follow-on access. Critical Infrastructure Sector: Information Technology Cybersecurity & Infrastructure Security Agency	Practice 6: Integrate visibility of the external supply chain of AI into vendor and 3rd party risk management	A trusted vendor ships a poisoned model, tampered weights, or an AI-generated build component through its signed update channel.
	Practice 7: Manage internal AI supply chain and data provenance	The tainted model/component is now deployed across many internal systems that fine-tune on or call it.
	Practice 12: Independently verify AI-generated operational logic and artifacts across their lifecycle	AI generates build code/configuration inside the pipeline and that machine-authored logic carries a flaw or backdoor.
i10: Email and collaboration server on-prem exploitation <i>(hypothetical AI scenario)</i> Zero-day flaws in on-premises email and collaboration servers were mass-exploited to drop web shells that gave attackers persistent access to government and enterprise networks. Critical Infrastructure Sector: Government Services and Facilities U.S. Government Accountability Office	Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools	Unauthorized or shadow AI agent executes with excessive privilege in an unvetted environment and persists after remediation, enabling continued attacker access despite patching or cleanup efforts.
	Practice 7: Manage internal AI supply chain and data provenance	A locally hosted AI model or serving component with unverified provenance is exploited and used to maintain persistent unauthorized logic inside the enterprise environment.
i11: Remote management tool supply-chain ransomware <i>(hypothetical AI scenario)</i> Attackers exploited zero-days in a remote-management tool to push ransomware downward through managed service providers to their many downstream customers. Critical Infrastructure Sector: Information Technology Cybersecurity & Infrastructure Security Agency	Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools	AI-enabled management agent retains broad standing privilege across multiple customer environments, allowing a single compromise to propagate malicious actions or ransomware at downstream scale.
	Practice 6: Integrate visibility of the external supply chain of AI into vendor and 3rd party risk management	Trusted AI orchestration or remote-management platform in the external supply chain is compromised, enabling attackers to distribute malicious activity across dependent tenants, service providers, or downstream customers.
i12: Health system ransomware <i>(hypothetical AI scenario)</i> Ransomware entered a national healthcare IT system via a malicious email, spread over weeks, and forced a shutdown of IT-driven clinical systems across the country's public health service. Critical Infrastructure Sector: Healthcare and Public Health Health Service Executive	Practice 2: Define AI Robustness, Resilience, and Quality of Service expectations	The compromise cascades to a total lockout of all clinical systems.
	Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools	A compromised identity/agent escalates and moves laterally across ~70,000 devices.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Incident	Practices	Commentary
	Practice 8: Incorporate AI-aware incident analysis and response procedures	A compromise of AI-enabled healthcare systems propagates across clinical operations, but responders lack procedures to identify affected AI services, assess impacts to patient-care functions, coordinate recovery priorities, and investigate how the disruption spread through interconnected systems.
	Practice 11: Maintain AI-aware mission continuity and disaster recovery planning	All IT-driven clinical systems (including any AI) are down, affecting healthcare services.
i13: Healthcare payments system ransomware (hypothetical AI scenario) Ransomware hit a large healthcare payments provider (entering via a portal without MFA), knocking out claims and payment processing for much of the national healthcare system. Critical Infrastructure Sector: Healthcare and Public Health U.S. Securities and Exchange Commission	Practice 2: Define AI Robustness, Resilience, and Quality of Service expectations	A highly concentrated AI-mediated claims and payment clearinghouse lacks validated availability and resilience expectations, causing widespread healthcare transaction disruption when the service becomes unavailable.
	Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools	An AI/agent access path to the clearinghouse lacks MFA/least-privilege and is compromised.
	Practice 8: Incorporate AI-aware incident analysis and response procedures	Compromise of a highly concentrated AI-mediated healthcare transaction platform disrupts dependent organizations, but the organization lacks procedures to assess ecosystem-wide impacts, coordinate incident response, prioritize restoration efforts, and communicate operational consequences to affected stakeholders.
	Practice 11: Maintain AI-aware mission continuity and disaster recovery planning	An AI-mediated claims and payment-processing service lacks effective continuity alternatives, causing prolonged transaction outages and financial disruption for dependent healthcare providers.
i14: Water treatment incident (hypothetical AI scenario) An operator at a city water plant saw and reversed a remote change that spiked sodium-hydroxide dosing; the event's status as a deliberate attack was later disputed. Critical Infrastructure Sector: Water and Wastewater Systems Cybersecurity & Infrastructure Security Agency	Practice 3: Define risks, policies, and oversight for automated AI and agentic behavior	An AI agent can write chemical-dosing setpoints; it (or an attacker acting through it) drives sodium hydroxide to a dangerous level.
	Practice 4: Define procedures for emergency avoidance override, recovery, and situation awareness	The AI's setpoint action must be caught and reversed in real time.
	Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools	AI-managed or agent-generated credentials for OT interfaces are weak, default, or insufficiently governed, allowing exposed water-system devices to be accessed and manipulated by unauthorized actors.
i15: Active exploitation of water utility control systems (hypothetical AI scenario) Attackers believed to be nation-state actors took over internet-exposed programmable logic controllers (PLCs) at water utilities by using the devices' default password. Critical Infrastructure Sector: Water and Wastewater Systems Cybersecurity & Infrastructure Security Agency	Practice 3: Define risks, policies, and oversight for automated AI and agentic behavior	An agent with authority to generate or modify control logic installs logic that does not perform the required function, with no boundary outside the device positioned to detect that it has stopped doing so.
	Practice 4: Define procedures for emergency avoidance override, recovery, and situation awareness	The interface operators would use to override the system is itself disabled, and the display they would read is replaced, so intervention depends on a path independent of the affected device.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Incident	Practices	Commentary
	Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools	Internet-exposed AI/OT devices or agents run on default or weak credentials.
i16: National power grid attack (hypothetical AI scenario) Attackers believed to be nation-state actors phished into three power distributors and remotely opened breakers, cutting power to ~225,000 people (restored via manual operation). Critical Infrastructure Sector: Energy Cybersecurity & Infrastructure Security Agency	Practice 3: Define risks, policies, and oversight for automated AI and agentic behavior	An agent with breaker-control authority (or an attacker through it) opens breakers.
	Practice 4: Define procedures for emergency avoidance override, recovery, and situation awareness	The control layer led by AI is issuing hostile breaker commands and must be overridden.
	Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools	Phished credentials/agent identities give access to the SCADA/control network.
	Practice 11: Maintain AI-aware mission continuity and disaster recovery planning	Automated control is untrusted and grid operation must continue when AI responsible for operational actions fails.
i17: City-wide electrical outage (hypothetical AI scenario) Malware purpose-built to operate grid equipment issued breaker commands over ICS protocols and caused a 2016 outage (DoS) in a major capital city. Critical Infrastructure Sector: Energy Cybersecurity & Infrastructure Security Agency	Practice 3: Define risks, policies, and oversight for automated AI and agentic behavior	Autonomous AI logic issues grid breaker commands over ICS protocols.
	Practice 4: Define procedures for emergency avoidance override, recovery, and situation awareness	The control layer operated by AI is autonomously opening breakers and must be overridden.
	Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools	Compromised AI or agent identity with trusted access to the control network issues unauthorized breaker commands, enabling automated manipulation of grid equipment through legitimate operational pathways.
	Practice 11: Maintain AI-aware mission continuity and disaster recovery planning	AI-supported grid-control operations become unavailable or untrusted during an automated attack, and the absence of AI-aware continuity procedures prevents reliable transition to safe manual or alternate operating modes.
i18: Satellite communication disruption to wind turbines (hypothetical AI scenario) Wiper malware, pushed via a compromised management appliance, caused a Denial of Service, bricking satellite modems and knocking ~5,800 wind turbines off remote control. Critical Infrastructure Sector: Communications Viasat	Practice 2: Define AI Robustness, Resilience, and Quality of Service expectations	An AI-enabled single push bricks a whole modem fleet, with cross-border spillover to other operators.
	Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools	Management appliance network access lets an agent/actor push a destructive command fleet-wide.
	Practice 6: Integrate visibility of the external supply chain of AI into vendor and 3rd party risk management	Compromised third-party AI management plane or appliance becomes the entry point for fleet-scale destructive commands, disrupting downstream operational assets that depend on the affected communications service.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Incident	Practices	Commentary
	Practice 11: Maintain AI-aware mission continuity and disaster recovery planning	AI-supported remote-control operations for dependent assets lose connectivity, and inadequate continuity planning leaves operators unable to maintain or restore mission functions during the communications outage.
i19: Critical infrastructure persistent access (hypothetical AI scenario) Malware believed to be nation-state linked used stealthy living-off-the-land (LOTL) techniques to pre-position long-term persistent access inside critical-infrastructure networks for possible future disruption. Critical Infrastructure Sector: Communications; Energy; Transportation Systems; Water and Wastewater Systems Cybersecurity & Infrastructure Security Agency	Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools	An actor abuses valid accounts/agent identities and living-off-the-land techniques to persist stealthily.
	Practice 7: Manage internal AI supply chain and data provenance	End-of-life or unmaintained AI tools and agents remain inside the environment as untrusted internal supply-chain artifacts, increasing exposure and enabling stealthy persistence within critical-infrastructure systems.
	Practice 10: Implement multi-tiered AI system logging and audit capabilities	The pre-positioned presence stays invisible because logging of AI systems is thin.
i20: Malware targeting critical infrastructure (hypothetical AI scenario) A malware campaign compromised trusted third-party energy-sector suppliers as staging points to reach and reconnoiter intended critical-infrastructure targets. Critical Infrastructure Sector: Energy Cybersecurity & Infrastructure Security Agency	Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools	Harvested credentials/agent identities enable lateral movement to the intended victims.
	Practice 6: Integrate visibility of the external supply chain of AI into vendor and 3rd party risk management	Trusted but less-secure third-party AI suppliers (or their AI tools) are used as staging pivots toward the real targets.
i21: Botnet malware (hypothetical AI scenario) Botnet malware infects network devices to build resilient botnet infrastructure. Critical Infrastructure Sector: Information Technology Cybersecurity & Infrastructure Security Agency	Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools	AI-operated or agent-managed network devices are reachable through exposed or weak authentication paths, allowing attackers to compromise the devices and use them as persistent infrastructure.
	Practice 7: Manage internal AI supply chain and data provenance	Org-controlled network devices run tampered firmware/agent code.
i22: Malware targeting mobile devices (hypothetical AI scenario) Mobile device malware infected devices used by the military to persist and exfiltrate operational data. Critical Infrastructure Sector: Defense Industrial Base Cybersecurity & Infrastructure Security Agency	Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools	A malicious persistent agent runs on org-controlled mobile devices with excessive access.
	Practice 7: Manage internal AI supply chain and data provenance	Unauthorized agent code persists on managed operational devices without trusted provenance or integrity validation, enabling continued access and exfiltration of sensitive operational data.
i23: Maritime terminal operator cyber incident (hypothetical AI scenario) A cyber intrusion led a large maritime terminal operator to disconnect its network, halting land-side operations at major ports and stranding tens of thousands of containers. Critical Infrastructure Sector: Transportation Systems DP World	Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools	An internet-facing AI or agent access gateway is exploited to inherit excessive operational privileges, forcing disconnection of port networks and disrupting land-side cargo movement.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Incident	Practices	Commentary
i24: Steel mill cyberattack <i>(hypothetical AI scenario)</i> Attackers pivoted from a steel mill's office network into its control systems, preventing a controlled blast-furnace shutdown and causing massive physical damage. Critical Infrastructure Sector: Critical Manufacturing Public Broadcasting Service	Practice 2: Define AI Robustness, Resilience, and Quality of Service expectations	An AI-supported blast-furnace control or shutdown function fails to meet robustness and safe-operation expectations, preventing a controlled shutdown and contributing to physical equipment damage.
	Practice 3: Define risks, policies, and oversight for automated AI and agentic behavior	AI-enabled furnace-control behavior lacks defined risk limits, oversight, and fail-safe governance, allowing manipulated or disrupted control actions to cause unsafe physical operating conditions.
	Practice 4: Define procedures for emergency avoidance override, recovery, and situation awareness	An AI furnace-control function is disrupted and a safe, controlled shutdown cannot be performed.
	Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools	A compromised AI or agent identity bridges IT-to-OT access paths and reaches furnace-control systems, enabling attackers to interfere with industrial operations and prevent safe shutdown.
i25: Dam intrusion <i>(hypothetical AI scenario)</i> Hackers believed to be nation-state actors gained SCADA access to a small flood-control dam via a cellular modem; the sluice gate happened to be offline for maintenance. Critical Infrastructure Sector: Dams U.S. Department of Justice	Practice 3: Define risks, policies, and oversight for automated AI and agentic behavior	An AI agent or attacker acting through an AI-enabled control path can actuate a high-risk dam component without defined oversight, authorization boundaries, or risk thresholds for physical control actions.
	Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools	A weakly governed remote-access path exposes an AI or agent identity with dam-control privileges, allowing unauthorized actors to reach physical sluice-gate controls.
i26: Government personnel agency breach <i>(hypothetical AI scenario)</i> Attackers exfiltrated ~21.5 million sensitive background-investigation records from a government personnel agency over a long, undetected intrusion. Critical Infrastructure Sector: Government Services and Facilities U.S. Government Accountability Office	Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools	A contractor/agent identity with broad reach of sensitive data and weak auth is compromised and moves laterally.
	Practice 8: Incorporate AI-aware incident analysis and response procedures	Unauthorized AI-enabled access to sensitive personnel records persists over an extended period because the organization lacks procedures to investigate anomalous AI or agent activity, determine the scope of data exposure, reconstruct attacker actions, and coordinate enterprise-wide response and remediation efforts.
	Practice 10: Implement multi-tiered AI system logging and audit capabilities	The agent exfiltrates records silently over a long dwell time and insufficient logging does not record these malicious actions.
i27: Interbank messaging fraud <i>(hypothetical AI scenario)</i> Using stolen credentials, attackers sent fraudulent payment orders through the global interbank network to move ~US\$81M with malware hiding the confirmations. Critical Infrastructure Sector: Financial Services U.S. Department of Justice	Practice 3: Define risks, policies, and oversight for automated AI and agentic behavior	Risks and oversight of AI agents initiating or approving high-value payment messages are not taken into account.
	Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools	A compromised or over-privileged AI agent identity can initiate or approve high-value payment messages, enabling fraudulent transfers through trusted financial transaction workflows.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Incident	Practices	Commentary
	Practice 8: Incorporate AI-aware incident analysis and response procedures	A compromised or manipulated AI-assisted payment-processing workflow initiates unauthorized financial transactions, but the organization lacks procedures to rapidly reconstruct transaction activity, identify affected systems and accounts, coordinate containment actions, and support regulatory and financial recovery efforts.
	Practice 10: Implement multi-tiered AI system logging and audit capabilities	Malware (or a manipulated agent) suppresses logs to hide the fraud.
i28: Telecommunications company data breach (hypothetical AI scenario) An exposed, effectively unauthenticated API let attackers extract the personal information of roughly 9.5 million customers. Critical Infrastructure Sector: Communications Office of the Australian Information Commissioner	Practice 1: Establish requirements for success	An AI- or agent-accessible API endpoint is deployed without validated security acceptance requirements, allowing unauthenticated or insufficiently controlled access to bulk customer personal information.
	Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools	An AI/agent API endpoint is exposed without authentication and returns bulk PII.
i29: Resort operator cybersecurity incident (Form 8-K) (hypothetical AI scenario) Attackers social-engineered the resort operator's IT help desk to gain privileged access, then deployed ransomware that disrupted casino and hotel operations for days. Critical Infrastructure Sector: Commercial Facilities U.S. Securities and Exchange Commission	Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools	An AI-assisted help desk or identity-support workflow is manipulated through social engineering to reset or escalate privileged access, enabling ransomware deployment and disruption of casino and hotel operations.
i30: Resort operator cybersecurity incident (hypothetical AI scenario) Attackers social-engineered an outsourced IT support vendor to breach resort operator and steal its customer loyalty-program database; a ransom was reportedly paid. Critical Infrastructure Sector: Commercial Facilities U.S. Securities and Exchange Commission	Practice 6: Integrate visibility of the external supply chain of AI into vendor and 3rd party risk management	Outsourced AI-enabled IT support vendor with privileged access is compromised through social engineering, enabling unauthorized access to enterprise systems and theft of customer loyalty-program data.
i31: Credit bureau data breach (hypothetical AI scenario) Attackers exploited a known vulnerability in an open-source toolkit powering the credit agency's online portal and found stored unencrypted credentials to reach ~48 databases, and exfiltrated the personal data of ~147 million people over 76 days - undetected because an expired certificate had left network traffic uninspected for about 10 months. Critical Infrastructure Sector: Financial Services U.S. Government Accountability Office	Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools	The compromised component yields stored, unencrypted credentials that unlock dozens of additional databases.
	Practice 7: Manage internal AI supply chain and data provenance	A known-vulnerable component in an org-controlled AI/application stack is left unpatched, and weak segmentation lets a foothold reach many back-end data stores.
	Practice 8: Incorporate AI-aware incident analysis and response procedures	AI or data-processing environment is compromised and exfiltration continues undetected because incident analysis does not identify, scope, and coordinate response to the breach in a timely manner.
	Practice 10: Implement multi-tiered AI system logging and audit capabilities	A monitoring control silently stops inspecting traffic (an expired certificate), so months of data exfiltration go unseen.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aicprof@nist.gov.

Incident	Practices	Commentary
i32: Incorrect flight control system behavior (generic hypothetical AI scenario) An automated flight control system receives corrupted, erroneous, or single-source sensor telemetry (e.g., due to environmental icing, hardware failure, or data spikes), leading to uncommanded control inputs or abrupt disengagement of automated protections. The combined effect of unexpected control forces, cascading ambiguous alerts, and rapid authority transfer creates severe cognitive friction and mode confusion, impairing the ability of human operators to rapidly establish situational awareness and execute timely recovery, resulting in dangerous system instability, injury, or catastrophic loss. Critical Infrastructure Sector: Transportation Systems (Multiple historic incidents.)	Practice 3: Define risks, policies, and oversight for automated AI and agentic behavior	Automated control logic executes high-consequence physical commands based on unvalidated or single-source sensor feeds without deterministic cross-validation or hard boundary logic, allowing corrupted inputs to drive unsafe automated responses.
	Practice 4: Define procedures for emergency avoidance override, recovery, and situation awareness	An automated system steps down authority or disengages during an abnormal event without sufficient handoff pacing or clear "state-at-handoff" displays, leaving human operators to diagnose complex system behavior from a cold start.
	Practice 9: Provide calibrated, needs-based AI risk management training	Personnel trained primarily on nominal automation performance experience mental model lag when forced to take manual control during sudden, edge-case mode transitions, reinforcing the need for scenario-based training on degraded-mode handoffs.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Appendix C: Use Cases and Operational Scenarios

> (TBD - this will include a variety of use cases and operational scenarios, specific to different critical infrastructure sectors.

We welcome suggestions and contributions!

Appendix D: Crosswalks

> To the Reviewer:

> While TACIP prioritizes operational workflows and entry points for critical infrastructure acquirers, owners, and operators, we recognize that systems engineering teams, software developers, and compliance auditors often organize risk management activities within formal lifecycle models.

> This appendix is under active development to provide explicit crosswalks mapping TACIP's 13 Practices to established systems engineering standards (ISO/IEC/IEEE 15288, NIST SP 800-160) and AI management frameworks (ISO/IEC 42001, NIST AI RMF). We welcome feedback on which specific lifecycle phases, decision gates, or sub-processes within these standards offer the greatest utility for your organization's compliance and engineering workflows, and additional general resources that we should prioritize for crosswalking.

> We also welcome suggestions for sector-specific crosswalks that we can pass on to sector-specific organizations for their consideration.

Appendix E: Additional Information for the Reviewer

>This appendix supports the review of this discussion draft and will not appear in the published profile.

Document Design Criteria:

The guidelines in this section are internal design suggestions for document authors that guide them when writing the practices, tasks, and implementations, not operational controls for critical infrastructure. They are not compulsory although deviating from these should be done with care. Note that as this document is still very much a draft and work in progress, with text at different levels of refinement, it's likely that some parts are inadvertently out of compliance with these criteria. Feel free to note this if you see cases where this is particularly important.

Overall:

1. **“Do no harm.”** This criterion serves as an internal writing constraint to protect operators from the dangers of blind compliance, misinformed blanket regulations, or rigid management mandates. Every practice, task, and implementation should be drafted so that qualified professional and engineering judgment is baked into the requirement itself. To achieve this, avoid broad or generalized statements, instead bounding commands with conditional triggers and engineering qualifiers (e.g., “where technically feasible” or “commensurate with process safety thresholds”). Furthermore, text should leverage deliberate semantic scoping so that if a control is truly inapplicable or physically unsafe for a specific environment, an operator can explicitly satisfy the mandate “to the letter” by formally declaring that specific operational path out of scope, although boundaries should be constructed tightly to prevent loopholes.
2. **Modular and Entry-Point Agnostic.** Every practice, task, and implementation is designed under the assumption that the reader has reviewed the foundational frontmatter, but not necessarily any other specific row in the framework. While rows work synergistically, an individual reading a single item in isolation should find sufficient context to understand its immediate risk-management utility. If a hard dependency or critical relationship exists with another practice, the row should explicitly route the reader to that section to ensure a seamless “random-access” reading experience.
3. **Refer to other standards/guidance/resources as much as possible.** Use as few words as necessary to help the reader to understand if this relates to them and to help them scope and interpret those references, especially if it's a long reference and only part of it is relevant.
4. **Understandable to the target audience.** Target audiences are described more below.
5. **Actionable and useful.** At each level of abstraction, there should be a clear line between the practice/task/implementation and something that can actually be done and will improve risk management, particularly given the resource restrictions and legacy infrastructure and policies often present in CI.
6. **Achievable and provides a gradient.** While our goal is to cover the ideal and industry best practice alongside what a ‘minimum viable’ looks like for resource-constrained environments, we are still evaluating how to best standardize these definitions across different critical infrastructure sectors. This criteria is currently treated as an exploratory objective to determine if tiered implementations prevent compliance fatigue, or if they inject unnecessary complexity into cross-sector governance.
7. **Risk-proportional.** Practices, tasks, and implementations should help the reader understand the significance of a risk (or lack thereof) to help them allocate limited time, attention, and other resources.
8. **Acknowledge the tradespace.** Risk management involves managing all relevant risks. Reducing risk in one area might increase risk in others and there may already be existing legacy trade-offs that organizations are used to (or may have mandated) that might be difficult to adjust. We should give stakeholders space to make this trade-off, even if they are obliged to follow a given practice/task/implementation.
9. **General to all forms of AI that could be in scope.** The terminology we use should be relatable to the various audiences but also leave open room for novel approaches that don't fit into existing (or commonly understood) approaches. For example, whatever we say should make sense for a neural network approach, as well as a traditional logic-based approach or a neuro-symbolic approach. Actually, I expect some of what we would say would be implicitly comparing/contrasting these. (If we find something that is narrow but really impactful, we need to make that scope clear.)
10. **Verifiable, measurable, and audit-ready.** Outcomes of these practices, tasks, and implementations should be naturally measurable, and compatible with the “Measure” function of the AI RMF, to allow leadership to track risk mitigation progress and enable regulatory oversight and forensic investigation.

COMMUNITY OF INTEREST DISCUSSION DRAFT, NOT OFFICIAL GUIDANCE, FOR DISCUSSION ONLY.

This document is a work-in-progress, intended to promote discussion and solicit early feedback from the [community of interest](#) in preparation for the formal comment period. Please send feedback and requests to join the community of interest to aiciprof@nist.gov.

Practices:

1. **Management/Governance audience.** This might be the only column that a non-technical manager might read and decide to tell the folks under them to do.
2. **Clear connection to the organization's goals.** It should be clear to a management audience what the incentive is to pay attention to this practice. This should reference the business/organizational goals and governance, rather than purely technical goals.
3. **Industry/Sector keywords.** This should tie AI risk management concepts to industry and sector keywords so a non-AI, non-technical person who is just scanning keywords is likely to have an accurate intuition as to the type of risk and mitigation we're talking about, and the point in the process lifecycle at which it applies.
4. **Defensively non-technical.** Where possible, language should either be general enough, or appropriately explained, so that interpretation is accurate regardless of if this document is being read in a technical, sector-specific, or colloquial context.
5. **Clear Ownership with Explicit Routing.** Each practice should allow the reader to identify which internal team or department is best suited to lead the objective. Rather than treating the Practice as an isolated silo, its standalone tasks and implementations serve as navigational signposts, guiding the lead department to the cross-functional collaborators they need to coordinate with next.

Tasks:

1. **Technical Management audience.** Note that this could be hands-on-keyboard technical, but it could also be technical policy.
2. **Discrete, assignable steps.**
3. **Each should be easily identifiable with achieving some aspect of the practice.**
4. **May be executed independently.**

Implementations:

1. **Should point to specific ways of implementing a task.** Avoid actually going into technical/sequencing details beyond what is necessary to help the reader contextualize what we're pointing at.
2. **Should provide necessary, scoped context.** Avoid just pointing at a document and saying "Read this ..." especially if the document is very long, involved, and/or from an area that the reader is unlikely to be familiar with. There should be just enough words to tell the reader which aspect of that document they need to pay attention to.
3. **Ideally should include a minimal implementation.** This should give the reader a good idea of what some minimal steps are to reduce their risk, at minimal expense (and, by implication, when they shouldn't bother if they don't even have the resources to do that - that they might be better off spending their resources on something else that has a greater impact).
4. **Ideally should include an "ideal" implementation.** This should give the reader a good idea of what a "reasonable" attempt looks like, beyond which it might be worth looking at other measures should be taken to achieve a balanced risk management strategy. These paired structures are experimental; rows may leverage general illustrative examples if a strict resource split proves artificial or unhelpful for a given task.
5. **Should concretely acknowledge the tradespace.** At least some hints as to specific things that might be traded off, particularly when it comes to mismatched lifecycles (20-30 years for typical CI assets, vs possibly <1 year for many AI systems) and the need to scale across distributed infrastructure with limited resources.
6. **Should try to be broadly relatable.** With 16 critical infrastructure sectors, it is likely impossible to come up with singular implementations that are directly relatable to all of them but language should be structured, where possible, to allow folks in sectors that are adjacent to still understand how the crux of the implementation might relate to them. This might require a fleshed out "primary" implementation and some minimal "secondary" ones that relate to the same idea but cover another group of sectors.

Ideas and References Already in Progress:

We've identified a number of promising ideas, structural changes, and candidate references that we're actively working through internally, but haven't yet incorporated into the document itself. We're sharing this list so that if you were about to suggest one of these, you'll know it's already on our radar, and so you can help us prioritize, refine, or strengthen it.

For each item below, we'd especially value:

- **Prioritization:** If you could only see three of these addressed in the next revision, which would they be?
- **Better or additional references:** Especially ones with a brief note on which part of the reference applies and where.
- **Placement:** Where in the document (which Practice/Task/Implementation) a given idea or reference would be most useful as an illustrative example.
- **Sector-specific angles:** Whether an idea needs to be adapted, split, or caveated differently for your sector.

This list is not exhaustive, and its presence here doesn't guarantee inclusion in the next draft. It reflects our current thinking, not a commitment. If something below turns out to be off-base or lower priority than we think, please tell us that too.

Cross-Cutting Themes

These don't sit neatly under a single Practice, with each touching several. We've noted the Practices most relevant to each so you can jump to related content if useful.

Enrichment of Search Keywords and references. The comprehensive enrichment of "Search Keywords" and the operational contextualization of references are ongoing. In this draft, keyword fields remain sparse or blank, and references primarily serve as pointers to what we are considering and where we think they fit in. These will be expanded with additional context in later iterations and we welcome your feedback and suggestions on what would be most useful.

Autonomy isn't one-dimensional. We want to avoid framing AI autonomy as a single linear "level," since real systems vary across multiple independent dimensions. *Relates to: Practices 3, 4. Feedback welcome on: whether a multi-dimensional framing would be clearer for your sector, and what those dimensions should be.*

Theoretical vs. actual capability. Distinguishing what a system is formally capable of from what it reliably does in practice. *Relates to: Practices 1, 2, 3. Feedback welcome on: where this distinction most needs to be made explicit.*

Cost as a risk-management input. Considering a "cost of controls" framing so that overinvestment in one control doesn't crowd out resources for higher-value ones elsewhere. *Relates to: Practice 1: [Establish requirements for success](#), but potentially applicable wherever a gradient of implementations is offered. Feedback welcome on: whether this deserves standalone treatment or should be folded into the existing gradient/"minimum viable" language.*

"Living off the land." Noting that intended, legitimate functionality (not just malicious code) can still be used to cause harm, both from adversarial action (human or AI), and from legitimate, known, but misbehaving, internal or external AI systems. *Relates to: Practices 2, 3, 5. Feedback welcome on: whether this needs its own treatment or is better folded into existing guardrail/access-control language.*

Predictive/monitoring use cases (e.g., environmental or hazard forecasting) as possible additions to the Scope section's example list. *Feedback welcome on: sector-appropriate variants beyond a single illustrative case.*

Document format changes. This document has outgrown its original tabular format as presented in the PDF version. As we are also ensuring that the same information is also available in the Markdown, we are investigating other ways of presenting views into this same information that can be automatically (and deterministically) generated that may be easier (for both people and AI assistants) to digest, be it in print or interactively. We welcome suggestions.

Practice-Specific Items

Practice [1: Establish requirements for success](#) (Establish requirements for success)

Understanding what the system is actually optimizing for. Ensuring requirements-setting explicitly accounts for possible gaps between a stated objective and what a system optimizes toward in practice.

Practice [2: Define AI Robustness, Resilience, and Quality of Service expectations](#) (Robustness, resilience, and QoS)

Specification gaming. Addressing cases where a system optimizes for a stated metric in ways that violate the intent behind it.

Financial/resource risk from compute cost volatility. Both unpredictable usage spikes and vendor pricing changes over time as an operational risk category.

Practice [3: Define risks, policies, and oversight for automated AI and agentic behavior](#) (Risks, policies, and oversight for automated/agentic behavior)

Agentic interconnection and interdependence. Framing point on how agentic systems' dynamic, multi-system interactions differ structurally from more static traditional software.

Untested tool/dependency pulls. Risk of an agent adopting an updated tool or dependency that hasn't itself been through TEVV.

Practice [6: Integrate visibility of the external supply chain of AI into vendor and 3rd party risk management](#) / 7 (Supply chain and provenance)

AI/use-case inventory. Considering a structured example-use-case index or appendix, separate from the main practice table.

Reference candidates: NIST SP 800-53 AI control overlays (COSAIS, as opposed to CoSAI); additional context around the emerging AIBOM/SBOM standards cluster (SPDX AI & Datasets, OWASP AIBOM, CycloneDX ML-BOM) as candidate machine-readable formats for Implementation [6.1.2: Require AIBOM for mission-critical applications](#); MITRE System of Trust as a possible supply-chain reference alongside NIST SP 800-161.

Reference candidate: NCCoE's Software and AI Agent Identity and Authorization project, which is directly relevant to Practice [5: Implement identity and access management \(IdAM\) for AI agents, systems, and tools](#)'s identity requirements; worth checking for any newly published output.

Practice [8: Incorporate AI-aware incident analysis and response procedures](#) (Incident analysis and response)

Near-miss reporting. Expand on capturing near-misses, not just realized incidents.

Aligning incident definitions. Checking whether the profile's working definition of an "incident" should explicitly cross-reference existing definitions used elsewhere (e.g., JCDC-style playbooks).

Practice [9: Provide calibrated, needs-based AI risk management training](#) (Training)

Explicit stakeholder-engagement task. Adding task/implementation guidance ensuring the right people are involved in developing AI policies and procedures and receive adequate training, not solely technical controls.

Maintaining skills for human oversight. Adding guidance here (and in other practices as relevant) to better stress that human oversight and human-as-backup requires not just existing, but possibly new, training as taking over from an AI system (particularly in an emergency) can require additional skills compared to just performing the task.

Practice [12: Independently verify AI-generated operational logic and artifacts across their lifecycle](#) (Validating AI-generated artifacts)

AI-assisted coding tech debt. Risk that AI-generated code or documentation drifts from, or misrepresents, actual system behavior over time.

Sector-Specific References to be Included

We have compiled an initial baseline of established, sector-specific cybersecurity, process safety, and operational standards brought to our attention by the community. Moving forward, our internal roadmap aims to do more than simply index these documents; we intend to explicitly translate them into an AI risk management context.

We actively seek targeted input from domain experts on how to best frame this translation, which specific clauses or sub-sections offer the most transferable utility to AI deployment, where these references can be most effectively mapped into our profile, supporting text to properly contextualize them, and additional/alternative references that we should consider.

Oil and Natural Gas: API Standard 1164 (Pipeline Control Systems Cybersecurity), API RP 780 (Security Risk Assessment), API RP 754 (Process Safety Performance Indicators), IOGP Report 556 (Cybersecurity Capability and Maturity), TSA Security Directive Pipeline-2021-02, and ONG-ISAC threat advisories.

Electric / Bulk Power: NERC CIP-002 through CIP-014 (with emphasis on CIP-013-2 for supply chain controls), IEEE Standard 1547-2018 (Interconnection and Interoperability of Distributed Energy Resources), IEC 61850 (Power Utility Automation Networks), EPRI AI research program outputs, and DOE CESER AI guidance.

Water and Wastewater Systems: AWWA G430 (Security Practices for Operation and Management), AWWA M19 (Emergency Planning), the EPA Cybersecurity for the Water Sector toolkit, America's Water Infrastructure Act (AWIA) of 2018 Section 2013 risk assessment requirements, and WaterISAC 15 Cybersecurity Fundamentals.

Healthcare and Public Health: HHS 405(d) Health Industry Cybersecurity Practices, FDA Good Machine Learning Practice for Medical Device Development, the HIPAA Security Rule (45 CFR Part 164, Subpart C as applied to AI processing of protected health info), and HHS HC3 sector advisories.

Emergency Services / Public Safety: NFPA 1500 (Fire Department Occupational Safety, Health, and Wellness), NFPA 1600 (Continuity, Emergency, and Crisis Management), and NIST Public Safety Communications Research (PSCR) AI for First Responders program outputs, and placeholders for upcoming IAFC AI working group outputs.

Cross-Sector Industrial & Process Safety Foundations: ISA-84 / IEC 61511 (Functional Safety: Safety Instrumented Systems for the Process Industry), ANSI/ISA-95 (Enterprise-Control System Integration), IEC 61508 (Functional Safety of Electronic Safety-Related Systems), and ISO 31000 (Risk Management Guidelines), and ISA-18.2 (Alarm Management Systems).

Standards Bodies, Consortia, and Efforts We're Tracking

Here's a broader (non-exhaustive) list of groups, standards, and initiatives already on our radar, including some we now cite in the table and are continuing to track as their work develops. Please feel free to suggest additions or additional contextualizations, particularly with a note on which specific part is most relevant to this profile.

AI supply chain / AIBOM: SPDX AI & Datasets Team; OWASP AIBOM Project and GenAI AI-SBOM Initiative; CycloneDX ML-BOM guidance; OpenChain AI SBOM compliance guide; MITRE System of Trust; the G7 shared vision paper on SBOM for AI; FDA's AIBOM effort.

Agentic system security: CoSAI Workstreams 1, 3, and 4 (supply chain; AI risk governance; secure design for agentic systems), including their persona/risk-map work and Project Codeguard; OWASP GenAI Agentic Security Initiative; AIUC-1 agent standards; GUAC (software security metadata aggregation).

Cross-industry consortia and working groups: OpenSSF's AI/ML Working Group and GEMARA project; the Coalition for Secure AI (CoSAI) more broadly; FINOS Common Cloud Controls; OSCAL-COMPASS; the Alliance for Critical Infrastructure (ACI) launched Feb 26, 2026 as a cross-sector resilience and crisis-coordination nonprofit

Sector-specific: Cyber Risk Institute's Financial Services AI RMF profile and associated guidebook/control matrix; FS-ISAC; FSSCC's AI lexicon; Oil and Natural Gas Sector Coordinating Council (ONG-SCC); DOE's Supply Chain Cybersecurity Principles and ICS cybersecurity testing guidance.

Standards bodies: ISO/IEC 22989 (AI concepts/terminology) and ISO/IEC TS 5723 (trustworthiness vocabulary); ISO/IEC TR 5469 (functional safety and AI systems); IEEE P7001 (transparency of autonomous systems) and IEEE 2841 (deep learning evaluation framework); the ISA/IEC 62443 series and IEC 62351 (grid automation/control protocol security).

Risk frameworks and taxonomies: FAIR Institute's cyber risk scenario taxonomy and risk ontology; UC Berkeley CLTC's work on AI risk thresholds and a standalone AI trustworthiness taxonomy.

International: OECD's Framework for the Classification of AI Systems; relevant EU AI Act provisions (Articles 25 and 53); national AI governance directives and automated-decision-making frameworks in other jurisdictions where CI supply chains cross borders.

Related NIST/NCCoE efforts already coordinated with this work: SP 800-53 AI control overlays (COSAIS) and the associated predictive-AI outline; NCCoE's Software and AI Agent Identity and Authorization project; the forthcoming Cyber AI Profile (IR 8596).

As with all items above, we're especially interested in: (1) whether these are worth including at all, (2) where they'd best fit if so, and (3) any stronger or more specific references you can point us to.

Conceptual Changelog

This section summarizes key conceptual changes between draft versions, deliberately omitting minor edits. It is not an exhaustive diff, but a targeted summary to help reviewers identify substantive updates relevant to their feedback.

Sep 28, 2026(a)

This is a minor update to the Sep 13 draft. It adds one Task, six Implementations and a section on using the profile, and otherwise clarifies and corrects existing text. No Practice, Task or Implementation has been removed.

Three new Implementations address how operating context and source data can change without any change to the AI system. Implementation [1.1.3: Establish triggers for re-validating requirements...](#) covers assets whose applicable rules change when they relocate or their contract status changes, such as a mobile asset entering a different jurisdiction, and Task [7.5: Conduct Impact Assessments and Risk Management for AI System and Model Updates](#) now also applies where such a change alters rules encoded in the AI system, such as in its prompts, retrieval corpus, or guardrails. Implementation [7.2.3: Assess the conditions under which source data is created](#) extends provenance upstream of ingestion to the point of capture, where records can be lost in manual transfer chains, overwritten, or degraded by migration between maintenance management systems. Implementation [9.1.3: Include data-originating roles in competency mapping](#) brings field engineers, maintenance technicians and others who create source data into role-based training, even where they never use an AI system directly.

A new Section 1.4, Using this Profile, suggests where different readers might start. It gathers the guidance on non-linear reading and on starting from Appendix B that was previously spread through the Introduction, adds starting points for technical staff, for those focused on a trustworthiness characteristic, for those mapping to other frameworks and for organizations with limited resources, and discusses using the document with an AI assistant, including the organizational context an assistant needs and the ways it can misrepresent the document.

The profile now states how it relates to existing assurance regimes and to zero trust. The Scope now says that existing assurance regimes, including authorization and continuous monitoring, can remain the foundation, and that this profile builds on them with attention to what should trigger reassessment and to monitoring what an AI system does, not only how it is configured. It also describes the profile as applying the zero trust principle, that trust is verified at each boundary rather than assumed, to AI risk more generally, including to a legitimate, uncompromised AI system that is not behaving as intended. This is carried into Practice [3: Define risks, policies, and oversight for automated AI and agentic behavior](#), Task [3.2: Implement independent guardrails \("safety wrappers"\) for AI outputs](#) and Practice [5: Implement identity and access management \(IdAM\) for AI agents, systems, and tools](#), and zero trust is added to the Glossary.

Language incorrectly implying guarantees removed. Throughout the table, statements that an item "ensures" an outcome now say that it "helps ensure" it, and similar claims elsewhere, such as guardrails that structurally block unsafe commands even from a fully compromised AI system, have been restated as what the item can do.

Terms used in their general sense do not carry sector-specific meanings. The introduction to the table now states that where a sector, regulation or standard gives a term such as validation, verification, incident or safety function a precise meaning, this profile does not invoke that meaning, and following the profile does not by itself establish conformance with requirements stated in those terms. The Glossary adds industrial control system, noting that ICS means something different in emergency management. Table 1 now cites National Security Memorandum 22 as the source of the 16 sectors.

Explanation features are no longer treated as evidence that a recommendation is correct. A new Task [4.6: Ensure that confidence and rationale shown to personnel reflect how the AI system reached its output](#) gathers the requirements on confidence and rationale shown to personnel, previously in Implementation [4.2.3: Human-Centered Interfaces for AI Uncertainty and Actionable Triggers](#), and adds guidance for symbolic, hybrid and self-interpretable AI systems, whose rationale can be a trace of the steps actually applied. Implementation [4.6.1: Design rationale displays that give personnel something to check](#) notes research finding that showing explanations alongside recommendations can increase acceptance whether or not the recommendation is correct, and suggests testing whether a rationale display improves decisions for the personnel who will use it, including whether they still reject incorrect recommendations. Task [9.2: Deliver specialized training on human-AI interaction and automation bias](#) adds training on this effect. Task [4.6: Ensure that confidence and rationale shown to personnel reflect how the AI system reached its output](#) also carries a new tension between the Accurate and Explainable & Interpretable characteristics, and Implementation [10.1.2: Immutable Runtime Telemetry and Artifact Tracking](#) notes that the inference receipt can record the rules applied, which provides the displayed trace. Implementation [4.2.3: Human-Centered Interfaces for AI Uncertainty and Actionable Triggers](#), previously titled Human-Centered Interfaces for AI Uncertainty, Rationale, and Actionable Triggers, now addresses uncertainty and triage cues, and its Trust/Execute cue is renamed Proceed, which indicates that an output falls within the conditions the AI system was validated for rather than that it is correct.

A refused action part-way through a sequence needs its own fail-safe state. Implementation [3.2.3: Specify fail-safe states and fallback behavior](#) now covers the case where an AI action is refused under Implementation [5.2.2: Action-level, context-aware authorization policies](#) after earlier steps have already executed, with a worked example of a pump changeover.

Vendor hazard reachability attestations should be corroborated before they suppress alarms. Implementation [6.1.5: Operational AI Hazard Reachability Disclosures](#) now says vendor self-attestation should not be treated as sufficient to suppress a warning, and Task [4.4: Attention Governance and Alert/Alarm Flood Mitigation](#) applies this to alarm suppression. Implementation [6.1.5: Operational AI Hazard Reachability Disclosures](#) also notes that the existing VEX justification for inline mitigations covers only protections built into the product, so controls that an operator deploys around an AI system would need to be stated as a separate justification.

Retiring a protective AI capability is a change to controls as well as an asset disposal. Implementation [13.3.2: Treat the retirement of a protective AI capability as a change to controls](#) and Task [13.3: Preserve what is needed and hand over what depended on the system](#) previously framed these as alternatives.

Some statements now cite their source in the text. Where a sentence rests on a specific study or document, the source is now named in the form "(see Author Year)" or "(see ID Year)", for example in Task [3.6: Mitigate automation complacency and skills degradation](#), Implementation [4.5.1: Define engineering time-constant thresholds](#), Implementation [4.6.1: Design rationale displays that give personnel something to check](#), Implementation [6.1.2: Require AIBOM for mission-critical applications](#) and Implementation [6.1.5: Operational AI Hazard Reachability Disclosures](#).

Corrections. The example in Implementation [2.1.2: Develop process-informed guardrails](#) had the operating conditions reversed; guardrails now allow more headroom during quieter periods and tighter control during rapid change or heightened activity. Several pointers to where an adjacent concern is handled now point to a more specific item, most notably from Task [3.9: Assess and document organizational readiness for each AI-enabled capability](#) and Practice [5: Implement identity and access management \(IdAM\) for AI agents, systems, and tools](#) to Task [13.2: Withdraw authority completely and confirm that it is withdrawn](#) rather than Task [7.6: Establish processes for internal AI component deprecation and decommissioning](#), and from Practice [13: Establish procedures for retiring AI systems and withdrawing their authority](#) to Implementation [2.3.4: Recurrent Risk Evaluations](#) and Implementation [3.9.2: Define Decision Authority and Reassessment Triggers](#) rather than Practice [2: Define AI Robustness, Resilience, and Quality of Service expectations](#).

Other clarifications. Table 2 relates the Reliable, Robust and Resilient characteristics to the terms of a typical service-level agreement, and revises the Bias Managed and Fair entries. Implementation [2.2.2: Deploy "watchdog" controllers](#) notes that a watchdog may itself be part of the attack surface. The References field description notes that citation descriptions are meant to help locate successors to revised or superseded documents. Search Keywords were added in Practices [2: Define AI Robustness, Resilience, and Quality of Service expectations](#), [3: Define risks, policies, and oversight for automated AI and...](#), [4: Define procedures for emergency avoidance override, recovery, and situation...](#), [5: Implement identity and access management \(IdAM\) for AI agents...](#), and [8: Incorporate AI-aware incident analysis and response procedures](#), and reviewer notes were added on the crosswalks, the glossary, and record retention for retired systems.

Sep 13, 2026

This entry is organized by what changed rather than by where, because most of what follows was answered in more than one place. Feedback on the August draft was often combined with related input and addressed somewhere other than where it was raised, sometimes at a different level of the table, and sometimes through several smaller changes that only add up when read together. If you are looking for whether something you raised was acted on, you may find it more quickly by scanning the themes below than by returning to the cell you commented on.

We have indicated where changes apply substantially to only part of the document. No Practice, Task or Implementation has been removed; everything present in the August draft is still there.

A thirteenth Practice covers retiring AI systems. Practice [13: Establish procedures for retiring AI systems and withdrawing their authority](#) treats the permanent removal of an AI capability as its own problem rather than as an extreme form of updating one: an update transfers trust from one version to the next, while retirement withdraws authority, removes a capability other things have come to rely on, and destroys operational knowledge that may exist nowhere else. Task [13.1: Prepare for retirement while the system is still running](#) covers what has to be prepared while the system still runs, because retirement can be imposed by a withdrawn vendor or a deprecated model and can arrive after the system has stopped working. Task [13.2: Withdraw authority completely and confirm that it is withdrawn](#) covers withdrawing authority completely and confirming it. Task [13.3: Preserve what is needed and hand over what depended on the system](#) covers preserving evidence that teardown would destroy and recording what happens to everything that depended on the system. The existing treatment of internal AI artifacts, in Task [7.6: Establish processes for internal AI component deprecation and decommissioning](#), is unchanged; Practice [13: Establish procedures for retiring AI systems and withdrawing their authority](#) addresses the operating capability and its authority rather than the models, datasets and pipelines themselves.

Placeholder Implementations are now written, most heavily in Practice 5: Implement identity and access management (IdAM) for AI agents, systems, and tools and Practice 11: Maintain AI-aware mission continuity and disaster recovery planning. Thirty-two Implementations that carried a single line of intent in the August draft now carry actual guidance. Nine of them are in Practice [5: Implement identity and access management \(IdAM\) for AI agents, systems, and tools](#), covering AI agent identity, access mapping, action-level authorization, permission scope, and logging and anomaly detection for agent activity. Nine more are in Practice [11: Maintain AI-aware mission continuity and disaster recovery planning](#), covering process ranking, dependency mapping, manual fallback, safe operating mode, standby personnel and infrastructure, re-engagement validation, and fail-to-manual exercises. If you passed over either Practice in August because there was little to review, they are worth a second look.

Organizational readiness is now something to assess and record before adopting an AI capability. New Task [3.9: Assess and document organizational readiness for each AI-enabled capability](#), with Implementation [3.9.1: Establish Accountable Ownership](#), Implementation [3.9.2: Define Decision Authority and Reassessment Triggers](#), Implementation [3.9.3: Establish Escalation to Empowered Authority](#), Implementation [3.9.4: Assess Operational Capability](#), and Implementation [3.9.5: Demonstrate Operational Enforceability](#) covering accountable ownership, decision authority and reassessment triggers, escalation to an empowered authority, operational capability, and demonstrated enforceability. Related material sits in Task [3.6: Mitigate automation complacency and skills degradation](#) on maintaining human capability and in Implementation [9.2.1: Include role-specific training on "AI failure modes"](#) and Implementation [9.2.2: Implement realistic incident simulation training](#) on role-specific training.

Near-misses can now be reported without the reporter bearing the cost. New Task [8.6: Establish non-punitive reporting for AI-related near-misses](#), with Implementation [8.6.1: Separate benefit-claiming from risk-reporting](#) on separating benefit-claiming from risk-reporting, Implementation [8.6.2: Protect reporter identity through an independent reporting route](#) on protecting reporter identity through an independent route, Implementation [8.6.3: Ensure supplier terms do not penalize degradation disclosure](#) on supplier terms that penalize disclosure, and Implementation [8.6.4: Share de-identified incident records for collective defense](#) on sharing de-identified records. Implementation [9.2.3: Recognizing disincentives to reporting AI degradation](#) addresses recognizing the disincentives themselves.

External AI components are now tracked from procurement through end of life. Implementation [6.1.1: Add AI disclosure to existing procurement policies](#) on AI disclosure in procurement policy and Implementation [6.1.2: Require AIBOM for mission-critical applications](#) on requiring an AI Bill of Materials, and Implementation [6.2.1: Register externally sourced AI components in asset management systems](#), Implementation [6.2.2: Track vendor updates and third-party entity changes through change management process](#), and Implementation [6.2.3: Manage end-of-life transitions for externally sourced AI components](#) on registering externally sourced components, tracking vendor updates and third-party changes through change management, and managing end-of-life transitions.

An AI entity's authority can be bounded, delegated and withdrawn. Implementation [5.3.2: Task-Bounded and Revocable Agent Authority](#) became Task-Bounded and Revocable Agent Authority, Implementation [5.2.2: Action-level, context-aware authorization policies](#) became Action-level, context-aware authorization policies, and new Implementation [5.3.3: Separate privilege via encapsulated downstream agents and tools](#) covers separating privilege through encapsulated downstream agents and tools.

Constraints on AI behavior are now required to be enforced independently of the AI system. Implementation [3.2.2: Define and independently enforce deterministic operational constraints](#) became "Define and independently enforce deterministic operational constraints", and Practice [12: Independently verify AI-generated operational logic and artifacts across their lifecycle](#) became "Independently verify AI-generated operational logic and artifacts across their lifecycle". Both titles changed to carry that point rather than imply it.

In Practices 1 to 6, each Practice and Task now states what it does not cover and where the adjacent concern is handled. This is the combined effect of three rebuilt fields: the AI RMF mappings now say what an item contributes and what it does not; the trustworthiness entries state the limits of each contribution; and reference descriptions name the part of a source that applies and where it stops. Practices 7 to 12 have not yet had this work and carry markers instead; Practice [13: Establish procedures for retiring AI systems and withdrawing their authority](#) was written on the new scheme from the start.

The AI RMF mapping field was replaced rather than renamed. "Primary AI RMF Mappings" is now "Related AI RMF subcategories", and the change is one of meaning: listing a subcategory indicates that an item can contribute toward that outcome, not that following it satisfies the subcategory. If you commented on the previous field, the basis of that comment has changed.

References now say which part of a source applies and why it is cited here. Each entry opens with a label for the kind of document, and the description names the clause, section or control that bears on the item. This has been done for Practices 1 to 6 and 13; Practices 7 to 12 retain their earlier reference lists.

Cross-references now carry the title of what they point to. Every internal reference in the table is a link showing the name of the target Practice, Task or Implementation, rather than an index number alone.

Human oversight has a defined vocabulary. The Glossary and Terminology Crosswalk now defines human oversight together with oversight mode, oversight capacity, oversight threshold and oversight authority, and these terms are used consistently through the table.

An appendix is reserved for crosswalks to external frameworks. Appendix D is now Crosswalks, and is a placeholder under development. The reviewer material that was Appendix D in the August draft is now Appendix E. If you have notes referring to "Appendix D", check which one you meant.

The profile states that it covers high-consequence applications beyond critical infrastructure. This was implicit in the August draft and is now stated in the title and carried through the Introduction and Scope.

Search Keywords updated across the document. These have been chosen to both assist readers (and their AI assistants) in locating relevant Practices and Tasks in this document, as well as to provide candidate keywords for readers to use when searching other resources.

Cells whose text was substantially rewritten

Thirty Practices, Tasks and Implementations that carried substantive text in the August draft have been materially rewritten, over and above the thirty-two placeholders now written out and the thirty-two cells that are new. If you commented on any of these, the text you commented on has changed.

Location	What changed
1	Requirements now cover the end-to-end system, not the AI component alone; states that deciding against AI is a valid outcome
1.1.2	Expanded from a requirements matrix into named categories: task and mission scope, dependencies, and the operational system around the AI
1.3.1	Test suites now scale to consequence tier, with nominal and boundary envelope testing named
1.3.4	Evidence now pairs governance artifacts with technical artifacts
1.4	Scoped to systems that interact in natural language, and extended to ontologies, graphical conventions and multimodal output
2.2	Recast from "integrate non-AI backups" to a risk-proportionate redundancy strategy matched to consequence severity
2.2.1	Same recasting at implementation level, with a redundancy gradient tied to risk thresholds
2.2.2	Watchdogs must not themselves introduce unmanaged complexity or new attack surface
2.3.3	Substantially expanded: digital twins and hardware-in-the-loop, beyond offline data replay
2.3.4	Re-evaluation is now periodic and trigger-based, with distribution drift defined
2.5	Adds the worked example of a learned policy depending on out-of-specification component behavior
2.5.1	Training across the full operating range, with simulation and synthetic parameter cycling

Location	What changed
3	Now states its relationship to Practices 1, 2 and 4, and separates deterministic boundaries from human intervention
3.2.1	Intercept points may be enforced at more than one location; introduces the guarded proxy architecture
3.2.5	A reviewer must hold authority to reject and capacity to examine; presence of a reviewer is not verification
3.6	Reframed: reliance on AI is the intended result of adopting it, and practice has to be arranged rather than assumed
3.8.3	Couples the risk surface to the time-constant thresholds, since a widened surface can cross a previously satisfied threshold
4	Now points to Practice 11: Maintain AI-aware mission continuity and disaster recovery planning for sustained manual operation
4.4.3	Rewritten: reduced staffing is named as an expected benefit, and oversight capacity is drawn from the pool that benefit reduces
4.5	Oversight of any mode fails where the event outruns what the operator can be relied on to do; thresholds make this testable
4.5.1	Rebuilt around what intervention can be relied upon at minutes versus seconds, rather than a single reaction-time figure
6.1.5	Extended to contextual hazard reachability attestations and their use in alarm suppression
7.4	Separates who may act on the system from whether a specific action is permitted at execution time
7.4.1	Approvals and logging framed around reduced oversight modes and automation bias; records the evidence an approval rested on
10.1.2	Adds the inference receipt: the data elements, thresholds and configuration that produced an output
11.5.2	Simulation drills now require at least one full loss of AI infrastructure
12.1	Accountable ownership now routes to Task 3.9: Assess and document organizational readiness for each AI-enabled capability rather than being defined only here
12.1.3	Authorization roles sit within the decision authority documented at Implementation 3.9.2: Define Decision Authority and Reassessment Triggers
3.2.5, 4.1.1, 3.8.1	Changed only by relocating a citation into the References field or adding a cross-reference; the guidance itself is unchanged

Note: Versions “Sep 13, 2026 (a)” and “Sep 13, 2026 (b)” only differ by line/breaks, table spacing, and this note.

Aug 3, 2026

1. Document Scope & Formatting Updates

- **Markdown Availability & Parsing Guidance (*Document Structure*)**: Updated from HTML to Markdown for AI assistant pre-processing. Added explicit warnings that pre-processors may truncate table rows or appendices unless directed to parse the document in its entirety.
- **General-Purpose AI Assistants (*Section 2: Scope*)**: Expanded scope to explicitly cover general-purpose AI tools (e.g., code, configuration, or procedure generators; summarizers). Added the concept of "second-order risk," noting that engineer review of AI-generated output does not eliminate operational risk when deployed to OT/ICS environments.

2. Brand New Tasks & Major Structural Additions

- **Task 3.8: Scope and map the expanded AI Attack Surface and Risk Surface**: Added a dedicated task explicitly bifurcating exposure into adversarial threats (**AI Attack Surface**) and systemic/operational non-adversarial failure modes across all 7 TACIP Trustworthiness Characteristics (**AI Risk Surface**).
- **Task 4.5: Define operational regimes for human-on-the-loop and human-out-of-the-loop operation**: Added controls for processes with tight time constants where real-time human intervention should not serve as a primary risk mitigation control.
- **Implementation 3.3.3: Actionable Operator Decision & Escalation Pathways**: Added four operational response buckets (*Trust & Execute*, *Spot-Check & Investigate*, *Escalate to Oversight*, *Immediate Emergency Override*).
- **Implementation 4.2.3: Human-Centered Interfaces for AI Uncertainty and Actionable Triggers**: Suggests requirements for HSI/HMI displays (visual confidence bands, rationale summaries). Explicitly recommends against post-hoc attribution tools (e.g., SHAP, LIME) for primary operator rationale displays.
- **Implementation 6.1.5: Operational AI Hazard Reachability Disclosures**: Adapts VEX principles to AI by separating standard software CVE VEX from *Contextual Hazard Reachability* for probabilistic model behaviors.
- **Implementation 8.1.5: Multi-agent cascade reconstruction capabilities & 8.1.6: Incident Triage Across the Dual Attack/Risk Surface**: Added guidance to differentiate cyber intrusions from non-adversarial algorithmic failures.
- **Implementation 10.1.3: Forensic Integrity and Privacy-Preserving Log Partitioning**: Added guidance on log partitioning to route raw unredacted text/prompts directly into appropriately isolated, secure, tamper-evident storage.
- **Implementation 11.2.3: Human Factors and Cognitive Transition Protocols for Control Handoffs & 11.2.4: Unplanned Shutdown and Controlled Isolation Protocols**: Added *State-at-Handoff* displays and controlled isolation steps to reduce operator "cold start" cognitive shock during forced manual handoffs.

3. Key Conceptual Revisions to Existing Controls

- **TEVV Production Guidance (*Implementation 1.3.1: Define TEVV scope and requirements per AI system & 1.3.2: Categorization of Testing Environments*)**: Advises that high-risk testing, fuzzing, or red-teaming should be performed on isolated staging, HIL test rigs, digital twins, or during scheduled downtime windows, rather than on live systems.
- **Process-Informed Rate Limiting (*Implementation 2.1.1: Implement baseline rate limiting*)**: Clarified that rate limits should be dynamic and process-informed (*Implementation 2.1.2: Develop process-informed guardrails*) rather than fixed ceilings, so that valid high-volume commands are less likely to be suppressed during abnormal process upsets.

- **Time-to-Divergence Cadence** (*Implementation 2.3.4: Recurrent Risk Evaluations*): Introduced quantitative *Time-to-Divergence* baselining during staging to dictate model risk evaluation schedules as a fraction of estimated drift velocity.
- **Consequence-Driven Risk Thresholds** (*Implementation 3.1.3: Define acceptable risk thresholds and associated control responses*): Warns against over-indexing on CVSS or raw confidence scores, directing organizations to consequence-driven frameworks like SSVC.
- **Non-Human Identity (NHI) Enforcement** (*Implementation 5.1.1: Audit for and replace shared credentials, service accounts, secrets, passwords, and API keys*): Specifies distinct cryptographic identities per sub-agent/tool invocation and warns against sharing enterprise API keys or master service accounts across agent nodes.
- **Compensating Controls for Silent Updates** (*Implementation 6.1.1: Add AI disclosure to existing procurement policies & 6.1.2: Require AIBOM for mission-critical applications*): Added alternative controls (perimeter staging, egress gates, safety wrapper tightening) when suspending automated vendor updates is unfeasible, and reframed AIBOM compliance as a flexible gradient.
- **Logical Policy Locks** (*Implementation 7.3.3: Implement Logical Policy Locks for Adaptive and Online-Learning Models*): Specifies automated "Policy Locks" to programmatically freeze model weights, hyperparameters, and boundary logic for adaptive/online-learning models during operational windows.
- **Substrate Substitution Triage** (*Implementation 7.5.4: Audit Interoperability for Hardware or Data Substrate Substitution*): Expanded component replacement change-management logic into a 3-tier triage approach (unrelated vs. non-critical vs. safety-critical paths requiring full regression).
- **Forensic Interpretability Gap** (*Implementation 8.1.2: Identify AI systems that may not satisfy root cause analysis requirements*): Added new citations and warnings emphasizing that post-hoc explanations (SHAP/LIME) are ungrounded "reconstructed narratives" and should not satisfy forensic requirements.

4. New Appendices

- **Appendix B (Historic Incident-to-Practice Mapping)**: Added a complete table mapping 32 real-world incidents (i1–i32) across CI sectors directly to the 12 Practices to justify governance controls.
- **Appendix A & C**: Designated explicit placeholders for *Trustworthiness Characteristics* (App A) and *Use Cases & Operational Scenarios* (App C).

Jul 7, 2026

- Initial Community of Interest Discussion Document.

END OF DISCUSSION DRAFT